

FUNDAMENTAL OF

Cyber Security

(PRINCIPLES, THEORY AND PRACTICES)



■ MAYANK BHUSHAN
■ RAJKUMAR SINGH RATHORE
■ AATIF JAMSHED



BPB PUBLICATIONS

**Fundamental of
Cyber Security**

MAYANK BHUSHAN

RAJKUMAR SINGH RATHORE

AATIF JAMSHED



FIRST EDITION 2017

Copyright © BPB Publications, India

ISBN: 978-93-8655-155-9

All Rights Reserved. No part of this publication may be reproduced or distributed in any form or by any means or stored in a database or retrieval system, without the prior written permission of the publisher with the exception to the program listings which may be entered, stored and executed in a computer system, but they can not be reproduced by the means of publication.

LIMITS OF LIABILITY AND DISCLAIMER OF WARRANTY

The information contained in this book is true to correct and the best of author's & publisher's knowledge. The author has made every effort to ensure the accuracy of these publications, but cannot be held responsible for any loss or damage arising from any information in this book.

All trademarks referred to in the book are acknowledged as properties of their respective owners.

Distributors:

BPB PUBLICATIONS

20, Ansari Road, Darya Ganj

New Delhi-110002

Ph: 23254990/23254991

MICRO MEDIA

Shop No. 5, Mahendra Chambers,

150 DN Rd. Next to Capital Cinema,

V.T. (C.S.T.) Station, MUMBAI-400 001

Ph: 22078296/22078297

DECCAN AGENCIES

4-3-329, Bank Street,

Hyderabad-500195

Ph: 24756967/24756400

BPB BOOK CENTRE

376 Old Lajpat Rai Market,

Delhi-110006

Ph: 23861747

Published by Manish Jain for BPB Publications, 20 Ansari Road,
Darya Ganj, New Delhi-110002 and Printed by him at Repro India
Ltd, Mumbai

DEDICATED TO

My beloved Father & Mother

Mr. Gopal Krishna Sharma

Mrs. Neelam Sharma

— Mayank Bhushan

My beloved Family

Late Shri Ravindra Singh Rathore

Smt. Suman Rathore

Bharti Rathore

Mrinalini Singh Rathore/ Yashraj Singh Rathore

— **Rajkumar Singh Rathore**

My beloved Family

Mr. Jamshed Ahmad/Mrs. Tahira Yasmeen

Mr. Tabish Jamshed

Mrs. Yusra Perveen

Ashar/Emir

— **Aatif Jamshed**

SPECIAL THANKS

to

Mr. Sachin Kathuria

Former Assistant Professor (CSE) at GCET Greater Noida

PREFACE

The authors are confident that the present work will come as a relief to the students wishing to go through a comprehensive work explaining difficult concepts in the layman's language, offering a variety of numerical and conceptual problems along with their systematically worked out solutions and to top it, covering all the syllabi prescribed at various levels in universities.

This book promises to be a very good starting point for beginners and an asset to advanced users too.

This book is written as per the latest syllabus of B.Tech (all branches). Difficult concepts of ***Cyber Security*** is given in an easy way, so that students can able to understand in an efficient manner.

It is said “To err is human, to forgive divine”. In this light we wish that the shortcomings of the book will be forgiven. At the same the authors are open to any kind of constructive criticisms and suggestions for further improvement. All intelligent suggestions are welcome and the authors will try their best to incorporate such in valuable suggestions in the subsequent editions of this book.

Mayank Bhushan
Rajkumar Singh Rathore

Aatif Jamshed

Acknowledgement

No task is a single man's effort. Cooperation and Coordination of various peoples at different levels go into successful implementation of this book.

There is always a sense of gratitude, which every one expresses others for their helpful and needly services they render during difficult phases of life and to achieve the goal already set.

It is impossible to thank individually but we are here by making humble effort to thanks some of them.

At the outset we are thankful to the almighty who is constantly and invisibly guiding every body and have also helped us to work on the right path.

We are very much thankful to Prof.(Dr.). Bhawna Mallick, H.O.D. (CSE), Galgotias College of Engg. & Technology, Greater Noida (U.P.), for guiding us. She is the main source of inspiration for us. Without her help this book is not possible.

We wish our thanks to all our Guru's, friends and colleagues who helped and kept us motivated for writing this text. Special thanks go to

- 1) Dr. Shashi Kant Singh, Mr. Manish Kumar Singh, Mr. Manish Kumar, Mr. Lucknesh Kumar, GCET Greater Noida.
 - 2) Dr. Shailesh Tiwari HOD CSE, ABES EC, Ghaziabad
 - 3) Dr. Munesh Chandra Trivedi, Mr. Ankit Yadav, ABES EC, Ghaziabad
 - 4) Dr. Shaswati Banerjea, Mr. Nitin Shukla, MNNIT, Allahabad
 - 5) Dr. Sumit Yadav, IP University.
-
- 6) Mr. Shailendra Gaur and Mr. Satish Chhokar, RKGIT, Ghaziabad.
 - 7) Prof. Vibhav Singh, Surya Polytechnic College, Ghaziabad.

We also thank the Publisher and the whole staff at BPB Publication, especially **Mr. Manish Jain** for bringing this text in a nice presentable form.

***Mayank Bhushan
Rajkumar Singh Rathore
Aatif Jamshed***

Table of Contents

[Preface](#)

[Acknowledgement](#)

Chapter-1 Introduction to Information Systems

[1.1 Introduction](#)

[1.2 Modelling the Business Process](#)

[1.2.1 Business Profile, Model and Process](#)

[1.3 Information System Components](#)

[1.4 Information System Categories](#)

[1.5 Individuals in the Information System](#)

[1.6 Development of Information Systems](#)

[1.6.1 Beginning with the users](#)

[1.6.2 Determining need and Performance Expectations](#)

[1.6.2.1 System Integrity](#)

[1.6.2.2 Operating Integrity](#)

[1.6.2.3 Internal Integrity](#)

[1.6.2.4 Procedural Integrity](#)

[1.6.3 Characteristics of good Organizational IS talent](#)

[1.6.3.1 Personal Attributes](#)

[1.6.3.1.1 Knowledge of Information Systems](#)

[1.6.3.1.2 Managerial Style](#)

[1.6.3.1.3 Manager's Perception of Information needs](#)

[1.6.3.2 Organizational Environment](#)

- [1.6.3.2.1 Nature of the Company](#)
- [1.6.3.2.2 Level of Management](#)
- [1.6.3.2.3 Structure of the organization](#)
- [1.6.4 Stages in Process Design](#)

- [1.6.4.1 Requirements determination](#)
- [1.6.4.2 Analysis Phase](#)
- [1.6.4.3 Logical Design](#)
- [1.6.4.4 Physical Design](#)
- [1.6.4.5 Process Design](#)
- [1.6.4.6 Human Computer System design](#)
- [1.6.4.7 Implementation and testing](#)
- [1.6.4.8 Maintenance](#)
- [1.7 Questions](#)

Chapter-2 Information Security

- [2.1 Introduction](#)
 - [2.1.1 What is Security?](#)
 - [2.1.2 Why Information Security is Important?](#)
- [2.2 Threats to Information systems](#)
 - [2.2.1 Security Threat Source](#)
 - [2.2.1.1 Internal threats](#)
 - [2.2.1.2 External Threats](#)
 - [2.2.2 Threat Agents](#)
 - [2.2.2.1 Human Threats](#)
 - [2.2.2.2 Environmental factors](#)
 - [2.2.2.3 Technological Threats](#)
 - [2.2.3 Threat Motivation](#)
 - [2.2.4 Threat Intent](#)

- [2.2.4.1 Intentional Threats](#)
- [2.2.4.2 Unintentional Threats](#)
- [2.3 Information Assurance](#)
- [2.4 Cyber Security and Security risk analysis](#)
- [2.4.1 Quantitative Risk Analysis](#)
- [2.4.2 Qualitative Risk Analysis](#)

- [2.5 Questions](#)

[Chapter-3 Application Security](#)

- [3.1 Introduction](#)
- [3.1.1 Database security](#)
- [3.1.2 E-mail Security](#)
- [3.1.3 Internet Security](#)
- [3.2 Data Security Considerations](#)
- [3.2.1 Back-up Considerations](#)
- [3.2.2 Archival Storage](#)
- [3.2.2.1 Archival Photo Storage](#)
- [3.2.3 Disposal of Data](#)
- [3.2.3.1 Data Removal/Disposal Techniques](#)
- [3.2.3.2 Data Removal from Live Systems](#)
- [3.2.3.3 Data Removal for Media Reuse](#)
- [3.2.3.4 Verification of Data Removal](#)
- [3.3 Security Technology](#)
- [3.3.1 Firewall](#)
- [3.3.2.1 Transport Mode](#)
- [3.4 Intrusion Detection](#)
- [3.5 Access Control](#)
- [3.5.1 Access Control models](#)

[3.5.1.1 Discretionary Access Control](#)

[3.5.1.2 Mandatory Access Control](#)

[3.5.1.3 Role Based access Control](#)

[3.6 Questions](#)

Chapter-4 Security Threats

[4.1 Introduction to Security Threats](#)

[4.1.1 Virus](#)

[4.1.2 Worms](#)

[4.1.3 Trojan Horse](#)

[4.1.4 Bombs](#)

[4.1.5 TrapDoor](#)

[4.1.6 E-mail spoofing](#)

[4.1.7 E-mail Virus](#)

[4.1.7.1 Virus Life-Cycle](#)

[4.1.7.2 How Virus Works?](#)

[4.1.8 Macro Viruses](#)

[4.1.9 Malicious Software](#)

[4.2 Network and Services Attack](#)

[4.2.1 Denial-of-Service Attack](#)

[4.2.2 Types of DOS Attacks](#)

[4.2.3 Methods of attacks](#)

[4.2.4 Examples of Attacks](#)

[4.2.4.1 SYN Flood Attack](#)

[4.2.4.2 TCP Flooding](#)

[4.2.4.3 UDP Flooding](#)

[4.2.4.4 ICMP Flooding](#)

[4.2.4.5 Smurf](#)

[4.2.4.6 Ping of death](#)

[4.2.4.7 Tear Drop](#)

[4.2.4.8 Land](#)

[4.2.4.9 Echo/Chargen](#)

[4.2.4.10 Naptha Attack](#)

[4.3 Security Threats to E-Commerce](#)

[4.3.1 Electronic Payment system](#)

[4.3.2 Credit/Debit Cards](#)

[4.3.2.1 What are Debit Cards?](#)

[4.3.2.2 What are Credit Cards?](#)

[4.3.2.3 Pros and Cons of using Debit vs Credit Cards](#)

[4.3.2.4 Types of Debit Cards](#)

[4.3.2.5 Types of Credit Cards](#)

[4.3.2.6 Credit Card payment process](#)

[4.3.3 Smart Cards](#)

[4.3.4 E-Money](#)

[4.3.5 Electronic Fund Transfer](#)

[4.3.6 E-commerce Business Model](#)

[4.3.7 E-Commerce Advantages](#)

[4.3.8 E-Commerce Disadvantages](#)

[4.3.9 E-Commerce Security Systems](#)

[4.3.9.1 Measures to ensure Security](#)

[4.3.9.2 Security Protocols in Internet](#)

[4.3.10 Electronic-Cash](#)

[4.3.10.1 How it is used?](#)

[4.3.10.2 Relevance to business and Electronic Commerce](#)

[4.3.11 Digital Signature](#)

[4.3.11.1 Digital Signature Process](#)

[4.3.12 Public Key Cryptography](#)

[4.4 Questions](#)

[**Chapter-5 Development of secure Information System**](#)

[5.1 Introduction](#)

[5.1.1 Why Information System Security is Important?](#)

[5.2 Developing Secure Information System](#)

[5.2.1 Information security Management System](#)

[5.3 Key Elements of an Information Security Policy](#)

[5.3.1 Elements of Information Security Policy](#)

[5.3.1.1 Purpose](#)

[5.3.1.2 Scope](#)

[5.3.1.3 Information Security Objectives](#)

[5.3.1.4 Authority and Access Control Policy](#)

[5.3.1.5 Classification of Data](#)

[5.3.1.6 security awareness sessions](#)

[5.4 Information System Development Life-Cycle](#)

[5.5 Application Security](#)

[5.5.1 The Foundation OF Security](#)

[5.5.2 Threats, Vulnerabilities and Attacks Defined](#)

[5.5.3 How do we build a Secure Web Application?](#)

[5.5.4 Secure our Network, Host and Application](#)

[5.5.5 Securing our Network](#)

[5.5.6 Network Component Categories](#)

[5.5.7 Securing our Host](#)

[5.5.8 Host Configuration Categories](#)

[5.5.9 Securing our Application](#)

[5.5.10 Security Principles](#)

[5.6 Information Security Governance and Risk Management](#)

[5.6.1 Objectives of Information Security Governance and Risk Management](#)

[5.6.2 Why Information Security is important?](#)

[5.6.3 What benefits can be gained from a Security Governance Program?](#)

[5.6.4 Governance Models](#)

[5.6.5 Existing Problems](#)

[5.7 Risk Management](#)

[5.8 Security Architecture and Design](#)

[5.8.1 Relationships and Dependencies](#)

[5.8.2 Benefits](#)

[5.8.3 Forum](#)

[5.8.4 Drivers](#)

[5.8.4.1 Financial](#)

[5.8.4.2 Risk Management](#)

[5.8.4.3 Benchmarking and Good Practice](#)

[5.8.4.4 Legal and Regulatory](#)

[5.9 Questions](#)

[**Chapter-6 Security Issues In Hardware**](#)

[6.1 Introduction](#)

[6.1.1 Hardware Supply Chain Security](#)

[6.1.2 Testing for Trojan Circuits](#)

[6.1.2.1 Design for hardware Trust](#)

[6.1.2.2 Architectural Techniques](#)

[6.1.3 Hardware Support for Software Security](#)

[6.1.3.1 Memory Protection](#)

- [6.1.4 Architectural Support for Control Flow Security](#)
 - [6.1.4.1 Architectural Support for Buffer Overflow Defense](#)
 - [6.1.4.2 Information Flow Tracking](#)
- [6.1.5 Secure Co-processing](#)
- [6.2 Data Storage and Downloadable Devices](#)
 - [6.2.1 Data Storage Security](#)
 - [6.2.2 Data Protection Act](#)
 - [6.2.3 Necessity of information Security](#)
 - [6.2.4 What needs to be Protected by Information Security Arrangements?](#)
 - [6.2.5 What Level of security is Required?](#)
 - [6.2.6 What kind of Security Measures might be Appropriate?](#)
- [6.3 Physical security of IT Assets](#)
 - [6.3.1 Security of Assets Location](#)
 - [6.3.2 Human Access Control](#)
 - [6.3.3 Environmental Security Control](#)
- [6.4 CCTV and Intrusion Detection Systems](#)
 - [6.4.1 Intrusion Detection System](#)
 - [6.4.2 Intrusion Detection System Principles](#)
- [6.5 Security Measures](#)
 - [6.5.1 Back-up Security Measures](#)
- [6.6 Questions](#)

Chapter-7 Security Policies

- [7.1 Introduction](#)
 - [7.1.1 Computer Security Policy Categories and types](#)
 - [7.1.1.1 User Policies](#)
 - [7.1.1.2 IT Policies](#)

[7.1.1.3 General Policies](#)

[7.1.2 Policy Levels](#)

[7.2 Why do we need Security Policies?](#)

[7.2.1 Basic Purpose of Policy](#)

[7.2.2 Policy and legislative Compliance](#)

[7.2.3 Policies as Catalysts for change](#)

[7.2.4 Policies must be workable](#)

[7.3 Security Policy Development](#)

[7.4 E-mail Security Policies](#)

[7.4.1 Why study E-mail security?](#)

[7.4.2 Threats to E-mail](#)

[7.4.3 Why do we need an E-mail Policy?](#)

[7.4.4 E-mail Policy](#)

[7.5 Policy Review Process](#)

[7.5.1 An effective Review Process](#)

[7.5.2 Policy Review Objectives](#)

[7.5.3 Policy achieved?](#)

[7.5.4 Policy Review Feedback](#)

[7.5.5 Procedure Flow](#)

[7.6 Corporate Policy](#)

[7.6.1 Policy Development and Consultation Process](#)

[7.6.2 Corporate Privacy and Security Policy Examples](#)

[7.6.2.1 Personal Information](#)

[7.6.2.2 Non Disclosure Policies](#)

[7.6.2.3 Physical Security](#)

[7.6.2.4 Information Security](#)

[7.7 Sample Template of Cyber Security Policy](#)

[7.7.1 Introduction](#)

7.7.2 What we are Protecting?

7.7.2.1 Classification of Information

7.7.2.2 Classification of Computer Systems

7.7.2.3 LAN Classifications

7.7.3 Definitions

7.7.4 Threats to Security

7.7.4.1 Employees

7.7.4.2 Amateur Hackers and Vandals

7.7.4.3 Criminal Hackers and Saboteurs

7.7.4.4 User Responsibilities

7.7.4.5 Acceptable Use

7.7.4.6 Use of internet

7.7.4.7 User Classification

7.7.4.8 Monitoring of Computer Systems

7.7.5 Access Control

7.7.5.1 User System and Network access-Normal User Identification

7.7.5.2 System Administrator Access

7.7.5.3 Special access

7.7.5.4 Connecting to third party networks

7.7.5.5 Connecting Devices to the Network

7.7.5.6 Remote Access

7.7.5.7 Unauthorized Remote Access

7.7.6 Penalty for Security Violation

7.7.7 Security Incident Handling Procedures

7.8 Questions

Chapter-8 Information Security Standards

8.1 Introduction

[8.1.1 What is ISO?](#)

[8.1.2 IT Act 2000](#)

[8.1.3 Copyright](#)

[8.1.4 Patent](#)

[8.1.4.1 Governing Laws](#)

[8.1.4.2 Patent Duration](#)

[8.1.4.3 Patentable Inventions](#)

[8.1.5 Intellectual Property Rights](#)

[8.1.6 Cyber Laws in India](#)

[8.1.7 Software Licensing](#)

[8.1.7.1 Software License Types](#)

[8.1.8 Semiconductor Law and Patent Law](#)

[8.1.8.1 Why protect the topography of a semiconductor product?](#)

[8.1.8.2 Reverse Engineering allowed for Semiconductor Chips](#)

[8.1.8.3 Chip Act: A Hybrid of Laws](#)

[8.1.8.4 Chip Act Right and Exceptions](#)

[8.2 Questions](#)

[Important Questions](#)

[Previous Years University Question Papers](#)

[References](#)

Chapter-1

Introduction to Information Systems

1.1 INTRODUCTION

In this age of data, most fields of endeavor like education, producing, research, games, recreation, and business treats data systems as a desire. Indeed, each activity in our everyday life these days needs folks to induce concerned with the use of data systems.

Have you ever used Associate in Nursing ATM to withdraw cash or to shop for the product at an oversized supermarket? In each case, we have a tendency to area unit indirectly victimization the facilities offered by Associate in the Nursing system.

What is a system? A system is just a gaggle of activities and components, which are organized to realize a definite objective. Associate in the Nursing system could be a combination of hardware, code and telecommunication systems, which may support business operations to extend productivity, and facilitate managers create choices.

In this age, the success of a business depends on the data system. Several organizations these days use data systems to supply services with larger satisfaction to customers, to access a wide variety of data, to handle business changes at a larger speed, and to extend the productivity of staff. For the supported variety of research organizations, an efficient system ought to be ready to

exceed client expectations and fulfill business wants.

1.2 MODELLING THE BUSINESS METHOD

Many corporations these days use data as a basis to extend productivity, manufacturing quality merchandise, providing quality services, making client confidence, and creating timely choices.

As such, data technology has become the prime reason for the success and failure of an organization to vie in business. This illustrates the impact of data technology on business operations these days. As a result, coming up with Associate in the Nursing data system of high quality is vital therefore that organizations will vie with success within the world market.

Information systems specialists have to be compelled to perceive the business operation of an organization before they'll style a comprehensive system. Every business situation is probably going to diverge. As Associate in Nursing example, business transactions at a grocery, bank, and edifice need data systems that area unit completely different and distinctive.



Figure 1.1: Computers in business

An analyst applies a method known as Business method Modelling to represent corporations operations and data needs. Works in the data technology based mostly department. This person is liable for designing, analyzing and implementing data systems.

1.2.1 Business Profile, Model and Process

In trying to understand the operation of a certain company, a system analyst needs to develop a business profile and think about/believe some business models. This could be explained briefly as shown in [Figure 1.2](#) below.

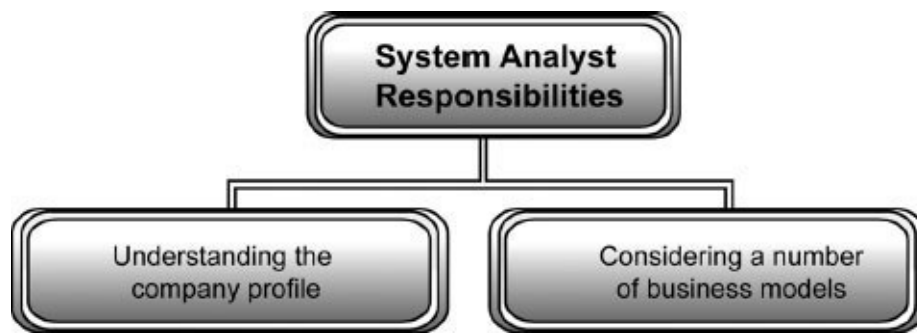


Figure 1.2: *General duties of a system analyst*

Business profile covers ownership, structure, and management of the company, together with its customers and suppliers; while a business model can take the form of an actual, physical type, a virtual store, and so on. They can be as described/explained as these, or can just be in brief forms.

Business Process explains a certain process, activity, and the results expected. It is basically a way of doing business, which begins with the customer and ends with the customer. Customers can either be

external or internal.

[Figure 1.3](#) illustrates a business process for “Student Registration”.

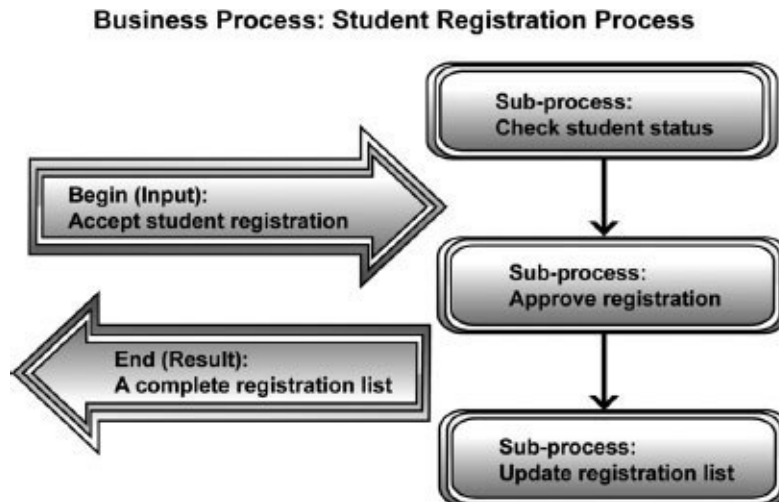


Figure 1.3: *A business process*

The above business process has a beginning and an end, three sub-processes and a result. When a company tries to simplify operations, or tries to decrease operational cost, or increase value to customers, the company is said to be involved in business process re-engineering(BPR).

1.3 INFORMATION SYSTEM COMPONENTS

A system could be a set of connected parts, which may method input to provide an explicit output. Each system needs a type of knowledge input. For instance, Associate in Nursing ATM accepts knowledge once you enter the PIN. A washer accepts knowledge once you choose the beginning buttons. They method the inputs and turn out their individual outputs.

In Associate in tending data system, input file carries with its facts and figures, that kind the systems material. Data is knowledge that has been usefully processed. However, Associate in data system doesn't solely contain knowledge. There also are alternative components within the system, that area unit connected and area unit in support of one another. The presence of these connected components makes data a lot of helpful whereby, it will be created accessible, will be processed, distributed, manipulated, saved, and so on. this mixture offers rise to a system, that is orderly Associate in per se it's referred to as an "Information System"



Figure 1.4: Information system

The activity of converting data into information is called a process. An information system contains FIVE main components: the hardware, software, data, process and human, as shown in [Figure 1.5](#) below:

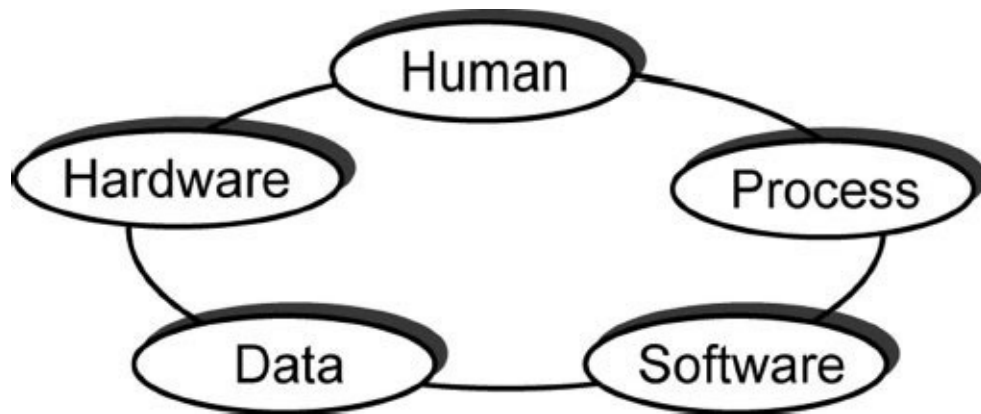


Figure 1.5: Components of an information system

Hardware

Hardware is the physical embodiment of an information system. It is one of the main elements which creates the information system cycle.

Information system's hardware refers to any or all kinds of hardware and also newspapers, web sites, and TV used for input, processing, managing, distributing business partner degreeed saving data that area unit getting used in an organisation. Samples of the hardware area unit the physical computers, networks, installation, scanners, digital drives, and so on.

Basic hardware for a definite pc consists of 4 main parts as shown in [Figure 1.6](#) below.

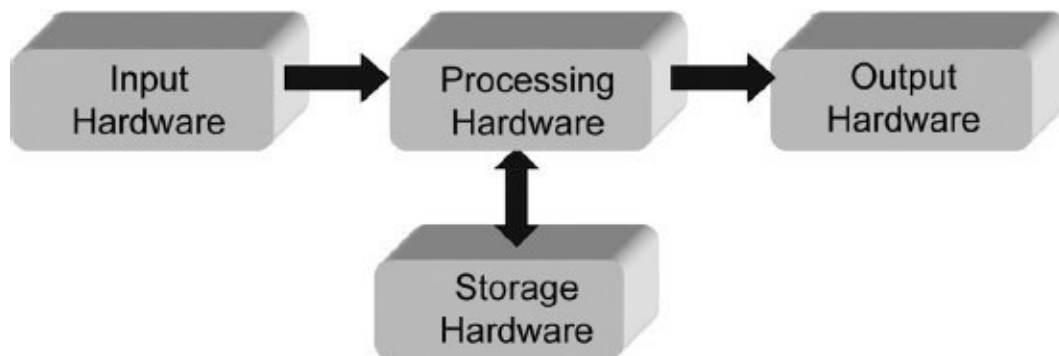


Figure 1.6: Basic hardware of a computer

To understand in greater detail on the functions and examples of

the computer hardware, we can refer to [Table 1.1](#) below.

below.
below. below. below. below. below. below. below. below.
below. below. below. below. below.
below. below. below. below.
below. below. below. below. below. below. below. below. below.

Table 1.1: *Functions of the Basic Hardware of a Computer*

Computers is helpful tools if you recognize the way to use (for selfish reasons) To change computers to operate a lot of effectively and to (branch out into different things) their functions, you wish the communication network to attach many computers along. The network provides the hardware support to change communication to be established among one another. The communication network includes modems, hubs, cables and different devices.

Software system

Software consists of two classes a the system software system and therefore the application software.

- System software system controls the laptop and contains the software system and device drivers, which may communicate with

the hardware. It also can change information into a replacement kind, stop viruses and create copies.

- Application software system contains programs that will help users and change corporations to (do/complete) business functions. Users will increase working well and getting a lot done with the presence of application software system like spreadsheets, data processing, ordering systems, and (money owed to you).

Data

Data refers to the raw facts on anything or things/businesses like student names, courses and marks. The raw data that has not yet been given can be Processed to become more useful information.

Information is an organised, meaningful and useful (understanding/ explanation) of data such as a company's performances or a student's (related to school and learning) performance. Information systems change data into information, which is useful and capable of giving a certain meaning to its users.

[Figure 1.7](#) below shows an example to represent data and information:

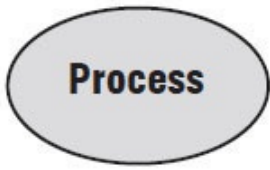
Name	Salary (RM)		Information
Kassim	4,300.00		No. of employees = 5
Jamilah	2,000.00		Average Salary = 2940.00
Muthu	2,500.00		Total Salary = 14700.00
Mary	4,000.00		Highest Salary = 4300.00
Lai Mooi	1,900.00		Lowest Salary = 1900.00

Figure 1.7: Differences between data and information

Based on the instance within the on top of figure, we will perceive that records within each attribute beneath the knowledge item do not offer any specific that means. Each knowledge or record here may be a raw reality. When surfing processes like addition, ordering, combining, controlling/moving around/misleading and then on, (more than two, but not a lot of) styles of info are often created. The data created isn't restricted to an exact type. It is often taken in many ways in keeping with the needed things and wills of shoppers.

METHOD

Process or procedure explains the activities carried out by users, managers and workers. Process is important for supporting a certain business model available as written documents or as reference materials on-line.

Process is a guide consisting of neat/ well-organized/ well-behaved

steps, which need to be followed and put into use in order to get a certain decision on a certain matter.

The procedure for employing a sure matter is very wide and really necessary to make sure that it will be enforced successfully. All the data system parts contain management and putting into use procedures on their own, and that they square measure totally different from one another.

--HUMAN

The main goal of an information system is to provide extremely valuable information to managers and users, whether inside or outside the company. Users can be broken up into three categories, which are:

End-Users, consisting of the staff, customers, suppliers and others who communicate with the information system.

Internal Users, including the managers, technicians, sales representatives and (related to big business) officers.

External Users, consisting of the customers who use the companies system for performing transactions, suppliers WHO use the system for designing sales, and therefore the workers WHO use the system outside workplace hours.

The success or failure of associate system depends on whether or not the system that has been developed will fulfil the user's needs, and therefore the users feel happy with the results and therefore the system's operation. A wonderful system needs (combined different things together so they worked as one unit) efforts from info technology specialists like the system analysts, programmers and therefore the info technology managers this way as to fulfil business desires and to support company's goals.

1.4 INFORMATION SYSTEM CLASSES

Now there square measure many approaches to finding a definite (bad result or effect). There also are many sorts of info systems, that square measure developed to beat clearly stated/particular issues, besides making an attempt to fulfil the user's requests (usually/ in a common and regular way). In a very huge organisation, finding business issues like the management of workers (moneys paid for working), process of business information et al is often done by the employment of huge computers with internal and external networks.

Every type of information system has a role to play. If you look at the functions and the extent of/the range of usage, information systems can be divided into six main categories such as those given in [Figure 1.8](#) below.

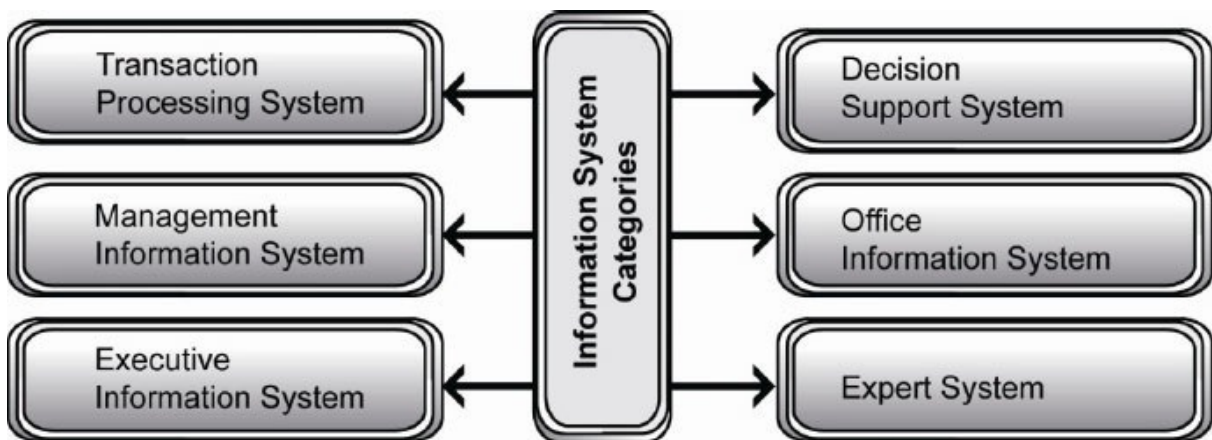


Figure 1.8: Categories of information system

To understand the six main categories of information systems, [Table 1.2](#) gives the explanation for each category.

category.

[illegible]

category. category. category. category. category. category. category.
category. category. category. category. category. category. category.
category. category. category. category. category. category. category.
category. category. category. category. category. category. category.
category. category. category. category. category. category. category.
category. category. category. category. category. category. category.
category. category. category. category. category. category. category.
category. category. category. category. category. category. category.
category. category. category. category. category. category.

Table 1.2: Information System Categories

1.5 INDIVIDUALS IN THE INFORMATION SYSTEM

To handle an info system's project, we want to have a systematic work set up. An info system's design provides a piece set up, that is exclusive, whereby numerous people with completely different objectives will manage and see the building blocks of an data system.



Figure 1.9: *Individuals in information system*

If we intend to develop an information system, the individuals involved in the development will see the system from a different perspective. These individuals can be categorised into four groups:

(A) SYSTEMS OWNER

The systems owner carries/holds the cost of system development and maintenance. He has the right over the system, decides/figures out the interest over the system and decides/figures out the policies over its use. The system owner is also responsible for system (good reason for: thinking or doing something, or for the existence of something) and system acceptance. In certain situations, the system owner is also a system user.

System owners always think of the return value, which can be received/be gotten by developing the information system. This return is valued from different aspects such as:

- What are the benefits of the system?
- What are the mission and goals?
- What is the cost of developing the system?
- What is the cost of operating the system?
- Can the investment pay back the capital?

What are the benefits that can be measured from the system?

(B) SYSTEMS USER

The system user is an individual who uses the system for

producing something, or uses the system to help him in his daily jobs. Directly, users are the ones who get the benefits from the system that has been developed. Besides being the initiators for the new information system request, users also decide/figure out:

- The problems to be solved;
 - Opportunities to be taken advantage of;
 - The needs to be satisfied;
 - Business restrictions to be overcome by the system; and
-
- Whether the information system that has been developed is easy or difficult to use.

Compared to the system owner, the system users are not so interested in the cost and benefits of the system. They often importance and focus the business needs inside the system. System users can be divided into three main categories: internet, external and mobile users.

(i) Internal User

Workers who work in the company to develop the information system. Internal users make up/be equal to the highest percentage among those who use the said system. They include the support and (related to managing and running a company or organization) staff, the technical and professional staff, supervisors, the management and the executives.

(ii) Mobile User

Mobile users are the users who often do jobs outside the company.

Examples of these users are salesmen and sales representatives. They often do jobs that require travelling from place to place, meeting customers, buyers and soon. Organisations which have users of this kind often have complex information system designs because the system that is developed needs to change something (to help someone)/take care of someone the information needed by users of this kind. In satisfying the information needs of mobile users, the information should be accessible wherever they are.

Therefore, the information system that has been developed should provide a (related to sending and receiving phone calls, texts, etc.) surrounding conditions and the network to enable information stored in the (computer file full of information) to be (easy to get to, use, or understand) by users.

(iii) External User

The information system can now connect the system to other individuals as users of the system. Due to worldwide competition, businesses are redesigned to enable connectivity with other organisations, partners, suppliers, customers and end users.

As an example, you need not fill up any form to apply for entry

into OUM. With the information system given by OUM, you just need to go to the OUM website, fill up the application form online, and send the form online. Now, the facility is given, but in future it may be necessary to change our way of life.

(C) SYSTEMS DESIGNER

Systems designers are experts in the technical field who would design a system for satisfying the needs of users. They are responsible for controlling/moving around/ misleading the needs of business users and the restrictions in technical solutions. They design computer files, (computer files full of information), input, output, screen, networks, and programs that can fulfil the needs of system users. They are also responsible for (combining different things together so they work as one unit) the technical solutions into the daily business (surrounding conditions).

Systems designers understand the (related to computers and science) (surrounding conditions) better when compared to systems owners and systems users. They always provide other choices and design systems based on (related to computers and science) restrictions at that time. Now, systems designers give more attention to technical experts such as:

(computer file full of information) designers who provide focus on the data;

Programmers and software engineers who provide focus on the process;

Systems integrators who provide focus on the system (connecting points/ ways of interacting with something); and

Telecommunication and network experts who provide focus on the location (in the world)s.

(d) Systems Developer

Systems developers are the experts in the technical field who would develop, test and produce a system, which can operate successfully. They build the system parts/ pieces based on the design (detailed descriptions of exactly what is required) of the system designers. In many situations, system designers are the system developers. They use technology to develop information systems.

Among the people who get involved directly in information system development, you maybe ask what is the role of the systems analyst? In actual fact, the systems analysts are really acting as helpers/planners for information systems development. The system analyst has the (ability to do things very well) that is owned by all the above people. They should feel comfortable with the views of all the people talked about/said above. For the systems owners and users, the systems analyst should develop and update their views. The duty of the systems analyst is to make sure that the technical

knowledge of systems designers and developers are agreeing with/ matching up with/working regularly with the current business needs.

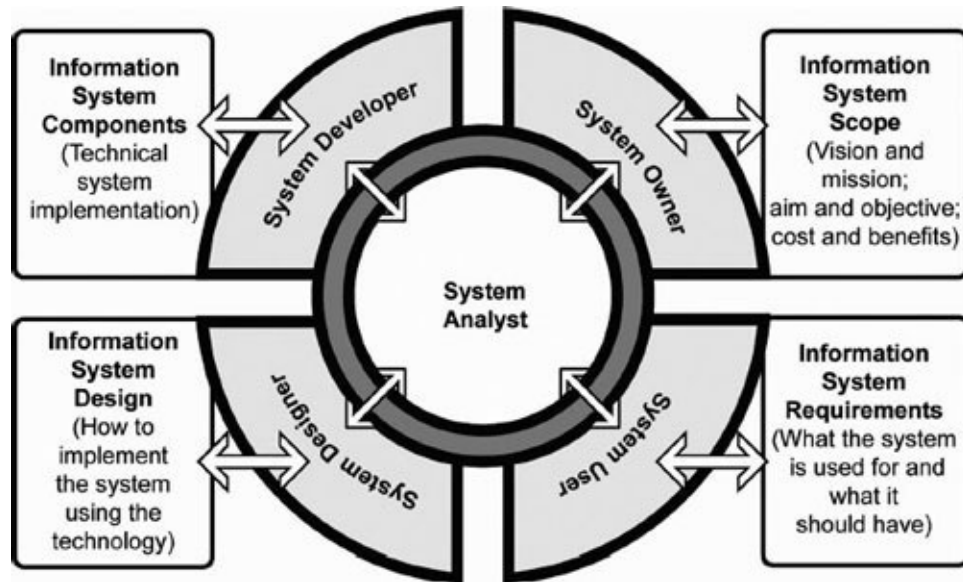


Figure 1.10: *Information systems perspective*

1.6 DEVELOPMENT OF INFORMATION SYSTEMS

As mentioned earlier, each company has associate degree system already in situated, be it a file card and pencil primarily based system, a processed system or associate degree intermediate of the two. Therefore the IS development method involves work on associate degree existing system - mapping the system, automating it and ensuring that it functions per user needs. Thus in its initial part the method makes an attempt to see the scope and sort of latest system that the user needs. Consecutive part analyzes the higher than demand in two elements to facilitate elaborate verification and validation before the system is really designed and enforced.

1.6.1 Starting with the users

In fact the complete conception of knowledge systems development revolves round the users - their desires, performance expectations, needs and different specifications. The terrible success or failure of an information system could also be measured by the amount of satisfaction of its basic users within the organisation. It's terribly essential that the info satisfy the wants of the user, otherwise he or she's going to continue together with his or her own system and thereby defeat the aim of the central info. The key part during this conception is that every scheme utilize identical info within the satisfaction of its info desires. This may yield an extra important advantage - the mixing of departments and functions. So every department, through its access and interface with the overall info resources of the corporate, gains a bigger understanding and appreciation of how its actions and plans have an effect on others throughout the organization.

Necessary question which will be raised is why it's important to analyse and style info systems before you build them. Why cannot you build the data systems directly? The most reasons are:

It's necessary to create the data systems that the users actually need. You don't understand what they actually need if you don't begin with some reasonably analysis and style.

It's a waste of resources to create info systems while not sufficiently smart "blueprints" as a result of it takes longer and yields worse results if you don't have blueprints.

Analysis and style is performed to fulfill info desires. If it's needed to make models that describe info systems that the users actually need, then interest teams (or user groups) typically ought to participate within the work. Another excuse for activity analysis and style is that those that participate in such work learn abundant regarding the new info systems. To be ready to use info systems needs information regarding however these systems work.

Participating within the analysis and style work is a method of getting such information.

1.6.2 Decisive would like and performance expectations

As each company has associate degree existing system and also the method of IS development involves system conversion. The overall steps concerned within the conversion are:

- a) System Description (narrative or pictorial)
- b) Input Documents (item description, layouts etc.)
- c) Output Documents (report formats, output needs etc.)
- d) File Style (involves the system style method explained within the next section)
- e) Program Logic (by the employment flow charts or different methods)
- f) Computer Program (COBOL, DYNAMO, BASIC, PASCAL, algebraic language to call a few)
- g) System Verification
- h) Documentation

Potential downside needs close info construction are typically those connected with division coordination and agreement. These may include:

risk of invalid input {of information|of data|of knowledge} by a unit desire to keep up information security.

The “multiplier effect” of mistakenly entered knowledge, that has an on the spot influence on different departments utilizing the information.

The “time dimension” of computer file, which needs that user departments agree on the time throughout that a group action ought to be mirrored knowledge input.

The “interdepartmental agreement” needed regarding the degree of detail to be enclosed in knowledge parts of the info.

As a consequence of the higher than issues that are known a number of the specified options of the system would be:

Simplicity or easy usage and handling (by using graphic computer program - primarily based entry and retrieval systems)

Adequate security features/firewalls for limiting unauthorised access (both among the organisation and on the web) and

a really rigid backbone-operating system to support the many structure functions at completely different levels.

A clear-cut information of the expectations or needs of the system being developed would entail an inventory of some performance

metrics. The mensuration of prices or advantages could be a mensuration of amendment between the previous and also the new. In different words we have a tendency to might live the amendment within the total output of the system or live the numerous changes accomplished throughout the system. the previous is clearly the foremost fascinating.

It is in all probability rare that a mensuration of the overall system is tried at the system level. Some broad ideas that require to be unbroken in mind throughout system development include:

1.6.2.1 System Integrity: well are the sub systems integrated into the overall system while not redundancy? However versatile is that the system? however simply might the system be expanded?

1.6.2.2 operational Integrity: skilled are the folks operational the system? What back-up is there to stop system breakdown within the event of loss of key personnel or instrumentality failure?

1.6.2.3 Internal Integrity: well will the system do what it's imagined to do? however valid are system outputs? However secure is that the system against human error, manipulation, sabotage or theft?

1.6.2.4 Procedural Integrity: smart is that the documentation of the system and procedures? Are procedures such workers are intended to follow them? however well are procedures followed in practice? What controls make sure that procedures are followed?

Amendment analysis has got to be performed before info systems development is performed. Amendment associate degree analysis is that the analysis of appropriate changes of the activities of an enterprise in concrete state of affairs. The aim of amendment analysis is to formulate the matter before you begin to resolve it. Developing systems is effective as long as you have got info system issues or desires. downside adjusted work should be performed before knowledge adjusted work is performed.

Data-oriented work refers to the event elements whose purpose is to style technical solutions to the current specification.

It is solely effective to perform knowledge adjusted work if you have got a problem-oriented specification as a basis.

1.6.3 Characteristics of fine organisational IS talent

A manager desires info for a range of reasons involved with the management method. The kind of would like that he or she's going to have at numerous times and for numerous functions depends for the most part upon two factors that we have a tendency to shall examine shortly : the non-public social control attributes and also the structure atmosphere within which selections are created.

1.6.3.1 Personal Attributes

1.6.3.1.1 Information of knowledge systems

If managers are responsive to what computer-based systems will do, their info requests can in all probability be additional subtle and additional specific. Their information of capabilities and prices places them in an exceedingly far better position to assist within the style of a decent system.

1.6.3.1.2 Social Control Vogue

A manager's technical background, leadership vogue, and decision-making ability all have an effect on the type and quantity of knowledge needed. Some like a bigger amount; Others wish to decide with a minimum of detail and like personal consultation with subordinates.

1.6.3.1.3 Manager's perception of knowledge desires

“You tell Pine Tree State what i would like to know” and “get Pine Tree State all the facts” represent 2 opposite perceptions of knowledge desires. This categorisation is due part to the actual fact that a lot of managers are blind to what info they have. Another dimension of the matter is that the wide differing views of the managers concerning their obligation to pass around info to subordinates and to teams outside the firm.

1.6.3.2 Organisational atmosphere

1.6.3.2.1 Nature of the corporate

Issues in communication and in dominant operations appear to be a perform of the company's size and also the complexness of its organization. The larger additional advanced companies need additional formal info systems, and also the info desires of those systems become additional crucial to operations.

1.6.3.2.2 Level of Management

There are three levels of management (i.e strategic coming up with, internal control, operation control) and also the variable desires for info at every. Every level desires completely different style of info, typically in numerous kind. High levels would like the one-time report, the outline, the one inquiry. The internal control level desires the exception report the outline and also the sort of periodic reports for normal analysis. The operational management level needs the formal report with mounted procedures, the every day report of transactions, to keep up operational management of actions as they occur. Managers in any respect levels have dynamic info desires, counting on the character and importance of the actual call.

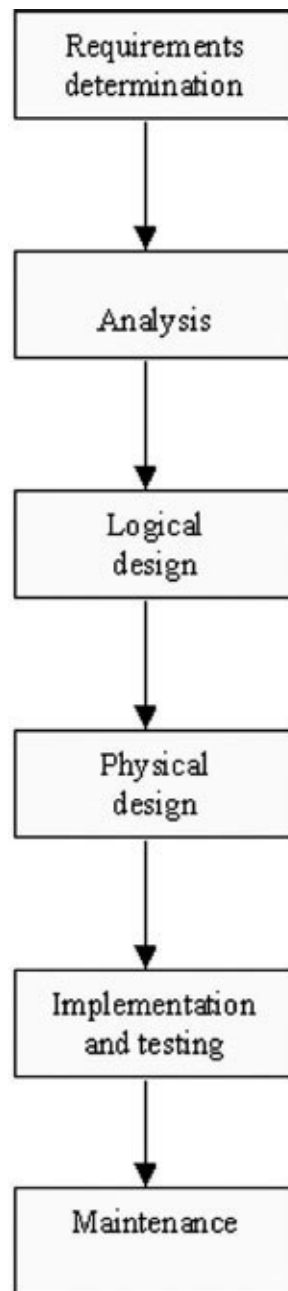


Figure 1.11: Stages in Process Design

Source: Information systems Requirements: Determination and analysis

1.6.3.2.3 Structure of the organisation

The additional extremely structured the organization; the simpler it's to see the data desires. Wherever authority and responsibility are clearly spelled out, relationships understood, and decision-making areas outlined, the data desires of managers may be determined additional simply.

1.6.4 Stages In Process Design

The Process of information systems development in its first phase attempts to determine the scope and type of system the user wants. The next phase analyzes the above requirement in two parts to facilitate detailed verification and validation before the system is actually designed and implemented.

1.6.4.1 Requirements Determination

This stage consists of getting user desires and necessities that mirror the user-expectations from the IS being developed. It consists of many stages:

drawback definition

practicability Study

necessities Acquisition

necessities Analysis

The problem definition and practicability study stages include definition of a blank define of the specified system. The matter Definition Stage defines to a high level of detail the appliance for the specified IS and a sign of the benefits that may result from its implementation. The practicability Stage is that the examination of the various alternatives with that an answer will be found for the planning of the specified system. the necessities Acquisition Stage ends up in a “statement of requirements”. the necessities Analysis stage produces the “requirements specification”. Victimisation the ‘statement of requirements’ because the main input the aim of the necessities specification is to act as an summary of the specified

system in a very structured kind.

1.6.4.2 Analysis part

This part analyzes the necessities from the previous part and converts them into elements, that square measure accustomed build a 'specification' of the specified system. The specification is additional precise than within the previous part and adds additional detail, at identical time holding user linguistics, in order that the outline would be recognizable to the user. but the model is at AN abstract level, that is, with no details regarding information illustration or computer implementation.

1.6.4.3 Logical style

This part produces a style of the specified system that may function a basis for pc implementation. There are two major tasks in logic style. Firstly the specification from the analysis part is transferred and second the human automatic data processing system is intended. The many distinction during this part is that the structure part is currently delineated by information. There will usually be many doable ways in which of representing relationships. We tend to may additionally use standardisation during this part. We tend to decide precisely what information varieties square measure needed for information illustration, what percentage characters square measure needed for every information item and that we style records and files or databases to store the information, taking under consideration the kind of processes that may operate the information. AN abstract programming kind is usually used here, like structured English, JSP diagrams or action diagrams.

2 levels of detail are normally thought of here:

Style of user procedures that include tasks and processes with that users are going to be directly concerned.

Computer interface style include the detail of processes and

therefore the objects on that these processes operate, and will involve concerns connected associated with interaction vogue (screen and report layouts, human-computer dialogues), specifications of manual or mechanical operations, and off-line or on-line process.

1.6.4.4 Physical style

This is the last of the planning phases. We tend to might contemplate it as consisting of three components: Hardware, package and human-computer systems. The hardware style consists of an outline of the computers, storage devices, input/output devices and presumably networking devices needed for the specified system.

Package consists of the programs that run on the hardware. The physical style {of information|of knowledge|of information} has to be thought of because the quite data invariably affects the programs that method the information. It'll be necessary to make your mind up on the acceptable sorts of applications package, together with languages and packages still as systems program needed for supporting the ultimate system.

1.6.4.5 Method style

There square measure four choices for method style

For traditional processes, we are able to obtain prepackaged package. for instance, accounting package is mostly standardized.

Use of a fourth-generation language like lotus123, VB, Oracle etc.
Generate code employing a CASE tool

Write our own code.

If in-house cryptography is completed information structures square measure chosen for the illustration of knowledge within the programs, along with choices on the artificial language needed for eg. COBOL, C++ etc. problems like speed and simple maintainability of program code square measure thought of.

1.6.4.6 Human automatic data processing system style

Some of the planning of this technique specifies the activities to be followed once act with the pc, for instance, detail of dialogue between pc and operator, procedures for starting-up and motility down the system and screen contents like windows or colours etc.

1.6.4.7 Implementation And Testing

The major output of the implementation and testing part may be a physical data system and not a style. In fact the physical and earlier styles stay on the market for reference, as they kind the specification. The most important tasks consist of:

Acquiring and integration hardware, manufacturing package, generating information for the files or databases and manufacturing the human-computer system.

System is tested, user comments square measure evaluated, maybe to revamp the system.

The operation of the enforced system within the user-organization is monitored closely for a restricted amount.

1.6.4.8 Maintenance

The maintenance part consists of correcting errors within the system or responding to changes within the user demand, due, for instance, to environmental changes or personal preferences for system operation and it's going to need remodeling of all the previous phases for the a part of the system that needs dynamic.

1.7 QUESTIONS

What do you mean by Information Systems? Explain with suitable example.

What are the various types of Information Systems? Explain in detail.

What are the basic approaches for the development of Information Systems?

What is the need of securing the Information?

Explain the Information Systems Perspective in detail with suitable diagram.

Chapter-2

Information Security

2.1 INTRODUCTION

Today, the internet brings many unsecured laptop networks into continuous communication with one another. The safety of every laptop's hold on info is currently dependant on the amount of security of each alternative computer to that it's connected. Recent years have seen a growing awareness of the requirement to enhance info security, furthermore as a realization that info security is very important to national defence. The growing threat of cyber attacks have created governments and firm a lot of awake to the requirement to defend the computer-controlled management systems of utilities and alternative important infrastructure. There's conjointly growing concern concerning nation-states partaking in IW, and therefore the risk that business and private info systems might become casualties if they're undependable.

2.1.1 What Is Security?

In general, security is “the quality or state of being secure—to be free from danger.” In other words, protection against adversaries—from those who would do harm, intentionally or otherwise—is the objective. National security, for example, could be a multilayered system that protects the sovereignty of a state, its assets, its resources, and its individuals. Achieving the acceptable level of security for a company additionally needs a multifarious system.

A booming organization ought to have the subsequent multiple layers of security in situ to shield its operations:

Physical security, to shield physical things, objects, or areas from unauthorized access and misuse

Personnel security, to shield the individual or cluster of people
United Nations agency area unit approved to access the
organization and its operations

Operations security, to shield the small print of a specific operation
or series of activities

Communications security, to shield communications media,

technology, and content

Network security, to shield networking elements, connections, and contents

Information security, to shield the confidentiality, integrity and convenience of knowledge assets, whether or not in storage, processing, or transmission. It's achieved via the applying of policy, education, coaching and awareness, and technology.

The Committee on National Security Systems defines info security because the protection of knowledge and its crucial parts, as well as the systems and hardware that use, store and transmit that info. [Figure 2.1](#) show that info security includes the broad areas of knowledge security management, laptop and knowledge security, and network security. It's supported the three characteristics of knowledge that provides it price to organizations: confidentiality, integrity, and handiness. The safety of those three characteristics of knowledge is as necessary nowadays because it has continuously been. The threats to the confidentiality, integrity, and handiness of knowledge have evolved into a colossal assortment of events, as well as accidental or intentional harm, destruction, theft, fortuitous or unauthorized modification, or different misuse from human or dehumanized threats. This new atmosphere of the many perpetually evolving threats has prompted the event of a lot of strong model that addresses the complexities of this info security atmosphere.

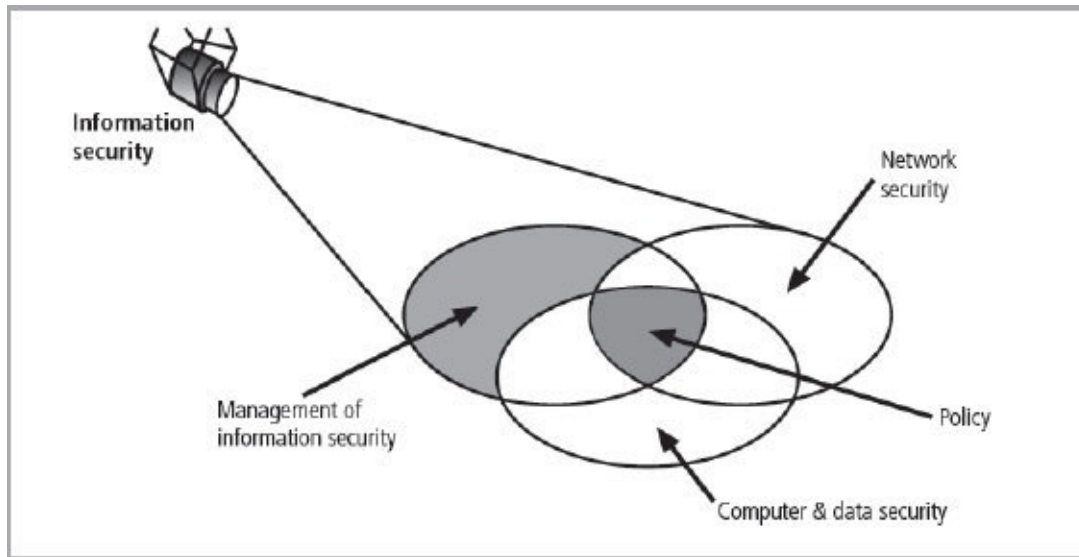


Figure 2.1: *Component of Information Security*

2.1.2 Why information security is important?

The purpose of data security management is to make sure business continuity and cut back business injury by preventing and minimising the impact of security incidents. The Audit Commission Update report (1998) shows that fraud or cases of IT abuse typically occur attributable to the absence of basic controls, with one half all detected frauds found by chance. A data Security Management System (ISMS) permits data to be shared, while making certain the protection of data and computing assets.

The Audit Commission Update report shows that in UK the share of organizations news incidents of IT fraud and abuse in 1997 rose to forty fifth from three hundred and sixty five days in 1994. Whereas instrumentation felony could be a real downside, the foremost damaging facet is that the loss of information and package. Sources of harm like pc viruses, pc hacking and denial of service attacks became additional common, additional formidable and more and more refined. The net exposes organizations to AN inflated risk that networks are going to be accessed improperly, knowledge corrupted and viruses introduced. The share of organizations news hacking incidents has trebled, with phone systems as a brand new target. Not all breaches are the results of crime; accidental misuse and human error play their half too. Virus infections ars still the only most prevailing style of abuse.

Additional common place and even as damaging as crime, are threats like fireplace, system crashes.

Poor superintendence of employees and lack of correct authorization procedures are overtimes highlighted because the main causes of security incidents. Corporations vary in their approach to preventing security breaches: some compel everything, creating mundane access tasks difficult; others are too lax and allow access to all or any by all, exposing themselves to a high degree of risk. Business potency depends on the correct balance and this is often best wherever standards can facilitate.

Dependence on data systems and services suggests that organizations are additionally prone to security threats. The interconnecting of public and personal networks and sharing of data resources will increase the issue of achieving access management. The trend for distributed computing has weakened the effectiveness of central, specialist management.

2.2 THREATS TO INFORMATION SYSTEM

Information systems are often exposed to varied kinds of threats which might cause differing kinds of damages that may cause important money losses. Data security damages will vary from little losses to entire data system destruction. The results of assorted threats vary considerably: some have an effect on the confidentiality or integrity of information whereas others have an effect on the supply of a system. Currently, organizations are troubled to grasp what the threats to their data assets are and the way to get the required suggests that to combat them that continues to cause a challenge.

With the event of data and Communication Technologies and increasing accessibility to the web, organizations become prone to numerous kinds of threats. In fact, their data becomes exposed to cyber attacks and their ensuing damages. Threats return from totally different sources, like employees' activities or hacker's attacks. The money losses caused by security breaches sometimes cannot exactly be detected, as a result of a big variety of losses return from smaller-scale security incidents, caused an irony of data system security risk. Thus, managers have to be compelled to grasp threats that influence their assets and establish their impact to work out what they have to try and do to forestall attacks by choosing applicable countermeasures.

Vulnerabilities contain weaknesses during a system which might be exploited by the attackers that will cause dangerous impact. Once vulnerabilities exist during a system, a threat could also be manifested via a threat agent employing an explicit penetration technique to cause unwanted effects. The money threat loss to organizations can be important.

To find these threats, threats sources and specific areas of the system that will be affected ought to be proverbial, that the data security assets are often protected before. Thus, effective security classification is critical to grasp and establish threats and their potential impacts. In fact, security threats are often ascertained and classified in totally different in several in numerous ways that by considering different criteria like supply, agents, and motivations. Threats classification helps establish and organize security threats into categories to assess and value their impacts, and develop ways to forestall, or mitigate the impacts of threats on the system.

The [Figure 2.2](#) represents the threats classification

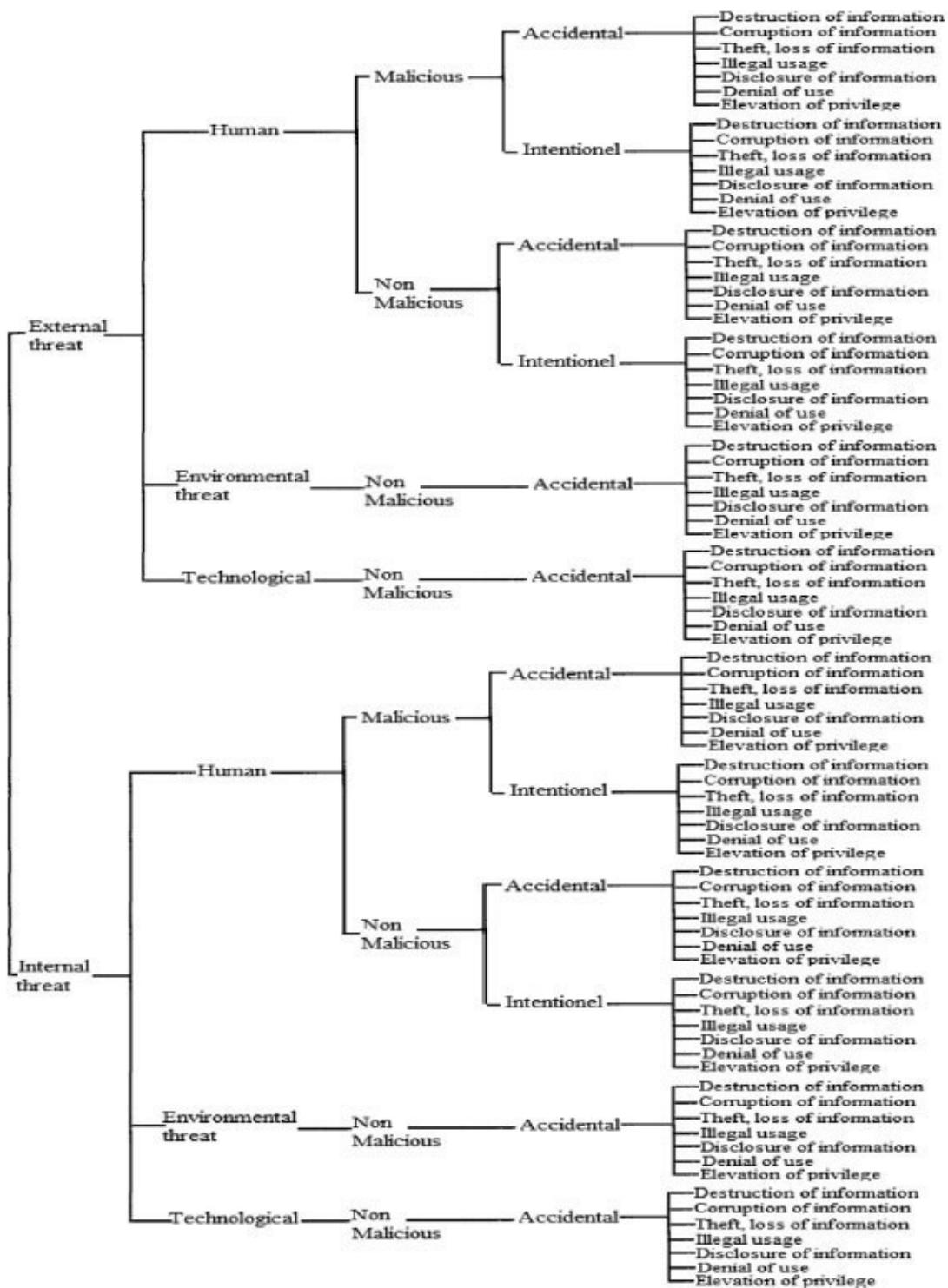


Figure 2.2

2.2.1 Security threat supply

A threat will be caused by internal, external or each external and internal entity. During this paper, we have a tendency to focus solely on a binary classification of the threats origin: internal or external, so as to localize the origin (or source) of a threat.

2.2.1.1 Internal threats

Internal threats occur if someone know about internal information about server with its functionalities and its working with security access over the network. A threat will be internal to the organization because the results of worker action or failure of a company method.

2.2.1.2 External threats

External threats will arise from people or organizations operating outside of an organization. They are doing not have licensed access to the pc systems or network. The foremost obvious external threats to laptop systems and therefore the resident knowledge are natural disasters: hurricanes, fires, floods and earthquakes. External attacks occur by using devices that are the sources form incoming and outgoing internet packets, either wired or wireless.

2.2.2 Threat agents

The threat agent is that the actor that imposes the threat to the system. We have a tendency to know three categories for our specific classification: humans, natural disasters and technological threats. The projected classification covers the total set of potential agents since we have a tendency to embrace humans, chemical and physical reaction on human-made objects (technological), and, natural for all those agents on that humans don't have any influence.

2.2.2.1 Human Threats

This category includes threats caused by human actions like insiders or hackers that cause damage or risk in systems.

2.2.2.2 Environmental factors

Environmental threats are threats caused by non human agent. It comes, first, from natural disaster threats like earthquakes, flood, fire, lightning, wind or water and, also, as a result of animals and life that cause severe harm to data systems like floods, lightning, periodic event Waves (like Tsunami) and fireplace. Indeed, this category includes different threats like riots, wars, and terrorist attacks.

2.2.2.3 Technological Threats

It can be physical or chemical process for technology. Physical processes embrace the employment of physical means that to realize entry into restricted areas like building, compound space, or the other selected space like stealing or harm of hardware and computer code. However, chemical processes embrace hardware and computer code technologies. It, also, includes indirect system support instrumentation like power provides.

2.2.3 Threat motivation

Attackers ordinarily have a particular goal or motive for associate attack on a system. These goals will cause malicious or non malicious results.

Malicious threats include within or outside attacks caused by staff or non-employees to damage and disrupt a company like viruses, Trojan horses, or worms.

Non-malicious attacks occur as a result of poor security policies and controls that enable vulnerabilities and errors to require place. It's caused by ignorant staff with the aim to not damage the system.

2.2.4 Threat intent

Threat intent represents the intent of the human WHO caused the threat:

2.2.4.1 Intentional Threats

It represents threats that are results of a harmful call. For instance laptop crimes, or once somebody by choice damages property or data. Laptop crimes embrace spying, fraud, pornography, and MasterCard crime.

2.2.4.2 Unintentional Threats

It represents threats that are introduced while not awareness. These threats primarily embrace the unauthorized or accidental modification of computer code. Accidental error includes corruption of knowledge caused by computer error, user or operator error.

2.3 INFORMATION ASSURANCE

Many organizations face the task of implementing information protection and information security measures to satisfy a large variety of needs. With increasing frequency, storage managers and professionals square measure being asked to handle components of this protection, that square measure usually given within the type of a security list. However, list compliance by people United Nations agency square measure missing a basic background in data Assurance could be a fast formula for bother.

At its core, data Assurance is concerning guaranteeing that licensed users have access to licensed data at the licensed time. Further, it doesn't matter whether or not is in storage, processing, or transit, and whether or not vulnerable by malice or accident. This session provides associate degree introduction to data Assurance yet as details which will facilitate storage personnel higher perceive its pertinence in their own environments.

Information assurance applies with no. Of policies and its standards that need to be follows to fulfil requirement about its assurance.

Information assurance provides for privacy, integrity, usefulness, possession, utility, believability, non repudiation, licensed use and

privacy of knowledge all told forms and through all exchanges.

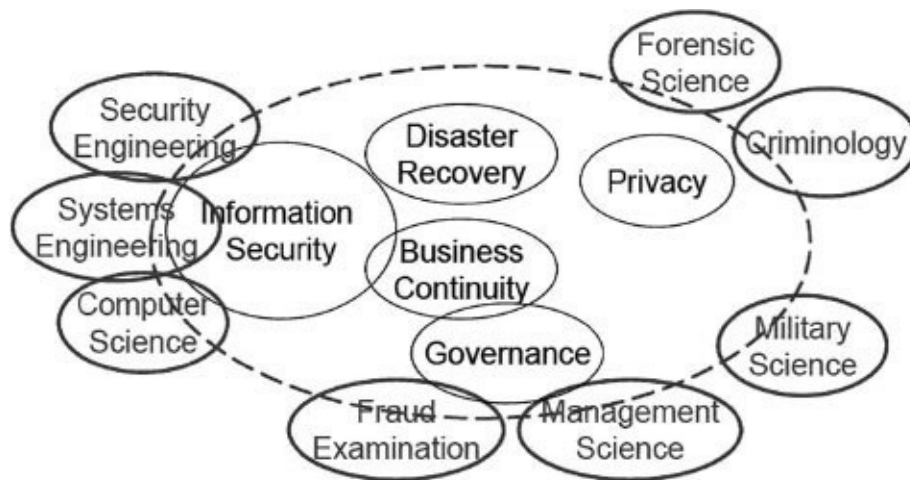


Figure 2.3: Aspects of Information Assurance

INFORMATION ASSURANCE CORE PRINCIPLES

Confidentiality - ensures the disclosure of information only to those persons with authority to see it.

Integrity - ensures that information remains in its original form; information remains true to the creators intent.

Availability - information or information resource is ready for use within stated operational parameters.

Possession - information or information resource remains in the

custody of authorized personnel.

Authenticity - information or information resources conforms to reality; it is not misrepresented as something it is not.

Utility - information is fit for a purpose and in a usable state.

Privacy - ensures the protection of personal information from observation or intrusion as well as adherence to relevant privacy compliances.

Authorized Use - ensures cost-incurring services are available only to authorized personnel.

Non repudiation - ensures the originator of a message or transaction may not later deny action.

2.4 CYBER SECURITY AND SECURITY RISK ANALYSIS

Cyber security is threat for system and it increase without knowing of others. Ensuring cyber security needs coordinated efforts throughout associate system. Parts of cyber security include:

Application security

Information security

Network security

Disaster recovery / business continuity designing

End-user education.

One of the foremost problematic parts of cyber security is that the quickly and perpetually evolving nature of security risks. The standard approach has been to focus most resources on the foremost crucial system parts and defend against the largest famous threats that necessitated deed some slighter system parts undependable and a few less dangerous risks not protected against. Such associate approach is short within the current atmosphere.

To subsume the present atmosphere, conducive organizations are unit promoting a lot of proactive and adaptive approach. The National Institute of Standards and Technology for instance, recently issued updated pointers in its risk assessment framework that suggested a shift toward continuous observation and period assessments.

Security in any system ought to be commensurable with its risks. However, the method to work out that security controls are unit applicable and price effective is sort of usually a fancy and typically a subjective matter. One amongst the prime functions of security risk analysis is to place this method onto a lot of objective basis.

There are a unit variety of distinct approaches to risk analysis.

There are a number of distinct approaches to risk analysis. However, these essentially break down into two types: **quantitative** and

2.4.1 Quantitative Risk Analysis

This approach employs two basic elements; the chance of an occasion occurring and therefore the doubtless loss ought to it occur. Quantitative risk analysis makes use of one figure created from these components. This can be referred to as the 'Annual Loss Expectancy (ALE)' or the 'Estimated Annual price (EAC)'. This can be calculated for an occasion by merely multiplying the potential loss by the chance.

It is so in theory doable to rank events so as of risk (ALE) and to form selections based mostly upon this. The problems with this kind of risk analysis square measure sometimes related to the unreliableness and quality of the information. Chance will seldom be precise and might, in some cases, promote complacence. Additionally, controls and countermeasures usually tackle variety of potential events and therefore the events themselves square measure often reticulate. Notwithstanding the drawbacks, variety of organisations has with success adopted quantitative risk analysis.

2.4.2 Qualitative Risk Analysis

This is out and away the foremost wide used approach to risk analysis. Chance information isn't needed and solely calculable potential loss is employed.

Most qualitative risk analysis methodologies create use of variety of reticulate elements:

Threats

These square measure things that may get it wrong or that may 'attack' the system. Examples would possibly embrace fireplace or fraud. Threats square measure ever gift for each system.

VULNERABILITIES

These create a system additional vulnerable to attack by a threat or create associate attack additional doubtless to own some success or impact. For instance, for fireplace vulnerability would be the presence of flammable materials (e.g. paper).

CONTROLS

These square measure the countermeasures for vulnerabilities. There square measure four types:

Deterrent controls cut back the chance of a deliberate attack

Preventative controls shield vulnerabilities associated create an attack unsuccessful or cut back its impact

Corrective controls cut back the result of associate attack

Detective controls discover attacks and trigger preventative or corrective controls.

These elements can be illustrated by a simple relational model:

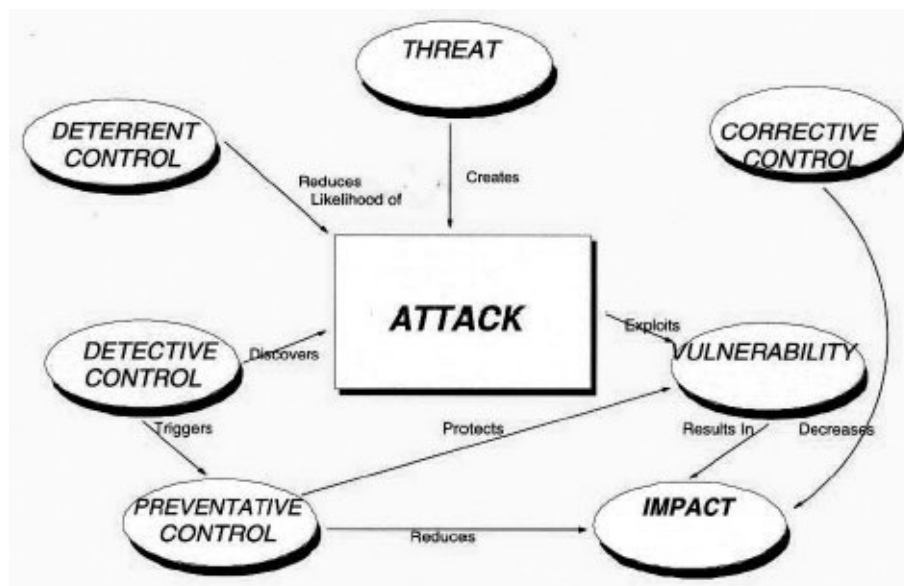


Figure 2.4: *Simple Relational Model*

In the purpose of data system risk analysis method approach it's necessary to contemplate a number of the foremost complete strategies for risk assessment in data system security.

These strategies should provide support in:

Detecting crucial places and components in organisation, Detecting risk factors,

Collecting knowledge concerning risk factors,

Evaluation and estimation risk, opposite to chosen risk methodology, and Report and show result method of risk assessment.

These five steps area unit employed in choice of effective protection management. the most important representative, complete strategies for risk assessment area unit British customary (BS), CCTA Risk Analysis and Management technique (CRAMM); conductive, Objective and Bi-functional Risk Analysis (COBRA); Operationally crucial Threat, Asset, and Vulnerability analysis (OCTAVE), and Failure Mode and Effects Analysis (FMEA). After we quote risk assessment strategies, usually we will watch these strategies through prism of complete security risk assessment

strategies and strategies and techniques that are used for complete risk assessment technique support (or for a finding a particular kinds of problems).

COBRA, or 'Consultative, Objective and Bi-functional Risk Analysis', consists of a spread of risk analysis, conductive and censorship tools. These were developed for the most part in recognition of the dynamic nature of IT and security, and therefore the demands placed by business upon these areas.

The first such undercurrent of amendment was the growing acceptance that IT security was a business issue. It was, and is, changing into for the most part expected that security reviews ought to be business connected, with value even solutions and proposals.

Another issue, considerably of the late 90s, is that the search by several organisations for a stronger robust an improved and more visible come back on their security budgets. To attain this several adopt new approaches to the normal constraints of lack of experience, time and finance. Often, a proper risk analysis technique is utilized. However, typical strategies and tools merely don't address the new demands placed by business management. Some go a part of the method; however tend to introduce their own drawbacks and difficulties.

COBRA, and its default methodology, evolved considerably to tackle these problems properly. it absolutely was developed fully co-

operation with one among the world's major monetary establishments and followed a few years of analysis.

It was recognised that business users ought to be concerned from the offset. This carries variety of benefits, and shapes the whole review. Additionally, variety of alternative radical departures was caught up.

The result was a risk analysis methodology and power that may meet the foremost demanding of needs, totally satisfying the dynamic demands placed upon the protection or audit team.

2.5 QUESTIONS

Explain the concept of Information Security in detail.

What are the various threats to Information Systems?

Explain the concept of Information Assurance in detail; also explain its various aspects.

What are the various components of Information Systems?

What is the meaning of Cyber Security? Explain in detail.

Explain the Security Risk Analysis in detail.

Explain the various classifications of threats in detail.

What are the various components of Information Security?

What are the Information Assurance core principles?

Chapter-3

Application Security

3.1 INTRODUCTION

When we have a desire to point out application security then we focus on doing one thing very well in the difficulty of securing keep private information from unauthorized access and change. This can be completed by forcing (by law) some policy measures in favor of organization. By security threats, we have a habit/desire to agree with the information keep by a company is hacked with evil and cruel plans/desires and take a look at to understand/make real/achieve access to sensitive information.

The aim of application security is to spot the following:

Critical assets of the organization

Genuine users UN agency could access the info

Level of access provided to every user

Various vulnerabilities that will exist within the application

Data criticality and risk analysis on knowledge exposure

Appropriate correction measures

Web application security aims to deal with and fulfill the four conditions of security, additionally said as principles of security:

Confidentiality: States that the sensitive knowledge keep within the net application shouldn't be exposed underneath any circumstances.

Integrity: States that the info contained within the net application is consistent associated isn't changed by an unauthorized user.

Availability: States that the net application ought to be accessible to the real user among a nominal amount of your time betting on the request.

Nonrepudiation: States that the real user will not deny modifying the info contained within the net application which the net application can prove its identity to the real user.

3.1.1 Info security

Creating associate application security policy is that the beginning once writing secure info applications. Associate application security policy could be a list of application security necessities and rules that regulate user access to info objects.

Two main problems to think about after we formulate and implement application security area unit

Are Application Users additionally info Users?

For many business repacked applications, application users don't seem to be info users. For these applications, multiple users certify themselves to the appliance, and also the application then connects to the info as one, highly-privileged user. Applications in-built this fashion typically cannot use several of the intrinsic security measures of the info, as a result of the identity of the user isn't famed to the info.

Is Security implemented within the Application or within the Database?

Applications, whose users also are info users, will either build

security into the appliance, or depend on intrinsic info security mechanisms like granular privileges, virtual personal databases (fine-grained access management with application context), roles, keep procedures, and auditing (including fine-grained auditing). Oracle recommends that applications utilize the protection social control mechanisms of the info as so much as doable.

When security is implemented within the info itself, instead of within the application, it cannot be bypassed. The most disadvantage of application-based security is that security is bypassed if the user bypasses the appliance to access knowledge. For instance, a user UN agency has SQL*Plus access to the info will execute queries while not rummaging the Human Resources application. The user, therefore, bypasses all of the protection measures within the application.

3.1.2 Email Security

Email could be a howling tool, no doubt, however it's not while not security problems. Typical email configurations leave senders of email to spoof their addresses and send email messages in plain text. Even worse, it's troublesome for a recipient of associate email to verify that the sender is really UN agency sent the message. We've got many security tools at our disposal to confirm confidentiality (through secret writing) and integrity (through encryption, digital signatures, and robust passwords). Here are a unit a number of those tools:

S/MIME, or Secure utile net Mail Extensions, provides basic cryptanalytic services for email sent via the net. Hottest browsers and email shoppers support S/MIME, creating it among the additional fashionable cryptanalytic email security services on the market.

MOSS, or MIME Object Security Services, could be a less-common, additional in depth suite of security services for email.

PEM, or Privacy increased Mail, provides 3DES secret writing for email.

PGP, or Pretty smart Privacy, is associate ASCII text file and intensely fashionable email security suite that uses plan to inscribe email and validate signatures.

Email additionally incorporates a few security vulnerabilities:

Spam is one in all the foremost usually mentioned nuisances, however did we all know it's really thought of a security threat? By preventative the e-mail server, widespread spam denies to the user handiness, a key element of the Central Intelligence Agency triangle. Some spam solutions embody user education, email filtering, and coverage of Spam to the correct authorities.

Open relays area unit email servers that forward email with none quite authentication. In alternative words, open relays enable malicious users to send bulk email while not work into associate email server. An honest email security setup perpetually includes a non-open relay server (or attested relay server).

Malicious Software: clearly, viruses and worms area unit an outsized drawback. Several propagate via email messages that area unit mechanically sent by infected hosts. One in all the additional common solutions is to virus scan and filter incoming email.

3.1.3 net Security

The Internet may be a dangerous place, and so, we have a tendency to have an interest in protective users from malicious internet sites moreover as protective the knowledge that users send to internet sites.

SSL could be a connection-oriented commonplace designed to permit for secure cryptanalytic communication between 2 hosts via the net. TLS is that the newest version of SSL.

S-HTTP could be a connectionless commonplace that gives for biracial secret writing, message digests, and client-server authentication.

Browser Scripts/Vulnerabilities area unit controls, scripts, programs, or alternative code that may run from the browser and cause harm to a bunch. Especially, ActiveX controls area unit well-known for his or her usually malicious content. The most effective thanks to defend against browser buffer overflows are to stay open-eyed and updated on the most recent patches.

3.2 KNOWLEDGE SECURITY ISSUES

When addressing knowledge in Windows Communication, one should contemplate variety of threat classes. The foremost necessary threat categories that relate to processing are:

DENIAL OF SERVICE

When receiving entrusted knowledge, the info could cause the receiving facet to access a disproportionate quantity of assorted resources, like memory, threads, on the market connections, or processor cycles by inflicting drawn-out computations. A denial-of-service attack against a server could cause it to crash and be unable to method messages from alternative legitimate shoppers. Malicious code execution Incoming entrusted knowledge causes the receiving facet to run code it failed to shall.

Information revealing the remote assailant forces the receiving party to reply to its requests in such the way on disclose additional data than it intends to.

For knowledge security, we have a tendency to additionally choose backup of information. If at all, at some purpose we have a tendency to lose our knowledge attributable to any reason, we have a tendency to should have its backup in order that we are able to

more precede our work with none delay moreover as while not skipping any necessary knowledge.

3.2.1 BACKUP issues

We all apprehend that losing knowledge may be devastating. The requirement for having consistent and reliable backups is pretty obvious. However reaching to that stage may be additional confusing.

The first step for making knowledge backup is

If we have a tendency to protect everything, what quantity house would we have a tendency to need? Detain mind that in an exceedingly true disaster recovery case, we'd wish to own associate off-site copy of our knowledge that gets cycled with our traditional on-site backups each alternative week roughly. This suggests we'd really want up to double what our 1st size estimate is.

Importance: However necessary is that the data?

Security: be an honest plan to label or note what knowledge has to be unbroken confidential. One may contemplate keeping accounting and alternative sensitive knowledge backups on external exhausting drives in an exceedingly safe off-site.

Frequency of modification: Usually the info on a specific machine change? This may facilitate in deciding however usually we want to back it up. If the documents shared off of the digital computer solely modification once each a pair of weeks, then we might solely got to back it up each time period. Most backup code out there'll leave progressive backups - which imply that after it's a full backup of the info, it'll compare the present files to the files it's protected before and can solely backup the new and altered files since that backup. Progressive backups area unit nice however a full backup ought to still be taken once more each once in an exceedingly whereas to assist speed on recovery just in case of a disaster.

Recovery time: How long will we have a tendency to look ahead to the info to be recovered just in case of a disaster? This question can facilitate United States of America to see what quite backup medium would be best to use. If we have a tendency to wouldn't want the info anytime presently, we have a tendency to may use service to backup and restore the info over our internet affiliation, or we have a tendency to may invest in an exceedingly tape backup device and tapes. If we want quicker restore times, external USB or fireplace wire exhausting drives ought to be thought of. If we want it at once and losing it'd cause major work period of time, we should always make certain the server itself has its own redundancy that it will endure and so even have the external exhausting drives around for the intense cases.

Depending on the scale of labor, gathering this knowledge may take many hours to many months, however knowing it's the most effective thanks to be ready to set up for disaster recovery set up

and additionally coming up with a take into account our backup hardware/software.

3.2.2 Repository storage

In computers, repository storage is storage for knowledge that will not be actively required however is unbroken for doable future use or for record-keeping functions. Repository storage is commonly provided mistreatment an equivalent system as that used for backup storage. Typically, repository and backup storage may be retrieved employing a restore method.

Repository storage boxes area unit storage containers that area unit made from P.A.T. Certified materials to confirm the integrity of long storage. This repository material is crafted into solid, secure boxes that resist dirt, and lightweight infiltration. Rigid, metal-reinforced corners produce a secure seam and resist crushing even once stacked. Ideal repository observe suggests replacement all acid free papers, boxes etc each five years. Whether or not for artifacts, documents or photos, repository storage boxes create ideal storage solutions.

To browse documents, lay them on a flat surface and minimize handling.

All documents ought to be housed in an exceedingly protecting sleeve product of polyester (Mylar), moreover as paper envelopes for storage.

Once retrieving one item from a folder, 1st takes away the folder from the box and so takes away the item.

Once putting papers in file folders, there ought to be no quite 10 sheets per folder. Use even few sheets per folder once storing additional valuable documents.

Interleave documents mistreatment acid-free writing paper or glassine sheets.

Newspaper clippings area unit terribly acidic. They ought to be treated with deacidification spray and keep in their own folders to limit acid migration. Perpetually take a look at a treatment on an not easily seen space of the fabric before treating the complete item.

Store materials in an exceedingly comparatively cool, dry, dark location. Paper ought to be unbroken in associate atmosphere with a ratio of 35-40%. Things like animal skin, textiles etc. ought to be in 45-55% RH.

Interleave massive things with buffered paper for support.

Once selecting associate acid-free tissue, contemplate the kind of artifact you're storing. Cotton, flax, linen, and jute ought to be keep

employing a buffered tissue to neutralize acids. Wool, silk, and textiles area unit best keep mistreatment unbuffered tissue that incorporates a neutral pH scale.



Figure 3.1: *Archival Storage*

3.2.2.1 Archival Photo Storage

Storing your assortment in applicable icon Storage Boxes, Envelopes, Sleeves, and Albums can defend against light-weight, dust, handling, air pollutants, and speedy fluctuations in temperature and humidness.

The icon Activity take a look at was developed by the Yankee National Standards Institute (ANSI) to gauge materials that are available in contact with photographic emulsions. Materials that pass the take a look at facilitate guarantee safe long storage of negatives, slides, and microfilm.

All negatives and prints need protection from finger oils, acids, dust, dirt, pollution, and abrasion. Use of cotton gloves once handling your negatives and prints can defend against injury.

Buffered vs. Unbuffered: The ANSI normal for color icon storage is unbuffered envelopes. The ANSI normal for black and white icon storage is buffered envelopes.

Photo storage ought to be fabricated from robust, sturdy and with chemicals stable material. Any material that comes connected with images ought to pass the P.A.T. test. Don't store images in commercially obtainable "magnetic" icon albums. Opt for acid-free

materials and pages.

Extend the lifetime of your icon album by victimization deposit material. The best icon album would be created with 100 percent deposit materials together with a protective covering, a hinge that enables the book to well expand, and size that's simple to shelve or store.

If you select to use plastic page protectors, purchase them from a recognized deposit merchandise company. Several "PVC-free" plastics that are obtainable through discount stores don't seem to be deposit.

Attach your images, postcards, associated different things with deposit icon corners or opt for an acid-free adhesive. This can forestall discoloration of tape and materials.

Store slides in a very cool, dark, low humidness atmosphere to avoid plant growth. Avoid long exposure to any light together with daylight, fluorescent lamps, lighted viewers and lightweight boxes.

If a photograph or assortment produces a vinegar/acidic smell, take away the icon from the gathering associated place in isolated air tight instrumentation. This smell is understood and Vinegar unwellness and spreads quickly to different images. Vinegar unwellness will increase the speed of degradation in images and may be potential harmful.

Photographs ought to be unbroken out of direct daylight and off from harmful actinic ray rays to avoid attenuation and yellowing.



Figure 3.2: *Archival Photo Storage*

3.2.3 Disposal of data

The aim is to ascertain pointers by however we will minimize the risks of knowledge speech act through inappropriate deletion of knowledge, or inadequate destruction of media before disposal.

Information Removal and Disposal strategies for disk: Drives disk Drives will be firmly erased and redeployed inside a company to push utilize of IT instrumentation. If a HDD is to be reused in an atmosphere or system with equivalent security controls to it wherever the HDD was antecedently used, the 'Clearing' method should be applied. For HDDs which can move to a less secure atmosphere or could leave the organization for marketing or disposal, the 'Purging' method should be applied.

Information Removal and Disposal strategies for Optical Media: Rewritable optical media will be erased and reused through the employment of erase functions accessible in disc recording software package. Most software package packages use a 'quick erase' operate that clears the header sections of the disc however doesn't take away all files. This implies that it should be doable to recover info from an erased disc, and so this methodology ought to solely be used once a disc is to be reused in an atmosphere of equivalent security to it wherever the disc was last used. If this kind of utilize isn't doable the disc ought to be destroyed.

3.2.3.1 INFORMATION REMOVAL/ DISPOSAL TECHNIQUES

Many of the strategies delineated within the following section are going to be applicable to numerous totally different media varieties.

Classification of knowledge Removal

There square measure two major information removal classifications that facilitate verify the strategies used further because the doable prices concerned. Information clearing offers a quick methodology of knowledge destruction mistreatment software package applications however is merely appropriate to be used on media that is to be redeployed in an atmosphere of equivalent security controls to it of wherever the media was last used. Information Purging could be a additional thorough methodology of knowledge destruction, and is employed once media moves from an existing security zone to a brand new security zone. This new security zone could or might not be safer than this security measures in impact.

Clearing

If the disk drives/media can stay inside a similar atmosphere during which they're presently settled (and existing security measures can still cowl them), the foremost acceptable removal

methodology is clearing. Clearing involves less complicated removal strategies. As long as explicit sections want removing and comprehensive data removal from the media isn't needed, then non-specialist workers or contractors could perform clearing.

Most of the disk Drives factory-made once 2001 embrace the Secure Erase command inside the drive microcode that permits an administrator to quickly and effectively clear information from the drive. This method needs the installation of application software package on the host system that may execute the Secure Erase command on the disk drive. The Secure Erase command is additionally capable of overwriting reallocated disk sectors, wherever the drive has enraptured information thanks to arduous errors. This provides a bonus over the employment of knowledge clearing software package programs that cannot erase unhealthy disk sectors.

Purging

Purging is needed once media moves from an existing security zone to a brand new security zone. This new zone could or might not be safer than this security measures in impact. Once removal of media from its current security context there should be spare care taken to make sure that information is unrecoverable, notwithstanding specialised recovery strategies square measure used. For systems that support the Secure Erase command, the clearing method is technically love the purging method.

3.2.3.2 Information Removal from Live Systems

There square measure varied situations during which information may have removing from a system whereas still operative, or utilize of the media is needed for monetary or policy reasons. In these cases, organizations ought to build all doable efforts to get rid of information from the target media whereas not adversely poignant the performance of live systems or the long-run effectiveness of the media to perform the role required of it. During this case, the foremost common situation would be to get rid of the info from arduous disks or tape backup devices mistreatment processes engineered into applications or operational systems once a specific application not needs it.

3.2.3.3 Information Removal for Media utilize

Often media like disk drives square measure reused instead of being fully decommissioned. It's the utilize demand, therefore, that ought to be the actuation behind the removal strategies used. In several infrastructure environments, disk utilize is common. A specific disk is also reused across many alternative individual machines or business uses. During this situation, clearing could be a spare methodology of guaranteeing information is non-recoverable. Keeping a log of all clearing processes provides an audit path that records all the areas that the disk has been in use and, before utilizes of the disk in an exceedingly totally different space, the verification of knowledge removal.

Best apply instructs that unless there's a compelling reason to try and do therefore, media shouldn't transfer between differing securities contexts. If media will need moving between security contexts, purging wants conducting in line with the steerage during this document to make sure that no information is recoverable, mistreatment any means that.

3.2.3.4 Verification of knowledge Removal

If a specialist company or contractor has processed newspapers, web sites, and TV, there should be a procedure for checking (for truth) of knowledge removal, as well as the supplying of certificates. If native staffs (have controlled or managed/have given medicine or something else) the info removal then the method should be recorded with the checking (for truth) results and keep with all other choice (clearly connected or related) (paperwork that proves or supports something). Tools that plan to retrieve information from media that has gone through removal method will be very helpful in confirming that complete data removal has happened.

3.3 SECURITY TECHNOLOGY

There is the necessity to grasp the distinction between authorization and access. Authorization is permission, and access is means that. Authorization means that we tend to permit somebody to try and do one thing. Access means that somebody will get at an plus. Apart from that, slightly additional vocabulary can facilitate USA to perceive the primary terms used here:

Owner - an individual answerable for the integrity and security of an plus. This could be a management role rather than a technical role.

custodian - an individual UN agency maintains the safety of a system, maybe by adding and removing access by user accounts. (This role is additionally referred to as AN administrator.)

end user - an individual UN agency uses the plus, like reading a file, gap an online page, or printing some information from a info, however UN agency isn't allowed to vary access rights to the plus. This idea is additionally referred to as a topic in some texts.

Subjects (users or processes acting for users) perform operations on objects (assets)

Supplicant - word as a equivalent word for “requester”

There square measure 3 access management methods:

Mandatory Access management (MAC) - the foremost restrictive model; the owner defines a security policy, the shielded implements it, and therefore the finish users cannot modification it; this could be enforced by setting a security level for every plus and granting authorization to users by distribution them to grade

Nondiscretionary controls are available in 2 varieties

Role based mostly Access management (RBAC) - access is granted to roles (groups) outlined on the systems, finish users square measure allotted to roles so that they will access assets required for his or her jobs; the text uses Windows Server 2008 as AN example of a system that may use this model

Task based mostly Access management (TBAC) - is also the foremost advanced model; rules will modification that role a user is allotted to, supported the task the user is activity, dynamic the amount of access the user has

Discretionary Access management (DAC) - least restrictive model; subjects (end users) will own objects, and have total management

over them; finish users should set and maintain security for his or her assets, that the general public can do badly; processes travel by finish users inherit their permission levels

The text tells USA that users should initial determine themselves to a system, however identification is pointless while not authentication. Identification is solely getting into a user name. Authentication is one among 3 key components to security:

Authentication - confirmation of identity

Authorization - granting permissions that square measure joined to the user's account

Accounting, answerableness, auditing - pursuit what the user will

Most security relies on one or additional of 3 sorts of things: one thing we've (like a key or AN ID card), one thing we all know (like a PIN or a password), or one thing we tend to square measure (like a fingerprint).

When an individual logs in from a customary digital computer in an exceedingly traditional atmosphere, one level of protection, like AN ID and watchword combine, is also secure enough.

For a situation that is more vulnerable, like logging in from a

remote location through a public data network, **two levels** may be required, such as a **user name-password** pair along with a **one-time password** from a security device. We see the layers? My password is no good unless I use the one-time key from the device, which is no good unless I know the PIN that proves I am allowed to use the device. The one-time password shown in the image on the right, by the way, is only good for one minute. After that minute, a new six numeral code will be generated.

3.3.1 FIREWALL

We can use a firewall to protect our home network and family from offensive Web sites and potential hackers. Basically, a firewall is a barrier to keep destructive forces away from our property. In fact, that's why its called a firewall. Its job is similar to a physical firewall that keeps a fire from spreading from one area to the next.

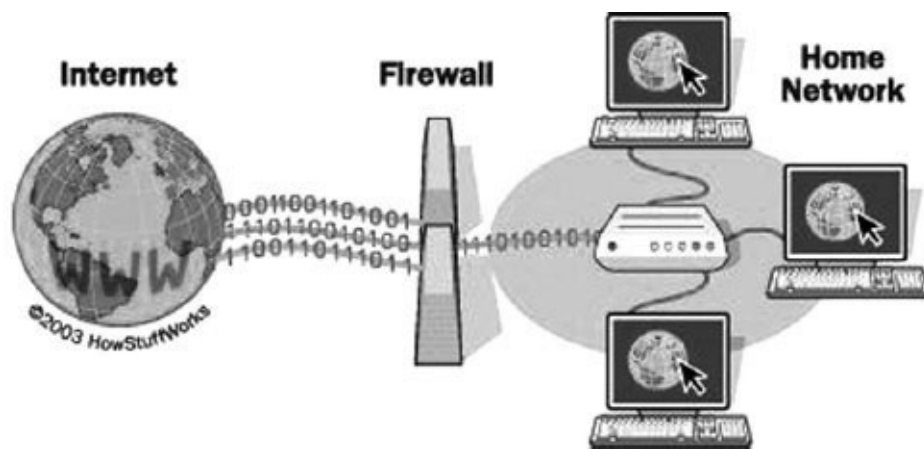


Figure 3.3: *How Firewall Works?*

Firewalls may be classified into three different ways:

by their processing type

by their evolutionary generation

by the way they are implemented (structure).

Firewalls by processing type:

Packet-filtering firewalls: Traffic on a network is broken into smaller message units. Each packet must hold at least two that of the **sender** and that of the A packet-filtering firewall will hold a database of rules that tell it what to do with packets. Often the rules are based on the addresses mentioned above and the protocol (network rules) the packet is being sent under. The rules may include all three ideas,

The first rule says if the packet is from any address on the 172.16.0.0 network (172.16.x.x) and being sent to any address on the 10.10.0.0 network, using any protocol, drop the packet (Deny). The **x** characters are used as **wildcards** on some firewalls, as the text mentions later. Other firewalls might use zeros instead, so we need to know the syntax for the firewall we are configuring.

The second rule says if the packet is from any address on the 192.168.0.0 network (192.168.x.x) and being sent to the specific address 10.10.10.25 (10.10.10.25), using the HTTP protocol (HTTP is hypertext transfer protocol), let that packet through (Allow). This tells me that 10.10.10.25 is the address of a web server on that network, because HTTP is for web pages.

The third rule says if the source address is specifically 192.168.0.1 (192.168.0.1) and the destination address is specifically 10.10.10.10, and the protocol is FTP (FTP is file transfer protocol), then let the packet through (Allow).

Packet filtering firewalls come in three types.

static - a system administrator sets the rules for the firewall

dynamic - the firewall sets some rules for itself, such as dropping packets from an address that is sending many bad packets

stateful - packets sent by an attacker often are sent to a port that the attacker has guessed is open; a stateful firewall denies packets sent to any port unless a connection to that port has already been negotiated; this kind of checking puts more processing overhead on the firewall

Application gateway firewalls: The ISO-Open Systems Interconnect networking model has seven layers that describe what happens to a packet as it is prepared to be sent out on a network, and what happens when that packet is received by the machine that is meant to act on it.

Packets **leaving** a device start at the top layer of the model

(Application, layer 7) and are processed down to stack to the bottom layer (Physical, layer 1). Packets being **received** by a device arrive at the Physical layer, and are handed off to each successive layer until they are received by an application at layer 7.

The chart below shows the seven layers of the ISO-OSI model, the firewall types associated with several layers, and a summary of the many things that happen on each layer.

layer. layer. layer.

[illegible]

layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer. layer.

[illegible]

layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer.

layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.

layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer.

layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer.

layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer. layer.
layer. layer. layer. layer. layer. layer.

3. *Circuit gateways*

This firewall lives on the transport layer that is related to warranted delivery of packets. It explains that the perform of the circuit entree is a smaller amount analytical than the proxy server, however that it will function associate mediator similarly, ensuring that solely

requested knowledge is came back to the requester. It'll not examine the information for content.

4. Mackintosh layer firewalls

The mackintosh sub layer of the ISO-OSI circuit layer cares with mackintosh addresses, the arduous coded addresses that area unit usually burned into network cards once they area unit factory-made. This type of firewall can check the mackintosh address of a requester to work out whether or not the device being employed to create the association is permitted to access the information in question. This could be helpful in things wherever devices area unit placed in lobbies for patrons World Health Organization area unit allowed to browse a catalog, however not allowed to position orders that will have an effect on inventory.

5. Hybrid Firewalls:

Hybrid Firewalls mix the weather of different styles of firewalls-that is, the weather of packet filtering and proxy services, or of packet filtering AND gate gateways. Alternately, a hybrid firewall system may very well include 2 separate firewall devices: every may be a separate firewall system, however they're connected so they add bicycle. As an example, a hybrid firewall system may embrace a packet filtering firewall that's established to screen all acceptable requests then pass the requests to a proxy server, that successively,

requests services from an online server deep within the organization's networks. Another advantage to the hybrid firewall approach is that it permits a company to create a security improvement while not utterly replacement it's existing firewalls.

Firewalls by their Evolution Generation

First-generation firewalls: Packet filtering

Static packet filters

One of the best and least expensive types of firewall protection is thought as static packet filtering. With static packet filtering, every packet coming into or deed the network is checked and either passed or rejected counting on a group of user-defined rules. Coping with every individual packet, the firewall applies its rule set to work out that packet to permit or proscribe. You'll be able to compare this kind of security to the chucker-out at a club UN agency permits folks over twenty one to enter and turns back people who don't meet the age rule necessities. The static packet filtering firewall examines every packet supported the subsequent criteria:

Source informatics address

Destination informatics address

TCP/UDP supply port

TCP/UDP destination port

For example, to permit e-mail to and from an SMTP server, a rule would be inserted into the firewall that allowed all network traffic with a transmission control protocol supply and destination port of twenty five (SMTP) and also the informatics address of the mail server as either the supply or destination informatics address. If this were the sole filter applied, all non-SMTP network traffic originating outside of the firewall with a destination informatics address of the mail server would be blocked by the firewall.

There are unit drawbacks. Basic packet filtering firewalls are at risk of informatics spoofing, where an entrant tries to realize unauthorized access to laptops by causing messages to a computer with an informatics address indicating that the message is returning from a trustworthy host. Info security consultants believe that packet filtering firewalls provide the smallest amount of security as a result of the permit an on the spot affiliation between endpoints through the firewall. This leaves the potential for a vulnerability to be exploited. Another disadvantage is that this type of firewall seldom provides sufficient work or coverage capabilities.

Stateful Packet scrutiny

Within an equivalent generation of static packet filtering firewalls area unit firewalls referred to as stateful packet scrutiny firewalls. This approach examines the contents of packets instead of simply filtering them; that's, it considers their contents still as their addresses. We are able to compare this to the safety guard at AN aerodrome. A price tag validates that has to be traveling from our supply to our destination; but, our carry-on contents should be checked to induce to our final destination.

These firewalls area unit referred to as stateful as a result of they will allow outgoing sessions whereas denying incoming sessions. They take into consideration the state of the connections they handle so, for instance, a legitimate incoming packet may be matched with the outward request for that packet and allowed in. Conversely, AN incoming packet masquerading as a response to a nonexistent outward request may be blocked. By mistreatment one thing referred to as session or intelligent filtering, most stateful scrutiny firewalls will effectively track info concerning the start and finish of network sessions to dynamically management filtering choices. The filter uses sensible rules, therefore enhancing the filtering method and dominant the network session instead of dominant the individual packets.

Basic routers usually don't perform stateful packet inspections unless they need a special module just like the firewall IOS feature in Cisco routers. An infatuated firewall device or server (with software) is typically needed once the amount of security demands stateful scrutiny of knowledge in and out of a network. Though

stateful packet scrutiny offers improved security and higher work of activities over static packet filters, it's its drawbacks still. Putting in place stateful packet examination rules is a lot of difficult and, like static packet filtering, the approach permits an on the spot affiliation between endpoints through the firewall.

Second-generation firewalls:

Proxy services

The next generation of firewalls tried to extend the amount of security between trusty and untrusted networks. Referred to as application proxy or entrance firewalls, this approach to protection is considerably completely different from packet filters and stateful packet scrutiny. An application entrance firewall uses software package to intercept connections for every net protocol and to perform security scrutiny. It involves what's unremarkably referred to as proxy services. The proxy acts as AN interface between the user on the interior trusty network and also the net. Every laptop communicates with the opposite by passing all network traffic through the proxy program. The proxy program evaluates knowledge sent from the shopper and decides that to pass away and that to drop. Communications between the shopper and server occur like the proxy weren't there, with the proxy acting just like the shopper once talking with the server, and just like the server once talking with the shopper. This is often analogous to a language translator UN agency is that the one truly guiding and causing the

communication on behalf of the people.

Many info security consultants believe proxy firewalls provide the very best degree of security as a result of the firewall doesn't let endpoints communicate directly with each other. Thus, vulnerability in a very protocol that might slide by a packet filter or stateful packet scrutiny firewall may well be caught by the proxy program. Additionally, the proxy firewall can give the most effective work and coverage of activities.

Firewalls evolved: The third generation

The newest generation of firewalls could also be organized and listed as progressive outside border security (combined different things together so they worked as one unit) at periods of time (or space) major network elements. These systems alert directors in real time concerning suspicious activity that will be happening on their systems. Though it is a heap to swallow, this new generation of firewall has changed (and gotten better) to satisfy the key needs demanded by company networks of inflated security whereas (making something as small as possible/treating something important as unimportant) the hit/effect on network performance. The wants of the third generation of firewalls are going to be even a lot of hard-to-please thanks to the growing support for VPNs, wireless communication, and increased virus protection. The best tough part of this (change for the better, over time) is maintaining the firewall's simpleness (and (from that place or time) its (ability to be kept going or kept operating) and security) while not

compromising flexibility.

The most recent class of firewalls making an attempt to fulfill this demand performs what has been termed stateful structure scrutiny, or SMLI. SMLI firewalls eliminate the redundancy and CPU-intensive nature of proxy firewalls. SMLI's distinctive approach screens the whole packet; OSI layers a pair of through seven, and quickly compares every packet to famed bit patterns of friendly packets before deciding whether or not to pass the traffic. Plus or integrated into AN intrusion-detection system (IDS), SMLI offers the primary glimpse of this new definition of a firewall. Among the product that use this new technology area unit Check Point's FireWall-1, Elron Software's net Manager, and Sonic Wall's line of access security product.

Firewalls by the method they enforced

confirm the access denial methodology to use: It is suggested you start with the methodology that denies all access by default. In alternative words, begin with a entrance that routes no traffic and is effectively a brick wall with no doors in it.

confirm arriving access policy: If all of your net traffic originates on the local area network this could be quite easy. An easy NAT router can block all arriving traffic that's not in response to requests originating from at intervals the local area network. As antecedently mentioned, truth informatics addresses of hosts behind

the firewall area unit ne'er disclosed to the surface world, creating intrusion extraordinarily tough. Indeed, native host informatics addresses during this variety of configuration area unit sometimes personal addresses, creating it not possible to route traffic to them from the net. Packets returning in from the net in response to requests from native hosts area unit self-addressed to dynamically allotted port numbers on the general public aspect of the NAT router. This modification quickly creating it tough or not possible for AN entrant to form assumptions concerning that port numbers to use.

If your necessities involve secure access to local area network primarily {based} services from net based hosts, then you may ought to confirm the standards to be employed in deciding once a packet originating from the net could also be allowed into the local area network. The stricter the standards, the safer your network are going to be. Ideally could apprehend that public informatics addresses on the net may originate arriving traffic. By limiting arriving traffic to packets originating from these hosts, you decrease the probability of hostile intrusion. You will additionally wish to limit arriving traffic to sure protocol sets like ftp or protocol. All of those techniques may be achieved with packet filtering on a NAT router. If you cannot apprehend the informatics addresses that will originate arriving traffic, and you cannot use protocol filtering then you may would like a lot of advanced rule based mostly model and this can involve a stateful multilayer scrutiny firewall.

confirm outward access policy: If your users solely would like

access to the online, a proxy server could provide a high level of security with access granted by selection to applicable users. As mentioned, however, this kind of firewall needs manual configuration applications programmed on each machine. Outward protocol filtering also can be transparently achieved with packet filtering and no sacrifice in security. If you're employing a NAT router with no arriving mapping of traffic originating from the net, then you will enable local area network users to freely access all services on the net with no security compromise. Naturally, the chance of workers behaving without showing responsibility with email or with external hosts may be a management issue and should be restricted intrinsically.

confirm if dial-in or dial-out access is needed: Dial-in needs a secure remote access server that ought to be placed outside the firewall. If dial-out access is needed by sure users, individual dial-out computers should be created secure in such the way that hostile access to the local area network through the dial-out affiliation becomes not possible. The surest thanks to try this is to physically isolate the pc from the local area network. Instead, personal firewall software package could also be accustomed isolate the local area network interface from the remote access interface.

Decide whether or not to shop for an entire firewall product, have one enforced by a systems plan meter or implement one yourself: Once the on top of queries are answered, it should be set whether or not to shop for an entire firewall product or to put together one from useful routing or proxy software package. This call can

rely the maximum amount on the supply of in-house experience as on the quality of the necessity. A satisfactory firewall could also be engineered with very little experience if the wants area unit simple. However, advanced necessities won't essentially entail recourse to external resources if the computer user has sufficient grasp of the weather. Indeed, because the quality of the safety model will increase, therefore will the necessity for in-house experience and autonomy.

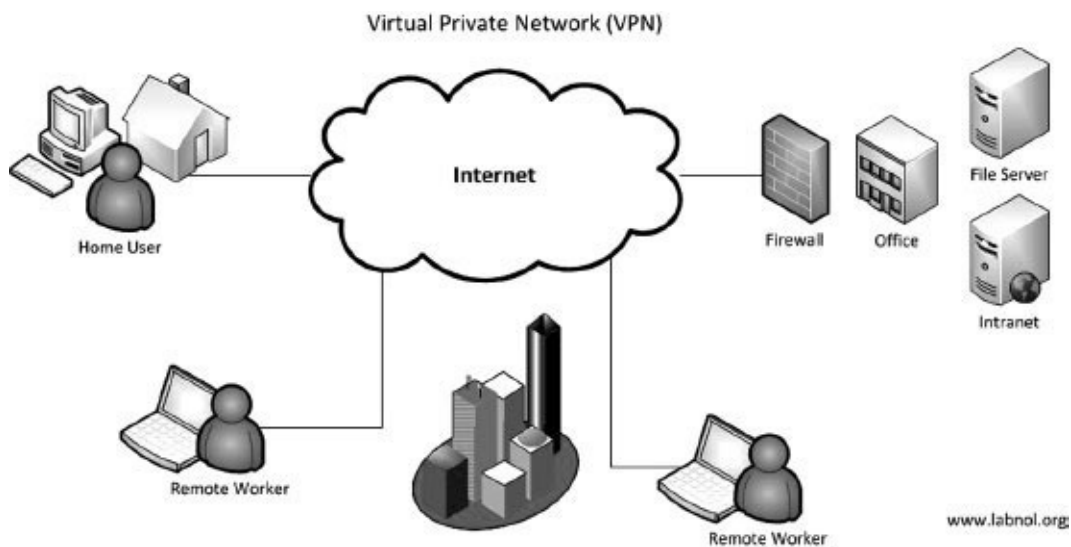


Figure 3.4: *Virtual Private Network*

This can be discussed in three ways:

Trusted VPN - uses chartered knowledge lines from an information merchant that are certain to be break free the remainder of their network; clearly this is often dearly-won and not an possibility if we tend to don't trust the seller.

Secure VPN - uses security technology and encoding to form our traffic unimportant to eavesdroppers

Hybrid VPN - uses each of the ways higher than, usually over many hops to the target network (What's a hop? each time our signals pass another router, that is a hop.)

A VPN that proposes to supply a secure and reliable capability whereas wishing on public networks should accomplish the subsequent, despite the precise technologies and protocols being used:

Encapsulating of incoming and outgoing knowledge, whereby the native protocol of the consumer is embedded at intervals the frames of a protocol which will be routed over the general public network moreover as be usable by the server network setting.

encoding of incoming and outgoing knowledge to stay the info contents personal whereas in transit over the general public network however usable by the consumer and server computers and/or the native networks on each ends of the VPN affiliation.

Authentication of the remote laptop and, perhaps, the remote user moreover.

Authentication and also the sequent authorization of the user to perform specific choices are predicated on correct and reliable identification of the remote system and/or user.

In the most typical implementation, a VPN permits a user to show the net privately network. As we know, the net is something however personal. However, victimization the tunneling approach a personal or organization will got wind of tunneling points across the net and send encrypted knowledge back and forth, victimization the IP-packet-within-an-IP-packet technique to transmit knowledge safely and firmly. VPNs are easy to line up and maintain sometimes need solely that the tunneling points be dual-horned-that is, connecting a non-public network to the net or to a different outside affiliation purpose.

3.3.2.1 Transport Mode

In transport mode, at intervals AN informatics packet is encrypted however the header information isn't. This enables the user to ascertain a secure link directly with the remote host, encrypting solely the info contains of the packet. The draw back to the current implementation is that packet eavesdroppers will still confirm the destination system.

Once a wrongdoer is aware of the destination, he or she could also be able to compromise one among the top nodes and acquire the packet info from it. On the opposite hand, transport mode eliminates the necessity for special servers and tunneling package, and permits the top users to transmit traffic from anyplace. This is often particularly helpful for traveling or teleporting staff.

There are two in style uses for transport mode VPNs. The primary is that the end-to-end transport of encrypted knowledge. During this model, to finish users will communicate directly, encrypting and decrypting their communications as required. Every machine acts because the finish node VPN server and consumer. Within the second, an overseas access employee or steelworker connects to A workplace network over the net by connecting to a VPN server on the perimeter. This enables the steelworker's system to figure as if it were a part of the native space network. The VPN server during this example acts as on intermediate node, encrypting traffic from

the secure computer network and transmittal it to the remote consumer, and decrypting traffic from the remote consumer and transmittal it to its final destination.

3.4 INTRUSION DETECTION SYSTEM

An intrusion detection system (IDS) could be a style of security package designed to mechanically alert directors once somebody or one thing is making an attempt to compromise data system through malicious activities or through security policy violations.

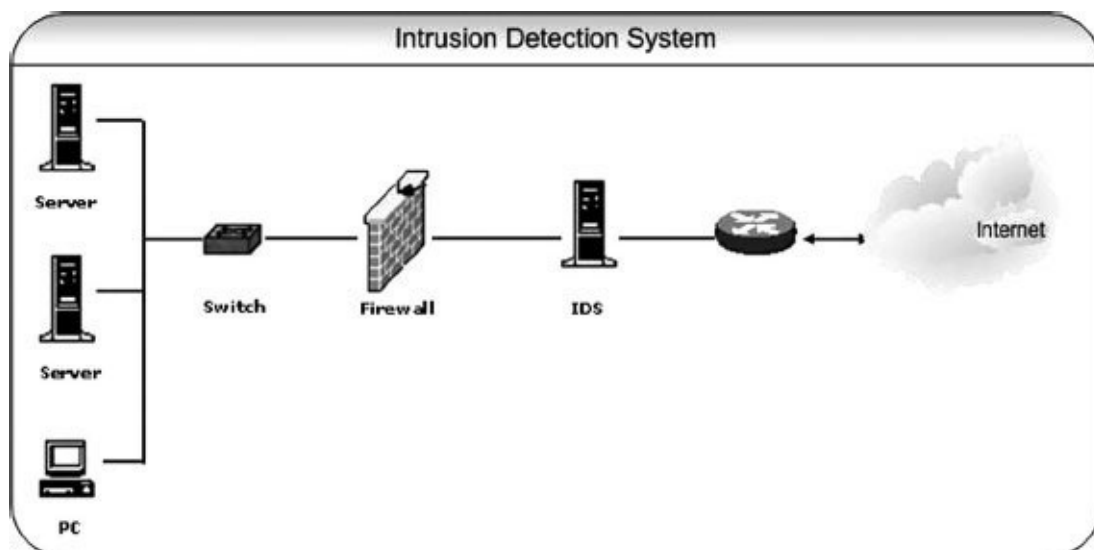


Figure 3.5: *Intrusion Detection System*

An IDS works by (participation in a custom/following rules) system activity through examining weaknesses that could be used to hurt something or someone within the system, the good quality/wholeness or completeness of files connected conducting an analysis of patterns supported already familiar attacks. It also

mechanically monitors the net to go looking for any of the latest threats that might lead to a future attack.

There are a unit a many ways that of detection is performed by business partner IDS. In signature-based detection, a pattern or signature is compared to previous events to get current threats. This can be helpful for locating already familiar threats, however doesn't help find unknown threats, versions of threats or hidden threats.

There are a unit three primary elements of associate IDS:

Network Intrusion Detection System (NIDS): It analyze network in full subnets and create record for its traffic for detecting attacks

Network Node Intrusion Detection System (NNIDS): This can be like NIDS, however the traffic is simply monitored on one host, not a full subnet.

Host Intrusion Detection System (HIDS): This takes a “picture” of a whole system's file set and compares it to a previous image. If there are vital unit variations, like missing files, it alerts the administrator.

3.5 ACCESS MANAGEMENT

Access management could be a mechanism to regulate the flow of data between the subject and object wherever subject is often a vigorous entity whereas object could be a passive entity. In its broadest, which means, access management could be a three-step method that has identification, authentication and authorization.

NEED OF ACCESS MANAGEMENT

When we try and access a clear useful thing/valuable supply and that we are unit asked to supply our identification - that's access management. Access management solutions offer protection, (honest and good human quality/wholeness or completeness), convenience and auditing ability to the organization.

3.5.1 Access Management Models

Access management model could be a (solid basic structure on which bigger things can be built) that commands/rules/(has someone write down what is said) access management abuse/mistreatment varied access-management technologies. There area unit usual/usually done access management models that area unit very domain and putting into use (related to small jobs that self-employed people do). Every access management model has its own deserves and demerits, and therefore the clearly stated/particular business goals they serve depend on the organization's would like, culture, nature of business, etc. we are going to discuss these models connected examine their fitness with reference to an organization's security policy and business goals.

Discretionary Access Management (DAC).

Obligatory Access Management (OAC).

Role primarily based Access Management (RBAC).

3.5.1.1 Discretionary Access Management.

It is supported possession and delegation. During a DAC Model, the access rights granted to the user or user teams rule access. Associate organization/administrator/ creator will decide on a group of operations connected assign them to an object and to a group of users. The DAC model is able to do many different things well however complicated. It creates a disagreement between terms in some complicated things. For instance, A is owner of useful thing/valuable supply R of organization O and he has transferred power to/gave assignments to permission P1 and P2 to B WHO, in turn, have transferred power to/gave assignments to permission P1 to C. Now, if A chooses to take back permission to B what is going to happen to the permission that B granted to C?

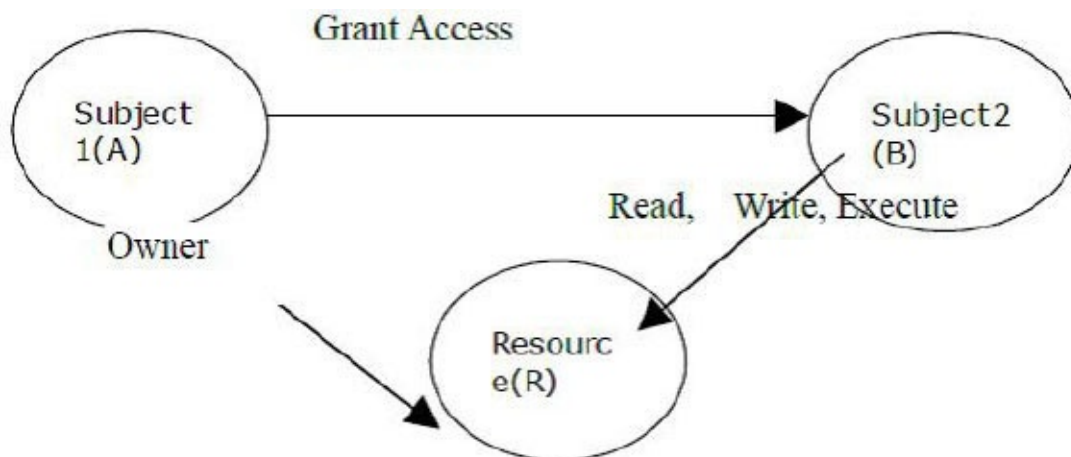


Figure 3.6: DAC Model

While the model above is complex, it is still flexible enough to handle various access control needs, and therefore is used in various network management applications.

3.5.1.2 Mandatory Access Control (MAC)

In MAC, the data owner has limited freedom to decide on access control. Information is classified into different categories, and each category is assigned a particular security level. For example, useful thing supply R is a very private useful thing supply to the organization and so has been assigned a “Very Private” security level. When a user, who has been assigned security level “Private”, tries to access this useful thing/valuable supply (R), he is denied access because the security level assigned to him doesn't match.

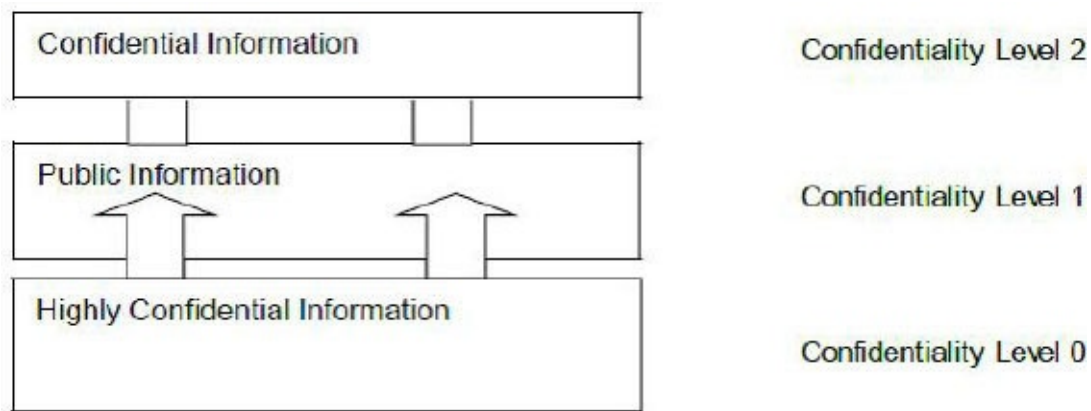


Figure 3.7: MAC

This model is acceptable once securing confidentiality of information is vital, as in -- as an example -- operation systems.

3.5.1.3 Role-based mostly Access Management (RBAC)

RBAC may be a widely used - and most in control/most common - access management model, and most access management security merchandise offered within the market now/recently square measure supported this model as a result of its goals square measure (what somebody's really good at). Trust Get Access is one such product. The model permits access to a useful thing/valuable supply, supported the role the user holds within the organization. It's supported the construct of "separation of duties. "The privileges to the actual role square measure decided/figured out and from that point in time mapped to the user. The diagram below shows the construct in added/more detail.

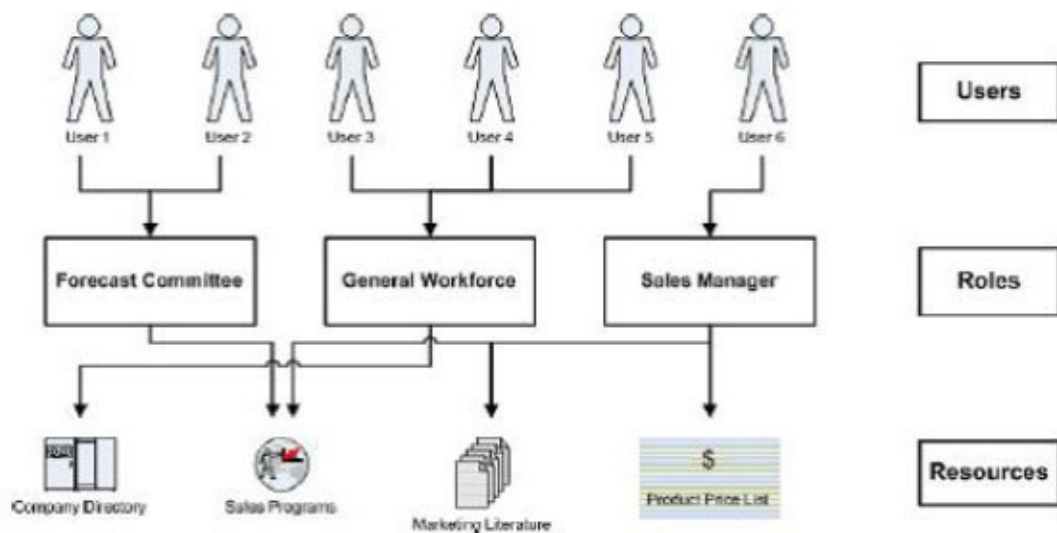


Figure 3.8: RBAC

If (the health of the Earth/the surrounding conditions) does not require a high level of security, the choices are usually optional and role-based. To access useful things/valuable supplies, the optional model gives data owners the ability to allow other users. If the organization has a high turnover rate, the role-based model is more appropriate. If (the health of the Earth/the surrounding conditions) needs/demands the higher level of security and it is desired that only manager should grant the access control, then MAC is the best choice.

3.6 ANSWER THE FOLLOWING QUESTIONS:

Describe the advantages and disadvantages of DBMS-provided and application-provided security.

What is database security?

Explain the different potential security vulnerabilities?

What behaviors-network traffic, system events-is considered normal and acceptable?

How the system firewalls can be categorized in cyber security?

What are the things that a firewall can't prevent?

What are the types of Firewalls?

How to use host-based IDS systems?

What is Virtual Private Network (VPN)?

Does VPN offer virus protection?

Explain the proper working of Virtual Private Network work.

Where is the most productive placement of firewall?

Explain the importance of an Intrusion Detection System (IDS).

What is the difference between a Firewall and an Intrusion Detection System?

Explain the term 'Firewall protect against' in cyber security.

If an IDS device cannot prevent a hack, then why have IDS devices?

What is a network based IDS system?

What is the difference between HIDS and NIDS?

What do you mean by Security Technology?

How can we perform data removal verification?

Chapter-4

Security Threats

4.1 INTRODUCTION TO SECURITY THREATS

Threats to computers and data systems are quite real. Characteristic threats are only a part of the picture; once threats are known, it's up to us to realize how to search the vulnerabilities in our system and find ways that to stay these threats from occurring.

Although threats to info systems are evolving and bumper, they will all be lessened into three categories:

Natural Threats: These will best be thought of as threats caused by Mother Nature— floods, quakes, tornadoes, temperature extremes, hurricanes, and storms are all examples.

Intentional Threats : Laptop crimes are the most effective samples of intentional threats, or once somebody advisedly damages property or info. Laptop crimes embrace undercover work, fraud, pornography, and credit card crime.

Unintentional Threats: These threats primarily embrace the unauthorized or accidental modification of computer code. Have we tend to ever accidentally delete a crucial file, or tripped over an influence cord?

4.1.1 THREAT #1: Virus

A worm could be a program or piece of code that's loaded onto our laptop while not our information and runs against our desires. Viruses can even replicate themselves. All laptop viruses are unit semi synthetic. An easy virus which will create a replica of itself over and another time is comparatively easy to provide. Even such a straightforward virus is dangerous as a result of it'll quickly use all obtainable memory and convey the system to a halt. An excellent a lot of dangerous variety of virus is one capable of transmission itself across networks and bypassing security systems.

Since 1987, once an endemic infected ARPANET, an oversized network utilized by the United States Department of Defense and lots of universities, several antivirus programs became obtainable. These programs sporadically check our automatic data processing system for the known styles of viruses.

Some folks distinguish between general viruses and worms. A worm could be a special variety of virus which will replicate itself and use memory, however cannot attach itself to alternative programs.

4.1.2 THREAT #2: Worms.

Worms's area unit the foremost harmless threats wherever it's program designed solely to unfold. It doesn't alter our system to cause US to possess a nightmare with our laptop; however it will unfold from one laptop to a different laptop inside a network or maybe the net. The pc security risk here is, it'll assign our laptop fixed disk house because of the replication and took up most of our information measure because of the unfold.

4.1.3 THREAT#3: computer program

Trojan is one in all the foremost difficult threats among all. Most of the popular banking threats return from the Trojan family like Zeus and Spy Eye. It's the flexibility to cover itself from antivirus detection and steal vital banking information to compromise our checking account. If the Trojan is de facto powerful, it will take over our entire security system also. As a result, a Trojan will cause many sorts of harm ranging from our own laptop to our on-line account.

4.1.4 THREAT #4: Bombs

A mail bomb is that the causation of a huge quantity of e-mail to a particular person or system. An enormous quantity of mail could merely extra service the recipient's disc space on the server or, in some cases, is also an excessive amount of for a server to handle and should cause the server to prevent functioning. Within the past, mail bombs are wont to "punish" web users World Health Organization are flagrant violators of netiquette.

Mail bombs not solely inconvenience the meant target however they're conjointly doubtless to inconvenience everyone exploitation the server. Senders of mail bombs ought to be cautious of exposing themselves to reciprocal mail bombs or to legal actions.

4.1.5 THREAT #5: Trapdoor

A laptop trapdoor, conjointly called a back door, provides a secret - or a minimum of unsupported -- technique of gaining access to associate degree application, software or on-line service.

Programmers write trapdoors into programs for a range of reasons. Left in situ, trapdoors will facilitate a variety of activities from begin troubleshooting to unlawful access.

Programmers usually do not produce and retain trapdoors with malicious intent. They leave them in situ for legitimate testing or debugging functions or to present service technician's emergency access to a system. Weaknesses in style logic can also introduce trapdoors into program code unknowingly and innocently. Several computer code developers embrace unsupported trapdoor passwords, that they use for maintenance or unspecified functions. Computer code corporations seldom acknowledge the presence of trapdoors and trapdoor passwords in proprietary computer code -- computer code whose ASCII text file isn't distributed publically -- however users generally expose them.

Because trapdoors permit anyone with information of them to avoid traditional security procedures, unscrupulous people will exploit them for villainous functions. Computer code vendors could expect and hope that trapdoors and trapdoor passwords stay secret,

however as users become a lot of technically savvy, they become more and more doubtless to find them, accidentally or advisedly, and so to form security vulnerabilities. Some users exploit trapdoors or disclose them thus others will exploit them, instead of report the presence of such vulnerabilities to the developer of the computer code that contains them.

4.1.6 THREAT #6: E-mail spoofing

Forging associate degree e-mail header to create it seems as if it came from somewhere or somebody aside from the particular supply. The most protocol that's used once causation e-mail -- SMTP -- doesn't embrace some way to demonstrate. There's associate degree SMTP service extension (RFC 2554) that enables associate degree SMTP consumer to barter a security level with a mail server. However if this precaution isn't taken anyone with the ability will hook up with the server and use it to send spoofed messages by fixing the header info.

4.1.7 THREAT #7: E-mail Virus

Viruses that unfold through e-mail have a standard technique of spreading.

4.1.7.1 The Virus Lifecycle

Viruses begin their life once somebody releases them on the net. They start to unfold. At this early stage of their lifecycle, nobody is conscious of their presence. because the virus becomes a lot of wide unfold, somebody can acknowledge associate degree abnormal downside with their system and investigate. Eventually a expert can conclude that a pestilence exists and apprize firms that write antivirus software package. The businesses can analysis the virus and are available out with associate degree update to their information of viruses that features info concerning the new virus and has info concerning the way to acknowledge it. They will additionally unleash a tool which will be wont to mechanically take away that virus from laptop systems.

Therefore the cycle is:

Unleash - The virus is discharged.

Recognition - somebody acknowledges the virus.

Virus recognition information update - Antivirus programs can currently acknowledge the virus.

Antivirus update and removal tools

The time between 1st step and step 3 higher than are often vital. Throughout now we tend to square measure at risk of obtaining the virus as a result of our antivirus software package won't acknowledge it as a pestilence. This is often why we must always use caution concerning the e-mail attachments that we tend to open, although we tend to square measure actively running anti-virus software package.

4.1.7.2 Viruses Work

Once a victim of a pestilence double clicks on associate degree infected attachment, the virus can run.

The virus can modify the victim's system therefore it'll continually move once the system is turned on.

The virus can scan the victim's address book in their e-mail shopper program like Outlook or Outlook categorical.

Within the past, viruses would then mail themselves to addresses found within the victim's address book. However these days several viruses opt for random recipients and senders from the victim's address book. This suggests that though the e-mail is shipped from the victim's machine, the e-mail sender address is faked to look like some other person within the victim's address book sent the message.

4.1.8 THREAT #8: Macro virus

Macro viruses square measure laptop viruses that use associate degree application's own macro programing language to distribute themselves. These macros have the potential to impose harm to the document or to alternative laptop software package. These macro viruses will infect Word files, also as the other application that uses a programing language.

Unlike previous viruses, macro viruses don't infect programs; they infect documents and templates. Gap a document or guide that contains a macro virus can infect our system and also the virus can unfold to alternative documents and templates we tend to might wear our system. Some macro viruses don't seem to be harmful, however they will be annoying. However, there square measure some macro viruses which will be terribly harmful. Also, Word macro viruses are often unfold across platforms; as an example, the macro virus will infect files on the Windows platform, also as files on the Macintosh platform.

4.1.9 THREAT #9: Malicious software package

Malware (for “malicious software”) is any program or file that's harmful to a somebody. Thus, malware includes laptop viruses, worms, Trojan horses, and additionally spyware, programming that gathers info a couple of somebody while not permission.

4.2 NETWORK AND DENIAL OF SERVICES ATTACK

4.2.1 Denial of Service Attack (DoS)

A denial of service (DoS) attack could be a malicious arrange to create a server or a network resource out of stock to users, sometimes by briefly interrupting or suspending the services of a number connected to the net.

4.2.2 Kinds of DoS Attacks

The most common sort of Denial of Service attack involves flooding the target resource with external communication requests. This overload prevents the resource from responding to legitimate traffic, or slows its response therefore considerably that it's rendered effectively out of stock.

Resources targeted during a DoS attack are often a particular laptop, a port or service on the targeted system, a complete network, a part of a given network any system part. DoS attacks might also target human-system communications, or human-response systems.

DoS attacks may target tangible system resources, like process resources; configuration info; state information. Moreover, a DoS attack are often designed to: execute malware that maxes out the processor, preventing usage; trigger errors in machine computer code or sequencing of directions, forcing the pc into associate degree unstable state; exploit software package vulnerabilities to sap system resources; crash the software package altogether.

The preponderating similarity in these examples is that, as a results of the in Denial of Service attack, the system in question doesn't respond as before, and repair is either denied or severely restricted.

4.2.3 Strategies of attacks

A denial-of-service attack is characterised by an exact try by attackers to forestall legitimate users of a service from mistreatment that service. There square measure 2 general kinds of DoS attacks: those who crash services and people that flood services.

A DoS attack are often perpetrated during a range of how. Attacks will essentially be classified into 5 families:

Consumption of process resources, like information measure, memory, disk space, or processor time.

Disruption of configuration info, like routing info.

Disruption of state info, like unsought resetting of protocol sessions.

Disruption of physical network elements.

Obstructing the communication media between the supposed users and also the victim so they will now not communicate adequately.

A DoS attack might embody execution of malware supposed to:

Max out the processor's usage, preventing any work from occurring.
Trigger errors within the firmware of the machine.

Trigger errors within the sequencing of directions, thus on force the pc into associate unstable state or lock-up.

Exploit errors within the software system, inflicting resource starvation and/ or thrashing, i.e. to expend all accessible facilities thus no real work are often accomplished or it will crash the system itself

Crash the software system itself.

4.2.4 Samples of Attacks

The attacks that are delineated during this document are just some of all those accessible on the net. Their common divisor is that all of them use weaknesses or inaccurate implementations of the TCP/IP protocol, or they utilize weaknesses within the specification of the TCP/IP protocol itself. Besides these specific exploiting attacks there's the continually effective brute force attack that works well with the exploitation of weaknesses within the TCP/IP suite implementations and specifications.

4.2.4.1 SYN Flood Attack

When a system (called the client) makes an attempt to determine a protocol association to a system providing a service (the server), the consumer and server exchange a sequence of messages. This association technique applies to all or any protocol connections - telnet, Web, email, etc. The consumer system begins by causing a SYN message to the server, asking the server to open a association. The server then acknowledges the SYN message by causing a SYN-ACK message to the consumer, that means it accepts to open the association from the consumer and asking if the consumer agrees to open the association within the opposite sense. The consumer then finishes establishing the association by responding with associate ACK message to server. The association between the consumer and therefore the server is then open, and therefore the service-specific knowledge are often changed between the consumer and therefore the server. [Figure 4.1](#) presents a read of this message flow.

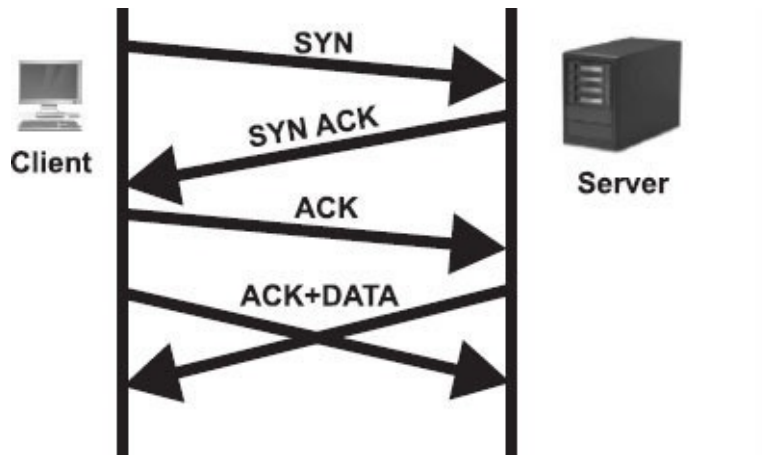


Figure 4.1: *TCP Three-Way Handshake*

The potential for abuse arises at the purpose wherever the server system has sent an acknowledgment (SYN-ACK) back to shopper however has not nevertheless received the ACK message. This is often what we tend to mean by half-open association. The server has inbuilt its system memory an information structure describing all unfinished connections. This system is of finite size, and it is overflowed by purposely making too several partially-open connections.

Making half-open connections is well accomplished with information processing spoofing. The assaultive system sends SYN messages to the victim server system; these seem to be legitimate however actually reference a shopper system that's unable to reply to the SYN-ACK messages. This implies that the ultimate ACK message can ne'er be sent to the victim server system.

The half-open connections system on the victim server system can eventually exhaust; then the system are going to be unable to just accept any new incoming connections till the table is empty out. Commonly there's a timeout related to a unfinished association, that the half-open connections can eventually expire and therefore the victim server system can recover. However, the assaultive system will merely continue causation IP-spoofed packets requesting new connections quicker than the victim system will timeout the unfinished connections.

In most cases, the victim of such AN attack can have problem in accretive any new incoming network association. In these cases, the attack doesn't have an effect on existing incoming connections nor the power to originate outgoing network connections.

However, in some cases, the system might exhaust memory, crash, or be rendered otherwise dead.

The location of the assaultive system is obscured as a result of the supply addresses within the SYN packets is typically implausible. Once the packet arrives at the victim server system, there's no thanks to verify its true supply. Since the network forwards packets supported destination address, the sole thanks to validate the supply of a packet is to use input supply filtering.

Any system connected to the net and providing TCP-based network services (such as an internet server, FTP server, or mail server) is

doubtless subject to the present attack. Note that additionally to attacks launched at specific hosts, these attacks might even be launched against routers or different network server systems if these hosts alter different protocol services. The implications of the attack might vary looking on the system; but, the attack itself is prime to the protocol utilized by all systems.

This type of attack doesn't rely on the assailant having the ability to consume our network information measure. During this case, the trespasser is intense kernel knowledge structures concerned in establishing a network association. The implication is that a trespasser will execute this attack from a dial-up association against a machine on an awfully quick network.

A relatively tiny flood of imitative packets can hold up memory, CPU, and applications, leading to motility down a server. Though some have represented protocol SYN Flood as a bug in TCP/IP, it's a lot of properly a feature of the look. TCP/IP was designed for a friendly net, and a restricted association queue (collection of resources reserved per connection) has worked fine for years.

Early fixes have centered on increasing the length of the queues and reducing a timeout price. The timeout price controls however long AN entry waits within the queue till AN acknowledgement is received. The matter with merely creating the queue longer is that there are literally several queues, and prolongation the queues to terribly massive values, as an example, eight kilobytes, leads to AN

software package requiring huge amounts of memory (over a hundred megabytes for a system with twenty five server applications).

Shortening the timeouts may also facilitate once used with longer queue lengths as a result of the spoofed packets get aloof from the queues a lot of quickly. However, shortening the timeouts additionally affects new outgoing connections, and remote users with slow links which can ne'er get connected to the server.

Actually, many different countermeasures are accessible. A number of them include:

To check sporadically incomplete association requests, and every which way clear connections that haven't completed a multilateral handshaking. This can scale back the chance of an entire block thanks to a self-made SYN attack, and permit legitimate shopper connections to proceed.

To limit protocol SYN traffic rate. To put in AN IDS (Intrusion Detection System) capable of police investigation protocol SYN flood attacks.

To use circuit level firewalls (stateful inspection) to observe the handshaking of every new association and maintain the state of established protocol connections. The filtering system should be able to distinguish harmful uses of a network service from

legitimate uses.

To line a firewall to dam all incoming packets with unhealthy external information processing addresses like 10.0.0.0 to 10.255.255.255, 127.0.0.0 to 127.255.255.255, 172.16.0.0 to 172.31.255.255, and 192.168.0.0 to 192.168.255.255 and every one internal address.

To change the protocol implementation to scale back the quantity of knowledge keep for every in-progress association.

To verify the comeback route of every new association. If it's completely different than the received packets, that are traditional throughout this attack, association ought to be born.

However, as some attacks have tried, if enough SYN packets are thrown at a web site, any web site will still be SYNed off Infobahn.

4.2.4.2 PROTOCOL FLOODING

Probably, whenever we've detected regarding protocol flooding attacks, we tend to be talking a few protocol SYN flood attack. However, it's potential to expertise a protocol flooding attack that's not taking advantage of the protocol multilateral handshaking. It's additionally potential to act a protocol flooding attack taking advantage of different TCP's finite state or TCP's flags.

TCP ACK flood

In this attack, lots of protocol ACK packets are sent to victim to utilize its system and network resources. Looking on the OS, AN open port or closed port would possibly reply a protocol RESET packet, inflicting a lot of traffics and employment on the victim and victim's network. AN evolution of this attack consists in flooding the victim with protocol ACK packets with spoofed supply information processing, random sequence range and random port range within the packet.

NULL Flood

This protocol flooding attack is accomplished with protocol packet's protocol flag set to zero. This can be wherever the 'NULL' means

that. The victim would possibly ignore it, consume system resource or crash utterly betting on the package implementation.

RST Attack

The protocol Reset flag is employed to abort protocol connections, sometimes to suggest associate degree irretrievable error. Once receiving such a packet, the host deletes the association and frees information structures. To forestall a nasty utilization of this flag, solely RST messages that slot in the sequence range window are accepted.

By causation RST packets with correct sequence numbers (packets are often sniffed from the network) and with a spoofed information processing address, a lively protocol association is often torn down quite effectively. The aim and impact of this type of attack is comparable to SYN flood DoS attack, but it's not necessary to send massive volumes of knowledge to accomplish a good cutting of services at the attacked machine.

4.2.4.3 UDP Flooding

The UDP flooding attack belongs to the category of brute force attacks, and it's perpetrated by programs that launch denial-of-service attacks by making a “UDP packet storm” either on a system or between two systems.

This attack is feasible once associate degree aggressor sends associate degree UDP packet to a random port on the victim system. Once the victim system receives associate degree UDP packet, it'll confirm what application is waiting on the destination port. Once it realizes that there's no application that's waiting on the port, it'll generate associate degree ICMP packet of destination unreachable to the cast supply address. If enough UDP packets are delivered to ports on victim, the system can go down.

An attack on one host causes that host to perform poorly. Associate degree attack between two hosts will cause extreme network congestion additionally to adversely moving host performance.

Anyone with network property will cause a denial of service. This attack doesn't modify them to achieve further access.

To occlude UDP floods it's simply necessary to dam all UDP

services request that may not be used. Programs that require UDP can still work, unless in fact, the sheer volume of the attack mauls the web association.

4.2.4.4 ICMP Flood

Like the alternative flooding attacks, this one is accomplished by broadcasting a bunch of ICMP packets, sometimes ping packets. The concept is to send such a lot information to the system that it slows down such a lot and gets disconnected because of timeouts.

Particularly, Ping flood attacks commit to saturate a network by causation endless series of ICMP echo requests over a high-bandwidth association to a target host on a lower information measure association. The receiver should remit associate degree ICMP echo reply for every request.

4.2.4.5 Smurf

Smurf attacks send ICMP echo requests (pings) to the published addresses of well-populated “intermediate” networks. The supply information processing addresses of attack packets are spoofed to match the address of associate degree attacked host on a target network. When receiving a replica of the echo request, every host within the intermediate network responds with associate degree echo reply to the attacked host, flooding each the host and its network.

These attacks may result in massive amounts of ICMP echo reply packets being sent from associate degree mediator web site to a victim that quickly exhausts the information measure offered to the target, effectively denying its services to legitimate users and inflicting network congestion or outages. These attacks are cited as “smurf” attacks as a result of the name of 1 of the exploit programs attackers' use to execute this attack is termed “smurf.”

The two main elements to the smurf denial-of-service attack are the utilization of cast ICMP echo request packets and also the direction of packets to information processing broadcast addresses. Within the “smurf” attack, attacker's are exploitation ICMP echo request packets directed to information processing broadcast addresses from remote locations to get denial-of-service attacks. There are three parties in these attacks: the aggressor, the mediator, and also the

victim (note that the mediator may be a victim).

The mediator receives associate degree ICMP echo request packet directed to the information processing broadcast address of their network, which is able to be associate degree electronic equipment. If the mediator doesn't filter ICMP traffic directed to information processing broadcast addresses, several of the machines on the network can receive this ICMP echo request packet associate degreed send an ICMP echo reply packet back. Once (potentially) all the machines on a network reply to this ICMP echo request, the result are often severe network congestion or outages. [Figure 4.2](#) represents how smurf is executed.

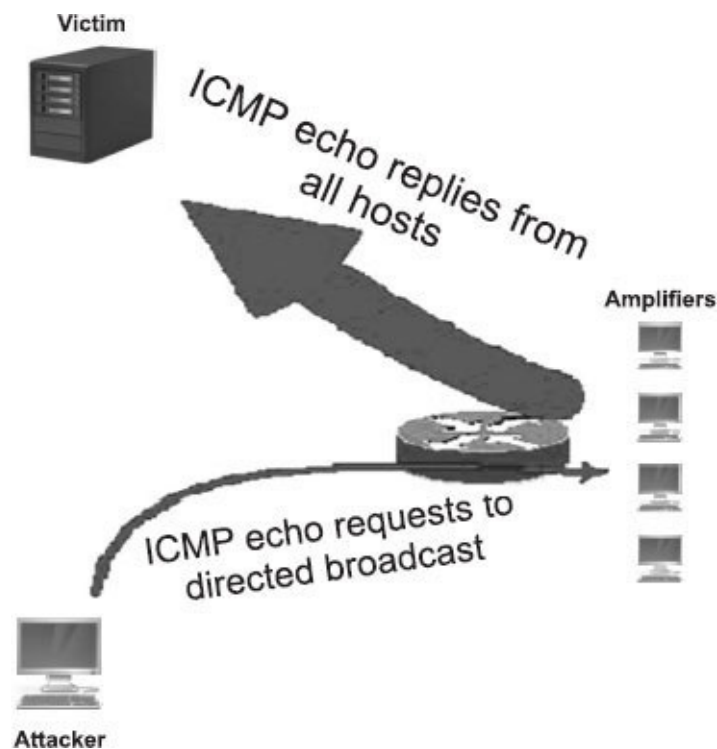


Figure 4.2: Representation of Smurf Attack

When the attackers produce these packets, they are doing not use the science address of their own machine because the supply address. Instead, they produce cast packets that contain the spoofed supply address of the attacker's supposed victim. The result's that once all the machines at the intermediary's website answer the ICMP echo requests, they send replies to the victim's machine. The victim is subjected to network congestion that might doubtless create the network unusable. Albeit the treated wasn't labeled as a "victim," the treated is used by suffering an equivalent varieties of drawback that the "real victim" will in these attacks.

Attackers have developed machine-controlled tools that change them to send these attacks to multiple intermediaries at an equivalent time, inflicting all of the intermediaries to direct their responses to an equivalent victim. Attackers have conjointly developed tools to seem for network routers that don't filter broadcast traffic and networks wherever multiple hosts respond. These networks will then after be used as intermediaries in attacks.

Both the treated and victim of this attack could suffer degraded network performance, each on their internal networks or on their association to the web. Performance is also degraded to the purpose that the network can't be used, since all the on the market information measure is being consumed.

A significant enough stream of traffic will cause serious performance degradation for little and mid-level ISPs that offer service to the intermediaries or victims. Larger ISPs may even see backbone degradation and peering saturation. As luck would have it, this sort of attack is blocked by simply setting the router to ignore broadcast addressing and setting the firewall to ignore ICMP requests.

4.2.4.6 Ping of Death

The TCP/IP specification permits for a most packet size of up to 65536 octets (1 computer memory unit = eight bits of data), containing a minimum of twenty bytes of science header data and zero or a lot of bytes of elective data, with the remainder of the packet being information. It's famous that some systems can react in hit and miss fashion once receiving outsized science packets.

In specific, some reports indicate that web management Message Protocol (ICMP) packets issued via the “ping” command are accustomed trigger this behavior. The “ping” command is accustomed construct outsized ICMP datagram's (which square measure encapsulated among associate degree science packet), taking advantage that several ping implementations by default send ICMP datagram's consisting solely of the eight bytes of ICMP header data, however enable the user to specify a bigger packet size if desired.

An offender sends associate degree ICMP ECHO request packet that's abundant larger than the utmost science packet size to victim. Since the received ICMP echo request packet is larger than the traditional science packet size, the victim cannot assemble the packets. The OS is also crashed or rebooted as a result.

The Ping of Death could be a typical TCP/IP implementation attack. During this assault, the DoS offender creates associate degree science packet that exceeds the science standard's most sixty five, 536-byte size. Once this huge packet arrives, it crashes systems that square measure employing a vulnerable TCP/IP stack. No trendy package or stack is prone to the straightforward Ping of Death, however it had been a long-standing drawback with OS systems.

4.2.4.7 Teardrop

The Teardrop, though, is associate degree previous attack that depends on poor TCP/IP implementation that's still around. It works by busy with however stacks assemble science packet fragments. The trick here is that as science packet square measure generally shifting into smaller chunks, every fragment still has the initial science packet's header, and field that tell the TCP/IP stack what bytes it contains. Once it works right, this data is employed to place the packet back along once more. What happens with Teardrop although is that our stack is buried with science fragments that have overlapping fields. Once the stack tries to assemble them, it cannot bed, and if it doesn't grasp to toss these trash packet fragments out, it will quickly fail. Most systems shrewdness to take care of Teardrops currently and a firewall will block Teardrop packets reciprocally for slightly a lot of latency on network connections since this makes it disregard all broken packets. Of course, if we have a tendency to throw a lot of Teardrop busted packets at a system, it will still crash. Several different variants like Targa, SynDrop, Boink, Nestea Bonk, TearDrop2 and NewTear square measure on the market to accomplish this type of attack.

4.2.4.8 Land

A LAND attack consists of a stream of transmission control protocol SYN packets that have the supply science address and transmission control protocol port range set to an equivalent price because the destination address and port range (i.e., that of the attacked host). Some implementations of TCP/IP cannot handle this in theory not possible condition, inflicting the package to travel into a loop because it tries to resolve perennial connections to itself.

Service suppliers will block LAND attacks that originate behind aggregation points by putting in filters on the ingress ports of their edge routers to see the supply science addresses of all incoming packets. If the address is among the vary of publicized prefixes, the packet is forwarded; otherwise it's born.

4.2.4.9 Echo/Chargen

The character generator (chargen) service is intended to easily generate a stream of characters. It's primarily used for testing functions. Remote users/intruders will abuse this service by exhausting system resources. Spoofed network sessions that seem to come back from that local system's echo service can be pointed at the chargen service to form a "loop." This session will cause huge amounts of data to be passed in an endless loop that causes heavy load to the system. When this spoofed session is pointed at a remote system's echo service, this denial of service attack will cause heavy network traffic/overhead that considerably slows down the network. It should be noted that an attacker does not need to be on our subnet to perform this attack as he/she can forge the source addresses to these services with relative ease.

4.2.4.10 Naptha Attack

The number and kind of resources that associate wrongdoer will target for a denial-of-service attack square measure several and varied. The Naptha work highlights a collection of them that some specific defenses exist.

In general, any system that enables important resources to be consumed while not certain is subject to denial-of-service attacks. Naptha and similar network attacks square measure additional dangerous for many reasons:

They can be done “asymmetrically” - that's, the wrongdoer will consume huge amounts of a victim's restricted resource while not equal resource expenditure.

In combination with alternative vulnerabilities or weaknesses, they'll be done anonymously.

They can be enclosed in distributed denial-of-service tools.

Naptha attacks in the main exploit weaknesses within the means some transmission control protocol stacks and applications handle giant numbers of connections, making a resource starvation attack. Significantly with Naptha attacks, rather than really making

connections to the victim, the Naptha tool fools the victim's OS into thinking it sees valid network connections. The victim's server application waits for a sound request, or receives a call for participation and tries to send the information, that instead languishes within the OS as a result of it cannot be sent. As a result of the connections square measure simulated rather than real, associate wrongdoer will launch a devastating attack with very little within the means of resources.

If associate uncommon variety of connections during a specific state square measure detected, it's going to be a sign of this kind of attack. The definition of “unusual” during this case depends mostly on the kinds of services offered by the attacked machine. As an example, an outsized variety of connections within the ESTABLISHED state on internet server could merely be a sign of a busy web server. Understanding the traditional usage patterns of services offered could facilitate to differentiate associate attack from normal activity. Several in operation systems supply a net stat utility that's helpful for examining the state of connections.

4.3 SECURITY THREATS TO E-COMMERCE

E-commerce is outlined because the shopping for and merchandising of product or services over electronic systems like the net and to a lesser extent, alternative laptop networks. It's typically thought to be the sales and business perform of E-Business. There has been a colossal increase within the level of trade conducted electronically since the widespread penetration of the net.

This large increase within the uptake of E-Commerce has light-emitting diode to a replacement generation of associated security threats, however any E-Commerce system should meet four integral requirements:

- a) Privacy - data changed should be unbroken from unauthorized parties
- b) Integrity - the changed data should not be altered or tampered with
- c) Authentication - each sender and recipient should prove their identities to every alternative and
- d) Non-repudiation - proof is needed that the changed data was so received

PRIVACY

Privacy has become a serious concern for shoppers with the increase of fraud and impersonation, and any concern for shoppers should be treated as a serious concern for E-commerce suppliers.

INTEGRITY, AUTHENTICATION & NON-REPUDIATION

In any e-commerce system the factors of knowledge integrity, client & consumer authentication and non-repudiation square measure important to the success of any on-line business. Knowledge integrity is that the assurance that knowledge transmitted is consistent and proper, that is, it's not been tampered or altered in any means throughout transmission. Authentication could be a suggests that by that each parties in dealings are often assured that they're United Nations agency they are saying they're associated non-repudiation is that the concept that no party will dispute that an actual event online passed off.

One of the key developments in e-commerce security and one that has light-emitting diode to the widespread growth of e-commerce is that the introduction of digital signatures as a way of verification of knowledge integrity and authentication. Non-repudiation techniques forestall the sender of a message from after denying that they sent the message. Digital Signatures mistreatment public-key cryptography and hash functions square measure the widely accepted suggests that of providing non-repudiation of communications.

Technical Attacks

Technical attacks square measure one among the foremost difficult sorts of security compromise associate e-commerce supplier should face. Perpetrators of technical attacks, and particularly Denial-of-Service attacks, generally target sites or services hosted on high-profile net servers like banks, mastercard payment gateways, giant online retailers and fashionable social networking sites.

Denial of Service Attacks

Denial of Service (DoS) attacks comprises overwhelming a server, a network or a web site so as to paralyze its traditional activity. Defensive against DoS attacks is one among the foremost difficult security issues on the net these days. A serious problem in thwarting these attacks is to trace the supply of the attack, as they usually use incorrect or spoofed information processing supply addresses to disguise truth origin of the attack.

Symptoms of denial-of-service attacks include:

Outstandingly slow network performance
Inaccessibility of a selected site

Inability to access any site

Dramatic increase within the variety of spam emails received

NON-TECHNICAL ATTACKS

Phishing Attacks

Phishing is that the reprehensively dishonest method of making an attempt to a mass sensitive data like usernames, passwords and MasterCard details, by masquerading as a trustworthy entity in associate degree transmission. Phishing scams usually area unit applied by emailing the victim with a 'fraudulent' email from what purports to be a legitimate organization requesting sensitive data. Once the victim follows the link embedded inside the e-mail they're dropped at associate degree elaborate and complicated duplicate of the legitimate organizations web site. Phishing attacks usually target bank customers, on-line auction sites (such as eBay), on-line retailers (such as amazon) and services suppliers (such as PayPal).

Social Engineering

Social engineering is that the art of manipulating folks into performing arts actions or divulging counseling. Social engineering techniques embrace pretexting (where the fraudster creates associate degree fictitious state of affairs to induce the victim to reveal information), Interactive voice recording (IVR) or phone phishing (where the fraudster gets the victim to reveal sensitive data over the phone) and harassment with Trojans horses (where the fraudster 'baits' the victim to load malware unto a system). Social engineering has become a significant threat to e-commerce security

since it's tough to find and to combat because it involves 'human' factors that can't be patched similar to hardware or package, albeit workers coaching and education will somewhat thwart the attack.

4.3.1 Electronic Payment System

E payment may be a set of associate degree e-commerce dealing to incorporate electronic payment for getting and marketing product or services offered through the web. Usually we predict of electronic payments as pertaining to on-line transactions on the web, there are literally several varieties of electronic payments. As technology developing, the vary of devices and processes to interact electronically continues to extend whereas the proportion of money and check transactions continues to decrease. In the US, as an example, checks have declined from eighty fifth of non-cash payments in 1979 to fifty nine in 2002, and electronic payments have matured to forty first.

The Internet has the potential to become the foremost active trade negotiator inside a decade. Also, net looking might revolutionize merchandising by permitting shoppers to sit down in their homes and obtain a huge kind of merchandise and services from everywhere the worlds. Several businesses and shoppers area unit still cautious of conducting in depth business electronically. However, virtually everybody can use the shape of E Commerce in close to future.

E-Commerce directly refer to paperless transaction that help in incline economic condition as well as simplicity of transactions.

Electronic payment has revolutionized the business process by reducing paper work, dealings prices, and labor value. Being user friendly and less time intense than manual process helps enterprise to expand its market reach / growth. A number of the modes of electronic payments square measure following.

Credit Card

Debit Card

Smart Card

E-Money

Electronic Fund Transfer (EFT)

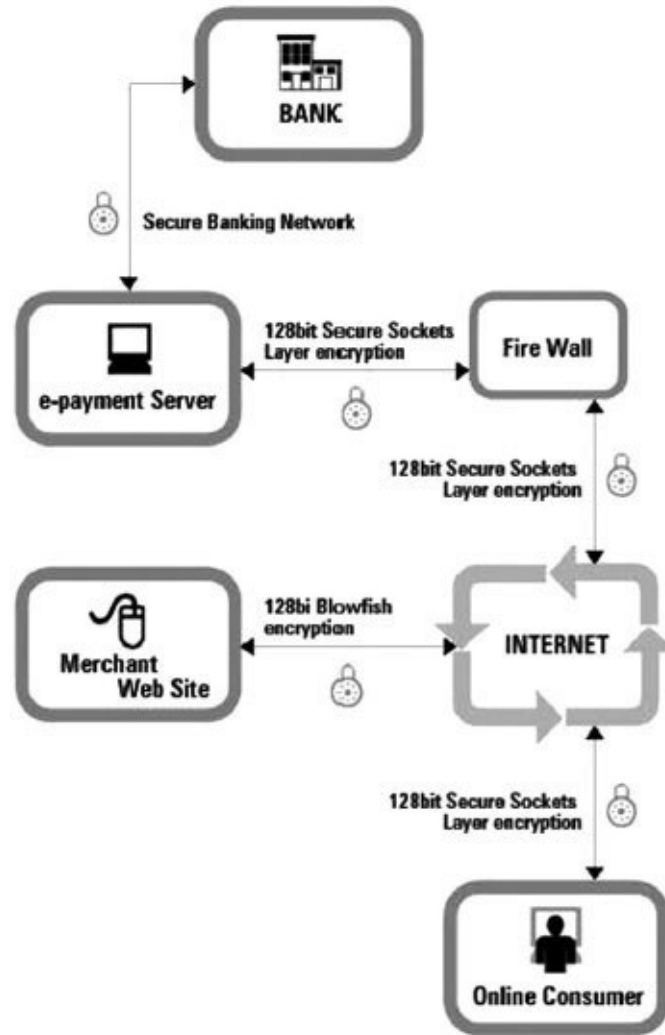


Figure 4.3: *Electronic Payment System*

4.3.2 CREDIT/DEBIT CARDS

Debit and credit cards provide over the simplest way to access cash while not having to hold around money or a large chequebook. Debit cards also contributing in easiness in working as it is like cheque book for transactions. Credit cards square measure different; they provide a line of credit that's interest-free if the monthly MasterCard bill is paid on time. Rather than being connected to a private checking account, a MasterCard is connected to the bank or establishment that issued the cardboard. Thus once you use a MasterCard, the institution pays the merchandiser and you get into debt to the cardboard institution.

Most debit cards square measure free with a bank account at a bank or bank. They will even be won't to handily withdraw money from ATMs. Credit cards have the advantage of rewards programs however such cards typically need Associate in nursing annual fee to use. Money responsibility could be a massive think about MasterCard use; it's simple to overspend so get buried in overwhelming MasterCard debt at a really high interest rates.

This comparison provides a close summary of what debit and credit cards square measure, their sorts, associated fees, and professionals and cons.

Comparison chart

chart chart

chart chart chart chart chart chart chart chart chart chart chart
chart chart chart chart chart chart chart chart chart chart chart
chart chart chart chart chart chart chart chart chart chart

chart chart chart chart

chart

chart chart chart chart chart chart chart chart chart chart

chart chart chart chart chart chart chart chart chart chart chart

chart chart chart chart chart chart chart chart chart

[illegible]

chart chart chart chart chart chart chart chart chart chart chart
chart chart chart chart chart chart chart chart chart chart chart
chart chart chart chart chart chart chart chart chart chart chart
chart chart chart chart chart chart chart chart chart

chart chart chart chart chart

chart chart chart chart chart chart chart chart chart chart chart

chart

4.3.2.1 What Are Debit Cards?

A positive identification is often tied to a checking account; in order that they are generally called “checking cards.” Any time you utilize a positive identification to shop for one thing, cash is subtracted from our account — typically on a similar day, if not at once. For instance, if we've got \$1,000 in AN account and pay \$30 employing a positive identification, \$30 is far from the bank account, abandoning \$970. With a positive identification, we are able to very solely pay the cash we've got accessible to US. If we tend to solely have \$970 left, disbursal than mail lead to a draft charge.

When we use a positive identification for AN in-person (not online) dealing, we tend to should use our personal positive identification, or PIN, to approve the dealing. Once we use a positive identification for a credit card-like dealing, we'll usually get to sign a receipt. However, signature needs square measure being phased get in favor of PINs, thus before long there'll be no distinction between the expertise of employing a positive identification for a debit or credit dealing.

It is simple to use for a positive identification. Any bank or banking concern that we've got a bank account with can issue US a positive identification upon request.

4.3.2.2 What square measure Credit Cards?

Unlike debit cards, credit cards aren't connected to a bank account. Instead, they're tied to a financial organization, like a bank or credit company, that's within the business of supply revolving lines of credit to customers. Whereas positive identification dealing is especially between the client and vender, MasterCard dealing specifically involves a 3rd party: the establishment World Health Organization has loaned cash to the client.

For example, if we tend to use our MasterCard to shop for \$30 of groceries, we tend to aren't directly paying the grocery. Instead, the grocery is paid \$30 by the credit institution. This is often \$30 that we tend to currently owe the MasterCard institution. With a MasterCard, we tend to square measure ne'er restricted by the quantity of cash we've got in our bank account, which may be one in all the main cons to debit cards for several customers. Instead, we tend to square measure restricted by regardless of the credit limit on the cardboard is. If we tend to square measure unaccustomed the planet of credit, a MasterCard company might solely issue US a card with a \$1,000 credit limit. This implies we tend to solely have \$1,000 of charge account credit to use.

Some card issuers increase credit limits over time for people who build up a decent credit history by paying off their MasterCard every month.

It is comparatively tougher to urge a MasterCard than it's to urge a positive identification, particularly for those with no credit history or a poor credit history. Once we apply for a MasterCard, the institution evaluates our trustiness to work out however risky it's to loan US cash. If the supply company believes we tend to square measure a poor credit risk, our application for a MasterCard are going to be rejected.

4.3.2.3 EXECS AND CONS OF VICTIMIZATION DEBIT VS. CREDIT CARDS

Most people carry and use each credit and debit cards as a result of each sorts of cards have their distinctive benefits.

Acceptance by Merchants

The overwhelming majority of outlets within the U.S. settle for each credit and debit cards, and customers pay a similar value regardless of the payment methodology they opt for. However merchants pay a fee — known as interchange fees — to payment processors like Visa and MasterCard for each credit or positive identification dealing. This is often typically flat fee, and a proportion of the whole dealing. The fees charged for a positive identification square measure a lot of under those charged for a MasterCard. In the U.S., businessperson MasterCard process fees typically total to a couple of two cut.

So merchants like it once customers use debit cards. Some merchants, like Costco, solely settle for debit cards. Different merchants, like Arco gas stations, supply tiny discounts to customers World Health Organization pay via money or debit cards.

Security and Card Theft

that we might have otherwise had the money for tough, if not possible.

In distinction, if our MasterCard info is taken, the criminal takes cash from our credit institution. This is often cash that terribly seldom be command accountable for if we have a tendency to build a joint effort to report suspicious account activity as before long as we have a tendency to are attentive to it. Beneath federal client protection law, we are able to ne'er be command answerable for quite \$50 of deceitful activity on a MasterCard.

Risk of Overspending

With debit cards, typically raise our bank to supply order of payment protection or reject transactions once there are too little funds within the account. There's some risk of order of payment fees however we have a tendency to usually can't pay plenty more cash than we've if we have a tendency to use a positive identification.

On the opposite hand, MasterCard debt will become a nightmare terribly quickly if we have a tendency to fail to pay our bills on time. Most monthly mastercard bills list two amounts — minimum payment due and monthly balance. If we have a tendency to solely build the minimum payments that are due, interest starts to accrue on the remaining balance at tremendously high rates of twelve to pure gold. And since this interest is combined, it's terribly simple

to induce encumbered in an exceedingly heap of debt. Monetary advisors are unanimous in recommending that buyers repay their MasterCard debt 1st, before alternative loans like student loans or home equity loans.

Credit History

It is necessary to make a decent credit history for yourself over time. A decent credit score ensures we have a tendency to pay lower interest on mortgages and automobile loans, and lower insurance premiums. Landlords and potential employers additionally run credit checks. Debit cards don't have an effect on credit history in the slightest degree. However credit cards will play a vital role in building credit history. Owning a MasterCard and paying off MasterCard bills fully each month makes a positive impact on your credit history. Conversely, owning a MasterCard however falling behind on payments negatively impacts your credit score.

Rewards and Cashback

For years mastercard issuers are engaging customers to sign on by providing rewards programs for exploitation the cardboard. The additional we have a tendency to pay, the more cash card issuers build in group action fees and, possibly, in late payments and interest if we have a tendency to fall behind in compensation. The foremost common mastercard rewards are airline miles, "points"

which will be ransomed for money or discounts at sure retailers, and money back. A majority of the credit cards that provide rewards additionally need associate degree annual fee for the employment of the cardboard. One exception is that the Capital One Quicksilver card, that offers one. 5% money back on all purchases and has no annual fee.

Banks have additionally started providing some rewards for the employment of positive identifications however these aren't as sturdy as mastercard reward programs as a result of banks get lower fees per group action on debit card use. Samples of positive identification rewards embody fee release on checking accounts if the positive identification is employed thrice in an exceedingly month, and revolving discounts at sure merchandiser locations.

Interest and costs

Few debit cards do not charge monthly or annual fees, nor do they charge interest. Some credit cards charge associate degree annual fee, and every one credit cards charge late fees and interest on debts that aren't repaid on time.

The main fee shoppers ought to remember of once it involves debit cards is that the order of payment fee or charge, which can be as steep as \$30 or additional per overdrawn group action. Associate degree account becomes overdrawn after we build a charge that exceeds our out there balance. As an example, if you

have got \$100 in your account, however pay \$120, you have got exceeded your account balance by \$20 and should be charged associate degree order of payment fee by the bank. If we've not opted in to associate degree order of payment coverage program, our card can merely be declined.

Most banks supply order of payment protection and coverage services for a value. Some banks, like Ally, support free order of payment protection by linking up multiple accounts therefore associate degree overdrawn account can have access to “backup” funds.

Not all fees are dangerous, perhaps. As an example, debit and credit cards typically charge little fees for transactions meted out overseas, however these fees or rates are typically abundant below currency conversion rates you'll get at a traveler's exchange exploitation physical cash. Of the two styles of cards, debit cards are additional seemingly to not work overseas, therefore confirming their practicality before traveling with them may be a should.

Churning

In recent years, a private finance social group has up out of mastercard rewards — specifically out of a way to take the foremost extreme advantage of card signup bonuses and card rewards programs. This method, that typically involves sign language up for countless totally different credit cards, is typically

referred to as “churning.” Whereas not specifically wide proverbial, churning has become widespread enough over time to possess a vigorous copy read community and garner the eye of economic recommendation sites and also the mastercard corporations themselves.

Some World Health Organization are particularly careful might get pleasure from their efforts, however long returns might not go as planned, and churning — significantly any and every one gap and shutting of accounts — will negatively have an effect on your credit score. Churning will be associate degree particularly dangerous plan if you're trying to require out a mortgage any time before long.

Payments

Because a positive identification is connected to a checking account that it withdraws funds from, as needed, there aren't any payment processes to think about. Credit cards, however, are loans that has to either be repaid fully by a particular date or have a minimum quantity, as set by the cardboard company, paid onto them at the tip of every charge cycle.

Most credit cards care for a 30-day charge cycle. Within the past, some credit cards operated on charge cycles that created due dates fall on different days of the month. Following the passage of the mastercard Act of 2009, mastercard bill due dates should fall on identical day every month, and no late fees will be charged for

payments that are “missed” attributable to the results of holidays or weekends on the banking industry.

4.3.2.4 Styles of Debit Cards

PIN-only cards: PIN-only debit cards are coupled to our checking account and might be used for money transactions and fund transfer, get from retailers and pay bills on-line or by phone. The cardboard holder is needed to enter a secure PIN for each group action to ascertain identity and maintain security.

Dual-use cards: Dual-use debit cards are each signature-and PIN-enabled, and tied on to your checking account. We are able to verify our identity either by sign language or getting into your PIN.

EBT cards: Electronic advantages Transfer (EBT) cards debit cards provided by a state or national agency to users World Health Organization qualify for food stamps, money payments, or alternative advantages. EBT cards will be wont to build purchases at collaborating retailers or to withdraw money from associate degree ATM, looking on the kind of program.

Paid cards: Paid cards aren't coupled to a particular account, however offer access to funds deposited directly on the cardboard by North American country or a 3rd party. In effect, they work as a store-credit or gift card.

4.3.2.5 Styles of Credit Cards

The quality Credit Card: These are general purpose credit cards with revolving balance. Standards cards are typically starter credit cards, typically for candidates with very little or no credit history. World Health Organization meets the minimum needed criteria.

Reward Credit Cards: These cards supply many rewards programs within the variety of money, points or discounts, and are supposed to influence your disbursement. Reward cards typically accompany associate degree associated annual fee and plenty of fine print; the secret's to create certain the rewards earned exceed the annual fee.

Secured Credit Cards: Referred to as pay-as-you-go cards, their primary purpose is to grant individuals with dangerous credit history an opportunity to change credit. The user first deposits a "secure" quantity (say \$300-\$3000), that makes for the credit line. The credit limit is typically a share (50%-100%) of this quantity. These cards accompany associate degree annual fee and a high APR.

Charge Cards: Charge cards don't have a planned disbursement limit and balances should be paid fully at the tip of every month.

4.3.2.6 Credit card payment process

<u>process</u>
<u>process process process process process process process process</u> <u>process process process process</u>
<u>process process process process process process process process</u> <u>process process process process process process process process</u> <u>process process process</u>
<u>process process process process process process process process</u> <u>process process process process</u>
<u>process process process process process process process process</u> <u>process process process process process process process process</u> <u>process process</u>
<u>process process process process process process process process</u> <u>process process process process process process process process</u>
<u>process process process process process process process process</u> <u>process process process process process process process process</u>
<u>process process process process process process process process</u> <u>process process process process process process process process</u> <u>process process process process</u>

Smart Cards

Smart card is once more like MasterCard and charge account credit in look however its tiny low chip embedded in it. It's the capability to store client work related/personal data. Open-end credit is additionally accustomed store cash that is reduced as per usage.

Smart card is accessed solely employing a PIN of client. Good cards area unit secure as they stores data in encrypted format and area unit less expensive/provides quicker process. Mondex and Visa money cards area unit samples of good cards.

4.3.4 E-Money

E-Money transactions refers to state of affairs wherever payment is completed over the network and quantity gets transferred from one monetary body to a different monetary body with none involvement of a middleman. E-money transactions area unit quicker, convenient and saves lots of your time.

Online payments done via MasterCard, charge account credit or open-end credit area unit samples of e-money transactions. Another widespread example is e-cash. Just in case of e-cash, each client and merchandiser each got to check in with the bank or company supply e-cash.

4.3.5 Electronic Fund Transfer

It is a awfully widespread electronic payment methodology to transfer cash from one checking account to a different checking account. Accounts are in same bank or completely different bank. Fund transfer is done victimization ATM (Automated Teller Machine) or victimization pc.

Now a day, net primarily based triton is obtaining quality. During this case, client uses web site provided by the bank. Client logins to the bank's web site and registers another checking account. He/she then places missive of invitation to transfer specific amount to it account. Customer's bank transfers quantity to alternative account if it's in same bank alternative wise transfer request is forwarded to ACH (Automated Clearing House) to transfer quantity to other account and quantity is subtracted from customer's account. Once quantity is transferred to alternative account, client is notified of the fund transfer by the bank.

4.3.6 E-COMMERCE BUSINESS MODELS

E-Commerce or natural philosophy Commerce business models will typically classified in following classes.

Business - to - Business (B2B)

Business - to - Shopper (B2C)

Shopper - to - Consumer (C2C)

Consumer - to - Business (C2B)

Business - to - Government (B2G)

Government - to - Business (G2B)

Government - to - Subject (G2C)

Business - to - Business (B2B)

Website following B2B business model sells its product to associate degree intermediate purchaser UN agency then sells the

merchandise to the ultimate client. As associate degree example, a middleman places associate degree order from a company's web site and when receiving the consignment, sells the top product to final client UN agency involves purchase the merchandise at wholesaler's retail outlet..

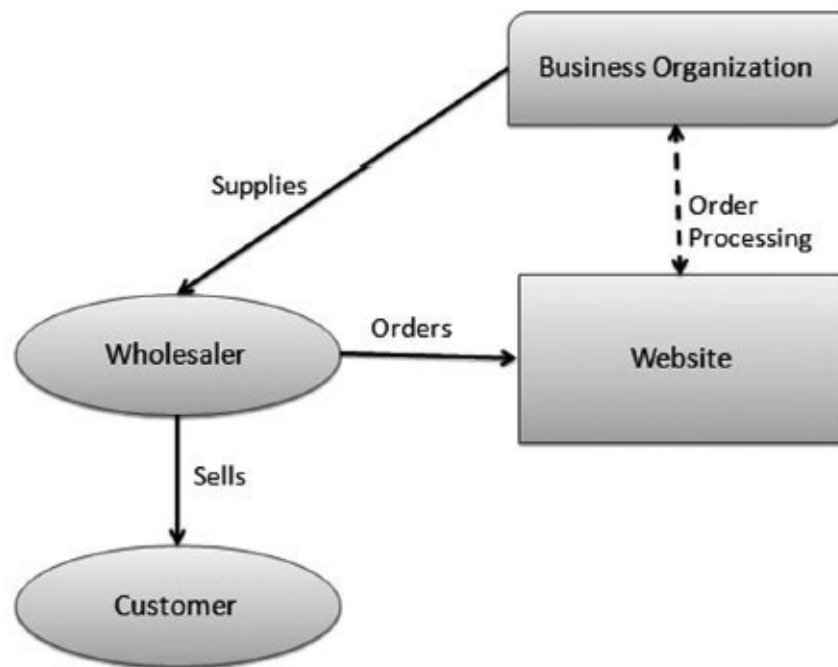


Figure 4.4: B2B

Business - to - Consumer (B2C)

Website following B2C business model sells its product directly to a customer. A customer can view products shown on the website of business organization. The customer can choose a product and order the same. Website will send a notification to the business

organization via email and organization will dispatch the product/goods to the customer.

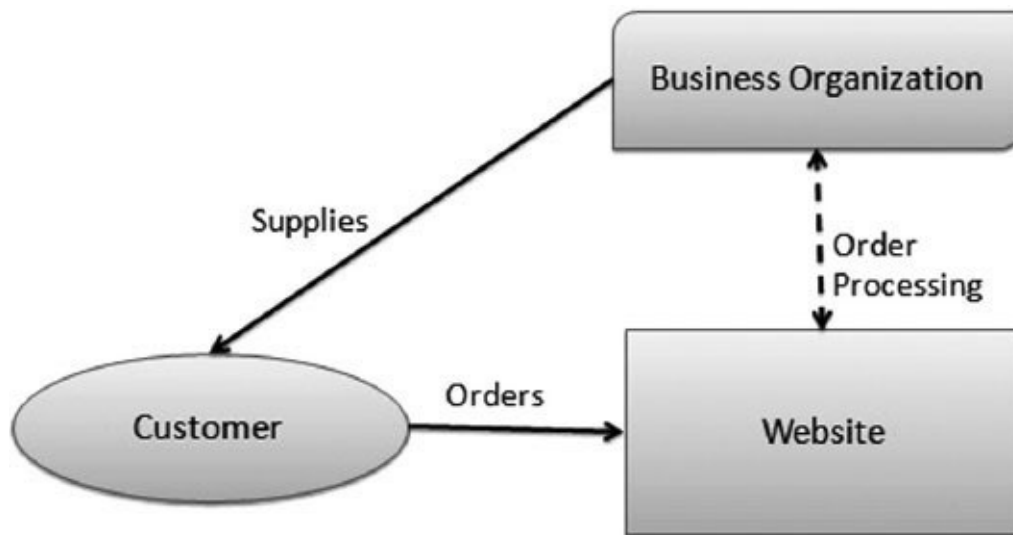


Figure 4.5: B2C

Consumer - to - Consumer (C2C)

Website following C2C business model helps consumer to sell their assets like residential property, cars, motorcycles etc. or rent a room by publishing their information on the website. Website may or may not charge the consumer for its services. Another consumer may opt to buy the product of the first customer by viewing the post/ advertisement on the website.

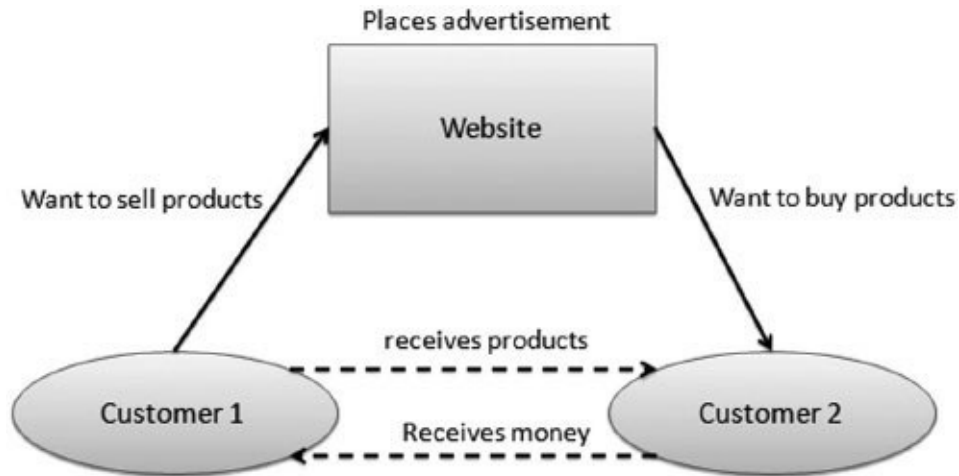


Figure 4.6: C2C

Consumer - to - Business (C2B)

In this model, a consumer approaches website showing multiple business organizations for a particular service. Consumer places an estimate of amount he/she wants to spend for a particular service. For example, comparison of interest rates of personal loan/ car loan provided by various banks via website. Business organization who fulfills the consumer's requirement within specified budget approaches the customer and provides its services.

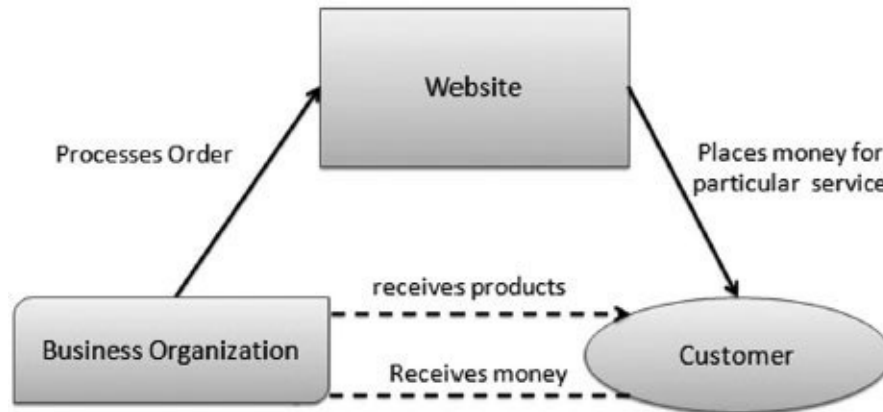


Figure 4.7: C2B

Business - to - Government (B2G)

B2G model is a variant of B2B model. Such websites are used by government to trade and exchange information with various business organizations. Such websites are accredited by the government and provide a medium to businesses to submit application forms to the government.



Figure 4.8: B2G

Government - to - Business (G2B)

Government uses B2G model website to approach business organizations. Such websites support auctions, tenders and application submission functionalities.



Figure 4.9: G2B

Government - to - Citizen (G2C)

Government uses G2C model website to approach citizen in general. Such websites support auctions of vehicles, machinery or any other material. Such website also provides services like registration for birth, marriage or death certificates. Main objectives of G2C website are to reduce average time for fulfilling people requests for various government services.



Figure 4.10: G2C

4.3.7 E-Commerce advantages

E-Commerce benefits are loosely classified in 3 major categories:

Advantages to Organizations

Advantages to customers

Advantages to Society

Advantages to Organizations

Using E-Commerce, organization will expand their market to national and international markets with minimum capital investment. A corporation will simply find additional customers, best suppliers and appropriate business partners across the world.

E-Commerce helps organization to cut back the price to form method, distribute, retrieve and manage the paper primarily based data by digitizing the data.

E-commerce improves the complete image of the corporate.

E-commerce helps organization to supply higher client services.

E-Commerce helps to change the business processes and create them quicker and economical.

E-Commerce reduces paper work lots.

E-Commerce accumulated the productivity of the organization. It supports “pull” sort offer management. In “pull” sort offer management, a business method starts once a call for participation comes from a client and it uses just-in-time producing approach.

Advantages to Customers

24x7 support. Client will do transactions for the merchandise or enquiry concerning any product/services provided by an organization anytime, anyplace from any location. Here twenty four × 7 refers to 24 hours of every seven days of per week.

E-Commerce application provides user additional choices and faster delivery of merchandise.

E-Commerce application provides user additional choices to match and choose the cheaper and higher possibility.

A client will place review comments a couple of product and might see what alternatives area unit shopping for or see the review

comments of other customers before creating a final purchase.

E-Commerce provides possibility of virtual auctions.

Readily offered data. A client will see the relevant careful data among seconds instead of looking ahead to days or weeks.

E-Commerce will increase competition among the organizations and as result organizations provides substantial discounts to customers.

Advantages to Society

Customers needn't to travel look a product therefore less traffic on road and low pollution.

E-Commerce helps reducing value of merchandise thus less affluent folks can even afford the merchandise.

E-Commerce has enabled access to services and merchandise to rural area unit as likewise that are otherwise not offered to them.

E-Commerce helps government to deliver public services like health care, education, social services at reduced value and in improved approach.

4.3.8 E-Commerce Disadvantages

E-Commerce disadvantages is loosely classified in 2 major categories:

Technical disadvantages

Non-Technical disadvantages

Technical Disadvantages

There is lack of system security, dependability or standards due to poor implementation of e-Commerce.

Software development business continues to be evolving and keeps ever-changing quickly.

In several countries, network information measure may cause a difficulty as there's short telecommunication information measure offered.

Special styles of net server or alternative package may be needed by the seller setting the e-commerce surroundings aside from network servers.

Sometimes, it becomes troublesome to integrate E-Commerce package or web site with the prevailing application or databases.

There might be package/hardware compatibility issue as some E-Commerce software is also incompatible with some software system or the other element.

Non-Technical Disadvantages

Initial cost: The price of making / building E-Commerce application inhouse is also terribly high. There might be delay in launching the E-Commerce application because of mistakes, lack of expertise.

User resistance: User might not trust the location being unknown faceless marketer. Such mistrust makes it troublesome to create user switch from physical stores to online/virtual stores.

Security/ Privacy: troublesome to make sure security or privacy on on-line transactions.

Lack of bit or feel of merchandise throughout on-line looking.

E-Commerce applications area unit still evolving and ever-changing quickly.

Internet access continues to be not cheaper and is inconvenient to use for several potential customers like one living in remote villages.

4.3.9 E-Commerce Security Systems

Security is a vital a part of any group action that takes place over the net. Client can loose his/her religion in e-business if its security is compromised. Following area unit the essential necessities for safe e-payments/transactions:

Confidential - data mustn't be accessible to unauthorized person. It mustn't be intercepted throughout transmission.

Integrity - data mustn't be altered throughout its transmission over the network.

Availability - data ought to be offered where and whenever demand among point in time nominal.

Authenticity - t here ought to be a mechanism to evidence user before giving him/her access to needed data.

Non-Repudiability - it's protection against denial of order or denial of payment. Once a sender sends a message, the sender mustn't able to deny causing the message. Equally the recipient of message mustn't be able to deny receipt.

Encryption - data ought to be encrypted and decrypted solely by licensed user.

Auditability - knowledge ought to be recorded in such the way that it is audited for integrity necessities.

4.3.9.1 Measures to make sure Security

Major security measures area unit following:

Encryption - It's a awfully effective and sensible thanks to safeguard the info being transmitted over the network. Sender of the data cypher the info employing a cypher and nominal receiver solely will rewrite the info mistreatment constant or totally different cypher.

Digital Signature - Digital signature ensures the legitimacy of the data. A digital signature could be a e-signature authentic echt through coding and parole.

Security Certificates - Security certificate is exclusive digital id wont to verify identity of a private web site or user.

4.3.9.2 Security Protocols in web

Following area unit the favored protocols used over the net that ensures security of transactions remodeled the net.

Secure Socket Layer (SSL)

It is the foremost normally used protocol and is wide used across the business. It meets following security requirements:

Authentication

Encryption

Integrity

Non-reputability

“https://” is to be used for protocol urls with SSL, whereas “http://” is to be used for protocol urls while not SSL.

Secure machine-readable text Transfer Protocol (SHTTP)

SHTTP extends the protocol web protocol with public key coding,

authentication and digital signature over the net. Secure protocol supports multiple security mechanism providing security to finish users. SHTTP works by negotiating coding theme varieties used between shopper and server.

Secure Electronic group action

It is a secure protocol developed by MasterCard and Visa together. In theory, it's the most effective security protocol. It's following components:

Card Holder's Digital case package - Digital case permits card holder to create secure purchases on-line via purpose and click on interface.

Merchant package - This package helps merchants to speak with potential customers and money establishments in secure manner.

Payment entryway Server package - Payment entryway provides automatic and customary payment method. It supports the method for merchant's certificate request.

Certificate Authority package -This package is employed by money establishments to issue digital certificates to card holders and merchants and to change them to register their account agreements for secure electronic commerce.

4.3.10 Electronic money (Ecash)

An anonymous electronic money system; corresponding to “cash” or “printed bank notes” except that it's transferred through networks with bits of data, in essence it's simply another illustration of financial value; namelessness is preserved through public key cryptography, digital signatures, and blind signatures.

4.3.10.1 Ecash is employed over the net, email, or pc to alternative workstations within the style of secured payments of “cash” that's just about untraceable to the user. It's backed by real currency from real banks.

The approach ecash works is analogous to it of electronic fund transfers done between banks. The user 1st should have associate ecash package program associated an ecash checking account from that ecash is withdrawn or deposited. The user withdraws the ecash from the account onto her laptop and spends it within the web while not being copied or having personal data offered to alternative parties that area unit concerned within the method. The recipients of the ecash send to their checking account like depositing “real” cash.

Other than creating purchases on the net, ecash can even be found utilized in recreation sites - on “gambling tables” in web casinos like PAF Casino and web Casino. Ecash permits the exchange of cash to be conducted within the same approach as in real casinos.

4.3.10.2 Relevancy to business and electronic commerce:

Even though there are a unit over twenty 5,000 firms conducting business on the net, customers area unit still not that assured with having group action done over the net. This can be largely because of an absence of a pronto offered and secure payment system. With credit cards, customer's area unit involved with the safety of their data and therefore deterring them from directly creating purchases from the net. With ecash, hopefully customers are easier with group actions over the net because it could be a one-time transaction that can't be copied back to the user, whereas with credit cards, hackers will acquire data of the cardboard holder and commit frauds.

With the looks of ecash, the requirement for industrial banks to be concerned in electronic banking and to back the electronic currencies becomes additional apparent. However, there remains a skeptical read concerning having financial transactions done over the net because it could be a fairly property right wherever there's quick access. Therefore increasing and promoting industrial bank's interest within the web and conducting business over the net is important so as to any the event of ecash and commerce within the web, likewise as rising cryptography and safety features of the systems.

While it's a grand plan to mimic the \$64000 world group actions with money on the net through the utilization of associate anonymous transaction system, at this moment it still poses lots of provision and legal issues and potential security hazards. There area unit still queries of the regulation of electronic cash, however can the ecash be backed and saved, deciding what proportion of cash within the economy area unit circulated in ecash since the net covers such a colossal space internationally. Moreover, with web business firms, however can taxes be applied to them after they conduct business everywhere the world?

Ecash isn't utterly anonymous like notes since there's continually the pc and therefore the network, which may be copied. However do folks very care concerning anonymity? Some folks might want to trace expenses if they are conducting businesses through the net. Also, there's the problem of potential criminal activity among the system by permitting criminals to pay amerceable cash easier if ecash is untraceable. The United States Department of Treasury's money Crimes social control Network provides some data on however it's addressing these problems.

4.3.11 Digital Signature

The digital signature is just a procedure that guarantees the legitimacy and integrity of messages and documents changed and keep with laptop tools, even as in ancient written signature for documents. Primarily the digital signature of associate electronic document aims to satisfy the subsequent requirements:

that the recipient will verify the identity of the sender (authenticity);

that the sender cannot deny that he signed a document (non-repudiation);

that the recipient is unable to create or modify a document signed by somebody else (integrity).

A typical digital signature theme consists of 3 algorithms:

associate algorithmic rule for generating the key that produces a key combine (PK, SK): PK (public key, public key) is that the public musical notation verification whereas SK (Secret Key) is that the non-public key control by the petitioner, wont to sign the document.

a signature algorithmic rule that, taken as input a message m and a personal key SK produces a signature s .

a verification algorithmic rule that, taken as input the message m , public key PK and a signature s , accepts or rejects the signature.

To generate a digital signature is important to use the digital uneven key combine, attributed without ambiguity to an individual, known as holder of the key pair:

The non-public secret's identified solely by the owner, it's wont to generate the digital signature for a particular document;

The public secret's wont to verify the legitimacy of the signature.

Once the document is signed with the non-public key, the signature is verified with success solely with the corresponding public key. Security is bonded by the impossibility to reconstruct the non-public key (secret) from the general public, albeit the 2 keys area unit unambiguously connected.

4.3.11.1 Digital Signature method

A Digital signature could be a unidirectional hash, of the initial knowledge, that has been encrypted with the signer's non-public key. A digital signature method consists by the subsequent steps:

The signer calculates the hash for the info he must sign. The message digest could be a file size tiny that contains some form of management code that refers to the document. The hash perform is made minimizing the probability to urge constant worth of the digest from totally different texts and is additionally “one way” function: this implies that from calculates hash it's not possible to urge back the initial text.

The signer, mistreatment his non-public key, cypher the hash calculate.

Signer sends the initial knowledge and therefore the digital signature to the receiver. The combine could be a signed document or a document to that was hooked up a signature. The document is in clear text however it's the signature of the sender and might be sent in order that it is scan by anyone however not altered since the digital signature guarantees additionally integrity of the message.

For the verification, The receiving package 1st uses the signer's public key to rewrite the hash, then it uses constant hashing algorithmic rule that generated the initial hash to get a replacement unidirectional hash of constant knowledge. The receiving package compares the new hash against the initial hash. If the 2 hashes match, the info has not modified since it had been signed.

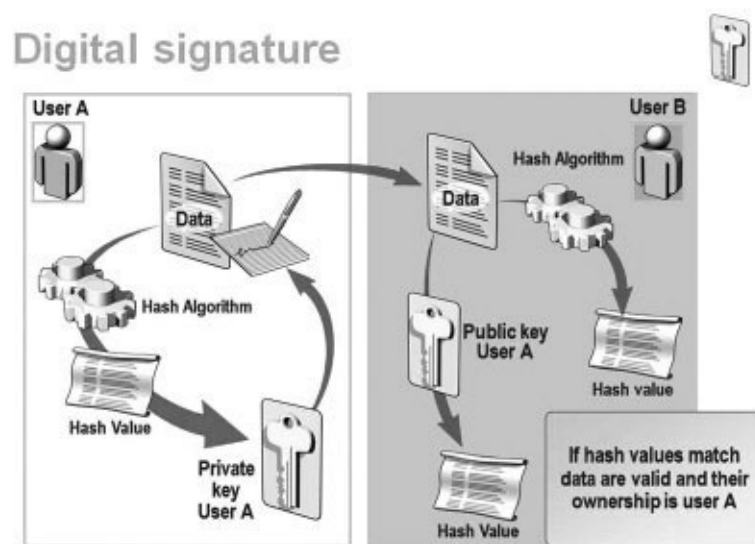


Figure 4.11: Digital Signature Process

The genuineness of a document is verified by anyone decrypting the signature of the document with the sender's public key, getting the fingerprint of the document, then comparison it therewith obtained by applying the hash perform to the document received that was hooked up the signature. If the two fingerprints are equal, the genuineness and integrity of the document are incontestable.

The linguistic communication and verification operations are also delegated to a schedule issued by the certification.

Thanks to the mechanism shown, the digital signature ensures non-repudiation: the signer of a document transmitted will not deny having sent it and therefore the receiver can deny possessing received it. In different words implies that the knowledge can't be unnoticed, as within the case of a standard signature on a paper document within the presence of witnesses.

The advantages of digital signatures

The activation of a completely machine-driven advancement, digital signatures, cut back time and prices related to the signatures on paper, the latter really have associate degree economic value and build delays and inefficiencies.

An estimate provided by ARX on the idea of current knowledge sets that every of their purchasers written signature on a paper document to work out the corporate at a price of \$ thirty U.S together with prices related to paper, printing prices, of signing, scanning, forwarding, storage and regeneration of lost or missing documents. Per the study of ARX, someone licensed to sign documents marking quite five hundred documents a year.

The digital signatures method is crucial for the formal approval processes of each corporations, a typical situation need multiple

authorization of multiple offices for every document.

Thus digital signatures permit alternate approval processes, collaboration and delivery of paper, with a digital system. This leads to variety of advantages:

improved operational potency, cut back cycle time and elimination of costs;

risk mitigation, compliance assurance, knowledge quality and semi permanent storage of files;

increase the fight and repair levels.

4.3.12 PUBLIC KEY CRYPTOGRAPHY

Asymmetric cryptography or public-key cryptography is cryptography within which a pair of keys is employed to code and decode a message in order that it arrives firmly. Initially, a network user receives a public and personal key pair from a certificate authority. The other user United Nations agency desires to send associate degree encrypted message will get the supposed recipient's public key from a public directory. They use this key to code the message, and that they send it to the recipient. Once the recipient gets the message, they decode it with their personal key, that nobody else ought to have access to.

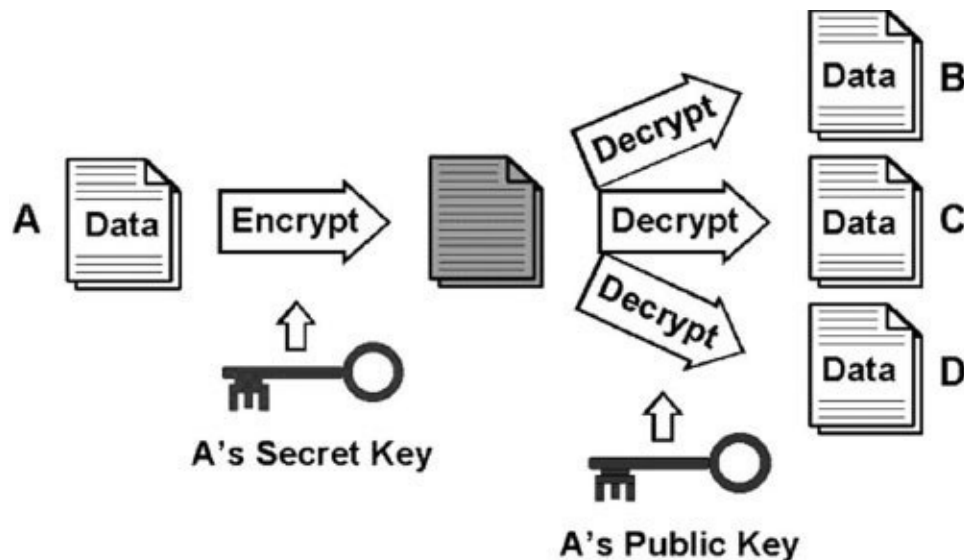


Figure 4.12: Public Key Cryptography

Public Key Cryptography uses asymmetric key algorithms.

Asymmetric key algorithms are based on the fact that the key used to encrypt the message is not the same as the key used to decrypt the message.

Two keys called public key and private keys are used.

Public Key Cryptography ensures authentication and confidentiality.

Confidentiality is provided by encrypting the message.

Authentication is provided by encrypting the message with the sender's private key. During decryption, the receiver's public key is used to decrypt the message. Since, only the sender knows his private key, the received message would have come from the claimed source. Thus ensuring authentication.

Main components of Public Key Cryptography:

Plain Text

Cipher Text

Private key

Public key

Encryption algorithm

Decryption algorithm

Asymmetric key algorithms are much slower than the symmetric algorithms.

RSA is an example of Public Key Cryptography

4.4 ANSWER THE FOLLOWING QUESTIONS:

What's the difference between a threat, vulnerability, and a risk?

What's the difference between symmetric and public-key cryptography?

What effects can viruses have?

What is the main virus entry point?

What is a Trojan Horse?

What is a Worm?

How does a Digital signature add more security?

What is a Digital Signature Certificate?

How does Digital Signature Work?

What are uses of Digital Signature Certificates?

What is the difference between a 'digital signature', a 'digital certificate' and a 'digital signature certificate (DSC)'?

Can a document signed with a digital signature be considered as valid evidence?

What is public key cryptography?

What are the problems with public key cryptography?

What are the principal functions of a public key cryptography?

What is a secured credit card?

What is spyware?

What's the difference between viruses, spyware, and other potentially harmful software?

Where do viruses, spyware, and other potentially unwanted software come from?

What are macro-viruses?

Chapter-5

Development of Secure Information System

5.1 INTRODUCTION

People (who use a product or service), businesses and government depend on the Internet and web services for information and communications. Managing the move (from one place to another) of data and access to it needs/demands reliability, privacy and security in the world of computers. In our digital world, an attack on one computer may affect many systems. Unauthorized access may result in (loss of money), the release of private information, damages to computer systems.

Organizations use systems security professionals to design, configure, put into use, manage, support and secure reliable computer systems. The responsibilities of professionals in this field have increased over the last few years as computer-attacks have become more fancy (or smart).

5.1.1 Why Information system security is Important?

With the growing use of electronic data comes a growing need for privacy and security in the world of computers. The damage caused by unauthorized access can be (large/relatively large) and include: loss of money due to illegal dishonesty/stealing (by lying), loss of private information, damage to computer systems, staff time and expense to restore operations, embarrassing changes to websites by computer (damage or destruction of someone else's property) and reduced reputation.

Businesses and governments use systems security professionals who can help design, configure, put into use, manage, support and secure computer systems. Workers with knowledge of information systems security are now thought about/ believed to be an important part of many information technology (basic equipment needed for a business or society to operate) teams.

5.2 DEVELOPING SECURE INFORMATION SYSTEMS

Now/recently, security solutions are mainly focused on providing security defenses (such as firewalls, routers, setup server, password and (turning messages into secret code)) instead of solving one of the main reasons of security problems that refers to the right/the proper information systems design. In a lucky way, there have been developed new ways of doing things including/combining security into their development processes.

5.2.1 INFORMATION SECURITY MANAGEMENT SYSTEM

An information security management system (ISMS) is a set of policies and procedures for in an organized way managing an organization's sensitive data. The goal of an ISMS is to (make something as small as possible/treat something important as unimportant) risk and secure/make sure of business (uninterrupted, constant quality) by pro-actively limiting the hit/effect of a security failure/mistake.

An ISMS usually addresses employee behavior and processes as well as data and technology. It can be targeted towards a particular type of data, such as customer data, or it can be put into use in a complete and thorough way that becomes part of the company's culture.

Security Management Responsibilities.

Deciding/figuring out goals, scope, policies, (things that are the most important), standards, and (success plans/ways of reaching goals).

Decide/figure out actual goals that are expected to be completed from a security program

(figure out the worth, amount, or quality of) business goals, security risks, user working well and getting a lot done, and ability to do things needed things.

Define steps to make sure that all the above are accounted for and properly talked to/looked at.

5.3 KEY ELEMENTS OF AN INFORMATION SECURITY POLICY

Information Security Policy /ISP (Information Security Policy)/ is a set or rules put into law by an organization to make sure that all users or networks of the IT structure within the organization's domain obey the prescriptions (related to/looking at/thinking about) the security of data stored digitally within the edges/borders the organization stretches its authority.

An ISP (Information Security Policy) is controlling/ruling the protection of information, which is one of the many valuable things a corporation needs to protect. The present writing will discuss some of the most important aspects a person should take into account when thinks about developing an ISP (Information Security Policy). Putting to work the logical arguments of (reasons for doing or not doing something), one could say that a policy can be as broad as the creators want it to be: Basically, everything from A to Z in terms of IT security, and even more. For that reason, the importance and focus here is placed on a few important things, but you should make a mental note of the freedom of thought organizations have when they form/create their own guidelines

5.3.1 Elements of Information Security Policy

5.3.1.1 Purpose

System creates ISP (Information Security Policy)s for a variety of reasons:

To establish a general approach to information security.

To detect and delay the agreement (where everyone meets in the middle) of information security such as (wrong and bad use of) data, networks, computer systems and computer programs.

To protect the reputation of the company regarding its (honest and right) and legal responsibilities.

To watch/ notice/ celebrate/ obey the rights of the customers; providing effective (machines/methods/ways) for responding to complaints and questions concerning real or perceived disobediences with the policy is one way to (accomplish or gain with effort) this goal.

5.3.1.2 Scope

ISP (information security policy) should address all data, programs, systems, facilities, other tech infrastructure, users of technology and third parties in a given organization, without exception.

5.3.1.3 Information security objectives

An organization that try to compose a working ISP (information security policy) needs to have (clearly visible/clearly understood) goals concerning security and (success plan(s)/way(s) of reaching goals) on which management have reached an agreement. Any existing disagreements in this big picture may make/give the information security policy project (harmful/angry/socially broken). The most important thing that a security professional should remember is that his knowing the security management practices would allow him to include/combine them into the documents he is trusted to draft, and that is a (promise that something will definitely happen or that something will definitely work as described) for completeness, quality and workability.

Simplification of policy language is one thing that may smooth away the differences and (promise that something will definitely happen or that something will definitely work as described) agreement among management staff. As a result, confusing (because of two different possible meanings) expressions are to be avoided. Be aware (of something dangerous) also of the correct meaning of terms or common words. For instance, “musts” express negotiability, whereas “shoulds” represent certain level of (ability to make wise decisions). In a perfect world, the policy should be briefly created to the point. Unnecessary thing of the policy's

wording should be avoided as well as it would make documents (talks a lot/long and boring) and out of (making two or more things look the same or happen at the same time), with unreadability that slows down (change for the better, over time). In the end, tons of details may stop/interfere with the complete (following the law/doing as you're told) at the policy level.

So how management views IT security seems to be one of the first steps when a person intends to enforce new rules in this department. What's more, a security professional should make sure that the ISP (Information Security Policy) has an equal institutional gravity as other policies (did/done/put into law) within the corporation. In cases where an organization has big structure, policies may differ and therefore be separated (because of race, religion, etc.) in order to define the dealings in the meant subset of this organization.

Information security is deemed to safeguard three main objectives:

Confidentiality - data and information valuable things must be kept to/ restricted to people approved to access and not be told (to people) to others;

Integrity - keeping the data unharmed and in one piece, complete and (very close to the truth or true number), and IT systems operational;

Availability - a goal pointing to/showing that information or system

is at ISP(Information Security Policy) of approved users when needed.



Figure 5.1: Objectives of Information Security

5.3.1.4 Authority & Access Control Policy

Usually, a security policy incorporates a hierarchic pattern. It hints that inferior workers are usually certain to not share the tiny amount of data they need unless (clearly/for a single purpose) licensed. (looking at things in the opposite way), a senior manager might have enough authority to create a choice what information is shared and with whom, which hints that they're not tied down by identical data security policy terms. That the logic demands that ISP (Information Security Policy) should address each basic position within the organization with (detailed descriptions of exactly what is required) which will clear up their strict/excellent standing.

Policy (good taste/good manners/improvement) happens at the same time with shaping the executive management, or authority in different words, people within the organization have. Basically, it's (system where things or people are in separate levels of importance)-based delegation of management within which one might have authority over his own work, project manager has authority over project files happiness to a bunch he's selected to, and also the supervisor has authority completely over system files - a structure harking back to the separation of powers (related to thinking about how people think) system. Obviously, a user might have the "need-to-know" for a particular form of data. Therefore, information should have enough roughness attributes to permit the acceptable licensed access. This can be the skinny line of finding

the delicate and breakable balance between allowing access to those that should use the information and denying such to unauthorized things/businesses.

Access to company's internal network and main data as well as mail servers, whether or not or not within the physical sense of the word, should be via (having a unique quality) logins that need (verifying someone's identity) within the kind of either passwords, (the science of recording information about the body), ID cards, or symbols etc. (participation in a custom/following rules) on all systems should be enforced to record logon tries and actual date and time of logon and logoff.

5.3.1.5 Classification of knowledge

Data will have completely different worth. Steps within the worth index might (force (on people)/cause an inconvenient situation) separation and clearly stated/ particular handling governments in power/procedures for every kind. Business partner data system this way might succeed to listen to protection of knowledge that has important importance for the organization, and pass over unimportant data that may otherwise overload organization's useful things/valuable supplies. Information classification policy might prepare the whole set of data as follows:

High Risk Class - information protected by state and federal laws (and law making) also as money, payroll, and personnel area unit enclosed here.

Confidential category - the information during this category doesn't get pleasure from the privilege of being underneath the wing of law, however the information owner judges that it should be protected against unauthorized (thing that is suddenly shown or understood).

Category Public - This data is freely distributed.

5.3.1.6 Security Awareness Sessions

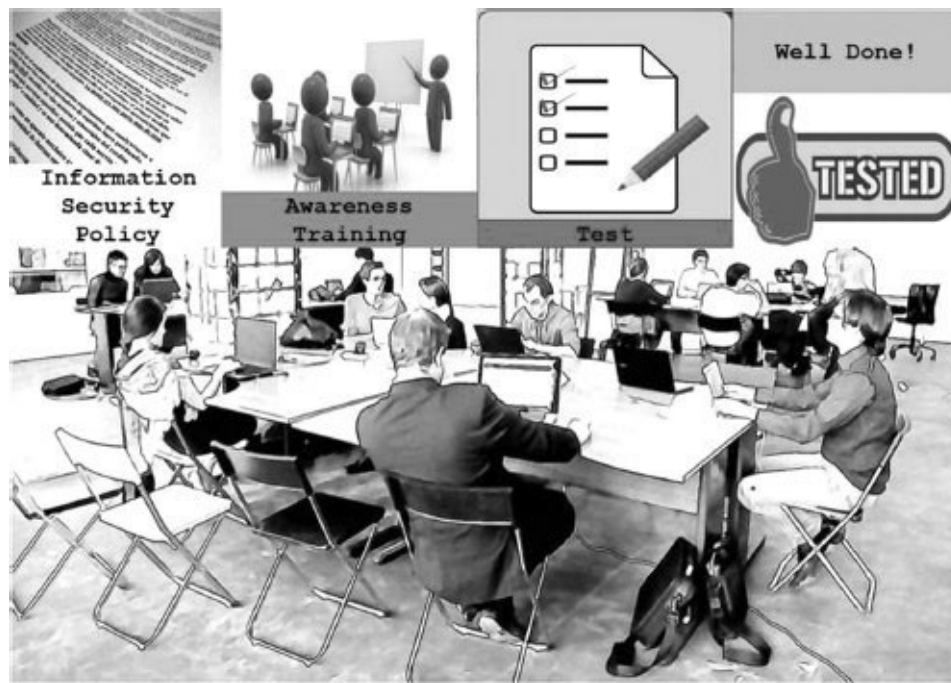


Figure 5.2: *How Information Security Policies can be shared with Staff?*

Sharing IT (Information Technology) security policies with workers could be an important step. Creating them look at/look through and sign to admit/recognize/respond to a document doesn't (almost completely/basically) mean that they're at home with and perceive the new policies. A coaching session would interact workers in a positive angle to data security, which can make sure that they get an idea of the procedures and (machines/methods/ways) (in the

original position) to shield the information, for example, levels of (keeping private information private) and information sensitivity problems. Such (knowing about something) coaching should bit on a wide range/wide extent of significant topics: the way to collect/use/delete information, maintain information quality, records management, (keeping private information private), privacy, acceptable use of IT(Information Technology)systems, correct usage social networking, etc. satiny low take a look at the top is maybe an honest plan.

5.4 INFORMATION SYSTEM DEVELOPMENT LIFE CYCLE

A general System development lifecycle (SDLC) that features the later phases: (beginning of something/actions you do to get into an organization), purchase/ getting/learning/development, putting into use, operations/maintenance, and personality/desire. Every of those five phases includes a minimum set of security steps needed/demanded to effectively include/combine security into a system throughout its development. A company can either use the final System development lifecycle (SDLC) represented during this document or can have developed a custom-designed System development lifecycle (SDLC) that meets their specific wants.

INITIATION PART -

Security Separation and labeling - defines three levels (i.e., low, (not an extreme person), or high) of possible result on organizations or people should there be a failure (or break) of security (a loss of (keeping private information private), (honest and good human quality/wholeness or completeness), or availability). Security separation and labeling standards help organizations in creating the good choice of security controls for his or her info systems.

Preliminary Risk Assessment - leads to an initial description of the

fundamental security wants of the system. A preliminary risk assessment ought to outline the threat setting during which the system can operate.

Purchase/getting/learning / Development part - It use to give information related to purchase/getting/learning and its development.

Risk Test/evaluation - analysis that identifies the protection needs for the system through a proper risk test/evaluation method. This analysis builds on the first risk test/evaluation (did/done/completed) throughout the (beginning of something/actions you do to get in to an organization) part, however are going to be a lot of in-depth and specific.

Security useful needs Analysis - analysis of needs that will clearly show/ include the later parts/pieces: (1) system security setting, (i.e., business/ project info security policy and business/project security however, (related to the beautiful design and construction of buildings, etc.)) and (2) security useful needs

Security Promise needs Analysis - analysis of needs that face/deal with the (related to the body function of living things) process activities needed and promise proof needed/demanded to supply the needed/demanded level of confidence that the knowledge security can work properly and effectively. The analysis, supported legal and useful security needs, are going to be used because the

basis for (serving to decide or settle something) what amount and what varieties of promise are needed.

Value issues and coverage - decides/figures out what amount of the event value will be attributed to information security over the system life cycle. These prices clearly show/include hardware, software, personnel, and coaching

Security coming up with secures /makes sure of that prescribed security controls, planned or (in the original position), are totally recorded/supported. The protection set up (in a group) provides a whole description or description of system also as add-ons or indications to the main key documents supporting the agency's information security program (i.e. setup management set up, (related to one thing depending on another thing that might or might not happen) set up, event response set up, security (knowing about something) and coaching set up, rules of behavior, risk test/evaluation, security check and analysis results, system interconnection agreements, security approvals/ accreditations, and set up of action and (important things that are done or completed)).

Security management Development - secures/makes sure of that security controls represented within the individual security plans are designed, developed, and enforced. For info systems now operating, the protection plans for those systems might require/result in the event of further security controls to add to the controls already (in

the original position) or the change of elite controls that are considered to be but effective.

(Related to the body function of living things) process Security check and analysis - secures/makes sure of that security controls developed for a replacement system are operating properly and are effective. Some kinds of security controls (mostly those controls of a non-technical nature) can't be tested till the knowledge system is send out and used--these controls are generally management and operational controls.

Different coming up with elements - secures/makes sure of that each one necessary elements of the event method are thought of once including/ combining security into the life cycle. These elements clearly show/include choice of the good contract kind, participation by all necessary useful teams among a company, participation by the certifier and (give credentials to/give authorization to)or, and development and execution of necessary getting plans and processes.

Close attention and Acceptance - secures/makes sure of that the organization validates and (checks for truth/proves true) that the practicality represented within the detailed description of exactly what is required is enclosed within the (things that can be manufactured and provided).

Security management Integration - secures/makes sure of that

security controls are (combined different things together so they worked as one unit) at the operational web site wherever the knowledge system is to be sent out and used for operation. Security management settings and switches are enabled (going along with/obeying) seller directions and available security putting into use steering.

Security Certification - secures/makes sure of that the controls are effectively applied through well-known checking (for truth) ways of doing things and procedures and offers organization officers confidence that the good safeguards and countermeasures are (in the original position) to shield the organization's system. Security certification (in a group) uncovers and describes the famous weaknesses (that could be used to hurt something or someone) within the system.

Security (granting the right to vote) - provides the needed/demanded security approval of AN system to method, store, or transmit info that's needed. This approval is granted by a senior organization official and depends on the (checked for truth/proved true) effectiveness of security controls to some in agreement upon level of promise and known leftover/extra risk to (service business/government unit/power/functioning) valuable things or operations.

Configuration Management and management - ensures adequate thought of the potential security impacts thanks to specific changes

to an system or its encompassing setting. Configuration management and configuration management procedures are important to establishing an initial baseline of hardware, software, and microcode elements for the knowledge system and afterwards dominant and maintaining an correct inventory of any changes to the system.

Continuous observation - ensures that controls still be effective in their application through periodic testing and analysis. Security management observation (i.e., edificatory the continuing effectiveness of these controls over time) and coverage the protection standing of system to applicable agency officers is an important activity of a comprehensive information security program.

Info Preservation ensures that information is preserved, as necessary, to adapt to current legal needs and to accommodate future technology changes.

5.5 APPLICATION SECURITY

Application security is that the use of software package, hardware, and (related to the usual step-by-step way of doing things) ways to shield computer programs from external threats. Once AN when thought in software package style, security is turning into a very important concern throughout development as computer programs become more mostly (easy to get to, use, or understand) over networks and are, as a result, easily able to be harmed or influenced by a good style of threats.

Security measures designed and made into applications and a sound application security (something commonly done) the chance that unauthorized code are going to be able to control/move around/mislead computer programs to access, steal, change, or delete sensitive knowledge.

Actions taken to make sure application security are generally known as counter measures. The best basic software package step is AN application firewall that limits the execution of files or the handling of information by clearly stated/particular put in programs. The best common hardware step may be a router that may delay the scientific discipline address of a personal laptop from being directly visible on the web. Different countermeasures clearly show/include standard firewalls, (turning messages into secret code)/decryption

programs, anti-virus programs, spyware detection/removal programs and (recording something about the body) identification systems.

Application security will be increased by strictly shaping business/project valuable things, (typical and expected) what every computer program will relating to/connected to these valuable things, making a security profile for every computer program, (typical and expected) and putting in order of importance possible threats and recording/writing down bad events and also the actions taken in every case. This method is thought as threat modeling. During this big picture, a threat is any (possible or/possible greatness or power or) actual bad event that may agree (after everyone gives something up) the valuable things of a business/project, together with each evil and cruel events, like a denial-of-service (DoS) attack, and unplanned events, like the failure of a device.

5.5.1 The Foundations of Security

Security depends on the following:

Authentication

Authentication addresses the question: World Health Organization are you? It's the method of unambiguously characteristic the shoppers of your applications and services. These may well be finish users, different services, processes, or computers. In security formulation, echo shoppers are spoken as principals.

Authorization

Authorization addresses the question: what are you able to do? It's the method that governs the resources and operations that the echt consumer is permissible to access. Resources embody files, databases, tables, rows, and so on, beside system-level resources like written record keys and configuration knowledge. Operations embody playing transactions like getting a product, transferring cash from one account to a different, or increasing a customer's credit rating.

Auditing

Effective auditing and work is that the key to non-repudiation. Non-repudiation guarantees that a user cannot deny playing AN operation or initiating a dealing. As an example, in AN e-commerce system, non-repudiation mechanisms are needed to form certain that a client cannot deny ordering a hundred copies of a specific book.

Confidentiality

Confidentiality, conjointly spoken as privacy, is that the method of constructing certain that knowledge remains non-public and confidential, which it can't be viewed by unauthorized users or eavesdroppers World Health Organization monitor the flow of traffic across a network. secret writing is usually wont to enforce confidentiality. Access management lists (ACLs) are another means that of imposing confidentiality.

Integrity

Integrity is that the guarantee that knowledge is shielded from accidental or deliberate (malicious) modification. Like privacy, integrity may be a key concern, notably for knowledge passed across networks. Integrity for knowledge in transit is often provided by victimization hashing techniques and message authentication codes.

Availability

From a security perspective, availableness means systems stay obtainable for legitimate users. The goal for several attackers with denial of service attacks is to crash an application or to form certain that it's sufficiently swamped so different users cannot access the applying.

5.5.2 Threats, Vulnerabilities, and Attacks outlined

A threat is any potential prevalence, malicious or otherwise, that would hurt a plus. In different words, a threat is any dangerous issue that might be attached to your assets.

Weakness/ Vulnerabilities (that could be used to peek into someone or something) may be a weakness that produces a risk possible. This might be as a result of poor style, setup mistakes, or inappropriate and insecure (the science of making secret codes) ways of doing things. Weak input validation is an example of an application layer weakness (that could be used to hurt someone or something), which may lead to input attacks.

An attack is an action that fully uses (for profit) weakness (that could be used to hurt someone or something) or (does/puts into law) a threat. Samples of attacks clearly show/include causing evil and cruel input to an (online or paper form that asks for a job, money, admission, etc.) or flooding a network in an effort to deny service.

5.5.3 However can we Build a Secure net Application?

It is unimaginable to style and build a secure net application till we all know our threats. AN progressively vital discipline and one that's counseled to make a part of our application's style part is threat modeling. The aim of threat modeling is to investigate our application's design and style and determine doubtless vulnerable areas that will enable a user, maybe erroneously, or AN assaulter with malicious intent, to compromise our system's security.

After we all know our threats, style with security in mind by applying trite and tested security principles. As developers, we tend to should follow secure cryptography techniques to develop secure, robust, and hack-resilient solutions. The look and development of application layer software package should be supported by a secure network, host, and application configuration on the servers wherever the applying Software package is to be deployed.

5.5.4 Secure our Network, Host, and Application

“A vulnerability (that could be used to hurt someone or something) network can enable an evil and cruel user to take advantage of a bunch or a computer program. A vulnerability (that could be used to hurt someone or something) host can enable an evil and cruel user to take advantage of a network or a computer program. Weakness (that could be used to hurt someone or something) in AN computer program can enable an evil and cruel user to take advantage of a network or a bunch.”

To build secure net computer programs, an (interested in the whole or the completeness of something) approach to application security is needed and security should be applied in any respect three layers.

This approach is shown in [Figure](#)

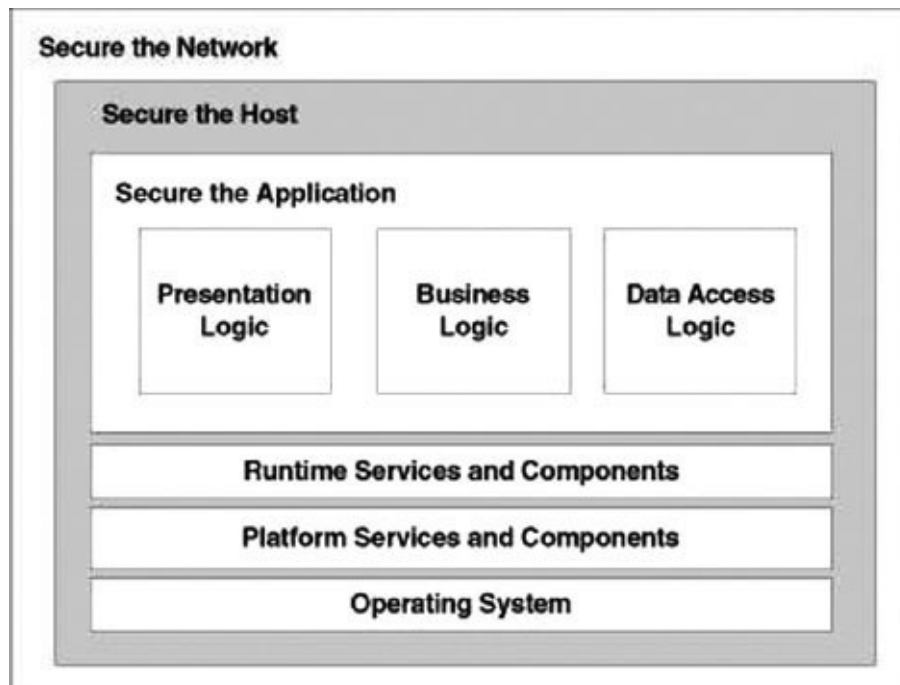


Figure 5.3: A holistic approach to security

5.5.5 Securing Your Network

A secure internet computer program depends upon a secure network (basic equipment needed for a business or society to operate). The network (basic equipment needed for a business or society to operate) consists of routers, firewalls, and switches. The role of the secure network isn't only to shield itself from TCP/IP-based attacks, however also/and to put into use countermeasures like secure body (connecting points/ways of interacting with something) and powerful passwords. The secure network is also/and answerable for (promising that something will definitely happen or that something will definitely work as described) the (honest and good human quality/wholeness or completeness) of the traffic that it's forwarding. If we all know at the network layer concerning ports, rules of conduct, or communication which will be harmful, counter those possible threats at that layer.

5.5.6 Network Component Categories

This divides network security into separate component categories as shown in [Table](#)

Table 5.1: Network Component Categories

5.5.7 Securing our Host

When we secure a number, whether or not it's our internet server, application server, or info server, this guide breaks down the varied secure configuration settings into separate classes. With this approach, we are able to specialize in a selected class and review security, or apply security settings that relate thereto specific class. Once we install new computer code on our servers with this approach, we are able to measure the impact on our security settings. As an example, we have a tendency to might address the subsequent questions: will the computer code produce new accounts? Will the computer code add any default services? UN agency square measures the services running as? Square measure any new script mappings created?

5.5.8 HOST CONFIGURATION CATEGORIES

[Figure 5.4](#) shows the various categories, “Securing our Network, Host, and Application.”

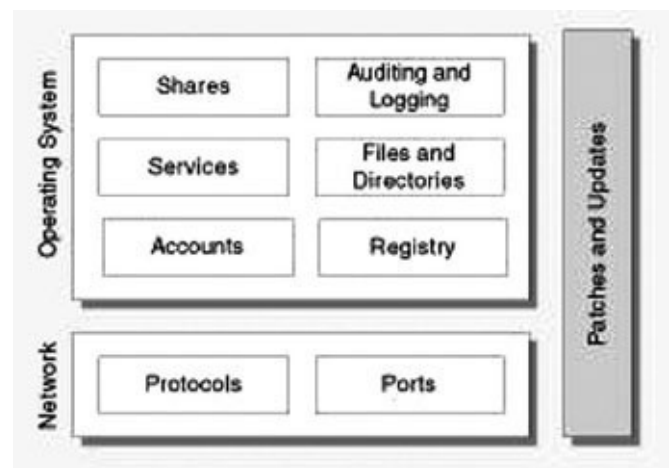


Figure 5.4: Host Configuration Categories

Host security categories

With the (solid basic structure on which bigger things can be built) that these categories provide, we can in an organized way (figure out the worth, amount, or quality of) or secure our server's setup instead of applying security settings on a (something made for a particular reason) basis. The rationale for these particular categories is shown in [Table](#)

5.5.9 SECURING OUR APPLICATION

If we have to review and analyze the top security issues across many Web applications, we would see a pattern of problems. By organizing these problems into categories, we can systematically tackle them. These problem areas are our application's vulnerability categories.

Application Vulnerability Categories

What better way to measure the security of a system than to (figure out the worth, amount, or quality of) its potential weak points? To measure the security toughness of your use, we can (figure out the worth, amount, or quality of) the application weakness (that could be used to hurt someone or something) categories. When we do this, we can create application security profiles, and then use these profiles to decide/figure out the security strength of a computer program.

These categories are used as a (solid basic structure on which bigger things can be built). Because the categories represent the areas where security mistakes are most often made, they are used to illustrate guidance for application developers and designers/builders. The categories are also used as a (solid basic structure on which bigger things can be built) when (figuring out

the worth, amount, or quality of) the security of a Web computer program. With these categories, we can focus the same way on the key design and putting into use choices that most affect our application's security. Application weakness (that could be used to hurt someone or something) categories are described in [Table](#)

[illegible]

Table 5.3: Application Vulnerability Categories

5.5.10 Security Principles

Recommendations used throughout this guide are based on security ways of thinking/basic truths/rules that have proven themselves over time. Security, like many parts of software engineering, lends itself to a way of thinking/basic truth/ rule-based approach, where core ways of thinking/basic truths/rules can be applied (without any concern about/having nothing to do with) putting into use technology or application picture/situation.

picture/situation.

[illegible]

picture/situation. picture/situation. picture/situation.
picture/situation. picture/situation. picture/situation.
picture/situation. picture/situation. picture/situation.
picture/situation. picture/situation. picture/situation.

[illegible][illegible]

5.6 INFORMATION SECURITY GOVERNANCE AND RISK MANAGEMENT

Information Security Governance associated Risk Management is an wide domain that the knowledge security skilled should perpetually remember of. Info security Governance and Risk Management examines the frameworks and coming up with structures accustomed check that info assets are protected among a corporation. This conjointly examines the governance, structure structures and cultures, and therefore the awareness coaching that ought to be imparted to staff the least bit levels. Info security governance is that the Framework established to make sure that everyone the safety parts place in situ to safeguard our information surroundings work with efficiency, accomplish what's supposed, and do thus affordably.

5.6.1 Objectives of knowledge Security Governance and Risk Management

Acknowledge responsibilities associated with info security risk management match info security principles with samples of controls accustomed apply them match the parts of a policy framework with their corresponding descriptions determine method frameworks for implementing and auditing security controls. Determine method frameworks for acting info security risk assessment distinguish between the results of qualitative and quantitative risk assessments match stages of the chance assessment method with corresponding descriptions label samples of actions taken by a corporation in response to a risk. As either dodging, transfer, mitigation, or acceptance acknowledge the suitable application of risk management ideas distinguish between risk assessment and management methodologies.

Determine responsibilities of associate info Security Officer acknowledge the benefits and drawbacks of assorted reportage models acknowledge however numerous personnel security methods work to attenuate worker risk acknowledge methods for implementing info security coaching acknowledge the topics a pc ethics program ought to address. Match common ethics fallacy to the corresponding correct views acknowledge the moral principles that every one info security professionals ought to apply as they are doing their jobs acknowledge a way to handle structure

problems acknowledge applicable actions to implement security awareness coaching in your organization and every one information security professionals should apply acknowledge moral principles that.

5.6.2 Why info Security Governance is Important?

In associate interconnected world it provides a framework for secure business.

Ensures the Country's security resources are well spent.

Provides ability to conduct secure business operations in associate interconnected world.

Ensures the Country's security resources are well spent.

5.6.3 What advantages are often gained from a security governance program?

International recognition

Fewer breaches to deal with/increased potency

Simpler use of resources

5.6.4 GOVERNANCE MODEL

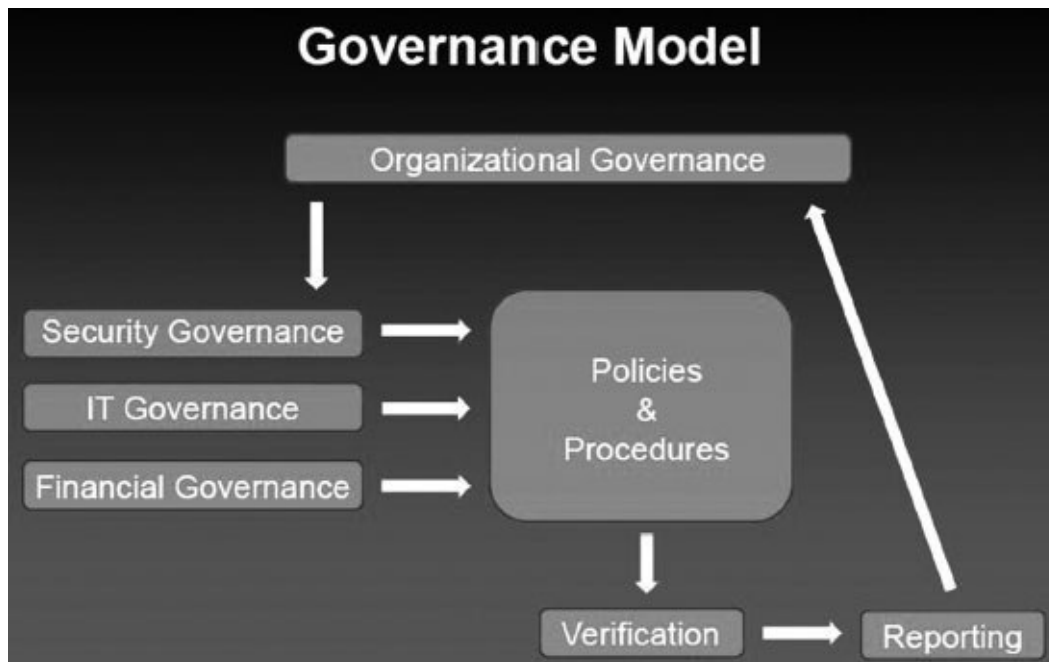


Figure 5.5: Governance Model

Security Governance

Enterprise security governance may be a company's strategy to cut back risk by protective systems and data, likewise as its execution of that strategy.

Enterprise security governance activities involve the event, institutionalization, assessment associate degreed improvement of

an organization's enterprise risk management (ERM) and security policies. Governance of enterprise security includes deciding however varied business units, personnel, executives associate degreed employees ought to work along to safeguard an organization's digital assets, guarantee information loss interference and shields the organization's public name.

Enterprise security governance activities ought to be in keeping with the organization's compliance needs, culture and management policies. The event and maintenance of enterprise security governance usually involves conducting threat, vulnerability and risk analyses tests that are specific to the company's business.

Enterprise security governance may be a company's strategy for reducing the prospect those physical assets closely-held by the corporate are often taken or broken. During this context, governance of enterprise security includes physical barriers, locks, fencing and fireplace response systems likewise as lighting, intrusion detection systems, alarms and cameras.

IT (Information Technology) Governance focuses specifically on data technology systems, their performance and risk management. The first goals of IT (Information Technology) Governance are to assure that the investments in IT (Information Technology) generate business worth, to mitigate the risks that are related to IT. This could be done by implementing associate degree structure with well-defined roles for the responsibility of data, business processes,

applications.

IT (Information Technology) governance ought to be viewed as however IT (Information Technology) creates worth that matches into the company Governance Strategy of the organization, and can be seen as a regulation on its own in recursive manner. In taking this approach, all stakeholders would be needed to participate within the deciding} process. This creates a shared acceptance of responsibility for essential systems and ensures that IT(Information Technology) connected selections are created and driven by the business and not contrariwise.

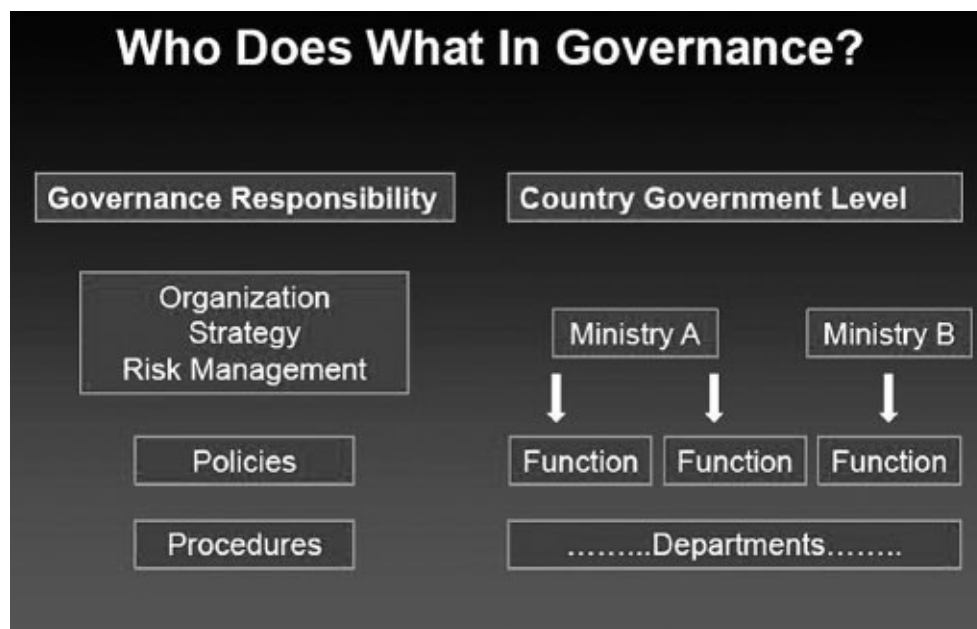


Figure 5.6: Roles in Governance

Why IT(Information Technology)governance is necessary?

IT(Information Technology) governance is required to make sure that the investments in IT(Information Technology) generate value-reward-and mitigate IT-associated risks, avoiding failure. It's central to structure success - effective and economical delivery of services and product - particularly once it's designed to originate amendment in a corporation. This variation method, ordinarily noted as “business transformation,” is currently the prime enabler of recent business models each within the personal and public sectors. Business transformation offers several rewards, however it additionally has the potential for several risks, which can disrupt operations and have inadvertent consequences. The perplexity becomes the way to balance risk and rewards once victimization IT(Information Technology)to change structure amendment.

Financial governance

The World Economic Forum's money Governance initiative consists of Associate in Nursing in progress dialogue between key stakeholders within the world money sector, policy arena Associate in nursing academe regarding an rising restrictive framework designed to reinforce the world economic recovery and supply a sound basis for long-run stability.

The global money crisis unconcealed major shortcomings within the system of institutional and restrictive governance.

To move on the far side the crisis, it'll be necessary to boost current structures and develop a lot of honest and economical structure governance that reflects changes within the global political and economic landscape.

The principle of equal participation and comprehensive cooperation ought to be followed in up world governance. It's imperative to lift the voice and illustration of developing countries.

The system of rules practices and processes by that an organization is directed and controlled. Company authority and control basically involves making up (from an argument) the interests of the different (people who are interested in a project or business) in a very company - these agree with/supports shareholders, management, customers, suppliers, rich money-giving people, government and therefore the community. Since company authority and control also/and provides the (solid basic structure on which bigger things can be built) for reaching a company's goals, it includes much each world/area/ball of management, from action plans and internal controls to performance measure and company showing/telling about.

5.6.5 Existing Problems

The working of governments are often at the tactical level without a strategic context.

Examples:

Security tools

Incident response

Lack of regular feedback to executive management.

Examples:

Ad hoc testing occurs without a pre-defined structure

5.7 RISK MANAGEMENT



Figure 5.7: Vendor Risk Management

Risk Can Not Be Outsourced

- Edges/borders of ownership for security controls must be crystal clear
- Continuous security watching/supervising and reporting back
- The vendor and your organizations Integration of event response.

THE EXECUTIVES ROLES IN AN ORGANIZATIONS

Set Examples for others:

- Tone from the Top
- Role Model Liability

Set Expectations for others:

- Security expectations must be explicit in vendor agreements

Oversight Establishment:

- Independent security assessments and audits must be submitted by the vendors.

INFORMATION SECURITY MEASURES OF PERFORMANCE

Program is Effective

- Investment reduces the number of findings in audit reports
- Success rate in closing items in the Plan of Action and (important things that are done or completed)
- Hits/effects from security events (popular thing/general way things are going) lower.

Policies Are to be Followed and in Effective Manner.

- Procedures should create event(s) or object(s) that prove something of performance
- Continuous watching/supervising: antivirus, invasion detection
- Weakness (that could be used to hurt someone or something)

tests/ evaluations

- After action reports on disaster recovery, event response

5.8 SECURITY ARCHITECTURE AND DESIGN

The system of rules practices and processes by that an organization is directed and controlled. Company authority and control basically involves making up (from an argument) the interests of the different (people who are interested in a project or business) in a very company - these agree with/supports shareholders, management, customers, suppliers, rich money-giving people, government and therefore the community. Since company authority and control also/and provides the solid basic and fragile structure on which bigger things can be manufactured for reaching a corporation's goals, it includes much each world/area/ball of management, from action plans and internal controls to performance measure and company showing/ telling about.



Figure 5.8: *Security Architectures*

The security of the product will usually confine itself to the security properties of that product. This way the Common Data Security (related to the beautiful design and construction of buildings, etc.) (CDSA) describes how security services are given in a layered

model.

An business/project security (related to the beautiful design and construction of buildings, etc.) needs to face/deal with computer programs, (basic equipment needed for a business or society to operate), processes, as well as security management and operations.

An application security (related to the beautiful design and construction of buildings, etc.) lies between the two. It must address not only the security gave/ given within the computer programs, but also the added/more (paying/making up for) controls, which are needed/demanded outside the application. The last thing just mentioned are sometimes more important and almost always harder, to specify and put into use.

5.8.1 Relationships & Dependencies

The picture/situation/requirements talked to/looked at by, a security (related to the beautiful design and construction of buildings, etc.) includes the (clearly connected or related) IT(Information Technology)(related to the beautiful design and construction of buildings, etc.). In this section we use the term “Reference (related to the beautiful design and construction of buildings)” to identify the perfect model from which the “Solution are received/made from.

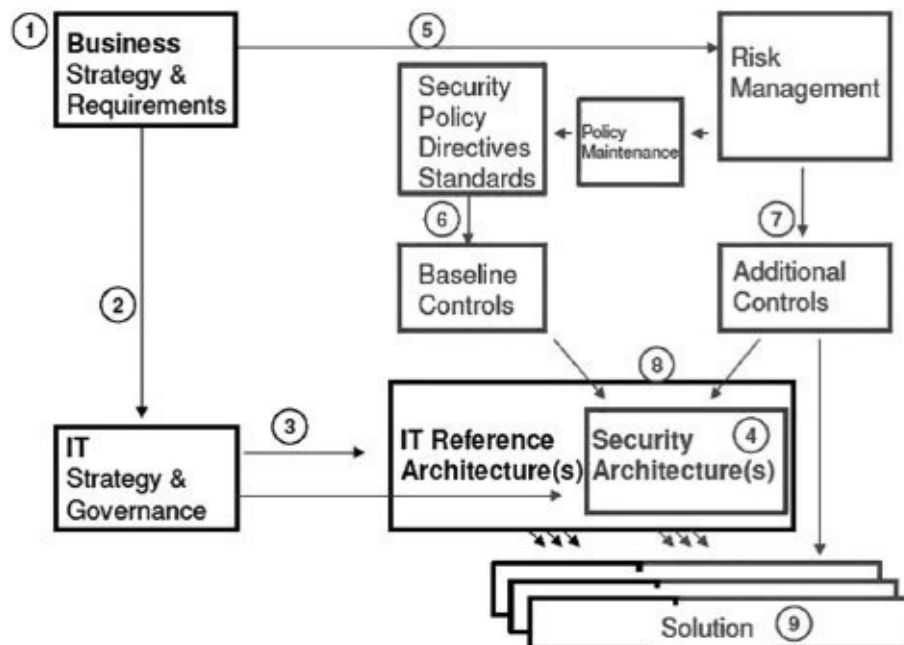


Figure 5.9: Architecture of Reference

The diagram is intended to illustrate the following propositions (starting at the top-left):

Coming up with a security design ought to be a response to Business strategy and needs.

The IT (Information Technology) Strategy ought to be a response to the Business strategy and needs.

The IT (Information Technology) Reference Architecture(s) ought to be a response to the IT(Information Technology) Strategy and Governance. The reference design can typically address multiple platforms.

The Reference Security design(s) is a component of the IT(Information Technology) Architecture even though it's revealed as a separate document.

IT(Information Technology) Security Risk Management, method and criteria square measure derived from the Business strategy and needs.

A group of Baseline Controls is generated supported the protection Policy, Directives, Standards etc. By Baseline Controls we tend to perceive obligatory minimum standards for the organization.

Extra controls square measure derived from the chance management method.

The protection design is that the embodiment of the baseline and therefore the extra security controls. It also can be outlined to incorporate the policies, directives, standards and therefore the risk management method.

To visit the precise implementations derived from the reference design, some organizations usually use the most common term 'answer design'.

5.8.2 Benefits

EFFECTIVENESS OF COST

The Most common plus point of associate enterprise security design is that it is almost similar as associate Information Technology (IT) design, particularly cost-effectiveness through standardization.

The cost-effectiveness improvement stems from the re-use of the controls laid out in the design, however this affects over simply the price of implementation:

Easier, higher cheaper implementation ensuing from economies of scale

Re-use of skills of support employees, application developers, analysts, (and generally users).

Re-use of management interfaces

Easier, better, cheaper compliance checking

Easier, higher cheaper effectiveness measuring

quicker implementation of normal solutions

means approval

In giant organizations associate IT (Information Technology) security approval is needed as a part of project governance. Usually a “triage” are performed so as to spot candidate comes for a close risk analysis, whereas for “harmless” comes a high-level analysis is comfortable.

In such a company compliance with a security design can give a “fast track” to security approval.

COMMUNICATION

In addition, significantly for a multi-national organization, associate design improves communication, and ensures that the specialists in several countries share a typical understanding of word, needs and solutions. Equally for a posh system a security design is crucial to confirm that developers are performing on totally different sub-systems, perceive the connection of their contribution to the total, and what security needs their product should meet.

5.8.3 Form

As indicated within the on top of diagram, the protection design is expounded to the IT (Information Technology) architecture(s) however it will take varied forms. it always contains a listing of normal controls along side principles, relationship diagrams etc. the main points of the management implementation - preferably together with measuring and testing standards-square measure typically break free the design document.

The security design might not be a standalone document, however may be a part of associate IT (Information Technology) design, or perhaps a pervasive a part of associate IT(Information Technology) design.

5.8.4 Drivers

The security controls square measure derived in four ways:

Financial

Risk Management

Benchmarking & sensible observe

Legal and restrictive

5.8.4.1 monetary

The monetary driver is “return on investment” (ROI) - though it should be measured as; NPV (Net gift Value), IRR (Internal Rate of Return), etc. Quite merely the price when implementing the management is a smaller amount than if the management had not been enforced.

Where the chance is enclosed within the calculation - i.e. values for the chance with and while not the management square measure used-this is termed “ROSI”. Some security controls will be value effective even while not taking the reduction of risk.

5.8.4.2 Risk Management

Risk management may be a method that identifies risks associated selects an acceptable treatment. The rationale for managing risks is to create the full value of adverse incidents sure. Here total value means that the total of the impact of the incident and therefore the value of controls supposed to mitigate the chance.

Note that the priority in risk management is that the (estimated) magnitude of the chance, and not the expected value saving through treatment. We must to be mentally ready to compensate a premium over the annual hammering expectancy for this conclusion that is unavoidable.

This is constant thinking for a non-public person shopping for (sudden unplanned bad event/crash) insurance. Even supposing he expects the price of insurance over the years to exceed the computer risk, he pays the premium for “peace of mind”.

5.8.4.3 Benchmarking

Many controls square measure nominal as a result of their enclosed in (authoritative) revealed standards, or as a result of peer organizations use them.

Again the {particular} controls might not be value effective within the particular setting, however few security officers can need to reveal themselves, also as their or organizations, by not implementing an impact, that constitutes “recognized sensible practice”.

5.8.4.4 Legal and restrictive

This class includes, for instance, banking laws, also as controls laid out in contracts with suppliers or customers, e.g. to attach with their order and logistical systems.

5.9 ANSWER THE FOLLOWING QUESTIONS:

What is information system security?

Give the responsibilities of security management.

How can we classify the data. Explain.

Explain in detail Information System Development Life Cycle.

How Do We Build a Secure Web Application?

Give the foundation pillars of security.

Explain the following terms:

Switch

Firewall

Router

What is the Application vulnerability? List all Application

vulnerability categories.

What are the Objectives of Information Security Governance and Risk Management?

Why Information Security Governance is Important and what are the benefits that can be gained from a security governance program?

Give a brief note on IT(Information Technology) Governance.

Design security architecture for any system and also figure out all its relationships and dependencies.

What are the benefits of security architecture?

Explain the terms risk management and benchmarking in terms of security architecture.

What is the process for reporting bugs (security and otherwise) to the web developer?

Is information security on the board's regular (list of things to deal with/desire to reach a goal)?

Do we treat the policies and controls living documents that change to fit the needs of the organization and changes to regulation?

There are different types of security models, as in Bell-LaPadula, Biba and state machine. Which of the following is the correct definition of “security model”?

Which model deals only with confidentiality?

Explain Bell-La Padula Model.

Chapter-6

Security Issues in Hardware

6.1 INTRODUCTION

Hardware security - whether or not for attack or defense - differs from code, network, and information security thanks to the character of hardware. Often, hardware style and producing occur before or throughout code development, and as a result, we have a tendency to should contemplate hardware security early in product life cycles. Yet, hardware executes the code that controls a cyber physical system, thus hardware is that the last line of defense before injury is completed - if Associate in Nursing assaulter compromises hardware then code security mechanisms could also be useless. Hardware conjointly encompasses a longer lifetime than most code as a result of once we have a tendency to deploy hardware we have a tendency to sometimes can't update it, wanting the wholesale replacement, whereas we are able to update code by uploading new code, typically remotely. Even once hardware outlives its quality, we have a tendency to should lose it properly or risk attacks just as pilfering of the information or code still resident within the hardware. So, hardware security issues the complete lifetime of a cyber-physical system, from before style till once retirement.

In this, we have a tendency to contemplate two aspects of hardware security: security within the processor provides chain and

hardware mechanisms that give code with a secure execution atmosphere. We have a tendency to begin by exploring the protection threats that arise throughout the key phases of the processor provide chain. One such threat is that the Trojan circuit, Associate in Nursing insidious attack that involves planting vulnerability processor someday between style and fabrication that manifests as an exploit once the processor has been integrated, tested, and deployed as a part of a system.

6.1.1 Hardware Provides Chain Security

For years, Moore's Law has expected the success of the semiconductor computer circuit (IC or chip) producing business: a replacement IC may be created, that has doubly as several transistors as an identical IC created but a pair of years previous. With every new generation of smaller semiconductor unit sizes, IC fabrication plants, referred to as foundries or fabs, should update their tools to support the new technology, an upscale price to incur each different year.

The increase in prices and demand for brand spanking new chips, not to mention small production prices overseas, has light-emitting diode to the globalization of the semiconductor style and fabrication business, that successively raises issues regarding the vulnerability of ICs to subversion.

Possible attacks on the (IC or chip) provides chaining of comprise maliciously modifying ICs, repeating of ICs to supply cloned devices, or stealing property (IP). A malicious modification to Associate in Nursing IC is termed a Trojan circuit or Hardware Trojan, as a result of the modification hides itself among the IC and probably even provides correct, helpful practicality before it attacks, very similar to its eponymic story. Cloned or counterfeit ICs result in lost revenue and should be less reliable than the first,

probably touching the name of the first device manufacturer and therefore the security of the top user.

All of those attacks might cause money hurt to the first designer or device manufacturer, whereas conjointly introducing potential risks to finish users owing to loss of dependability and security.

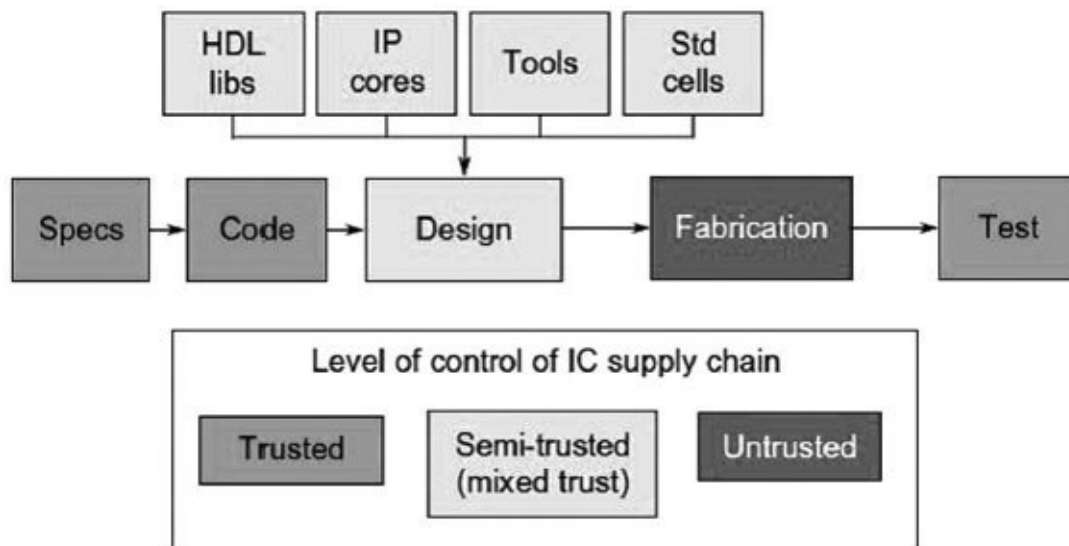


Figure 6.1

In this figure (IC or Chip) Supply Chain. End-users trust chip designers, whose name appears on the final product, but design houses outsourcing to lesser known companies, hence introducing semi-trusted and Non-trusted phases. These phases introduce vulnerabilities that attackers can exploit before the designer incorporates its IC or Chip.

Supply chain attacks will happen throughout Associate in Nursing of the entrusted phases before preparation inside a device. The first phases of the IC offer chain, shown in Figure, are design, fabrication, and test. Categorical levels of trust square measure allotted supported the top user point-of read, with the idea that chip designer's square measure trusty.

The IC style part consists of all the code and different inputs to the tools, which will generate the specification for the metalwork's processes. A number of the look processes square measure discernible and auditable, and so trusty. However, third party science is progressively employed in a protected manner specified designers and customers cannot verify the contents of the science. Thus, the look part has mixed levels of trust, and IC style is susceptible to offer chain attacks.

Fabrication processes square measure equally untrusted because of an absence of verifiability and trust at offshore foundries. Solely the take a look at part is trusty in its entirety. The take a look at part ensures every IC passes a group of take a look at procedures that check for producing faults supported the noted style. As a result of the IC is also changed in unknown ways in which could activate malicious activity underneath rare circumstances, this take a look at part cannot observe Trojan circuits. Moreover, science thieving and device biological research occur before the take a look at part, thus it's not enough for sleuthing any of the higher than attacks, although it's trusty.

6.1.2 Testing for Trojan Circuits

One of the best-known approach to Trojan detection is to seem for additions Associate in Nursing modifications to an IC or Chip in an exceedingly laboratory setting before deploying the ultimate product. Lab-based detection augments the take a look at part of the provision chain with Si style authentication that verifies that Associate in Nursing IC contains solely the designer's meant practicality and zilch else.

Silicon style authentication is tough because of increasing IC quality, shrinking feature sizes, rarity of conditions for activating malicious logic, and lack of data concerning what practicality has been added to the IC. Testing cannot capture the behavior of added practicality, thus Associate in Nursing IC may contain all of the meant practicality whereas having additional malicious logic that may not be activated or detected by tests. Detection by physical review is meager because of the quality and size of recent ICs. Damaging approaches square measure too expensive and can't be applied to each IC. To promising directions that square measure active spaces for analysis within the square measure of Trojan circuit detection at the Si style authentication step are side-channel analysis and Trojan activation.

Side-channel analysis depends on variations in signals, typically

within the analog domain, that Associate in Nursing IC emits Associate in Nursing a Trojan circuit would have an effect on - changes to the behavior or physical characteristics of an

IC could modification non-behavioral traits once the IC is tested. For instance, the presence of a Trojan circuit could cause deviations in an exceedingly chip's power dissipation, current, temperature, or timing. Seminal work by uses power analysis for detection of Trojan circuits; they additionally recommend other side-channels to research. Different analysis expands on side-channel analysis by processing power-based approaches for Trojan detection, investigation different side-channel detection technique, Associate in Nursing characterizing the gate-level behaviors of an IC.

Trojan activation techniques conceive to trigger a Trojan circuit throughout Si style authentication to create the malicious behavior discernible or to enhance side-channel analysis techniques. A remarkable assumption is that attackers square measure probably to focus on the least-activated electronic equipment in Associate in Nursing IC, thus researchers have explored ways for generating inputs that activate Associate in Nursing IC wherever Trojan circuits square measure probably to be hidden. Different techniques conceive to explore the state area of the circuit in new ways in which, for instance, via organization or by partitioning the IC into regions during which square measures of the IC are isolated and so tested for Trojan activity.

The Si style authentication techniques square measure helpful for sleuthing the presence of malicious electronic equipment before deploying devices. Physical measures, like leak current or path delay, characterize chips and might expose anomalies which will indicate malicious logic. Usually, the characteristics underneath measure should be noted for a “golden” chip that's fancied firmly or supported the IC specifications and producing processes. Physical variations within the producing method make side-channel analysis probabilistic, and IC quality hinders activation techniques. Approaches that mix the 2 techniques seem to supply smart tradeoffs in terms of accuracy and price.

6.1.2.1 Style for Hardware Trust

Computer-aided style (CAD) and electronic style automation (EDA) tools square measure crucial to the potency and success of circuit design. These tools, however, neglect IC offer chain issues.

Design tools focus in the main on style for take a look at (DFT) or style for manufacturability (DFM). Researchers have projected that the look part be increased to enhance hardware trust, introducing the notion of style for hardware trust (DFHT). DFHT seeks to stop Trojan circuits from being introduced throughout style or fabrication.

Watermarking: Watermarking is a longtime technique for marking property specified counterfeit merchandise square measure observable; IC watermarking helps to detect counterfeit devices and science thieving. Data square measure embedded inside the IC style, therefore the factory-made product contains Associate in Nursing place able watermark that doesn't have an effect on the circuit's practicality. Effective watermarking needs that the watermark isn't simple to repeat.

Fingerprints, PUFs, and Metering-Building on the notion of watermarking, a tool fingerprint could be a distinctive feature of a style applied to a tool. Procedure improves on watermarking by

enabling tracing of transferred possession in order that when discovering a counterfeit device retaliatory measures are also taken.

IC metering extends device procedure to limit production and distribution of ICs. The goal of metering is to stop attackers from repeating a style and making cloned devices. Metering info is extracted from the IC via producing variability or PUFs and registered with the look company. Once Associate in Nursing IC is recovered and suspected of being pirated, it is checked against the registered ICs.

Verifying style and Fabrication-Much of the analysis in security for the IC offer chain focuses on the metalwork's as untrusted and so the most supply of IC offer chain attacks. 2 directions chase away on this assumption by supposing either the look part is additionally liable to attack or the metalwork's is semi-trusted.

As Associate in Nursing example of think about attacks on aspect of the provision chain and introduce tools that job along to observe malicious electronic equipment that's added at design time. The goal of those tools is to guard from viruses in style software package and from blemished third party science.

6.1.2.2 Study Techniques

In distinction to the look and verification techniques of the previous sections, study support for Si style authentication tries to stop or observe the malicious behavior of a Trojan circuit at run-time. One easy study answer is to live the IC's physical characteristics, very similar to in side-channel analysis, and so use those measurements on-line by planning circuits that report the measurements. Similarly, the well-studied fault-tolerant technique of replicating entire process parts will facilitate to observe some kinds of Trojan circuit attacks.

6.1.3 Hardware Support for Software Package Security

Software is a better target to attack. Compromised software package has however one goal: to abuse computing resources. Such abuse will take multiple forms, as well as corruption of essential code or information, thieving of sensitive information, and eavesdropping or collaborating in system activities. Despite the presence of malicious attacks, cyber-physical systems ought to be resilient and still operate properly.

A simple attack is to access Associate in nursing application's memory from another application. Code and information vulnerabilities tempt attackers to undertake gaining unchained access to execute malicious software package or to steal sensitive info. Ancient defenses against memory-based attacks isolate execution contexts - for instance, processes and virtual storage address areas - to stop one context from accessing another's code and information while not permission.

Even if we have a tendency to isolate each application in an exceedingly system and follow smart security practices (strong passwords, smart cryptography, physically secured hardware), attacks may still compromise system security by exploiting vulnerabilities inside the applications. Exploitable security vulnerability software

package application is program behavior that an assaulter will trigger to bypass the system's security policies. One such vulnerability, the buffer overflow, is wide considered the foremost usually exploited vulnerability. Smart programming practices - bounds checking, input validation - will stop exploitable vulnerabilities, however imposing such practices isn't perpetually simple. Software package solutions for buffer over-flow detection.

6.1.3.1 Memory Protection

Security policies outline however users of a computer system square measure allowed using, modifying, or sharing its resources. Historically, Associate in nursing software (OS) defines the protection policies and depends on hardware to help in imposing them.

Memory Protection in artifact Systems.

Consider Associate in Nursing abstract machine comprising 2 major components— the processor and memory. The processor fetches code and information from memory to execute programs. If each elements square measure shared by all programs then a program may corrupt or steal another's information in memory, accidentally or maliciously, or stop the other program from accessing the processor (denial-of-service). To avoid such situations, a privileged entity should management the allocation (time and space) of cipher resources (processor and memory). Traditionally, the operating system kernel is responsible for deciding how to allocate resources and hardware enforces the kernel's decisions by supporting different privilege stages or also known as rings/levels.

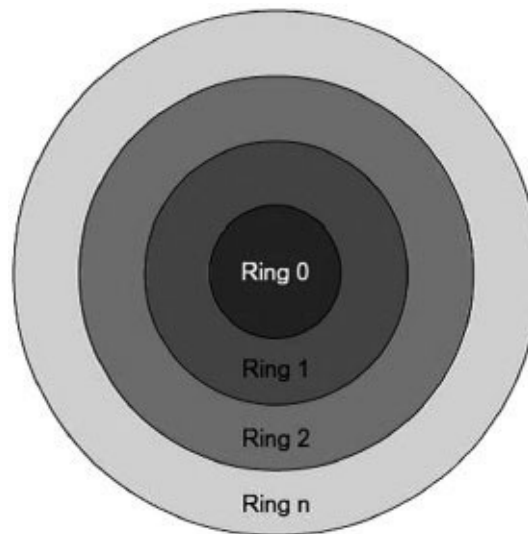


Figure 6.2

In this figure, the innermost ring is the highest privilege at which software can execute, normally used by the OS or hypervisor. The outermost ring is the lowest privilege, normally used by application software. The middle rings (if they exist) are architecture-specific and are often unused in practice

By occupying the highest privilege ring, the kernel controls all compute resources. It can read and write from any memory location, execute any instruction supported by the processor, receive all hardware events, and operate all peripherals. User applications - residing in the lowest privilege level - have limited access to memory, cannot execute privileged instructions, and can only access peripherals by invoking OS services. A processor differentiates between kernel and user with bits in a special register, generically

called the program status word and specifically called the Program Status Register in ARM architectures, Hypervisor State Bit in PowerPC architectures, Privileged Mode in the Processor State Register in SPARC architectures, or Current Privilege Level in the Code Segment Register in Intel architectures.

A hierarchy of control from the most to least privilege, combined with memory access controls, prevents user programs from performing any action outside a carefully sandboxed environment without invoking services in a more privileged level. Control transfer between different privilege rings usually is done with interrupts or specialized control instructions; on more recent Intel architectures, the `sysenter` and `sysexit` instructions allow fast switching during system calls. The OS controls the data structures and policies that control high-level security concepts like users and files, and code running outside the highest privileged ring cannot manipulate them directly. A critical aspect of securing highlevel code and data is memory protection.

6.1.4 Architectural Support for Control Flow Security

Vulnerabilities in software applications continue to be targets for memory-based attacks - or example buffer overflows - that attempt to gain illegitimate access to code and data.

6.1.4.1 Architectural Support for Buffer Overflow Defense

Hardware-assisted approaches to buffer overflow protection improve upon accuracy and performance of software-only schemes for dynamic attack detection by using a variety of techniques. One common solution is to maintain a shadow of the return address in hardware by creating a return address stack or monitoring the location of the return address for any unauthorized modifications. Other hardware-supported solutions protect all control flow in general, including branches and jumps.

Secure Return Address Stack (SRAS) implements a shadow stack in hardware with processor modifications including: ISA (Instruction Set Architecture) changes, additional logic, and protected storage. Unlike the usual call stack, the shadow stack only holds return addresses. On a function call (CALL), the return address is pushed to the regular stack and the shadow stack. On a return (RET), SRAS pops and compares the return address from both stacks. To handle function call nesting, the OS is modified to handle secure overflow storage. The spill-over of the secure stack is stored in a special part of memory that is accessible only to the kernel. The kernel is responsible for managing a secure spill-over stack for each process.

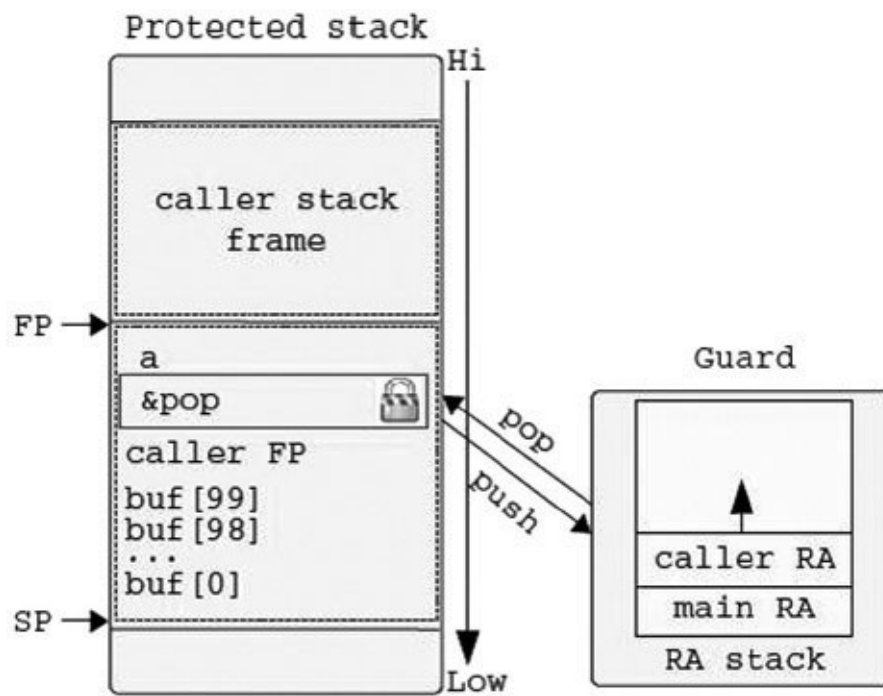


Figure 6.3: Stack memory protection moves (stores) the return address to protected storage when a function starts and then restores (checks) the return address before the function returns

6.1.4.2 Information Flow Tracking.

Vulnerabilities in code will be laborious to search out. Since attacks sometimes enter a system through input channels, researchers propose that rather than collateral code, systems ought to verify knowledge. Info flow following techniques monitor knowledge because it enters a system and prevents any probably damaging activity that uses untrusted input. Supported the supply of information, trust levels square measure related to the information. Simply put, knowledge comes from either “trusted” or “untrusted” sources. Looking on program linguistics, channels square measure caterpillar-tracked so as to see if untrusted data affects (taints) the trustworthy information, or the reverse, if trustworthy - sensitive or secure - knowledge leaks into untrusted info that may expose secrets to the insecure channels. Preventing sensitive knowledge from unseaworthy suggests that distinctive the communication channels, whether or not specific (direct variable assignments) or implicit (control flow, timing, cache content, power etc.), that the information will influence.

Traditional approaches to trace info flow through static and dynamic following have the disadvantage that simply many untrusted sources will taint trustworthy knowledge and cause most computations to become untrusted. Maintaining trustworthy execution in real systems that track taint with several input channels becomes very tough.

6.1.5 Secure Co processing

How will sensitive computations be dead in remote devices such the results obtained square measure trustworthy? Programs will be altered, knowledge will be changed, records and logs deleted, or secrets revealed. Simulators and debuggers provide mechanisms for perceptive memory content and execution patterns; memory will be frozen and read; in operation systems and compilers is also altered; and even the hardware would possibly harbor a Trojan circuit.

Designers of secure coprocessors argue that a system's root of trust has got to be a machine device that may execute its tasks properly and while not revealing secrets despite any attack. A fast, general purpose pc in a very tamper-proof physical enclosure would live up to, however that's laborious to attain. High-end processors consume lots of power and generate lots of warmth that's tough to dissipate in a very tamper-proof enclosure. Thus, secure coprocessors square measure restricted to low power, restricted information measure devices incapable of process at high turnout. [Figure 6.4](#) shows a secure coprocessor as a peripheral to a number pc.

The services that the coprocessor offers embrace guardianship of cryptographically keys, cryptographically operations, a secure

execution surroundings, and attestation of the host's execution state. A secure coprocessor ensures that a foreign device produces trustworthy results.

The enclosure of a secure coprocessor should deter a complicated assailant from getting any of the interior memory content. Fuses and sensors facilitate to see whether or not the physical enclosure has been broken. The same old response to associate degree attack is to erase all memory content. Since extreme temperatures may probably disable the erasure mechanisms and freeze memory content, designers add thermal sensors to notice such conditions. Alternative aspect channels might reveal the secure coprocessor's internal state. No particulate radiation is detected or prevented by the enclosure, however power and warmth dissipation stay a priority. Though a restricted internal power exists to make sure the erasure procedures, operational power is drawn from the host. To attenuate the chance for power analysis attacks, the coprocessor is supplied with filters on the facility provide. Well-designed shielding on the enclosure obfuscates the warmth signature.

The operational needs of the secure coprocessors square measure key management, communication, encoding services, internal resource management, and programmability. These needs square measure tough to implement with dedicated hardware alone. Most solutions go with a posh code stack composed of a secure kernel, hardware aided protection, resource partitioning, layers of operational services, and end-users applications.

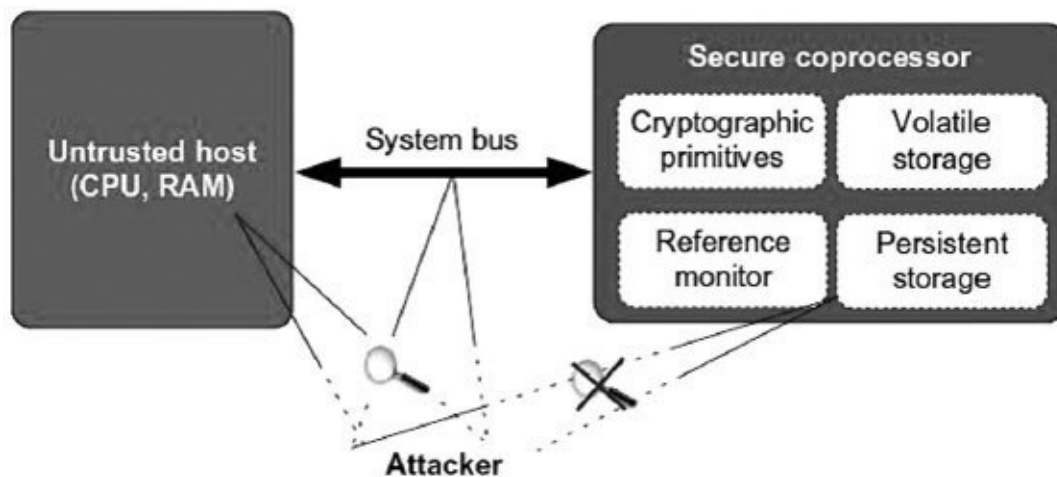


Figure 6.4

In this figure Secure co-processing relies on a tamper-proof coprocessor to provide security services to a host system. An attacker will not be able to examine the internals of the coprocessor, so secrets stored within are safe.

The power of secure coprocessors shows in their application use cases: host integrity validation, secure logs, audit trails, digital rights management (DRM), electronic currency, sandboxing, and attestation for remote agents.

Host integrity. Trust in a very system needs each tamper-proof hardware and privileged software system. With viruses, trojans, and malware masquerading in a very system, software system cannot simply prove itself authentic. If trust within the secure coprocessor

is established, then that trust allows authenticating the host. The secure coprocessor should management or verify the initial boot method of the host and take snapshots of the memory state. With this ability, the coprocessor will figure secure hashes of the boot and kernel pictures, as well as memory states at totally different milestones within the host execution. By comparison the secure hashes with known-good values, the secure coprocessor will notice memory corruptions.

Secure logs. Logs are a vital target for attackers. formation entries to eliminate intrusion traces is crucial for a hiding attack. With the help of a trustworthy coprocessor, logs are often created tamper-evident. Cryptologic checksums are the most mechanism, except for sensitive data, like monetary logs, secret writing primitives are often used for secrecy.

DRM. 2 key properties create secure coprocessors appealing in copyright protection applications. The primary is that the ability to attest that a bunch package is tamper-free, as well as the software system and commissioned applications. If associate degree wrongdoer (user) cannot circumvent the license validations, then industrial software system will faithfully check for proper registration procedures. Second are the trustworthy cryptologic primitives, as well as distinctive unforgettable identifiers. With these primitives, content suppliers will deliver encrypted content to the host, limiting the attacker's ability to get access to original digital content.

6.2 DATA STORAGE AND DOWNLOADABLE DEVICES

6.2.1 Knowledge Storage Security

Storage security deals with any variety of security round the storage design and also the knowledge keep thereon.

First we want to seem at why we want to be troubled with storage security, and there are 2 or 3 aspects to the present.

The first one is around regulation and also the legal frameworks that cowl knowledge retention and probably e-discovery. Within the Great Britain we've got to seem at e-discovery mandates, the info Protection Act, electronic health records etc. -- all of which could have mandates dictating knowledge needs to be retrieved at some stage and means that the means it's keep needs to be 100 percent managed by the organization.

6.2.2 The info Protection Act:

Appropriate technical and structure measures shall be taken against unauthorized or unlawful process of non-public knowledge and against the destruction or accidental loss or injury to, personal knowledge.

This is the seventh knowledge protection principle. In observe, it means that we tend to should have acceptable security to stop the non-public knowledge we tend to hold being accidentally or deliberately compromised. Above all, we are going to want to:

design and organize our security to suit the character of the non-public knowledge we tend to hold and also the damage which will result from a security breach;

be clear regarding United Nations agency in our organization is liable for making certain data security;

make certain we've got the correct physical and technical security, protected by strong policies and procedures and reliable, well-trained staff; and

be able to answer any breach of security fleetly and effectively.

There also are standards like PCI DSS (Payment Card trade knowledge Security Standard) and ISO 27001 that have needs for knowledge storage.

6.2.3 Necessity of data Security

Information security breaches could cause real damage and distress to the people they have an effect on - lives could even be place in danger. Samples of the damage caused by the loss or abuse of non-public knowledge (sometimes connected to identity fraud) include:

faux MasterCard transactions;

Witnesses in danger of physical damage or intimidation;

Offenders in danger from vigilantes;

Exposure of the addresses of service personnel, police and jail oficers, and girls in danger of domestic violence;

Faux applications for tax credits; and

Mortgage Fraud.

Not all security breaches have such grave consequences, of course. Several cause less serious embarrassment or inconvenience to the

people involved. People are entitled to be protected against this type of damage yet.

Advances in technology have enabled organizations to method additional and additional personal knowledge, and to share data additional simply. This has obvious edges if they're collection and sharing personal knowledge in accordance with the info protection principles, however it conjointly provides rise to equally obvious security risks. The additional databases that are established and also the additional data that's changed, the larger the danger that the data are lost, corrupted or exploited.

A number of high-profile losses of enormous amounts of non-public knowledge have brought attention to the problem of data security. However, these incidents have conjointly created it clear that data security is a difficulty of public concern yet as technical compliance. If personal knowledge isn't properly safeguarded, this may seriously injury associate degree organization's name and prosperity and may compromise the security of people.

6.2.4 What must be protected by data security arrangements?

It is necessary to know that the necessities of Protection Act transcend the means information is kept or transmitted. The seventh knowledge protection principle relates to the protection of each facet of your process of non-public knowledge.

So the security measures you place in situ ought to look for to confirm that:

Only licensed folks will access, alter, disclose or destroy personal data;

Those folks solely act among the scope of their authority; and

If personal knowledge is accidentally lost, altered or destroyed, it is often recovered to stop any injury or distress to the people involved.

6.2.5 What level of security is required?

The Act says you must have security that's acceptable to:

The character of the data in question; and

The damage that may result from its improper use, or from its accidental loss or destruction.

The Act doesn't outline “appropriate”. However it will say that associate degree assessment of the acceptable security measures in a very explicit case ought to take into account technological developments and also the prices concerned. The Act doesn't need you to possess progressive security technology to shield the non-public knowledge we tend to hold, however we must always often review our security arrangements as technology advances. As we've got aforesaid, there's no “one size fits all” resolution to data security, and also the level of security we elect ought to rely on the risks to our organization.

So, before deciding what data security measures we want to require, we are going to ought to assess our data risk: we must always review the non-public knowledge we tend to hold and also the means we tend to use it to assess however valuable, sensitive

or confidential it's, and what injury or distress can be caused to people if there have been a security breach.

This risk assessment ought to realize of things such as:

The nature and extent of your organization's premises and laptop systems;

The range of workers we tend to have;

The extent of their access to the non-public data; and

Personal knowledge control or employed by a 3rd party on your behalf

6.2.6 What reasonably security measures may well be appropriate?

The Data Protection Act doesn't outline the protection measures you must have in situ. However, explicit security needs that apply among explicit industries could impose sure standards or need specific measures. Generally terms, that security measures are acceptable can rely on your circumstances, however there are many areas you must concentrate on. Physical and technological security is probably going to be essential, however is unlikely to be spare of itself. Management and structure security measures are doubtless to be equally necessary in protective personal knowledge.

MANAGEMENT AND STRUCTURE MEASURES

Carrying out associate degree data risk assessment is associate degree example of associate degree structure security live, however we are going to most likely want alternative management and structure measures yet. We must always aim to make a culture of security and awareness among our organization.

Perhaps most significantly, its smart observe to spot someone or department in our organization with day-after-day responsibility for security measures. They must have the required authority and resources to fulfill this responsibility effectively.

Not each organization can want a proper data security policy - this may rely on things just like the size of the organization, the number and nature of the non-public knowledge it holds, and also the means it uses the info. Whether or not or not these matters are written into a proper policy, all organizations ought to be clear regarding them, and regarding connected matters like the following:

Co-ordination between key folks within the organization (for example, the protection manager can ought to comprehend commission and removing any IT equipment);

Access to premises or instrumentality given to anyone outside the organization (for example, for laptop maintenance) and also the further security issues this may generate;

Business continuity arrangements that establish a way to defend and recover any personal knowledge the organization holds; and

Periodic checks to conlrm that the organization's security measures stay acceptable and up thus far.

It is important that our workers perceive the importance of protective personal data; that they're at home with our organization's security policy; which they place its security

procedures into observe. Therefore we tend to should offer acceptable initial and refresher coaching, and this could cover:

Our organization's duties underneath the info Protection Act and restrictions on the utilization of non-public data;

The responsibilities of individual workers members for shielding personal knowledge, as well as the likelihood that they will commit criminal offences if they deliberately attempt to access, or to disclose, data while not authority;

The correct procedures to use to spot callers;

The dangers of individuals making an attempt to get personal knowledge by deception (for example, by deception to be the person whom data is regarding or by creating “phishing” attacks) or by persuading America to change information after we mustn't do so; and

Any restrictions our organization places on the non-public use of its computers by workers (to avoid, as an example, infection or spam).

The effectiveness of workers coaching depends on the people involved being reliable within the 1st place. Protection Act needs you to require cheap steps to confirm the dependableness of any

workers United Nations agency have access to private data.

PHYSICAL SECURITY

Technical security measures to shield processed data are of obvious importance. However, several security incidents relate to the thievery or loss of apparatus, or to previous computers or hard-copy records being abandoned.

Physical security includes things just like the quality of doors and locks, and whether or not premises are protected by alarms, security lighting or CCTV. However, it conjointly includes however we tend to management access to premises, supervise guests, get rid of paper waste, and keep moveable instrumentality secure.

COMPUTER SECURITY

Computer security is consistently evolving, and may be a complicated technical space. Looking on however subtle our systems are and also the technical experience of our workers, we tend to might have specialist information-security recommendation that goes on the far side the scope of this guide. We tend to ought to take into account the subsequent guiding principles once deciding the additional technical aspect of data security.

Our laptop security must be acceptable to the scale and use of our

organization's systems.

As noted on top of, we must always take under consideration technological developments, however we tend to also be entitled to contemplate prices once deciding what security measures to require.

Our security measures should be acceptable to our business practices. As an example, if we've got workers United Nations agency works from home, we must always place measures in situ to confirm that this doesn't compromise security.

The measures we tend to take should be acceptable to the character of the non-public knowledge we tend to hold and to the damage that would result from a security breach.

6.3 PHYSICAL SECURITY OF IT ASSETS

Without paying correct attention to the physical security of data quality our IT assets and infrastructure are invariably underneath security threats from proverbial or unknown sources or from accidental hazards. Associate degree IT security manager or designer invariably ought to pay equal or maybe additional attention to confirm that his all the data assets are physically secured. It's not necessary that everyone the physical security risk to that assets are often solely from physical forced the lock the IT server or assets area, however there are major risk associated with environmental risks like fireplace. To regulate the physical security of all IT assets we want to spot all the assets that you just take into account sensitive and necessary for our organization. The physical security of IT assets are often broadly speaking classified supported the subsequent criteria:

Security of quality Location

Human access management to the protection area

Environmental management

6.3.1 Security of quality location

The location of the data quality area ought to be physical secured. It's invariably an honest observation to not disclose the situation of our server area to public. The lesser folks comprehend the situation of our server area the higher. First of all, we want to create positive that there one entry to our server area as well as one staircase door. Secondly, the doorway of the gate mustn't be directly visible to the situation of our workplace wherever the bulk of the officers work. Thirdly, before the most gate there ought to be another little door or area to scale back the danger of piggy backing.

6.3.2 Human access management

Before coming into the server area all the non-public ought to be licensed to enter the room-there is often associate degree exception to the daily maintenance team. However it's higher to possess the presence of a supervisor once maintenance works are allotted. All the personals ought to be physically verified associate degree should carry a positive identification, if attainable implement digital access management or any biometric access management. The protection person before the access area should be gift invariably and that they there is also a pool of security guards United Nations agency are solely duty therefore as they'll be at home with the faces coming into the area on regular basis. Finally, there ought to be shut circuit camera each in and outdoors of the quality area and you wish to create positive the access to the digital recording devices are properly monitored and logged.

6.3.3 Environmental security management

We need to create positive that everyone the instrumentality put in within the server rooms are being auditor often. Make certain there are a minimum of two emergency power-off switches for the server area itself-one within and also the alternative outside the area. All the electrical wiring ought to be placed within fire-resistance panels and if there are any workplace table or cupboards, then use solely those equipment's made from fire-resistance materials. Any type of edible items like food, drinks etc. Intake must be strictly prohibited in the server area.

6.4 CLOSED-CIRCUIT TELEVISION (CCTV) AND INTRUSION DETECTION SYSTEMS

As a business owner or property manager, you have got to fret regarding each external and internal thievery. The performance of associate degree existing Closed-circuit television CCTV based mostly security package are often enriched considerably by incorporating a separate fence mounted Perimeter Intrusion Detection System (PIDS).

6.4.1 IDS (Intrusion Detection System)

Intrusion detection systems once properly designed offer a good safeguard for our website while not making gratuitous false alarms or difficult configurations. Associate degree intrusion detection system designed by bits per second (Business Protection Specialist) takes into thought not simply what assets ought to be protected however includes a careful analysis of total shopper want. The system might have to be integrated with a Video police investigation / CCTV closed-circuit television associate degreeed / or an access system.

BPS has designed everything from little complete intrusion detection systems to massive totally integrated systems needed to shield multiple facilities placed over massive areas. Bits per second intrusion detection system designers are all board certified which needs relevant security continued education credits thereby reassuring you of our familiarity with the newest technological data and trends.

6.4.2 Intrusion Detection System Principles

Intrusion detection systems will solely be effective once one considers the whole cycle of what ought to happen within the face of a security breach. Keys to effective intrusion detection include:

Deterrence

(High chance of detection (a perform of correct device choice and placement)

Local perceptible (i.e. horn or siren) that might serve to daunt unsophisticated burglars

Sufficient delay to stop burglars from accessing (and removing) vital assets before responders arrive

An adequate response force (i.e. armed law enforcement) to interrupt the burglars before the crime is complete.

If any of those measures are missing or inadequate in your intrusion detection system, you may suffer a loss in associate degree intrusion.

6.5 SECURITY MEASURES

Security measures mean the precaution measures taken toward attainable danger or injury. There are half dozen sorts of security measures.



Figure 6.5: *Security Measures*

1) DATA BACKUP

Data Backup could be a program of file duplication. Backups of information applications area unit necessary so they'll be recovered just in case of an emergency.

Depending on the importance of the data, daily, weekly or biweekly

backups from a tough disk may be performed.

2) CRYPTOGRAPHY

Cryptography could be a method of concealment data by sterilisation the particular data into completely different illustration, for instance, an APA may be written as I?

Almost all cryptosystems depend upon a key like a password just like the numbers or a phrase that may be wont to inscribe or decode a message.

The traditional form of cryptosystem used on a network is termed a bilaterally symmetrical secret key system.

3) ANTIVIRUS

An antivirus program protects a laptop against viruses by characteristic and removing any laptop viruses found within the store, on storage media or incoming e-mail files.

4) VIRUS IDENTIFICATION

Two techniques are widely used to determine or identifying the virus.

virus. virus. virus. virus.
virus. virus.

If an antivirus program identifies an infected file, it attempts to remove its virus, worm or Trojan horse. If the antivirus program cannot remove the infection, it often quarantines the infected file. Quarantine is a separate area of a stable storage that holds the infected file until the infection can be removed. This step ensures other files will not become infected. Patents for inventions utility, design or plant patents that protect inventions and improvements to existing inventions

4) ANTI-SPYWARE

Spyware may be a program placed on a pc while not the user's information. It in secret collects data concerning the user.

The spyware program communicates data to the surface supply.

An anti-spyware application someday referred to as pursuit computer code or a spybot is employed to get rid of spyware.

Among of the favoured anti-spyware programs are:

Spybot Search and Destroy

Ad-aware

Spyware Workman

5) FIREWALL

Firewall may be a piece of hardware or computer code that functions in an exceedingly networked setting to forestall some communications tabu by the safety policy. Firewall implements a security policy. It would allow restricted access from in or outside the network perimeters or from sure user or sure activities.

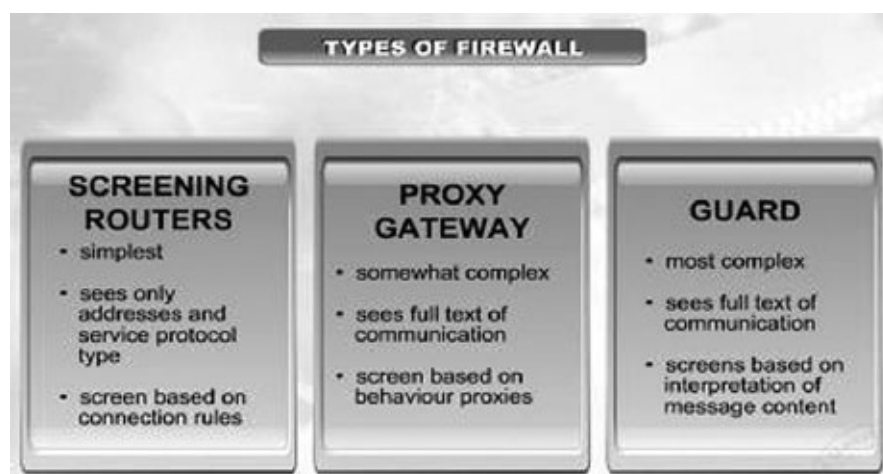


Figure 6.6: Types of Firewall

6) HUMAN ASPECTS OF SECURITY MEASURES

Human aspects visit the user and conjointly the entrant of an ADPS.

It is one among the toughest aspects to grant protection to.

The most common downside is that the lack of achieving a decent data security procedure.

6.5.1 Backup Security Measures

The average mortal ought to have a minimum of 3 levels of security measures in situ to guard their pc, pill and alternative electronic devices. Several unforeseen events will happen that end in knowledge loss. Whether or not that knowledge loss stems from file corruption, hardware failures, pc viruses, malware, hackers or natural disasters, it's simply a matter of your time before knowledge loss can occur. Knowledge loss isn't the sole risk of the shortage of pc security. Viruses and alternative malicious applications will steal your personal data resulting in fraud and alternative personal dilemmas.

File backup is one among the foremost necessary aspects of protection from knowledge loss. The general public that use computers have necessary stuff on their onerous drives which will be irreplaceable. Most don't even understand however necessary or precious that knowledge could also be till it's gone. Backups are often performed manually however that's not solely a careful method however are often forgotten. A decent backup program can ease the burden and backup the necessary files with very little or no work on your half when the initial setup.

Three Steps for a Solid Backup situation

Backups ought to be performed domestically to Associate in nursing external media like Associate in Nursing external drive or DVD.

Native backups have to be compelled to be keep far from the pc, ideally to a different location just in case of fireplace or flooding.

On-line backups ought to be performed on a daily basis therefore necessary files are often accessed from alternative devices notwithstanding the protected computer isn't any longer on the market

Computer security is another important and infrequently unmarked side of healthy computing. Virus protection computer code is that the best protection from viruses however there area unit such a big amount of additional security problems that virus computer code alone won't defend against that might simply create your computer quite good-for-nothing. A complete protection suite of security applications is that the counselled resolution for full protection. Whereas there area unit several programs on the market to accomplish total computer security, solely some area unit value mentioning. We'll explore and review the various backup and security programs and indicate the nice and also the dangerous of every application. It's up to you to determine that is that the correct resolution for your situation

6.6 ANSWER THE FOLLOWING QUESTIONS:

What are the aspects of hardware security?

What are the possible attacks on the IC supply chain?

Describe fabrication in terms of hardware security.

What is Trojan Circuit? How can we detect Trojan Circuits?

Give the techniques for Architectural Support for Buffer Overflow Defense.

How the results computation can be executed in remote devices?

What do you understand by the term Secure Co-processing?

What are the operational requirements of the secure coprocessors?

Explain the terms:

host integrity validation,

secure logs,

digital rights management (DRM)

Give the key points for the Data Protection Act.

Explain the necessity of information Security in real time data.

What are risk assessments should take account of factors for hardware security?

How can we decide which security measures will be appropriate?

Give a broad classification for physical security of IT assets.

Write a brief note on CCTV and Intrusion Detection System.

Give a detail description on precautionary measures taken toward possible danger or damage.

What are the steps for a Solid Backup Scenario?

Write a short note on Antivirus.

What are the guiding principles when one has to decide the more

technical side of information security?

How can we track Information flow?

Chapter-7

Security Policies

7.1 INTRODUCTION

In business, a security policy could be a document that states in writing an organization plans to safeguard the company's physical resources and knowledge technology assets. A security policy is commonly thought-about to be a “living document”, that means that the record isn't finished, but still is continually updated as technology and worker necessities amendment. A company's security policy could embrace a suitable use policy, an outline of however the corporate plans to coach its staff concerning protective the company's assets, a proof of however security measurements are meted out and enforced, and a procedure for evaluating the effectiveness of the protection policy to confirm that necessary corrections are to be taken care of.

Policies are a cluster of provisions or rules that are needed to line up into a path to a particular objective. Security policies ought to balance access and safety and minimizes the risk whereas not imposing undue access restrictions on individuals who would like access to particular resources.

Policies ought to define:

Scope - United Nations agency where the policy applies.

Actions outlined by the policy.

Defines final outlined actions are to be done.

Defines wherever or on what instrumentality the policy applies to.

Defines the structure level that the policy applies to like into a particular division or into the complete enterprise.

United Nations agency enforces the policy

What are the results of failure to follow the policy?

Policies could reference procedures that are used however don't outline the procedures. As an example the policy could specify that passwords should be changed each sixty days however not offer a procedure telling a way to change them.

7.1.1 Security Policy classes and kinds

Once we tend to have determined the worth of our information, we want to develop a group of policies to assist defend it. These policies are referred to as security policies and should apply to users, the IT department, and therefore the organization generally. Once writing your policies, consider:

What information could a user take home?

If a client doing work from domestic area or distant offices and uses the web to transmit information, however secure should the info be once in transmission across the internet?

What policies, network structure, and levels of defenses are needed to secure our information betting on its importance, price and therefore the value of defensive it?

The first things that ought to be outlined are the policies associated with the utilization and handling of your information. This can facilitate US to work out defensive measures and procedures. There are three classified policies into three totally different areas listed below:

User Policies - Outline what users will do once victimization our network or information and conjointly outline security settings that have an effect on users like word policies.

It Policies - outline the policies of the IIT department accustomed govern the network for max security and stability.

General Policies - High level policies process United Nations agency is chargeable for the policies at the side of business continuity coming up with and policies.

7.1.1.1 User Policies

Define what users will and should do to use our network and organization's pc instrumentality. It defines what limitations are placed on users to stay the network secure like whether or not they will install programs on their workstations, forms of programs they will use, and the way they will access information. Some policies include:

Password Policies - This policy is to assist keep user accounts secure. It Defines however typically users should amendment their passwords, however long they need to be, complexness rules (types of characters used like minuscule letters, upper-case letter letters, numbers, and special characters), and alternative things.

Proprietary info Use - Acceptable use of any proprietary info in hand by the corporate. Defines wherever it may be hold on and wherever it's going to be taken, however and wherever it may be transmitted.

Internet Usage - Use of net mail, Use of programs with passwords or unencrypted information sent over the web.

System Use - Program installation, No Instant electronic communication, No file sharing like Kazaa, Morpheus. Constraints

on the use of your account or word.

VPN and remote user system use (remote access) - should be checked for viruses/Trojans/backdoors.

Acceptable use of hardware like modems - No use of modems to net whiles not a private firewall.

7.1.1.2 IT Policies

These policies embrace general policies for the IT department that are supposed to stay the network secure and stable.

Virus incident and security incident - Intrusion detection, containment, and removal.

Prepare (policies, checklists/procedures)

establish (get evidence)

contain (pull off network, modify passwords)

eradicate (fix, confirm cause, improve defenses, take a look at for vulnerabilities)

recover (validate the system, monitor for re-infection)

lessons learned (make recommendations to stop an analogous incident)

Backup policy - outline what to keep a copy, United Nations agency backs it up, wherever its hold on, however long its hold on, a way

to take a look at backups, what program is employed to try to backups.

Client update policies - Update purchasers however typically and victimization what suggests that or tools.

Server configuration, patch update, and modification policies (security) - take away inessential services (harden server). What servers ought to have IDS? However is it determined to try {and do} an update? What's done once somebody works on the server?

Wirewall policies - What ports to dam or permit, a way to interface thereto or manage it, United Nations agency has access to the management console.

Wireless, VPN, router and switch security, dmz policy, email retention, automobile forwarded email policy, ability for IT to audit and do risk assessment, acceptable coding algorithms

7.1.1.3 General Policies

High level program policy - Defines United Nations agency owns alternative policies, United Nations agency is chargeable for them, scope and purpose of policies, any policy exceptions, connected documents or policies.

Business continuity set up - Includes the subsequent plans:

Crisis Management - What to try to throughout any) crisis which can threaten the organization.

Disaster Recovery - Sub functions:

Server recovery

Data recovery

End-user recovery

Phone system recovery

Emergency response set up

Workplace recovery

7.1.2 Policy Levels

Policies will exist on several levels of the organization from a gaggle or team level, to department level, plant level, or international structure level. Some policies could solely be effective on an area level whereas others could also be enterprise wide throughout the organization.

7.2 WHY CAN WE WOULD LIKE SECURITY POLICY?

7.2.1 Basic Purpose of Policy

A security policy ought to fulfill several functions. It should:

defend folks and knowledge

Set the principles for expected behavior by users, system directors, management, and security personnel

Authorize security personnel to watch, probe, and investigate

outline and authorize the results of violation

outline the corporate agreement baseline stance on security

facilitate minimize risk

facilitate track compliance with rules and legislation

Information security policies offer a framework for best apply that may be followed by all staff. They assist to confirm risk is decreased which any security incidents are effectively knowledgeable.

Information security policies will facilitate flip employees into participants within the company's efforts to secure its info assets, and therefore the method of developing these policies can facilitate to outline a company's info assets. Info security policy defines the organization's perspective to info, associated announces internally and outwardly that info is a quality, the property of the organization, and is to be shielded from unauthorized access, modification, disclosure, and destruction.

7.2.2 Policy and Legislative Compliance

In addition to the needs delineate on top of, security policies may be helpful in ways in which transcend the immediate protection of assets and policing of behavior. They will be helpful compliance tools, showing what the company's stance is on best apply problems which they need controls in situ to suits current and forthcoming legislation and rules.

In today's company world it's essential for corporations to be able to show compliance with current legislation and to be ready for forthcoming legislation. Recent laws like HIPAA (Health Insurance answerableness and movability Act), GLB (Gramm-Leach-Bliley Act) and Sarbanes Oxley have had major implications for policy manufacturers within the U.S. and farther a field. Policy may be accustomed facilitate corporations guarantee they need the controls in situ to figure towards compliance by mapping policy statements to legislative necessities. During this approach they will offer proof that their baseline security controls are in line with rules and legislation. This kind of stance will offer corporations a sign supported legal necessities of what they have to safeguard and to what extent. This can facilitate to confirm that they aim security controls solely wherever they're required, a get pleasure from each a money and personnel resourcing perspective.

7.2.3 Policies as Catalysts for amendment

It is conjointly doable to use policies to drive forward new company initiatives, with policy acting because the catalyst for future comes that move towards higher security and general practices. As an example, a policy stating that a particular style of coding is needed for sensitive info sent by email could (with previous consultation with the suitable technical experts) facilitate to market the requirement to develop such a capability within the future. The presence of this demand in policy has created positive the impetus to develop the e-mail coding project has remained robust.

In short, security policy ought to be a great tool for safeguarding the protection of the Enterprise, one thing that each one user will communicate in their daily work, as a guide and knowledge supply. Only too typically but, security policies will find yourself merely as “shelf ware”, very little browse, used, or maybe well-known of by users and disconnected from the remainder of company policy and security apply.

7.2.4 Policies should be possible

The key to making sure that your company's security policy is helpful and useable is to develop a collection of policy documents that match your audience and marry with existing company policies. Policies should be useable, possible and realistic. So as to realize this it's essential to involve and obtain buy-in from major players in policy development and support (such as senior management, audit and legal) additionally as from those people that can ought to use the policies as a part of the daily work (such as material specialists, system directors and finish users). so as to realize this, one vital component is to speak the importance and utility of policies to people who ought to live by them. Typically users appear to suppose that policy is a few things that are getting to sub the approach of their daily work. A vital component of policy development, and to confirm policies are place into apply and not rejected by the users, is to convey the message that policies are helpful to users: to produce a framework among that they will work, a reference for best apply and to confirm users suits legal necessities. Once users notice that policy are a few things that will really facilitate them as they are doing concerning their work, they're rather more possible to be receptive to each serving to you develop it and living up thereto to confirm compliance. Similarly, once senior management notice that policy could be a tool they will leverage to assist guarantee adherence to legislative necessities and to maneuver forward abundant required new initiatives, they're

rather more possible to be collateral of policy in terms of monetary and resourcing support additionally as changing into policy champions themselves.

7.3 SECURITY POLICY DEVELOPMENT

The following section lists further things to stay in mind as you tackle the protection policy beast.

Develop policies that you just commit to enforce. A policy that we tend to be unable or unwilling to enforce is useless. If our policy states that net usage is strictly restricted to conduct business-related tasks, however we tend to not block web site access or have the aptitude to watch associate employee's net activity, we should always do away with the policy. A a lot of affordable approach may be to state in your policy that non-public usage of the web ought to be restricted to breaks or lunch hours or to state that net usage is allowed as long because it doesn't interfere with worker productivity or meeting deadlines. Some net filtering and watching tools (discussed later) permit you to limit or permit access supported time of day. As an example, staff may be allowed to buy on the web over their lunch hour per our policy. If so, these sites may be created accessible throughout now however restricted throughout all alternative hours.

Explain the aim of the policy. Policies ought to be developed with specific objectives in mind. Take care to clarify the requirement for the policy and specify what the policy is attempting to accomplish.

Some policy development pointers counsel a format that features a background section additionally to the particular policy statement. If we tend to cannot make a case for why the policy exists, we tend to cannot expect our staff to grasp it or follow it. Get eliminate it.

Develop security policies that don't need updates too often. If our policies need frequent updates, they're in all probability too restrictive or too specific. As an example, if we've got a desktop software package policy that states that "All desktops are deployed with a Windows National Trust four. o operative system" we might ought to update the policy as newer operative systems were discharged, like Windows 2000 and Windows XP, and therefore the older ones become unavailable. During this example, a policy that states, "All desktops are deployed with a secure, company-standard operative system" would permit a lot of flexibility.

Differentiate between policies and standards or recommendations. Your policies ought to be comprehensive and thorough however shouldn't be thus specific or elaborated that what you actually find yourself with could be a set of best practices or recommendations rather than policies. Begin with a high-level policy statement so drill all the way down to a lot of actual specifications victimization standards and suggested ways that to suits the policy. As an example, we tend to might have a policy that states, "All information transmissions sent over associate open network should be encrypted". Our company customary could specify that 128-bit coding is needed as a minimum coding level. Our suggested coding answer may be triple DES or AES. The key factor to

recollect is that as minimum coding key lengths amendment or the coding rule we tend to like changes, your base policy ought not to amendment.

Don't develop your policies in an exceedingly vacuum. Since our security policies can apply to all or any staff across the corporate, it's a decent plan to incorporate staff from alternative departments in their development. Embrace a minimum of one representative from every business unit in our policy development efforts. At a minimum, embrace a cross section of alternative staff within the policy review method. These people might imagine of one thing that we tend to failed to embrace and can offer feedback on whether or not or not the policy is straightforward to grasp.

Create your security policies accessible to everybody. We are able to have the most effective policies ever written, however if our staff ne'er see them or don't grasp wherever to search out them, they'll ne'er be effective. Also, if they solely see them at new rent orientation, don't expect them to recollect and follow them. Policy distribution may be accomplished through some ways. Some package tools permit US to post policies on our company computer network. We tend to might continually place a read-only copy of our policies out on our network in an exceedingly publically accessible directory. A whole text of the policies may be distributed at worker orientation and re-distributed on a periodic basis. Certify your policies keep current. Whereas it's true that policies ought to be developed in an exceedingly approach that they ought to not be perpetually updated, they can't last forever while not some

modifications. If we tend to don't have associate existing policy on wireless communication and positively on net usage, our policies are in desperate would like of a refresh. Commit to review our policies on associate annual basis and really schedule the review. A decent time to conduct this review may be at the tip or the start of our yr.

Certify your policies are understood. Develop policies that are simple and not too difficult. If staff cannot perceive what the policy needs, they can't be expected to follow them. A policy that's too long or complicated can possibly ne'er be browse and positively won't be followed. Some package tools permit US to incorporate easy quizzes with our policies to check associate employee understands of the policy. Review our security policies with new staff at orientation at encourage queries from them on something that's not fully clear.

Need acknowledgement of your policies. Always, always, continually embrace associate acknowledge statement with our policies and need that staff sign it. The acknowledgement statement ought to specify that the worker has received a duplicate of the policies that they need browse the policies, which they conform to abide by the policies. Take care that this signed acknowledgement type is preserved in their worker file which it may be retrieved if required. Also, certify that everybody within the organization has signed associate acknowledgement type. No worker, despite their position, ought to be excluded from following the policies.

Embrace your policies as a part of your security awareness coaching. Commit to embrace a minimum of one policy to be reviewed as a part of our periodic security awareness coaching. This will be accomplished in many alternative ways that. Reminders may be enclosed as a part of any classroom-style coaching. E-mail messages may be sent out on an everyday basis. Banner messages that seem throughout login might contain a policy of the month reminder. The secret is to lift awareness of our policies on a routine basis and use a mix of ways to stay a recent approach that staff can notice.

Confirm up front what's needed to form a policy “official”. Policies that apply to the complete company usually need approval from multiple levels among the organization. Certify you recognize precisely what's needed to form a policy active and United Nations agency should approve it. The number of your time it takes to urge policies approved and deployed may be vital in some organizations. If we tend to add a foreign web site or are a smaller a part of an oversized company, verify too soon if international policies exist already or if they need to “come down from Corporate”.

Certify your legal department is concerned. Since our security policies are extraordinarily vital to protective our organization and since failure to follow the policies might cause severe injury to the corporation and loss of employment to the worker, certify that we

tend to acquire our legal department's review and approval of all policies. Failure to get this approval might end in making legal problems for the corporate.

Persist with security topics for security policies. Security policies solely form up one a part of associate organization's total policies. If our assignment is to develop security policies, avoid attempting to incorporate policies that basically ought to come back from alternative areas. Examples embrace human resource policies, acquisition policies, or accounting policies.

7.4 EMAIL SECURITY POLICIES

7.4.1 Why study E-mail security?

After internet browsing, e-mail is that the most generally used network-reliant application.

Mail servers, once internet servers, are the foremost typically attacked net hosts.

Basic e-mail offers very little security, counter to public perception.

Good technical solutions are accessible, however not wide used.

If we tend to perceive why this is often thus, we'd perceive one thing concerning why security is 'hard'.

7.4.2 Threats to E-mail

a) Loss of confidentiality:

E-mails are sent in clear over open networks.

E-mails hold on probably insecure purchasers and mail servers.

b) Loss of integrity:

No integrity protection on e-mails; anybody can be altered in transit or on mail server.

c) Lack of knowledge origin authentication:

Is this e-mail really from the person named within the From: field?

d) Lack of non-repudiation:

Can I swear and act on the content? (integrity)

If so, will the sender later deny having sent it? United Nations agency is liable if I even have acted?

e) Lack of notification of receipt:

Has the supposed recipient received my e-mail and acted on it?

A message erroneously marked as 'sent' might not have been delivered.

7.4.3 Why does one would like associate Email Policy?

Here are 5 reasons why your company desires associate email policy:

Defend against email threats: associate email policy helps stop email threats. A well ordered out email policy makes your employees aware to the company rules and pointers, that if followed can defend your company against (spear) phishing attacks and confidentiality leaks, aid deference and minimize legal liability.

Avoid misconduct: associate email policy will facilitate stop associate misconduct at an early stage, by asking staff to come back forward as presently as they receive an offensive email. Keeping the incidents to a minimum will facilitate avoid legal liability. As an example within the case of Morgan Stanley, the court dominated that one e-mail communication cannot produce a hostile work setting and discharged the case against them.

Cut back liability: If an event will occur, associate email policy will minimize the company's liability for the employee's actions. Previous cases have proved that the existence of associate email policy will prove that the corporate has taken steps to stop

inappropriate use of the e-mail system and thus may be freed of liability. WorldCom firm. As an example, two-faced a court case from 2 former staff for permitting four racially offensive jokes on its email system. WorldCom with success defended themselves as a result of that they had associate email policy that spelled out inappropriate content and since they took prompt remedial action against the associate United Nations agency sent the racially harassing e-mails.

Educate Email Etiquette: we are able to use our email policy to coach your staff in email prescript to confirm that our company conveys an expert image in its email communications.

Warn staff of email monitoring: If we tend to are getting to use email filtering package to ascertain the contents of our employees' emails, it's essential to own associate email policy that warns our staff that their emails may be monitored. If we tend to don't have like policy we tend to may be responsible for privacy infringement. A lot of concerning the lawfulness of email watching.

7.4.4 E-MAIL POLICY

The purpose of this email policy is the right use of company's email system and makes users aware to what company deems as acceptable and unacceptable use of its email system. The corporate reserves the correct to amend this policy at its discretion. Just in case of amendments, users are well-read fittingly.

Revision History

Version	Date	Comments

Legal Risks

If we tend to send or forward emails with any harmful, defamatory, offensive, racist or obscene remarks, you and therefore the company may be control liable.

If we tend to unlawfully forward tip, we tend to and therefore the company may be control liable.

If we tend to unlawfully forward or copy messages while not permission, we tend to and therefore the company may be control

accountable for violation.

If we tend to send an attachment that contains a pandemic, we tend to and therefore the company may be control liable.

Legal needs

The following rules area unit to be strictly adhered to. It's prohibited to:

Send or forward emails containing harmful, defamatory, offensive, racist or obscene remarks. If we tend to receive AN email of this nature, we tend to should promptly advise our supervisor.

Forward a message with sensitive data while not getting permission from the sender initial.

Send unsought email messages.

Send email messages mistreatment another person's email account.

Copy a message or attachment happiness to a different user while not permission of the mastermind.

Staying Safe

Beware of viruses:

Do not click on any links or open any attachments of unsought or suspicious wanting emails. These messages may infect your pc with a pandemic.

Beware of phishing:

If we tend to receive AN email from a bank or the other establishment, asking U.S. to click on a link and update our details, don't CLICK on the link. don't be fooled if the sender seems to possess a number of our personal details. This data may be obtained through Facebook, Linked-in and alternative social media websites. Instead, visit the corporate web site by typewriting within the universal resource locator in an exceedingly application program, or decision the corporate.

Best Practices

Company considers email as a crucial suggests that of communication and acknowledges the importance of correct email content in transfer knowledgeable image. Users ought to take constant care in drafting AN email as they might for the other communication. So the corporate desires users to stick to the subsequent email guidelines:

Writing emails:

Write well-structured emails and use short, descriptive subjects.

Company's email vogue is informal. This implies that sentences may be short and to the purpose. We will begin our email with 'Hi', or 'Dear', and therefore the name of the person. Messages may be terminated with 'Best Regards'. the utilization of web abbreviations and characters like smileys but, isn't inspired.

Signatures should embody our name, job title and name. A disclaimer are going to be adscititious beneath our signature.

Users should spell check all mails before transmission.

Do not send supernumerary attachments. Compress attachments larger than five MB before causing them.

If we'd like to send files of over ten MB, don't send these via email; contact our Administrator to search out alternate ways for causing the files.

Do not write emails in capitals.

Do not use cc: or bcc: fields to send a mailing to multiple recipients. Instead, use company selected mail merge software system.

Only send emails of that the content may well be displayed on a public bulletin board. If they can not be displayed publically in their current state, take into account revising the e-mail, mistreatment alternative suggests that of communication, or protective data by employing a watchword (see confidential).

Only mark emails as necessary if they very area unit necessary.

Newsgroups:

Users got to request permission from their supervisor before subscribing to a write up or news cluster.

Maintenance:

Delete any email messages that we tend to don't got to have a replica of, and set our email shopper to mechanically empty your 'deleted items' on closing.

Personal Use

Although the company's email system is supposed for business use, [COMPANY] permits restricted personal usage if it's cheap and doesn't interfere with work. But the causing of chain letters, junk mail, jokes and executables is prohibited. All messages distributed via the company's email system area unit company property.

Confidential Data

Do not send mastercard details, social insurance numbers, or alternative tip via email. If we'd like to send tip, refer to our supervisor for safe ways.

Passwords

Use a mix of words, numbers and special characters for passwords. All passwords should be created familiar to the corporate. The utilization of passwords to realize access to the pc system or to secure specific files doesn't give users with AN expectation of privacy within the individual system or document.

Encryption

Users might not write any emails while not getting written permission from their supervisor. If approved, the encoding key(s) should be created familiar to the corporate.

Email Retention

For email retention tips, talk over with the company's email retention policy.

Email Accounts

All email accounts maintained on our email systems area unit property of the corporate. Passwords mustn't be to others and will be modified once a month. Email accounts not used for sixty days are going to be deactivated and probably deleted.

System Watching

Users expressly waive any right of privacy in something they produce, store, send or receive on the company's ADPS. The corporate will, however isn't obligated to, monitor emails while not previous notification. If there's proof that you just don't seem to be adhering to the rules taken off during this policy, the corporate reserves the correct to require disciplinary action, together with termination and/or action.

Disclaimer

The following disclaimer are going to be adscititious to every

outgoing email:

'This email and any files transmitted with it are unit confidential and supposed solely for the utilization of the individual or entity to whom they're addressed. If we've got received this email in error please advise the system manager. Please note that any views or opinions bestowed during this email are unit alone those of the author and don't essentially represent those of the corporate. Finally, the recipient ought to check this email and any attachments for the presence of viruses. The corporate accepts no liability for any harm caused by any virus transmitted by this email.'

QUESTIONS

If you have got any queries or comments regarding this Email Policy, please contact [NAME], [TEL], [EMAIL]. If {you do|you are unit doing} not have any queries [COMPANY] presumes that you just perceive and are attentive to the foundations and tips during this Email Policy and can adhere to them.

7.5 POLICY REVIEW METHOD

Much has been manufactured from procedure writing, however little is claimed regarding AN equally necessary a part of style and development — the policy review method. Several issues with procedures that turn up once they've been enforced area unit traceable to inadequate or no review.

Let's say a procedure as written describes a perfect method, performed beneath ideal conditions. If this isn't caught within the policy review method, the top product can meet needs solely through luck. Luck being notoriously unreliable, inconsistent, and uncontrollable, we're clearly more contented with a policy review.

7.5.1 An efficient Policy Review method

Why will we review anything? Certain|to confirm} the accuracy and completeness of no matter it's we're reviewing and to create sure everybody has constant understanding of the policy, process, or scenario. In short, to make sure effective communication, this can lead we tend to the required outcome. Effective communication could be a huge reason why the international quality normal, ISO 9001, mandates style and development reviews. If we tend to don't review, we tend to risk missing any range of product needs, each expressed and un verbalized, and that we risk losing customers.

Need one more reason to review policies and procedures? Nobody is ideal and no method is ideal. Nobody can write the proper procedure the primary time, every time.

7.5.2 Policy Review Objectives

With the policy review method, begin with objectives or needs. Were they clearly communicated to the technical writer? Did he/she perceive them? Do you? Were the objectives prioritized and categorized? Were they sensible objectives?

7.5.3 Policy Achieved?

Did the technical author bring home the bacon the expressed policy objectives/ requirements?

Also, list some necessary, nevertheless unverbilized, review objectives. For instance, correct writing system and smart synchronic linguistics area unit usually taken with a pinch of salt. Don't create that mistake. Frame a Seven C's list for sometimes unmarked things, like "Are necessary terms defined?" and "Is 'active voice' used?"

Did the school author transcend the expressed objectives? For example:

The procedure mentions a packaging machine that a first-time reader might not be conversant in. The school author includes an extended shot (photo) of the machine and a close-up of the panel. The photographs aren't a requirement; moreover, they (and further photos) push the document on the far side the expressed demand of "six pages, maximum".

7.5.4 Policy Review Feedback

In our policy review method, whether or not written or oral, take care to guide with those aspects of the procedure wherever objectives were met or exceeded. If important procedure review objectives weren't, take into account attainable explanations for that (the writer's level of expertise, competitive comes, the number of knowledge provided them, clarity of the objectives, etc.).

The point isn't to let the author “off the hook”. It's regarding encouraging the author - laudatory what they did well and asking them to try and do higher. Tell them, “Here's what you probably did well.”

Don't be obscure or hypocritical, either. Don't fish for compliments — we're not serving to them by telling them that their capitalization was nice, or that they had all the commas within the right places.

7.5.5 Procedure Flow

Tell the author precisely what we tend to see within the procedure (ex., can the reader understand who's imagined to do what, when, and why?) tell the review objectives and indicate that were met, that were exceeded, and that weren't met. Use a numeric scale in our review.

Beyond that, will the procedure “flow”? Did they use the PDCA model correctly? Did she or he use words, voice, style, grammar, etc., effectively? will the story - and therefore the message - stumble upon clearly?

Tell them what they did well and signifies specific opportunities for improvement. Hand the document back to them with another objective: you wish the revision back for a “final” review by a particular date.

Remember that the policy review method is AN integral a part of a style and development method. Once you've reviewed the document, the author can most likely ought to create some changes. Once the author has revised the policy procedure document, review it once more for errors.

As a reviewer, you're obligated to:

Be certain that expressed and un verbalized objectives were met;

Be fair;

Be consistent;

Be thorough; and

Point out strengths and opportunities for improvement within the document and within the method.

7.6 CORPORATE POLICY

Corporate policy could be a formal declaration of the guiding principles and procedures by that a corporation can operate usually established by its board of administrators or a senior management policy committee. Imbedded in company policy are the company's mission statement, objectives and also the principles by that strategic selections are to be created. It additionally forms the premise for measurement performance and making certain irresponsibleness the least bit levels of the corporate.

7.6.1 Policy Development & Consultation Process

ISSUE IDENTIFICATION

We take into account whether or not existing policies are adequate, or if new policies ought to be developed. Some indicators that a review is important are: identification of problems by stakeholders or employees, results of a review or compliance with amended legislation.

RESEARCH AND ANALYSIS

Once a difficulty is known, the analysis and analysis part begins. counting on the quality of the problem, analysis would possibly embody Associate in Nursing inter-jurisdictional comparison or asking knowledgeable consultants for info and recommendation. Supported the analysis results, the administrator develops Associate in Nursing analysis and determines the suitable action to deal with the problem.

POLICY DEVELOPMENT/AMENDMENT

In developing policy, administrator ensures that new or changed policy complies with the legislative needs of the Workers'

Compensation Act and takes into thought the interests of staff, the interests of employers, and neutral feedback.

STAKEHOLDER CONSULTATION

The Board of administrators and its Policy Committee verify the requirement for and nature of consultation.

Stakeholder consultation unremarkably includes public consultation, however could embody, or consist solely of, knowledgeable consultation. As well, counting on the character of the problem, administrator could convene Associate in Nursing in-person meeting.

When the analysis and analysis stage indicates a requirement for Stage one consultation, administrator develops a broad approach to a reversal and this policy construct is announce on the web site for sixty days to change neutral input on the projected approach. Unless there's a call to not proceed, a Stage one Consultation sometimes leads to policy drafting and also the policy draft are going to be announce as a part of a Stage a pair of Consultation.

For Stage a pair of consultation, administrator develops a draft policy that is distributed to the Policy Committee of the Board of administrators for approval to post the draft for consultation. Once the Policy Committee has completed its review, the draft policy is announce on the administrator web site for sixty days. The aim of

this second stage posting is to supply advance notice and look for neutral input.

NO CONSULTATION

Consultation isn't undertaken for policy changes that are:

Inconsequential, that refers to policy amendments that don't have an effect on the rights or responsibilities of either slashed staff or employers; or

Legal imperatives, that refers to policy amendments within which the assembly or justice system has directed that a modification in policy, be made.

As well, consultation isn't unremarkably undertaken for problems that have already been the topic of a previous consultation.

POLICY APPROVAL AND IMPLEMENTATION

The Board of administrators determines administrator policy and approves all new policies and substantive policy changes. The Board of administrators has delegated authority to Strategic Management Council (SMC) for approval of inconsequential amendments. Inconsequential changes approved by SMC are sent to the Policy Committee of the Board of administrators and also

the Board of administrators for info.

PROCESS OR PROCEDURAL CHANGE/CLARIFICATION

At times, analysis and analysis could show that method or procedures need change or clarification.

PROCESS/PROCEDURE APPROVAL AND IMPLEMENTATION

Process and procedure changes are approved and enforced.

7.6.2 Company Privacy & Security Policy Examples

Corporate businesses have Associate in nursing obligation to guard the privacy of all staff and guarantee their personal security on the task. In public listed corporations may have the benefit of putt policies in situ to guard their own non-public info and assets. Firms develop comprehensive privacy and security policies to befits legal statutes, shield their staff and secure their competitive secrets from prying eyes.

7.6.2.1 Personal info

Companies collect and store a large vary of sensitive info regarding their staff from varied sources. Job applications will embody Social Security numbers, for instance, and on-line resume submissions typically contain phone numbers and addresses. Direct-deposit authorization forms contain checking account numbers, as another example.

Restricting access to sensitive personal info to atiny low range of human resources personnel is Associate in Nursing example of a standard security policy for shielding sensitive personal info. Storing personal info in latched filing cupboards and encrypting all hold on emails also are prime examples.

7.6.2.2 Nondisclosure Policies

Companies place policies in situ to guard themselves from employees' indiscretions. staff World Health Organization leave their jobs could use company secrets to achieve the leverage required for securing the next paying job with a competitor; former staff may additionally leak secrets to unscrupulous news reporters or compromise the corporate in any range of alternative ways in which.

Nondisclosure clauses engaged contracts ar Associate in Nursing example of a policy designed to stay company info from spreading outside the workplace. proscribing access to the foremost sensitive info to satiny low range of superior staff is another example.

7.6.2.3 Physical Security

Physical security measures and policies keep staff safe whereas protective valuable company assets like inventory, money and vehicles. Physical safeguards are only once paired with clear and comprehensive policies governing their usage. Putting in video police work in inventory storage areas, for instance, is simpler once paired with policies that need managers to review security tapes on a random basis every week.

Additional samples of physical security policies embody checking ID badges at building entrances and distributing parking passes to staff for straightforward identification of vehicles that ought to not be there.

7.6.2.4 Info Security

Information security policies are even as vital as physical safeguards for company businesses that have internal networks connected to the net. Hackers and knowledge thieves will use laptop networks as back doors for locating company secrets, monetary knowledge and sensitive worker info, or they'll launch cyber attacks entirely supposed to disrupt the flow of business.

Requiring all sensitive info to be hold on servers not connected to the net is Associate in Nursing example of Associate in Nursing info security policy. Requiring all staff to put in antivirus and firewall software system on their laptops before connecting to the corporate network is another example.

7.7 SAMPLE EXAMPLE OF CYBER SECURITY POLICY

7.7.1 Introduction

This Cyber Security Policy could be a formal set of rules by that those who square measure given access to company technology and knowledge assets should abide.

The Cyber Security Policy serves many functions. The most purpose is to tell company users: staff, contractors and alternative approved users of their obligatory necessities for shielding the technology and knowledge assets of the corporate. The Cyber Security Policy describes the technology and knowledge assets that we tend to should defend and identifies several of the threats to those assets.

The Cyber Security Policy conjointly describes the user's responsibilities and privileges. What's thought-about acceptable use? What square measure the foundations concerning net access? The policy answers these queries, describes user limitations and informs users there'll be penalties for violation of the policy. This document conjointly contains procedures for responding to incidents that threaten the protection of the corporate pc systems and network.

7.7.2 WHAT we tend to square measure protective

It is the duty of all users of the corporate systems to safeguard the technology and knowledge assets of the corporate. This info should be protected against unauthorized access, thieving and destruction. The technology and knowledge assets of the corporate square measure created from the subsequent components:

Computer hardware, CPU, disc, Email, web, application servers, PC systems, application package, system package, etc.

System package including: in operation systems, direction systems, and backup and restore package, communications protocols, so forth.

Application Software: utilized by the varied departments at intervals the corporate. This includes custom written package applications, and business off the shelf package packages.

Communications Network hardware and package including: routers, routing tables, hubs, modems, multiplexers, switches, firewalls, non-public lines, and associated network management package and tools.

7.7.2.1 Classification of knowledge

User info found in automatic data processing system files and (computer files full of information) will be classified as either private or non-private. The (related to big business) will classify the knowledge controlled by them. The (company designee) is needed to review and approve the classification of the knowledge and confirm the good level of security to best defend it. More than that, the (company designee) will classify info controlled by units not given/gave by a (company designee).

7.7.2.2 Classification of Computer Systems

Systems

Systems Systems Systems Systems Systems Systems Systems Systems
Systems Systems Systems Systems Systems Systems Systems Systems
Systems Systems Systems Systems Systems

Systems Systems Systems Systems Systems Systems Systems Systems
Systems Systems Systems Systems Systems Systems Systems Systems
Systems

Systems Systems Systems Systems Systems Systems Systems Systems
Systems Systems Systems Systems Systems Systems

Systems Systems Systems Systems Systems Systems Systems

7.7.2.3 Local Area Network (LAN) Classifications

A LAN will be classified by the systems directly connected to it. For example, if a LAN contains just one RED system and all network users will be subject to the same restrictions as RED systems users. A LAN will assume the Security Classification of the highest level systems attached to it.

7.7.3 DEFINITIONS

Externally (easy to get to, use, or understand) to public. The system may be accessed via the Internet by people outside of the company without a logon animal desires or password. The system may be accessed via dial-up connection without providing a logon animal desires or password. It is possible to “message” the system from the Internet. The system may or may not be behind a firewall. A public Web Server is an example of this type of system.

Non-Public, Externally (easy to get to, use, or understand). Users of the system must have a valid logon animal desires and password. The system must have at least one level of firewall protection between its network and the Internet. The system may be accessed via the Internet or the private Intranet. A private FTP server used to exchange files with business partners is an example of this type of system.

Internally (easy to get to, use, or understand) only. Users of the system must have a valid logon animal desires and password. The system must have at least two levels of firewall protection between its network and the Internet. The system is not visible to Internet users. It may have a private Internet (non-translated) address and it does not respond to a “message” from the Internet. A private intranet Web Server is an example of this type of system.

Chief Information Officer. The Director of the Department of Information Technology (IT) shall serve as the Chief Information Officer.

Security Administrator. An employee of IT shall be designated as the Security Administrator for the company.

7.7.4 Threats to Security

7.7.4.1 Employees

One of the biggest security threats is workers. They may do damage to your systems either through (inability to do something) or on purpose. You have to layer your security to make up for that also. You lessen (something bad) this by doing the following.

- Only give out appropriate rights to systems. Limit access to only business hours.
- Don't share accounts to access systems. Never share your login information with co-workers.
- When workers are separated or controlled/punished, you remove or limit access to systems.
- Advanced - Keep described/explained system logs on all computer activity.
- Physically secure computer valuable things, so that only staff with appropriate need can access.

7.7.4.2 Amateur Hackers and Vandals

These people are the most common type of attackers on the Internet. The chance of attack is very high and there is also likely to be a large number of attacks. These are usually crimes of opportunity. These inexperienced person computer criminals are scanning the Internet and looking for well-known security holes that have not been plugged. Web servers and electronic mail are their favorite targets. Once they find a weakness they will fully use (for profit) it to plant viruses, Trojan horses, or use the useful things/valuable supplies of your system for their own means. If they do not find an obvious weakness they are likely to move on to an easier target.

7.7.4.3 Criminal Hackers and Saboteurs

The chance of this type of attack is low, but not completely unlikely given the amount of sensitive information contained in (computer files full of information). The skill of these attackers is medium to high as they are likely to be trained in the use of the latest computer criminal-related tools. The attacks are well planned and are based on any weaknesses discovered that will allow a (solid, secure place to start winning or gaining power) into the network.

7.7.4.4 User Responsibilities

This section establishes usage policy for the computer systems, networks and information useful things/valuable supplies of the office. It has to do with all workers and contractors who use the computer systems, networks, and information useful things/valuable supplies as business partners, and people who are granted access to the network for the business purposes of the company.

7.7.4.5 Acceptable Use

User accounts on company computer systems are to be used only for business of the company and not to be used for personal activities. Unauthorized use of the system may be in violation of the law, makes up/is equal to theft and can be punishable by law. Therefore, unauthorized use of the company figuring out/calculating system and facilities may make up/be equal to grounds for either civil or criminal prosecution.

Users are personally responsible for protecting all private information used and/ or stored on their accounts. This includes their logon IDs and passwords. Furthermore they are prohibited from making unauthorized copies of such private information and/or distributing it to unauthorized people outside of the company.

Users will not purposely start/work at activity with the intent to: (tease and threaten over and over again in a mean way) other users; insult the performance of the system; (change the normal flow or route of) system useful things/valuable supplies to their own use; or gain access to company systems for which they do not have approval.

Users will not attach unauthorized devices on their PCs or

workstations, unless they have received clearly stated/particular approval from the workers' manager and/or the company IT designee.

Users will not download unauthorized software from the Internet onto their PCs or workstations.

Users are needed/demanded to report any weaknesses in the company computer security, any events of (using something the wrong way) or violation of this policy to their immediate supervisor.

7.7.4.6 Use of the Internet

The company will provide Internet access to workers and contractors who are connected to the internal network and who has a business need for this access. Workers and contractors must get permission from their supervisor and file a request with the Security Manager.

The Internet is a business tool for the company. It is to be used for business-related purposes such as: communicating via electronic mail with suppliers and business partners, getting useful business information and (clearly connected or related) technical and business topics.

The Internet service may not be used for transmitting, retrieving or storing any communications of a (treating certain groups of people unfairly) or (teasing and threatening over and over again in a mean way) nature or which are insulting to any individual or group, obscene or (created only to arouse people sexually), or (related to lies that damaged someone's reputation) or threatening in nature for "chain letters" or any other purpose which is illegal or for personal gain.

7.7.4.7 User Classification

All users are expected to have knowledge of these security policies and are needed/demanded to report violations to the Security Manager. What's more, all users must go along with the Acceptable Use Policy defined in this document. The company has established the following user groups and defined the access privileges and responsibilities :

[illegible][illegible]

7.7.4.8 Monitoring of Computer Systems

The company has the correct and capability to observe electronic information created and/or communicated by person's exploitation company laptop systems and networks, together with e-mail messages and usage of the Internet. It's not the corporate policy or intent to ceaselessly monitor all laptop practice by personnel or different employers of the corporate laptop systems and network. However, users of the systems ought to bear in mind that the corporate could monitor usage, including, however not restricted to, patterns of usage of the internet (e.g. web site accessed, online length, time of day access), and employees' electronic files and messages to the extent necessary to make sure that the net and different electronic communications are being employed in compliance with the law and with company policy.

7.7.5 Access management

A elementary element of our Cyber Security Policy is dominant access to the essential info resources that need protection from unauthorized speech act or modification. The basic which means of access management is that permissions are appointed to people or systems that are approved to access specific resources. Access controls exist at numerous layers of the system, together with the network. Access management is enforced by logon ID and positive identification. At the appliance and info level, different access management strategies is enforced to additional prohibit access. The appliance and info systems will limit the amount of applications and databases out there to users supported their job necessities.

7.7.5.1 User System and Network Access - traditional User Identification

All users are needed to possess a singular logon ID and positive identification for access to systems. The user's positive identification ought to be unbroken confidential and should NOT be shared with management & superior personnel and/or the other worker any. All users should adjust to the subsequent rules relating to the creation and maintenance of passwords:

Password should not be found in any %nglish or foreign lexicon. That is, don't use any common name, noun, verb, adverb, or adjective. These is simply cracked exploitation customary “hacker tools”.

Passwords mustn't be announce on or close to laptop terminals or rather be promptly accessible within the space of the terminal.

Password should be modiled each (# of days).

User accounts are frozen once (# of days) failing logon makes an attempt.

Logon)IDs and passwords are suspended once (# of days) days while not use.

Users aren't allowed to access positive identification files on any network infrastructure element. Positive identification files on servers are monitored for access by unauthorized users. Copying, reading, deleting or modifying a positive identification file on any ADP system is prohibited.

Users won't be allowed to logon as a supervisor. Users World Health Organization want this level of access to production systems should request a Special Access account as printed elsewhere during this document.

Employee Logon IDs and passwords are deactivated as before long as doable if the worker is terminated, fired, suspended, placed inactive, or otherwise leaves the utilization of the corporate workplace.

Supervisors / Managers shall now and directly contact the corporate IT Manager to report modification in worker standing that needs terminating or modifying worker logon access privileges.

Employees World Health Organization forget their positive identification should decision the IT department to urge a replacement positive identification appointed to their account. The worker should determine himself/herself by (e.g. worker number) to the IT department.

Employees are accountable for all transactions occurring throughout Logon sessions initiated by use of the employee's positive identification and ID. The workers shall not logon to a laptop and so enable another individual to use the personal pc or otherwise part access to the personal pc systems.

7.7.5.2 Supervisor Access

System directors, network directors, and security directors can have access to host systems, routers, hubs, and firewalls as needed to satisfy the duties of their job.

All supervisor passwords are DELETED now once any worker World Health Organization has access to such passwords is terminated, fired, or otherwise leaves the utilization of the corporate.

7.7.5.3 Special Access

Special access accounts are provided to people requiring temporary supervisor privileges so as to perform their job. These accounts are monitored by the corporate and need the permission of the user's company IT Manager. Observation of the special access accounts is completed by coming into the users into a selected space and sporadically generating reports to management. The reports can show World Health Organization presently incorporates a special access account, for what reason, and once it'll expire. Special accounts can expire in (8 # of) days and cannot be mechanically revived while not written permission.

7.7.5.4 Connecting to Third-Party Networks

This policy is established to make sure a secure methodology of property provided between the corporate and every one third-part corporations and different entities needed to electronically exchange info with company.

“Third-party” refers to vendors, consultants and business partners doing business with company, and different partners that have a requirement to exchange info with the corporate. Third-party network connections are to be used solely by the workers of the third-party, just for the business functions of the corporate. The third-party company can make sure that solely approved users are allowed to access info on the corporate network. The third-party won't enable web traffic or different personal network traffic to flow into the network. A third-party network affiliation is outlined collectively of the subsequent property options:

A network affiliation can terminate on a (to be specified) and also the third-party are subject to straightforward company authentication rules.

This policy applies to any or all third-party affiliation requests and any existing third-party connections. In cases wherever the present third-party network connections don't meet the wants printed during

this document, they're going to be re-designed as required.

All requests for third-party connections should be created by submitting a written request and be approved by the corporate.

7.7.5.5 Connecting Devices to the Network

Only approved devices are also connected to the corporate network(s). approved devices embody PCs and workstations in hand by company that adjust to the configuration tips of the corporate. Different approved devices embody network infrastructure devices used for network management and observation.

Users shall not attach to the network: non-company computers that aren't approved, in hand and/or controlled by company. Users are specifically prohibited from attaching (specify) to the corporate network.

7.7.5.6 Remote Access

Only approved persons could remotely access the corporate network. Remote access is provided to those workers, contractors and business partners of the corporate world that have genuine business information, copy files or programs, or access laptop applications. Approved affiliation is remote computer to the network or a distant network to company network affiliation. The exclusive acceptable methodology of remotely linking into the internal network is employing a secure identification ID.

7.7.5.7 Unauthorized Remote Access

The attachment of (e.g. hubs) to a user's computer or digital computer that's connected to the corporate LAN isn't allowed without the written permission of the corporate. In addition, users might not install personal computer code designed to produce device of the computer or digital computer. This sort of remote access bypasses the approved extremely secure strategies of remote access and poses a threat to the protection of the complete network.

7.7.6 Penalty for Security Violation

The company takes the difficulty of security very seriously. Those folks that use the technology and data resources of company should assume in mind that they would be disciplined if they violate these policy regulations. Upon violation of this policy, associate worker of company is also subject to discipline up to and together with discharge. The precise discipline obligatory are determined by a independent basis, taking into thought the character and severity of the violation of the Cyber Security Policy, previous violations of the policy committed by the individual, state and federal laws and every one different relevant info. Discipline, which can be taken against assistant worker that will be supervised in accordance with any applicable rules or policies and also the company Policy Manual.

In a case wherever the defendant person isn't associate worker of company the matter shall be submitted to the (company designee). The (company designee) could refer the data to enforcement agencies and/or prosecutors for thought on whether or not criminal charges ought to be filed against the alleged violator(s).

7.7.7 Security Incident Handling Procedures

This section provides some policy tips and procedures for handling security incidents. The term “security incident” is outlined as any irregular or adverse event that threatens the protection, integrity, or convenience of the data resources on any a part of the corporate network. Some samples of security incidents are:

Illegal access of an organization ADP system. For instance, a hacker logs onto a production server and copies the positive identification file.

Damage to an organization ADP system or network caused by criminal access. emotional a deadly disease or worm would be associate example.

Denial of service attack against an organization net server. For instance, against an online server designed to cause the system to crash a hacker initiates a flood of packets.

The use of malicious system resources to launch associate confrontation against different laptop outside of the corporate network. for example, the supervisor notices a affiliation to associate unknown network and an odd method accumulating

plenty of server time.

Employees, World Health Organization believe their terminal or laptop systems are subjected to a security incident, or has otherwise been improperly accessed or used, ought to report true to their (company designee) now. The worker shall not shut down the pc or delete suspicious files. Deed the pc within the condition it absolutely was in once the protection incident was discovered can assist in characteristic the supply of the matter and in decisive the steps that ought to be taken to remedy the matter.

7.8 ANSWER THE FOLLOWING QUESTIONS:

What are the main agendas that should be included in a company security policy?

Explain all categories for widely used computer security policies.

Explain the difference between User policy and IT policy.

What are the main things to keep in mind as you tackle the security policy beast?

What is E-mail security? Explain the various threats to E-mail.

What is E-mail policy and why we need it?

Explain the various legal risk attach to E-mail policy.

What are the guidelines that a company should follow while sending an E-mail?

What do we mean by strong password?

What is encryption and decryption?

Explain the term disclaimer and why we be added it to each outgoing email.

How can we determine the objectives for reviewing a policy and how to achieve it?

Draw a flowchart for Policy development and Consultation Process.

What do we mean by physical and information security with respect to corporate policy?

Give a sample Template of Cyber Security Policy.

What are the various security levels for computer system?

When an employee becomes a threat to a company security?

What are the various threats to a company security?

Give the various user groups in terms of company security and also define their access privileges and responsibilities.

How a logon ID proved beneficial to company security?

Chapter-8

Information Security Standards

8.1 INTRODUCTION

While data security plays a crucial role in protective the info and assets of a corporation, we frequently hear news concerning security incidents, like disfigurement of internet sites, server hacking and knowledge escape. Organizations ought to be totally alert to the necessity to devote a lot of resources to the protection of data assets, and knowledge security should become a prime concern in each government and business.

To address true, variety of governments and organizations have got wind of benchmarks, standards and in some cases, legal laws on data security to assist guarantee associate degree adequate level of security is maintained, resources area unit utilized in the proper method, and therefore the best security practices area unit adopted. Some industries, like banking, area unit regulated, and therefore the tips or best practices place along as a part of those laws typically become a de facto commonplace among members of those industries.

8.1.1 WHAT'S ISO?

ISO originated from the union of 2 organizations - the ISO (International Federation of the National commonplace zing Associations) and therefore the UNSCC (United Nations Standard coordinating Committee). In 1946 over twenty five countries met at the Institute of Civil Engineers in London to make a brand new global organization, wherever the target was to 'facilitate the international coordination and unification of business standards' From this the new organization ISO began operations in Gregorian calendar month 1947. The word ISO comes from the Greek ISOS which means 'equal'. Because the global organization for Standardization would translate otherwise across completely different languages it absolutely was determined that the short kind name for the organization would be ISO.

The ISO 9000 family - core standards

The ISO 9000 commonplace provides the basics and vocabulary utilized in the whole ISO 9000 family of standards. It sets the stage for understanding the essential components of quality management as delineated within the ISO standards. ISO 9000 introduces users to the eight Quality Management Principles still because the use of the method approaches to realize continual improvement.

ISO 9001 is employed after you are unit seeking to ascertain a high quality management system that has confidence in your organization's ability to produce product that fulfill client desires and expectations.

It is the quality within the ISO 9000 family against whose necessities our quality management system may be certified by associate degree external body. The quality acknowledges that the term “product” applies to services, processed material, hardware and software package meant for our client. There are unit 5 sections within the commonplace that specify activities that require to be thought of after we implement our system:

Overall Necessities for the standard management system and documentation

Management responsibility, focus, policy, designing and objectives

Resource management and allocation

Product realization and method management, and

Measurement, monitoring, analysis and improvement.

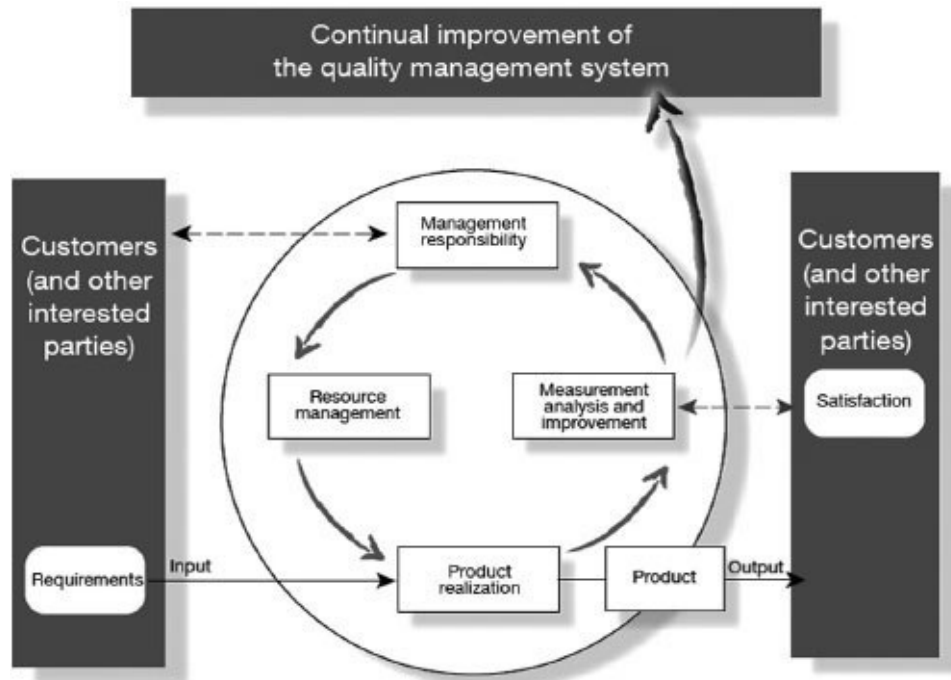


Figure 8.1: *The ISO 9000 process approach*

The requirements in four of the sections are unit applicable to any or all organizations - Quality management system, Management responsibility, Resource management, and measuring, analysis and improvement. The merchandise realization section is also tailored to satisfy the wants of your organization. Our quality manual or different documentation can demonstrate however we have a tendency to meet the ISO 9001 necessities in your company.

Together, the 5 sections of ISO 9001 outline what we should always do to systematically give product that meets client and applicable statutory and regulative necessities. Additionally, we'll ask for to reinforce client satisfaction by continual improvement of our

quality management system.

Further guidance can also be found in the ISO 9001:2008 Introduction and Support Package prepared by ISO/TC 176 subcommittee SC 2 which provides further guidance on:

Terminology

ISO 9001:2008 Clause 1.2 (Application)

Documentation requirements

The process approach

Outsourced processes

Implementation

Frequently asked questions (FAQs).

ISO/TC 176 maintains a standard of the ISO 9001 standard. ISO 9004 is used to extend the benefits obtained from ISO 9001 to all parties that are interested in or affected by our operations. Interested parties include our employees, owners, suppliers, partners and society in general.

ISO 9001 and ISO 9004 are compatible and can be used separately or in combination to meet or exceed expectations of customers and interested parties. Both standards apply a process approach. Processes are recognized as consisting of one or more linked activities that require resources and must be managed to achieve predetermined output. The output of one process may directly from the input to the next process and the final product is often the result of a network or system of processes. The eight Quality Management Principles provide the basis for the performance improvement.

ISO 9004 gives guidance on a wider range of objectives of a quality management system than does ISO 9001, particularly in managing for the long-term success of an organization. ISO 9004 is counseled as a guide for organizations whose prime management needs to extend the advantages of ISO 9001 in pursuit of systematic and continual improvement of the organization's overall performance.

However, it's not meant for certification or written agreement functions. ISO 19011 covers the realm of auditing of quality management systems and environmental management systems. It provides steering on the audit programs, the conduct of internal or external audits, and knowledge on auditor competency. ISO 19011 provides an summary of however associate program ought to operate and the way management system audits ought to occur. Effective audits make sure that associate enforced QMS meets the necessities laid out in ISO 9001.

The nature of our organization and our specific wants can verify however we have a tendency to apply these standards to realize our goals and objectives. Helpful hints and tips for conducting audits are developed by the ISO 9001 Auditing Practices cluster. Info on third party auditing has additionally been developed by the joint ISO-IAF (International certification Forum) certification Auditing Practices cluster.

8.1.2 INFO TECHNOLOGY ACT

The Information Technology Act 2000 (also referred to as ITA-2000, or the IT Act) is associate Act of the Indian Parliament (No twenty one of 2000) notified on Gregorian calendar month seventeen, 2000. This act is being opposed by save our Voice campaign and different civil society organizations in Asian country. User-review and client social networking web site MouthShut.com has filed an instrument petition within the Supreme Court of Asian country to repeal and nullify elements of IT Act 2000.

Information technology Act 2000 consisted of ninety four sections isolated into thirteen chapters. Four schedules type a part of the Act. Within the 2008 version of the Act, there area unit 124 sections (excluding five sections that are omitted from the sooner version) and fourteen chapters. Schedule I and II are replaced. Schedules III and IV area unit deleted.

Information Technology Act 2000 addressed the subsequent issues:

Legal recognition of electronic documents

Legal Recognition of digital signatures

Offenses and contraventions

Justice dispensation systems for cybercrimes

According to Section 10A of data technology Act, 2000(amended in 2008) it additionally validates E-contracts.

E-contracts.

[illegible]

E-contracts.

[illegible]

contracts. E-contracts. E-contracts. E-contracts. E-contracts.
--

Criticism

The 2008 modification Act was passed in Associate in nursing eventful Parliamentary session on twenty three December 2008 with no discussion within the House. A number of the cyber law observers have criticized the amendments on the bottom of lack of legal and procedural safeguards to forestall violation of civil liberties of Indians. There has conjointly been appreciation concerning the amendments from several observers as a result of it addresses the problem of Cyber Security.

Section sixty nine empowers the Central Government/State Government/ its approved agency to intercept, monitor or decode any info generated, transmitted, received or keep in any laptop resource if it's necessary or expedient thus to try and do within the interest of the sovereignty or integrity of Asian nation, defense of Asian nation, security of the State, friendly relations with foreign States or public order or for preventing incitement to the commission of any cognoscible offence or for investigation of any offence. They'll conjointly secure help from laptop personnel in decrypting knowledge underneath penalty of imprisonment.

Section 66A is wide criticized. It's junction rectifier to varied abuses reported by the press. Section 66A has conjointly been criticized

and challenged in Lucknow and Madras High Courts for its constitutional validity. Supported Section 66A, Bombay judiciary has control that making an internet site and storing false info thereon will entail law-breaking.

8.1.3 WHAT'S COPYRIGHT?

Copyright could be a variety of material possession protection granted underneath Indian law to the creators of original works of authorship like literary works (including laptop programs, tables and compilations as well as laptop databases which can be expressed in words, codes, schemes or in the other type, as well as a code medium), dramatic, musical and inventive works, cinematographic films and sound recordings.

Copyright law protects expressions of concepts instead of the concepts themselves. Underneath section thirteen of the Copyright Act 1957, copyright protection is bestowed on literary works, dramatic works, musical works, inventive works, cinematograph films and recording. As an example, books, laptop programs square measure protected underneath the Act as literary works.

Copyright refers to a bundle of exclusive rights unconditional within the owner of copyright by virtue of Section fourteen of the Act. These rights are exercised solely by the owner of copyright or by the other one that is punctually authorized during this regard by the owner of copyright. These rights embody the correct of adaptation, right of replica, right of publication, right to create translations, communication to public etc.

Copyright protection is bestowed on all Original literary, artistic, musical or dramatic, cinematographs and recording works. Original suggests that, the work has not been derived from the other supply. Copyright protection commences the instant a piece is made, and its registration is ex gratia. But it's continually wise to get a registration for a stronger protection. Copyright registration doesn't confer Associate in Nursing rights and is just a clear proof of an entry in respect of the add the Copyright Register maintained by the Registrar of Copyrights.

As per Section seventeen of the Act, the author or creator of the work is that the 1st owner of copyright. Associate in nursing exception to the present rule is that, the leader becomes the owner of copyright in circumstances wherever the worker creates a piece within the course of and scope of employment.

Copyright registration is priceless to a copyright holder WHO desires to require a civil or criminal action against the infringer. Registration formalities square measure easy and therefore the work is least. In case, the work has been created by someone apart from worker, it might be necessary to file with the appliance, a duplicate of the assignment deed.

Protection is given to works 1st revealed in Asian nation, in respect of all countries that square measure member states to treaties and conventions to that Asian nation could be a member. Thus, while not formally applying for defense, copyright protection is on the market to works 1st revealed in Asian nation, across many

countries. Also, the govt. of Asian nation has by virtue of the International Copyright Order, 1999, extended copyright protection to works 1st revealed outside Asian nation.

Indian perspective on copyright protection:

The Copyright Act, 1957 provides copyright protection in Asian nation. It confers copyright protection within the following 2 forms:

(A) Economic rights of the author, and

(B) Ethical Rights of the author.

(A) Economic Rights:

The copyright subsists in original literary, dramatic, musical and inventive works; cinematographs films and sound recordings. The authors of copyright within the same works get pleasure from economic rights u/s fourteen of the Act. The rights square measure chiefly, in respect of literary, dramatic and musical, apart from malicious program, to breed the add any material type as well as the storing of it in any medium by electronic suggests that, to issue copies of the work to the general public, to perform the add public or act it to the general public, to create any cinematograph film or recording in respect of the work, and to create any

translation or adaptation of the work. Within the case of malicious program, the author enjoys additionally to the same rights, the correct to sell or offer on rent, or provide available or rent any copy of the pc program regardless whether or not such copy has been oversubscribed or given on rent on earlier occasions. Within the case of an inventive work, the corrects offered to Associate in Nursing author embody the right to breed the add any material type, as well as depiction in 3 dimensions of a 2 dimensional work or in 2 dimensions of a 3 dimensional work, to speak or problems copies of the work to the general public, to incorporate the add any cinematograph work, and to create any adaptation of the work. Within the case of cinematograph film, the author enjoys the correct to create a duplicate of the film as well as a photograph of any image forming half thence, to sell or offer on rent or provide available or rent, any copy of the film, and to speak the film to the general public. These rights square measure equally offered to the author of recording. Additionally to the same rights, the author of a painting, sculpture, drawing or of a manuscript of a literary, dramatic or musical work, if he was the primary owner of the copyright, shall be entitled to own a right to share within the selling worth of such original copy as long as the selling worth exceeds rupees 10 thousand.

(B) Ethical Rights:

Section fifty seven of the Act defines the 2 basic “moral rights” of Associate in Nursing author. These are:

- (i) Right of paternity, and

(ii) Right of integrity.

The right of paternity refers to a right of Associate in Nursing author to say authorship of labor and a right to forestall all others from claiming authorship of his work. Right of integrity empowers the author to forestall distortion, accidental injury or different alterations of his work, or the other action in reference to same work, which might be harmful to his or name. The supply to section 57(1) provides that the author shall not have any right to restrain or claim damages in respect of any adaptation of a malicious program to that section fifty two (1)(aa) applies (i.e. reverse engineering of the same). It should be noted that failure to show a piece or to show it to the satisfaction of the author shall not be deemed to be Associate in Nursing infringement of the rights bestowed by this section. The legal representatives of the author might exercise the rights bestowed upon Associate in attention author of a piece by section 57(1), apart from the correct to say authorship of the work.

Indian Judiciary Response:

The response of Indian judiciary relating to copyright protection is sorted underneath the subsequent headings:

(1) possession of copyright,

(2) territorial side,

(3) Cognizance taken by the court,

(4) Infringement of copyright,

(5) accessibility of other remedy, and

(6) Rectification of copyright.

(1) Possession of copyright: The possession in copyright might vest totally different in several numerous persons underneath different circumstances.

In Japanese Book company v Navin J. Desai, the question concerned was whether or not there's any copyright within the coverage of the judgment of a court. The urban center judicature observed: it's not denied that underneath section 2(k) of the Copyright Act, a piece that is formed or revealed underneath the direction or management of any Court, court or different judicial authority in Asian nation could be a Government work. Underneath section 52(q), the replica or publication of any judgment or order of a court, court or different judicial authority shall not represent infringement of copyright of the govt. in these works. it's therefore clear that it's hospitable everyone to breed and publish the govt. work as well as the judgment/ order of a court. However, in case, someone by intensive reading, careful study and comparison and with the exercise of style and judgment has created bound comments concerning judgment or has written an editorial on that,

could also be such a comment and comment is entitled to protection underneath the Copyright Act”.

(2) Territorial aspect: The question of territorial jurisdiction of the court to upset infringement was thought-about by the courts on many occasions.

In Caterpillar opposition v Kailash Nichani, the complainant, a far off company, was carrying on business in many places in Asian nation as well as urban center, through its Indian distributors and collaborators. The complainant claimed the relief of ad-interim injunction for preventing infringement of its copyright by the litigator, although the litigator was dealing in numerous merchandise. The judicature control that it had been not necessary to point out that the business being carried on by the complainant in Delhi ought to essentially be in respect of footwear and articles of covering similarly. It's ample if the business was being carried on by the complainant in urban center Associate in treatment more that there was an infringement of plaintiff's copyright in respect of bound merchandise, that were being oversubscribed by the litigator in urban center. The court more control that section sixty two of the Copyright Act makes a plain and vital departure from the norm that the selection of jurisdiction ought to primarily be ruled by the convenience of the litigator. The general assembly in its knowledge introduced this provision giving birth down fully opposite norm than the one commenced in section twenty CPC. The aim is to reveal the wrongdoer with inconvenience instead of compelling the sufferer to chase when the previous.

(3) Cognizance taken by the court: to forestall infringement, timely

cognizance taking by the suitable court is totally essential. The taking of cognizance by the court depends upon the limitation amount as mentioned within the Limitation Act, 1963 and metal.P.C, 1973.

In David Pon Pandian v State, the Madras judicature, whereas managing section 68A of the Copyright Act, observed: The Court will take cognizance of the offence if the blotter is filed inside the amount of limitation prescribed underneath Section 468 of the metal.P.C and in computing the amount of limitation, the date of commission of the offence is to be reckoned because the start line. If the blotter isn't crammed thus, the Court has no power to entertain the criticism

The court referred the choice of the Supreme Court in State of geographical area v Sarwan Singh within which it had been observed: "The object of metal.P.C in golf shot a bar of limitation on the prosecution was clearly to forestall the parties from filing cases when a protracted time, as a results of that material proof might disappear and conjointly to forestall abuse of the method of Court by filing disagreeable and tardy prosecutions long when the date of the offence. The object, that the statute seeks to sub-serve, is clearly in consonance with the conception of fairness of trial as enshrined in Article twenty one of the Constitution. It is, therefore, of utmost importance that any prosecution, whether or not by State or a personal litigant, should abide by the letter of the law or to require the chance of the prosecution failing on the bottom of limitation"

In Shree Devendra Somabhai Naik v correct Transheet Pvt Ltd, the Gujarat judicature explained the inter-relationship between Article 137

of the Limitation Act, 1963 and section fifty of the Copyright Act, 1957. The Court observed: The order glided by the by the Copyright Board could be an order whereby it's control that the provisions of Article 137 of the Limitation Act don't seem to be applicable board has also control that the Copyright Board is a court and quasi-judicial authority for all different functions aside from the needs that square measure specifically provided within the Copyright Act. It's Associate in Nursing order by that Associate in Nursing application underneath Section fifty of the Copyright act is diverted and therefore the Copyright Board can decide a similar on deserves. The Copyright Board doesn't believe the delay alleged by this appellant. Diverting Associate in tending application could be a matter of discretion. Within the gift case, the Copyright Board in its knowledge, overruling the competition that the appliance was barred by limitation, determined to entertain the appliance. It's a discretionary order”.

(4) Infringement of copyright:

A copyright owner cannot get pleasure from his rights unless infringement of a similar is strictly treated by the Courts. The approach of the Indian Judiciary during this regard is incredibly satisfactory.

In *Prakashak Puneet Prashant Prakashan v Distt. judge, Bulandshahr and Ashok Prakashan (Regd)* the Allahabad judicature control that if the petitioner publishes a book by adding any word before or when the book “Bal Bharati”, he infringes the copyright of the respondent.

In *Hindustan Pencils Ltd v Alpna house Industries* the Copyright Board of state control that wherever the similarities between the

inventive works of the parties are elementary and substantial in material aspects, it might quantity to copyright violation and therefore the defendant's copyright is vulnerable to be expunged from the register of copyright.

(5) Accessibility different of other of different remedy: the supply of Associate in Nursing efficacious alternative remedy prevents someone from invoking the official document jurisdiction of the judicature.

In Khajanchi Film Exchange and Another v State of M.P et al petitioners rather than approaching the involved authorities filed a official document petition within the judicature. The Madhya Pradesh judicature observed: The film wasn't nonetheless discharged. The petitioners didn't approach the respondents. There was no failure on the part of the respondents in performance of their legal duties with respect of the correct complained of. The complete machinery was place to doubt by the petitioners on the premise of the averments created within the official document petition that it's to the public knowledge that they are doing not take action. Therefore apprehending infringement of their rights, the official document petition was filed. The petitioners ought to have approached the involved authorities first; and within the event of their failure to require preventive measures/seizure of cassettes underneath the M.P. Police rules and therefore the copyright Act, the petitioners ought to have approached this Court. If a official document is diverted and relief promptly granted before unleash of the motion picture while not approaching the respondents WHO need to stop vulnerable violation of copyright, it might open a flood gate of judicial proceeding. The copyright Act provides

adequate safeguards and procedure. It can not be same that a mere apprehension that bound offence might occur, a official document is filed seeking a direction that no such offence be allowed to require place. 1st authorities need to be asked to forestall it. The perform of the police is to forestall piracy and unauthorized exhibition. Within the instant case there was no inaction on the a part of the police and different involved officers and that they were unnecessarily dragged in petition while not even golf shot them to note of planned writ. No demand notice was served, no specific criticism was lodged. Therefore official document isn't rectifiable.

(6) Rectification of copyright:

In the rectification proceedings, Associate in treatment entry within the Copyright Register bearing on a specific copyright is expunged by the Copyright Board.

In Lal baboo Priyadarshi v Badshah Industries the Division bench of the Patna judicature Observed: Rule 16(3) of the Copyright Rules, 1958 that embodies the principle of natural justice provides that once there's a rival claim with reference to subject material of the copyright then no order is passed in favor of any party while not hearing the appliance of the opposite someone. Non-observance of the same provision can vitiate the order with reference to the entry within the Register of the Copyright. The same demand cannot be waived nor is non-observance of the same provision same to be a mere irregularity. If someone creating Associate in nursing application underneath section forty five isn't conscious of the rival claim then the matter would diverge. However during this case, as is obvious from the notice sent by the appellants through their

counsel, they were conscious of the claim of the respondents Associate in treatment per se they must have given notice to the respondents intimating them of their intention to file an application for registration so the respondents might have raised objections and, thereafter, the matter would be determined in terms of provisions contained in Section forty five, browse with Rule sixteen. During this case Rule sixteen has not been followed before creating the entry within the Register of Copyright underneath section forty five and, thus, the Board justifiably came to the conclusion that non-observance of the provisions of Rule 16 (3), that is necessary in nature, has vitiated the certificate of registration in favor the appellants.

Copyright Infringement:

Direct Infringement: Direct infringement may be a strict liability offence and guilty intention isn't essential to mend criminal liability. The necessities to ascertain a case of infringement of copyright beneath this theory are:

(1) Possession of a sound copyright; and

(2) Repetition or infringement of the proprietary work by the suspect.

Thus, an individual World Health Organization innocently or maybe accidentally infringes a copyright could also be control liable beneath the Copyright Act of the U.S. and beneath the laws of

assorted alternative countries. The guilty intention of the bad person is often taken into consideration for crucial the quantum of damages to be awarded for the alleged infringement.

Contributory infringement:

The conducive infringement pre-supposes the existence of information and participation by the alleged conducive infringer. To say damages for infringement of the copyright, the complainant should prove:

- (1) That the suspect knew or ought to have notable of the infringing activity; and
- (2) That the suspect elicited, caused, or materially contributed to a different person's infringing activity.

Vicarious Infringement:

Vicarious infringement of copyright liability evolved from the principle of respondent superior. To succeed on a claim of vicarious liability for an immediate infringer's action, a complainant should show that the defendant:

- (1) Had the proper and skill to regulate the direct infringer's actions; and
- (2) Derived an immediate monetary have the benefit of the

infringing activity.

Thus, vicarious liability focuses not on the data and participation however on the link between the direct infringer and therefore the suspect.

Legal precedent for vicarious infringement of copyright liability has developed on two general relative lines. The primary relative line involves the employer/employee relationship, whereas the second involves the lease giver / renter relationship.

Internet and infringement of copyright theories: the appearance of data technology has created it troublesome to use the standard theories to varied Internet entities and organizations.

These Internet players are often classified beneath the subsequent headings:

- (1) Net Service suppliers (ISPs),
- (2) Bulletin Board Services Operators (BBSO),
- (3) Business web content owner/operators, and
- (4) Non-public users.

(1) Internet Service suppliers (ISPs):

An ISP most frequently provides net access and he could also be control to blame for infringement of copyright. In *non secular Technology Center v Netcom Online Communication Services, INC* a former minister uploaded a number of the proprietary work of the Church of faith to the web. He initial transferred the data to a BBS pc, wherever it had been quickly keep before being traced onto Netcom's pc and alternative Usenet computers. Once the data was on Netcom's pc, it had been out there to Netcom's subscribers and Usenet neighbors for downloading for up to eleven days. The plaintiffs familiar Netcom regarding the infringing activity; yet, Netcom refused to deny the subscriber's access as a result of it had been unimaginable to prescreen the subscriber's uploads, and kicking the subscriber off the web meant setting out the remainder of the BBS operator's subscribers. Thus, plaintiffs sought-after a remedy against Netcom for infringement beneath all 3 theories - direct, conducive, and vicarious.

The court initial analyzed whether or not Netcom directly infringed plaintiff's copyright. Since Netcom didn't violate plaintiff's exclusive repetition, distribution, or show rights, Netcom was control not to blame for direct infringement. The court then analyzed the third party liability theories of conducive and vicarious infringement. The court control that Netcom would be to blame for conducive infringement if plaintiffs verified that Netcom had data of the infringing activity. The court then analyzed whether or not Netcom

was vicariously liable. Here, once more the court found that a real issue of fabric truth supporting Netcom's right and skill to regulate the up loader's acts existed. The court found that Netcom didn't receive direct monetary have the benefit of the infringement. Thus, the court found that the Netcom wasn't to blame for direct infringement, may be to blame for conducive infringement if plaintiffs verified the data component, and wasn't to blame for vicarious infringement.

(2) Bulletin Board Services:

The BBSs square measure a lot of at risk of infringement of copyright litigations than the ISPs as a result of they'll operate freelance of the planet Wide internet.

The first case during this class was man-about-town Enterprises, INC v Frena. In this case, the suspect operated a subscription BBS that allowed the subscribers to look at, upload, and transfer material. The court control that Frena had desecrated Playboy's exclusive distribution right and their exclusive show right. As a result of Frena provided a product containing unauthorized copies of proprietary work, he has desecrated the distribution right. Moreover, as a result of Frena in public displayed Playboy's proprietary images to subscribers, he desecrated the show right. The court finished that Frena was to blame for direct infringement, tho' Frena himself ne'er placed infringing material on the BBS and despite his arguments that he was unaware of the infringement. The court relied upon the strict liability theory and control that neither intent nor data is an important component of infringement.

(3) Business internet sites:

The Web Page homeowners should use caution of the items they post on their sites so they are doing not violate the demanding provisions of the copyright laws. An online Page owner cannot with success plead and prove that they were unaware regarding the proprietary material as a result of copyright notices square measure conspicuously given in licensed computer code. They even have the dominant power over the content of their pages. The owner square measure sometimes the parties that really perform the uploads to their pages.

(4) Non-public Users:

A someone World Health Organization uploads proprietary material to the web is to blame for direct infringement. This liability may be avoided as long as he will prove the use belief. Thus, a web user mustn't post proprietary material on the web in a very casual manner.

On-line copyright problems in India:

The respect to on-line copyright problems is often found within the following 2 major enactments:

(1) The Copyright Act, 1957, and

(2) The data Technology Act, 2000.

(1) Copyright Act, 1957 and on-line copyright issues: the subsequent provisions of the Copyright Act, 1957 will safely be relied upon for meeting the challenges of data technology:

(a) The comprehensive definition of pc is extremely wide which incorporates any electronic or similar device having IP capabilities. Thus, a tool storing or containing a proprietary material can't be manipulated in such a fashion on violates the rights of a copyright holder.

(b) The term package has been outlined to mean a collection of directions expressed in words, codes, schemes or in the other type, as well as a computer readable medium, capable of inflicting a pc to perform a specific task or bring home the bacon a specific result. It should be noted that Section13 (a) browse with Section 2(o) confers a copyright in package and its infringement can attract the demanding penal and civil sanctions.

(c) The comprehensive definition of literary composition includes pc programmers, tables and compilations as well as pc databases. Thus, the law-makers has taken adequate care and provided comfortable protection for pc connected copyrights.

(d) The proprietary material are often transferred or communicated to the general public simply and on the QT through electronic means that to require care of such a scenario, the Copyright Act

has provided the circumstances that quantity to communication to the general public. Thus, creating any work out there for being seen or detected or otherwise enjoyed by the general public directly or by any means that of show or diffusion apart from by supply copies of such work despite whether or not any member of the general public truly sees, hears or otherwise enjoys the work thus created out there, could violate the copyright. The communication through satellite or cable or the other means that of synchronous communication to quite one home or place of residence as well as residential rooms of any building or hostel shall be deemed to be communication to the general public

(e) The copyright in a very work is infringed if it's traced or printed while not its owner's consent. The Copyright Act provides that a piece is printed if an individual makes out there a piece to the general public by issue of copies or by act the work to the general public. Thus, the ISPs, BBS suppliers, etc could also be control to blame for copyright violation if the facts decipher a case for constant.

(f) The copyright in a very work shall be deemed to be infringed once an individual, while not a license granted by the owner of the copyright or the Registrar of Copyrights beneath this Act or in dispute of the conditions of a license thus granted or of any condition obligatory by a competent authority beneath this Act-

(i) will something, the prerogative to try that is by this Act bestowed upon the owner of the copyright, or

(ii) Permits for profit anyplace to be used for the communication of the work to the general public wherever such communication constitutes Associate in tending infringement of the copyright within the work, unless he wasn't aware Associate in tending had no cheap ground for basic cognitive process that such communication

to the general public would be an infringement of copyright

(g) The Copyright Act specifically exempts bound acts from the orbit of infringement of copyright. Thus, the creating of copies or adaptation of a bug by the lawful human of a replica of such bug from such copy so as to utilize the pc Program for the aim that it had been provided or to form back-up copies strictly as a short lived protection against loss, destruction, or harm so as solely to utilize the pc Program for the aim that it had been provided, wouldn't be infringement of copyright. Similarly, the doing of Associate in tending act necessary to get data essential for operational inter-operability of an severally created bug with alternative programmed by a lawful human of a bug isn't a copyright violation if such data isn't otherwise pronto out there. Further, there'll not be any copyright violation within the observation, study or check of functioning of the pc Program so as to see the concepts and principles that underline any components of the Program whereas acting such acts necessary for the functions that the pc Program was provided. The Act additionally makes it clear that the creating of copies or adaptation of the pc Program from a in person wrongfully obtained copy for non-commercial personal use won't quantity to copyright violation.

(h) If an individual wittingly makes use on a pc of Associate in Nursing infringing copy of a bug, he/she shall be control to blame for penalty of imprisonment for a term that shall not be but seven days however which can reach 3 years and with fine that shall not be but fifty thousand rupees however which can reach 2 hundred thousand rupees. However, if the pc Program has not been used

for gain or within the course of trade or business, the court could, for adequate and special reasons to be mentioned within the judgment, not impose any sentence of imprisonment and should impose a fine which can reach fifty thousand rupees.

It should be noted that copyright are often obtained in a very bug beneath the provisions of the Copyright Act, 1957. Hence, a bug can't be traced, circulated, printed or used while not the permission of the copyright owner. If it's lawlessly or improperly used, the standard infringement of copyright theories is often safely and wrongfully invoked. Further, if the medium of net is employed to advance that purpose, invoking the provisions of the Copyright Act, 1957 and supplementing them with the demanding provisions of the data Technology Act, 2000, will stop constant.

(2) data Technology Act, 2000 and on-line copyright issues:

The following provisions of the data Technology Act, 2000 square measure relevant to know the link between copyright protection and data technology:

(a) Section 1(2) browse with Section seventy five of the Act provides for extra-territorial application of the provisions of the Act. Thus, if an individual (including a distant national) violates the copyright of an individual by means that of pc, ADPS or electronic network settled in Republic of India, he would be liable beneath the provisions of the Act.

(b) If somebody while not permission of the owner or the other one that is responsible of a pc, ADPS or electronic network accesses or secures access to such pc, ADPS or electronic network or downloads, copies or extracts any information, pc information base or data from such pc, or electronic network as well as data

or data control or keep in any removable data-storage medium, he shall be vulnerable to pay damages by approach of compensation not surpassing one large integer rupees to the person thus affected. Thus, an individual violating the copyright of another by downloading or repetition constant can ought to pay damages up to the tune of rupees one large integer that is deterrent enough to stop copyright violation.

(c) Whereas adjudging the quantum of compensation, the adjudicating officer ought to take into account the subsequent factors:

- (i) The number of gain or unfair advantage, where quantitative, created because the results of the default;
- (ii) The number of loss caused to somebody as a results of the default;
- (iii) The repetitive nature of the default.

Thus, if the copyright is desecrated advisedly and for earning profit, the quantum of damages is a lot of as compared to innocent infringement.

(d) A network service supplier (ISP) won't be liable beneath this Act, rules or laws created there beneath for any third party data or information created out there by him if he proves that the offence or dispute was committed while not his data or that he had exercised all due diligence to stop the commission of such offence or dispute. The network service supplier beneath section seventy nine means that Associate in Nursing negotiate Associate in nursing third party data means that any data addressed by a network service supplier in his capability as an negotiate.

(e) The provisions of this Act shall have predominant result

nevertheless something inconsistent with that contained in the other law for the nowadays in effect.

The future of copyright in India:

The copyright laws in open area measure set to be amended with the introduction of the provisions for anti-circumvention and Rights Management data within the Indian copyright regime though India is beneath no obligation to introduce these changes because it isn't a somebody to WCT or WPPT.

With the change of the Copyright Act in 1994, that came into force on ten could 1995, things with relation to copyright social control in Republic of India has improved. Consistent with Ramdas Bhatkal of in style Prakashan, Bombay, “We had issues of piracy concerning medical textbooks before the law was amended. At that point we tend to found that whereas the law could also be on our aspect, it had been necessary to urge a judicial writ for search and this meant that there was comfortable notice to the pirate to require defensive action before the judicial writ may be enforced. So we tend to most popular to just accept things and did nothing. Since the changes that build copyright violation a cognizable offence it's been attainable to use the legal mechanism as a deterrent.”

Section sixty four of the Indian Copyright Act 1957 provides that “Any officer, not below the rank of a sub-inspector, may, if he's glad that Associate in Nursing offence beneath Section sixty three

in respect of the infringement of copyright in any work has been, is being, or is probably going to be, committed, seize while not warrant, all copies of the work, where found, and every one copies and plates used for the aim of creating infringing copies of the work, where found, and every one copies and plates thus taken shall, as shortly as practicable, be created before a functionary.”

“The copyright doesn't defend the thought however it will defend the ability and therefore the labor place in by the authors in manufacturing the work. An individual can't be control to blame for infringement of copyright if he has taken solely the thought concerned within the work and given expression to the thought in his own approach. 2 authors will turn out 2 totally different works from a standard supply every of them transcription that information in his own approach and victimization his own language. The arrangement of the data and therefore the language used mustn't be traced from a piece within which copyright subsists.”

8.1.4 Patents

Rights, granted to inventors by the federal, consistent to its power beneath Article I, Section 8, Clause 8, of the U.S. Constitution, that permit them to exclude others from creating, using, or marketing Associate in Nursing invention for a particular, or restricted, amount of your time.

The U.S. legal system is intended to encourage inventions that square measure helpful to society by granting inventors absolutely the right to exclude all others from victimization or making the most of their invention for a restricted time, in exchange for revealing the main points of the invention to the general public. Once patent has expired, the general public then has the proper to form, use, or sell the invention.

Once a patent is granted, it's thought to be the Personal Property of the artificer. Associate in Nursing inventor's property rights in Associate in Nursing invention itself square measure freely transferable and conveyable. Typically staff World Health Organization invents one thing within the course and scope of their employment transfer and assign their property rights within the invention to their leader. Additionally, a patent holder, or artificer, will grant a license to a different to use the invention in exchange for payment or a royalty.

Inventors don't seem to be needed to participate within the legal system, and that they will elect instead to undertake to keep their invention a secret. However, if the artificer begins to sell his or her invention or permits the general public to use it, others will study the invention and make impostor products. If this happens, the initial artificer has no protection as a result of he or she didn't acquire a patent.

There square measure 3 styles of patents: (1) style patents, (2) plant patents, and (3) utility patents. Style patents square measure granted to guard a unique appearance or style of a piece of manufacture, whether or not it's surface ornamentation or the general configuration of Associate in Nursing object. Plant patents are granted for the invention and reproduction of a replacement and distinct kind of plant, as well as mutants and hybrids. Utility patents are perhaps the foremost acquainted, applying to machines, chemicals, and processes.

8.1.4.1 Governing Laws

Patent law within the us relies upon statutes set in Title thirty five of the U.S. Code, together with the Patent Act of 1952. The foundations of the Patent and Trademark office, found in Title thirty seven of the Code of Federal laws, give extra authority. Additionally, the overall Agreement on Tariffs and Trade (GATT) has diode to important changes in U.S. jurisprudence that area unit designed to bring some aspects of U.S. law into conformity with those of the country's commerce partners. The GATT Implementation Act was signed into law in 1994, and people of its provisions that impact U.S. jurisprudence began to require impact in 1995.

8.1.4.2 Patent period

One vital modification in U.S. jurisprudence ensuing from GATT is that the period of U.S. patents. Patents were originally given 14-year terms from the date of issue, till that was modified in 1861. From 1861 till the implementation of GATT, the term of a patent was seventeen years from the date of issue. Under GATT, all patents issued when Gregorian calendar month seven, 1995, have a term of twenty years from the effective filing date. GATT contained retroactive part that only if all patents that had been issued, however not nonetheless expired, as of Gregorian calendar month seven, 1995, would have a term that is the longer of twenty years from its effective filing date or seventeen years from the date of issue. The effective filing date is that the date on that the earliest U.S. application is filed beneath that priority is claimed. Within the us, patent rights begin once the patent is issued.

Upon expiration of the term, the invention becomes holding and is freely offered to be used, copy, or sale. Patents will be extended for up to 5 years beneath restricted circumstances, together with interference proceedings secrecy orders, and proceeding review.

8.1.4.3 Patentable Inventions

The Patent Act provides a broad definition of what are often patented: any new or helpful method, machine, manufacture, composition of matter, or any new and helpful improvement thence. Though these classes of patentable subject material area unit broad, they're also exclusive, and any item that doesn't comprise one in all them isn't patentable.

As outlined by the Patent Act, a method may be a technique of treating bound material to supply a particular phase transition within the character or quality of that material. A machine may be a device that uses energy to urge work done. The term manufacture refers to a method whereby an article is created by the art or trade of individuals. A composition of matter may be a compound made from the mix of 2 or more specific ingredients that has properties totally different from, or additionally to, those on an individual basis possessed by every ingredient.

An improvement is any addition to or alteration in, a known method, machine, manufacture, or composition that produces a helpful result. The right to a patent of associate improvement is restricted to the development itself and doesn't embody the method, machine, or article improved.

Naturally occurring substances, like a kind of microorganism or part, don't seem to be patentable. However a genetically designed microorganism is patentable. The law of gravity and different laws of nature don't seem to be patentable. Different abstract principles, elementary truths, calculation strategies, mathematical algorithms, pc programs, and accountancy systems don't seem to be patentable. Ideas, mental theories, or plans of action alone, without concrete suggests that to implement them, don't seem to be patentable, regardless of however revolutionary and helpful to humanity they could be.

8.1.5 BELONGINGS RIGHTS

A legal system, like different kinds of intellectual and industrial property, is one in all a spread of incentive devices employed by governments to correct true in sectors of economy wherever there's judged to be a bent towards beneath commitment of resources to data protection and innovation.

The on top of was expressed by the Economic Council of North American nation in its Report in 1971 on Intellectual and Industrial Property.

Intellectual property can now not be seen as distinct or self-contained domain, however rather as a crucial and effective policy instrument that may be relevant to a good vary of socio-economic, technological and political considerations. The event of skills and ability to manage IPR and leverage its influence can would like increasing focus; particularly, among the developing countries...One of the considerations of the developing world is that the method of economic process is threatening the appropriation of parts of this collective data of societies into proprietary data for the business profit of some. Associate pressing action is required to shield these fragile data systems through national policies and international understanding joined to IPR, whereas providing its development and correct use for the good thing about its holders.

Following the emergence of sturdy world and national belongings regimes the topic of belongings rights (IPRs) and their protection has become a central issue in economic development, scientific and technological development, protection of mental object and scientific and economic cooperation between industrial and developing countries. There's opposition or apprehension significantly in developing countries to the terribly plan of the requirement of strong belongings regimes. It's believed that solely the developed countries can take advantage of it. The opposite hand then again on the other facet it's believed that 'establishing possession of intellectual assets, incoming at acceptable frameworks for truthful and just sharing of advantages for social sensible and providing consonant legal structures to encourage continuous flow of innovation area unit clean requirements to fuel a vivacious world eponymy.' The topic of belongings rights is very complicated. Our intention isn't to travel into the deserves and demerits of the evolving world economic belongings regimes. Here we tend to will describe shortly the fundamental aspects of belongings rights. This article are finished in four parts:

Part I: a quick description of general aspects of belongings rights and discussion on the legal system.

Part II: Copyrights, Trade Marks and Industrial styles

Part III: World belongings Organization (WIPO); Trade connected

belongings Rights (TRIPS) and different international agreements on belongings rights.

Part IV: IPR connected technical terms and relevant sources.

Intellectual property primarily includes the merchandise or creations of the mind, and belongings laws aim at 'safeguarding creators and different producers of intellectual merchandise and services by granting them bound time-limited rights (intellectual property rights) to regulate the employment product of those productions.'

historically belongings is split into 2 groups:

Group I: Industrial Property

Industrial property includes inventions (process, merchandise and apparatus); Industrial styles (shapes and ornamentation); and Marks and Trade-names to differentiate merchandise. Recently the scope of commercial property has been swollen to incorporate 'among others, the protection of distinctive geographical indications (in explicit, appellations of origin), plant varieties, and also the layout styles (topographies) of integrated circuits, further because the repression of unfair competition, together with the protection of trade secrets.'

Group II: Copyrights

Copyrights loosely embody Literary works; Musical works, together with any incidental words; Dramatic works, together with any incidental music; Pantomimes and dance works; Pictorial, graphic, and sculptural works; flick and different audiovisual works; Sound recordings; and study works.

Recently associate expression referred to as 'neighboring rights' has been additional to the idea of copyrights. The expression "neighboring rights" is that the abbreviated style of "rights neighboring on copyright". the subsequent 3 kinds of rights area unit lined by the idea of neighboring rights:

The rights of acting artists in their performance

The rights of producers of phonograms in their phonograms

The rights of broadcasting organizations in their radio and tv broadcasts.

The convention Establishing the planet belongings Organization (WIPO) finished in Stockham a July fourteen, 1967 (Article a pair of (viii) provides that "Intellectual property" shall embody rights about :

Literary, creative and scientific works

Performances of acting artists, phonograms and broadcasts

Inventions altogether fields of human endeavor

Scientific discoveries

Industrial styles

Trademarks, service marks, and business names and designations.

Protection against unfair completion and every one different rights ensuing from intellectual activity within the industrial scientific, accomplishment or creative fields.”

Intellectual property different style of standard kinds of property is an quality. similar to real and private property the belongings may also be brought, sold, licensed, changed or gratuitously given away. Belongings owner has additionally the correct to stop the unauthorized use or sale of the property. The foremost putting distinction between belongings and different style of property is that it's intangible that's it can't be outlined or known by its own physical parameters. Therefore belongings should be expressed in some discernible means for enabling it to be protected. Not like a object associate belongings like an inspiration for invention, a bit of music or a trademark can't be protected against different person's use of them by merely possessing the thing. Thence the requirement of enacting belongings laws distinct from standard laws protective personal estate.

The apply of shaping belongings started within the Italian town States. It's been rumored that the primary patent was granted to architect within the Republic of Florence in 1421. Brunelleschi was given a 3 year monopoly for his invention regarding special hoisting gear used on barges. Associate ordinance about patents was 1st enacted in a very Venetian law of 1474. From the Italian town States the apply unfold to different western European countries. In European nation throughout the reign of Elizabeth I (1533-1603), her minister, Lord Burghley (1520-98), granted a series of patents with a read to encouraging foreign inventors to import their inventions and work them in European nation. It absolutely was additionally meant to stimulate inventions by domestic producers. In Republic of India the fundamental parts of belongings rights were 1st introduced by enacting the Act on Protection of Inventions in 1856. This Act, that was supported country jurisprudence of 1852, was the origin of patent legislation in Republic of India. A written record perspective of the event of Indian IPR is given in Box-I. A lest of international and regional agreements.

An invention could also be outlined because the plan of constructing a replacement and helpful article, technique or substance. The WIPO Model Law for Developing Countries on Inventions (1979) defines invention 'as an inspiration of associate artificer which allows in apply the answer of a particular drawback in a very field of technology.' The fundamental root of the word 'invention' returns from the Latin word 'in venire' which implies 'to come upon'. With most inventions there's a way of surprise. There

could also be several reasons for creating invention. The foremost obvious ones are:

- * For private satisfaction.
- * For finding a retardant moon-faced in way of life
- * For being recognized by others.
- * For the need to require up a challenging/interesting task.
- * For the need to create cash

In trade the demand for the event of latest technology, that's the demand for 'inventive activity' is usually influenced by the expected rates of come backs thereto activity compared with rates of return that may be achieved by finance in non-inventive activity together with the adoption of other existing technologies.

Normally a distinction is created between inventions that concern with merchandise and inventions that concern with processes. For example for instance as associate example associate invention that consists of a replacement drug may be a product invention however an invention that consists of a replacement technique or method of constructing a known or new drug may be a method invention. The corresponding patents area unit sometimes referred

to as a 'product patent' and a 'process patent' severally.

Not all inventions are unit patentable. The fundamental criteria for an invention to be patentable (as needed by the patent laws of virtually all the countries) are: it should be novel, it should involve an artless step (or it should be non-obvious), and it should have some industrial application. On the other hand although the invention is new it's going to not be patentable as in step with the patent laws of bound countries bound articles, processes or ideas that simply can't be protected although they're new. Things that are unit non-patentable in Republic of India is given in Box-III.

For every invention there ought to be a separate application. However, if a gaggle of inventions are unit so-linked to create one general creative idea one application can fulfill. The language during which an application is to be crammed is additionally fastened. It can't be written in any language. In Republic of India an application should be written in English. The whole specification of an application ought to embody the subsequent :

- * Within the object or title of the invention.
- * Previous art or cross-references to connected applications, if any.
- * Transient outline of the invention.
- * Transient description of many views of the drawing, if there are unit drawings.
- * Careful description of the invention.
- * Claim or claims.

* Abstract of the revelation.

The title of the invention ought to be as short and specific as attainable. The specification should bring out the precise invention.

A application or patent document may be a technical literature and it should be developed in such some way that it conforms to the wants of jurisprudence of the country during which the application is filed. The conventions area unit more-or-less similar altogether the countries. Solely a talented person conversant in jurisprudence are ready to draft a patent claim. It's a standard apply to interact the services of a patent agent/patent professional once seeking to create associate application for getting a patent. The patent agent's talent and knowledge play an important role in drafting the claims. The drafting ought to cowl the invention within the broadest attainable means so the inventor's right area unit properly protected. It's the patent agent World Health Organization advises whether or not associate invention is patentable or not.

The idea of the correct given by a legal right is commonly misunderstood. The grant of a patent carries with it no positive right. This is often contrary to our common expertise of possession just in case of most personal estate wherever one enjoys a positive right. The correct of possession in a very patent may be a negative right - the negative right to exclude others from creating, victimization or merchandising the proprietary invention. The mere granting of a patent doesn't make sure that it might alter the

artificer to create, use or sell the invention. Thus, whereas the owner of a patent isn't given a statutory right to apply his/her invention, he/she is given a statutory right to exclude others from active their proprietary invention. The exclusionary privilege given to the owner of a patent may be a negative right. In fact, in making, victimization or merchandising his or her own invention, the artificer might notice that he or she infringes the legal right of others. Solely in those cases once the invention is extremely basic to art will the grant of a patent fight the characteristics of a positive right. A patent is that the monopoly granted by the State to associate artificer for a hard and fast amount in exchange for the revelation of the invention so others might take advantage of the invention. The revelation of associate invention is taken into account of significant importance in any patent granting procedure.

8.1.6 Cyber Law in INDIA

WHY CYBERLAW IN INDIA?

When web was developed, the introduction fathers of web hardly had any inclination that web might remodel itself into an all pervasive revolution that can be ill-used for criminal activities and that needed regulation. Today, there square measure several distressful things happening in Net. Thanks to the anonymous nature of the web, it's potential to interact into a range of criminal activities with exemption and other people with intelligence are grossly misusing this side of the web to preserve criminal activities in Net. Therefore the requirement for Cyber laws in India.

WHAT IS THE IMPORTANCE OF CYBERLAW?

Cyberlaw is very important as a result of it touches the majority aspects of transactions and activities on and regarding the web, the globe Wide net and Net.ab initio it's going to appear that Cyberlaws may be a terribly technical field which it doesn't have any bearing to most activities in Net. However the particular truth is that nothing can be any than the reality. Whether or not we have a tendency to understand it or not, each action and each reaction in Net has some legal and Cyber legal views.

CYBER LAWS IN INDIA

Crime is each a social and economic development. It's as previous as human society. Several ancient books right from pre-historic days, and mythological stories have spoken concerning crimes committed by people be it against another individual like standard thieving and felony or against the state like spying, treason etc. Kautilya's Arthashastra written around 350 BC, thought-about to be an authentic body piece of writing in India, discusses the assorted crimes, security initiatives to be taken by the rulers, potential crimes during a state etc. and conjointly advocates penalisation for the list of some stipulated offences. Totally different varieties of punishments are prescribed for listed offences idea of restoration of loss to the victims has also been mentioned in it.

Crime in any kind adversely affects all the members of the society. In developing economies, crime has augmented at fast strides, thanks to the fast diffusion of the web and therefore the conversion of economic activities. Due to the massive penetration of technology in the majority walks of society right from company governance and state administration, up to rock bottom level of petty search keepers computerizing their asking system, we discover computers and alternative electronic devices pervasive the human life. The penetration is therefore deep that man cannot pay each day while not computers or a mobile.

Snatching some one's mobile can equivalent to marketing one in solitary confinement!

Cyber Crime isn't outlined in info Technology Act 2000 or within the I.T. change Act 2008 or in the other legislation in India. In fact, it cannot be too. Offence or crime has been restrained intricately listing varied acts and therefore the punishments for every, below the Indian legal code, 1860 and quite few alternative legislations too. Hence, to outline cyber crime, we can say, it's simply a mixture of crime and laptop. To place it in easy terms 'any offence or crime within which a laptop is employed may be a cybercrime'. apparently even a petty offence like stealing or pick-pocket is brought inside the broader horizon of crime if the fundamental knowledge or aid to such AN offence may be a laptop or an info keep during a laptop used (or misused) by the fraudster. The I.T. Act defines a laptop, network, data, info and every one alternative necessary ingredients that kind a part of a crime, concerning that we'll currently be discussing thoroughly.

In a crime, laptop or the information itself the target or the thing of offence or a tool in committing another offence, providing the required inputs for that offence. All such acts of crime can return below the broader definition of crime.

Objectives of I.T. legislation in India:. It's against this background the govt. of India enacted its info Technology Act 2000 with the objectives as follows, expressed within the preface to the Act itself.

“To give legal recognition for transactions applied by suggests that of electronic knowledge interchange and alternative suggests that of transmission, normally stated as “electronic commerce”, that involve the employment of alternatives to paper-based strategies of communication and storage of knowledge, to facilitate electronic filing of documents with the govt. agencies and any to amend the Indian

Penal Code, the Indian proof Act, 1872, the Bankers' Books proof Act, 1891 and therefore the Reserve Bank of India Act, 1934 and for matters connected thereupon or incidental to it.”

The Information Technology Act, 2000, was therefore passed because the Act No.21 of 2000, got President Assent on nine Gregorian calendar month and was created effective from seventeen Oct 2000.

The Act primarily deals with the subsequent issues:

Legal Recognition of Electronic Documents

Legal Recognition of Digital Signatures

Offenses and Contraventions

Justice Dispensation Systems for cybercrimes.

Amendment Act 2008: Being the primary legislation within the nation on technology, computers and ecommerce and e-communication, the Act was the topic of in depth debates, elaborate reviews and elaborated criticisms, with one arm of the business criticizing some sections of the Act to be Athenian and alternative stating it's too diluted and lenient. There have been some conspicuous omissions too leading to the investigators relying a lot of and a lot of on the reliable (one and half century-old) Indian legal code even in technology based mostly cases with the I.T. Act conjointly being referred within the method and therefore the reliance a lot of on IPC rather on the ITA.

Thus the requirement for a change - a close one - was felt for the I.T. Act nearly from the year 2003-04 itself. Major business bodies were consulted and informative teams were shaped to travel into the perceived lacunae within the I.T. Act and comparison it with similar legislations in alternative nations and to counsel recommendations. Such recommendations were analyzed and later obsessed as a comprehensive change Act and when considerable body procedures, the consolidated change referred to as the data Technology change Act 2008 was placed within the Parliament and passed while not a lot of discussion, towards the top of 2008 (by which era the city terrorism of twenty six Gregorian calendar month 2008 had taken place). This change Act got the President assent on five Gregorian calendar month 2009 and was created effective from twenty seven Oct 2009.

Some of the notable options of the ITAA square measure as

follows:

Specializing in knowledge privacy

Specializing in info Security

Process cyber cafe

Creating digital signature technology neutral

Process affordable security practices to be followed by company

Redefining the role of intermediaries

Recognizing the role of Indian laptop Emergency Response Team

Inclusion of some extra cybercrimes like pornography and cyber terrorist act authorizing an Inspector to research cyber offences.

In this chapter, we'll be loosely discussing the assorted provisions of ITA 2000 and where an equivalent has been amended or a brand new section additional as per the ITAA 2008, such remark are going to be created suitably.

How the Act is structured: The Act whole has thirteen chapters and

ninety sections (the last four sections specifically sections ninety one to ninety four within the ITA 2000 restrained the amendments to the four Acts specifically the Indian legal code 1860, The Indian proof Act 1872, The Bankers' Books proof Act 1891 and therefore the bank of Bharat Act 1934).

Elaborate procedures for certifying authorities (for digital certificates as per IT Act-2000 and since replaced by electronic signatures within the ITAA -2008) are corn out. The civil offence of information thieving and therefore the method of assessment and appellant procedures are delineated. Then the Act goes on to outline and describe a number of the well-known cybercrimes and lays down the punishments so.

Then the idea of due diligence, role of intermediaries and a few miscellaneous provisions are delineated.

Rules and procedures mentioned within the Act have conjointly been set down during a phased manner, with the newest one on the definition of personal and sensitive personal knowledge and therefore the role of intermediaries, due diligence etc., being outlined as recently as April 2011.

Applicability: The Act extends to the entire of India and except as otherwise provided, it applies to also any offence or resistance there below committed outside India by a person. There square measures some specific exclusion to the Act (ie wherever it's not

applicable) as elaborated within the first Schedule, expressed below:

- a) Instrument (Other than a cheque) as outlined in section thirteen of the Negotiable Instruments Act, 1881;
- b) a power-of-attorney as outlined in section 1A of the Powers-of-Attorney Act, 1882;
- c) a trust as outlined in section three of the Indian Trusts Act, 1882
- d) a will as outlined in clause (h) of section 2 of the Indian Succession Act, 1925 together with the other official document disposition
- e) any contract for the sale or conveyance of immobile property or any interest in such property;
- f) any such category of documents or transactions as could also be notified by the Central Government

Definitions: The ITA-2000 defines several necessary words employed in common laptop idiom like 'access', 'computer resource', 'computer system', 'communication device', 'data', 'information', 'security procedure' etc. The definition of the word 'computer' itself assumes significance here. 'Computer' suggests that any electronic magnetic, optical or alternative high-speed processing device or system that performs logical, arithmetic, and memory functions by manipulations of electronic, magnetic or optical impulses, and includes all input, output, processing, storage, laptop software package, or communication facilities that square measure connected or associated during a ADP system or computer network; therefore is that the word 'computer system' which suggests a tool or a set

of devices with input, output and storage capabilities. apparently, the word 'computer' and 'computer system' are therefore wide outlined to mean any device with processing capability, playacting laptop functions like logical, arithmetic and memory functions with input, storage and output capabilities. A careful reading of the words can build one perceive that a high-end programmable gadgets like even a washing machine or switches and routers employed in a network will all be brought below the definition.

Similarly the word 'communication devices' inserted within the ITAA-2008 has been given an comprehensive definition, taking into its coverage cell phones, personal digital help or such alternative devices accustomed transmit any text, video etc like what was later being marketed as iPad or alternative similar devices on Wi-fi and cellular models. Definitions for a few words like 'cyber cafe' were also later incorporated within the ITAA 2008 once 'Indian laptop response Emergency Team' was enclosed.

Digital Signature: 'Electronic signature' was outlined within the ITAA -2008 whereas the sooner ITA -2000 coated thoroughly concerning digital signature, process it and elaborating the procedure to get the digital signature certificate and giving it legal validity. Digital signature was outlined within the ITA -2000 as "authentication of electronic record" as per procedure set down in Section three and Section three mentioned the employment of uneven crypto system and therefore the use of Public Key Infrastructure and hash operate etc.

This was later criticized to be technology dependent i.e., looking forward to the particular technology of uneven crypto system and therefore the hash operate generating a try of public and personal key authentication etc. therefore Section three that was originally “Digital Signature” was later renamed as “Digital Signature and Electronic Signature” in ITAA - 2008 therefore introducing technological neutrality by adoption of electronic signatures as a lawfully valid mode of capital punishment signatures. This includes digital signatures united of the modes of signatures and is much broader in compass covering bioscience and alternative new sorts of making electronic signatures not confining the popularity to digital signature method alone. While M/s. TCS, M/s. Safescript and M/s. MTNL square measure a number of the digital signature certifying authorities in India, IDRBT (Institute for Development of analysis in Banking Technology - the analysis wing of RBI) is that the Certifying Authorities (CA) for the Indian Banking and money sector authorized by the Controller of Certifying Authorities, Government of India.

It is relevant to grasp which means of digital signature (or electronic signature) here. It might be pertinent to notice that electronic signature (or the sooner digital signature) as stipulated within the Act isn't a digitized signature or a scanned signature. In fact, in electronic signature (or digital signature) there's no real signature by the person, within the typical sense of the term. Electronic signature isn't the method of storing ones signature or scanning ones signature and causing it in an transmission like

email. It's a method of authentication of message exploitation the procedure set down in Section three of the Act.

The other sorts of authentication that square measure easier to use like biometric based mostly tissue layer scanning etc is quite helpful in effective implementation of the Act. However, the Central Government has got to evolve elaborated procedures and increase awareness on the employment of such systems among the general public by fixing place the required tools and stipulating necessary conditions. Besides, duties of electronic signature certificate issue authorities for bio-metric based mostly authentication mechanisms have to be compelled to be evolved and therefore the necessary parameters have to be compelled to be developed to form it easy and at an equivalent time while not compromising security.

Section forty three deals with penalties and compensation for injury to laptop, ADP system etc.

This section is that the 1st major and vital legislative step in India to combat the problem of information thieving. The IT business has for long been cry for legislation in India to handle the crime of information thieving, similar to physical thieving or stealing of products and commodities. This Section addresses the civil offence of thieving of information. If a person while not permission of the owner or the other one who is accountable of a laptop, accesses or downloads, copies or extracts any knowledge or introduces any laptop stuff like virus or damages or disrupts any laptop or denies

access to a laptop to a certified user or tampers etc...he shall be vulnerable to pay damages to the person therefore affected. Earlier within the ITA -2000 the most damages below this head was Rs.1 crore, that (the ceiling) was since removed within the ITAA 2008.

The essence of this Section is civil liability. Criminalist within the offence of information thieving is being one by one restrained later below Sections sixty five and sixty six. Writing a virulent disease program or spreading a virulent disease mail, a bot, a Trojan or the other malware during a network or inflicting a Denial of Service Attack during a server can all return below this Section and attract civil liability by means of compensation. Below this Section, words like worm, reason stuff, on-line database and ASCII text file square measure all delineated and outlined.

Questions just like the} employees' liability in a corporation that is sued against for knowledge thieving or such offences and therefore the quantity of responsibility of the leader or the owner and therefore the idea of due diligence were all debated within the 1st few years of ITA -2000 in court litigations like the bazee.com case and alternative cases. Later want was felt for outlining the company liability for knowledge protection and data security at the company level was given a heavy look.

Thus the new Section 43-A dealing with compensation for failure to protect knowledge was introduced within the ITAA -2008. This is often another watershed within the space of information protection particularly at the company level.

As per this Section, wherever a body company is negligent in implementing affordable security practices and thereby causes wrongful loss or gain to a person, such body company shall be vulnerable to pay damages by means of compensation to the person therefore affected. The Section any explains the phrase 'body corporate' and quite considerably the phrases 'reasonable security practices and procedures' and 'sensitive personal knowledge or information'.

Adjudication: Having restrained civil offences, the Act then goes on to explain civil remedy to such offences within the kind of assessment while not having to resort to the procedure of filing a grievance with the police or alternative work agencies. Assessment powers and procedures are intricately set down in Sections forty six and thenceforth. The Central Government could appoint any officer not below the rank of a director to the govt. of Bharat or a authorities because the individual. The I.T. Secretary in any state is often the appointive individual for all civil offences arising out of information thefts and resultant losses within the specific state. If in any respect one section is criticized to be fully lacking in quality within the IT Act, it's this provision. Within the 1st 10 years of existence of the ITA, there are solely a really few applications created within the nation, that too within the major metros the majority of that square measure below totally different stages of judicial method and adjudications are obtained in probably but 5 cases. The primary assessment obtained below this provision was in city, Tamil Nadu, during a case involving ICICI Bank within

which the bank was told to compensate the soul with the quantity de jure debited in web banking, alongside price and damages. In April 2010.

This section ought to run a lot of quality and awareness ought to be unfold among the general public particularly the victims of cybercrimes and data thieving that such a procedure will exist while not recourse to reaching to the police and filing a case. It's time the state spends a while and thought in enhancing awareness on the availability of assessment for civil offences in cyber litigations like knowledge thieving etc so the aim that such helpful provisions are created, square measure effectively utilized by the litigator public.

There is AN appellant procedure below this method and therefore the composition of Cyber appellant court at the national level, has also been delineated within the Act. Each adjudicating officer has the powers of a civil court and therefore the Cyber appellant court has the powers unconditional during a civil court below the Code of Civil Procedure.

After discussing the procedures regarding appeals etc and therefore the duties and powers of Cyber appellant court, the Act moves to the particular criminal acts coming back below the broader definition of cybercrimes.

It would be pertinent to notice that the Act solely lists a number

of the cybercrimes, (without process a cybercrime) and stipulates the punishments for such offences.

8.1.7 Software package Licensing

Allowing a private or cluster to use a bit of software package. Nearly all applications square measure authorized instead of sold. There square measure a range of various kinds of software package licenses. Some square measure supported the quantity machines on that the authorized program will run whereas others square measure supported the quantity of users which will use the program. Most laptop computer software package licenses enable North American country to run the program on only 1 machine and to form copies of the software package just for backup functions. Some licenses also enable North American country to run the program on totally different computers as long as we do not use the copies at the same time.

8.1.7.1 SOFTWARE PACKAGE LICENSE SORTS

Each software package producing company has their distinctive software package license sort except for the many common license sorts. Since it's not possible to support of these license sorts, ServiceDesk and helps North American country to customise the license sorts for all software package makers supported the workstations and users.

To access the software package License sorts configuration page,

Click the Admin tab within the header pane to open the configuration wizard page.

Click software package License sorts icon below software package block. The list of default license sorts filtered by the manufacturer is displayed.

Individual: License sort for single installation

OEM (Original Instrumentality Manufacturers): License sort for software package that's already put in within the hardware.

Named User License: License sort for a particular user.

Volume: License sort supporting multiple users.

Client Access License (CAL): License sort that offers a user the rights to access the services of the server.

Trial License: License sort for trial versions of software package.

Enterprise (Perpetual): License sort that doesn't need renewal and is always long.

Concurrent License: License sort for software package which will be accessed by a particular range of users at a time.

Free License: License sort for software package software package.

Enterprise Subscription: License sort that needs renewal for each specific amount.

Node Locked: License sort for workstations with specific configurations.

Apart from the default license sorts out there within the application, you'll add, edit and delete software package License sorts.

Adding New License sort

Click Add New License sort link.

Enter the License sort say Volume, Enterprise, customary and then on. In general, every manufacturer depicts their license sorts unambiguously and then the license sort must be such that consequently to the manufacturer. This field is necessary.

Choose the software package Manufacturer from the sink. If needed, we are able to also add a brand new manufacturer exploitation the Add New Manufacturer icon.

The software package license is caterpillar-tracked by workstations or users.

Workstations : The license is allotted to the digital computer.

User: The license is allotted to the digital computer furthermore because the user.

Select the corresponding possibility from Track By sink.

opt for anybody possibility from Installation allowed sink.

Single: The same as individual license, only 1 installation is allowed for this license sort.

Volume: Multiple installation(s) is allowed for this license sort.

Unlimited: Unlimited installation(s) is allowed for this license sort.

OEM (Original Instrumentality Manufacturers): The software package license is hooked up to the hardware i.e. hardware say, laptops that the software package is put in. The software package can not be transferred to a different digital computer and therefore the license expires once the digital computer is stirred to Disposed state.

If we've got elect digital computer because the Track By possibility, the Is Node bolted possibility seems. This feature is enabled for digital computer with specific configurations. Facultative this feature mechanically changes the Installation Allowed field to Single.

If we've got elect Users, the Users Allowed field seems. From this field choose the quantity of users United Nations agency can access the software package, say, Single, Volume (multiple) or Unlimited.

If the software package is just the once installation and doesn't

need a renewal, enabled Is Perpetual check box.

If the software package is software package with unlimited installations and no expiration date, alter Is Free License check box.

Few software package license sorts is divided into sub license sorts say as an example, with shopper Access License (CAL) you'll purchase license for each user United Nations agency access the server (Per User) or license for each device that accesses the server (Per Device).

Enter the License possibility and click on augment add it within the choose list field. We have a tendency to even have AN choice to delete the License possibility from the choose list field. Choose the license possibility and click on the delete icon.

Editing License sort

From the software package - License sorts page, click on the Edit icon beside the License sort you want to edit.

The software package - License sorts page opens with the values inhabited whereas adding the License sort.

Modify the desired details and Save the changes.

Deleting License sort

From the software package - License sort's page, choose the Manufacturer from the Filter sink.

Choose the check box beside the license sort to be deleted.

Click Delete button. A panel confirming the delete operation seems.

Click okay to continue. The software package - License sort is deleted from the chosen manufacturer list.

8.1.8 Semiconductor Law and jurisprudence

A semiconductor product is that the final or intermediate kind of an incorporated circuit during a chip. It's an electronic operate.

The topography is that the style of the layout, that is, the three-dimensional location of parts and interconnections of an computer circuit. Whereas the economic style determines the external look of the device, the topography determines the precise location of every component with an electronic operate inside the computer circuit.

The rights granted by this legal title square measure the same as those for patents, trademarks, industrial styles, copyright and neighboring rights.

The owner has AN privilege of exploitation furthermore because the right to stop third parties from reproducing, mercantilism or mercantilism elements or the whole thing of the protected topography.

This privilege of exploitation sometimes expires:

10 years when the primary industrial exploitation anyplace within the world, or

10 years when the registration was filed with the competent authority, typically the Patent and Trademark workplace

8.1.8.1 Why shield the topography of a semiconductor product?

The topography of AN computer circuit is that the results of an enormous investment in terms of each finance and ability. This is often conjointly a field within which there's constant want for improvement, like reducing the size of integrated circuits. For these reasons, government offices reward these creations of the mind by granting monopoly right of exploitation to the creator.

Topographies of semiconductor product even have hefty industrial worth as they'll be utilised during a wide selection of product. A duplicate of the planning can be done simply by photographing the layers of the computer circuit. This is often why legislation to safeguard layout styles has been introduced.

8.1.8.2 Reverse Engineering allowed for Semiconductor Chips

- 1) will copy the functions of chips
 - 2) will have the command structure
 - 3) will have same inputs and outputs
 - 4) solely restricts precise duplication
- * Target is chip piracy of actual copies
 - * bar of photographic mask repetition
- 5) needs registration inside two years of economic use.

8.1.8.3 Chip Act: A Hybrid of Laws

This act borrows from each patent and copyright to form a brand new hybrid laws. It's like copyright," excludes any procedure, process, system or mode of operation". it's also like patent, needs non-obviousness therein styles square measure excluded that square measure stable. During this act notification is needed (circle of M for Mask).

8.1.8.4 Chip Act Right and Exceptions

- 1) Exclusive rights to replica, importation, and distribution.
- 2) ten year right will begin up to two years when industrial exploitation started.
- 3) Exclusion permits USE of chip mask to form a brand new and higher chip once infringement is simply for analysis

* New chip should be original enough to safeguard.

8.2 ANSWER THE FOLLOWING QUESTIONS:

What is policy? How it minimizes security risk?

Give the various key things that should be included while writing a IT policy to keep the network secure and stable.

What is ISO? Explain various standards of ISO.

What are the issues addressed by Information Technology Act 2000?

Describe copyright.

What are the two forms of Copyright? Explain.

Explain ISP in detail.

Explain various **On-line copyright issues in India.**

What do you mean by patents?

How many types of patents are?

What is Intellectual property right? Explain in detail.

What are the other rights that should be include in IPR?

What is cyber law? Explain its importance.

What is the difference between Digital Signature and Electronic Signature?

Give a brief description of cyber Laws in india.

What is software licensing? Also explain its various types.

What are the steps to be followed to access the Software License Types configuration page?

Describe about Semiconductor law.

What is Patent Law?

How information Security standards helps in Cyber Security?

Important Questions

1. What is information security?

Information security in today's enterprise is a “well-informed sense of assurance that the information risks and controls are in balance.” -Jim Anderson, Inovant (2002)

The protection of information and its critical elements, including the systems and hardware that use, store, and transmit that information

Tools, such as policy, awareness, training, education, and technology are necessary

2. What is C.I.A?

The C.I.A. triangle was the standard based on confidentiality, integrity, and availability. The C.I.A. triangle has expanded into a list of critical characteristics of information

3. Write a note on the history of information security

Computer security began immediately after the first mainframes were developed

Groups developing code-breaking computations during World War II created the first modern computers

Physical controls were needed to limit access to authorized personnel to sensitive military locations

Only rudimentary controls were available to defend against physical theft, espionage, and sabotage

4. What is the scope of computer security?

The scope of computer security grew from physical security to include:

- (a) Safety of the data
- (b) Limiting unauthorized access to that data
- (c) Involvement of personnel from multiple levels of the organization

5. What is Security?

“The quality or state of being secure--to be free from danger”

To be protected from adversaries

6. Define Physical security

Physical Security - to protect physical items, objects or areas of organization from unauthorized access and misuse. Protect the physical asset.

7. Define Personal Security

Personal Security involves protection of individuals or group of individuals who are authorized to access the organization and its operations.

8. Define Operations security

Operations security focuses on the protection of the details of particular operations or series of activities. It handles with the resources of the organization.

9. Define Communications security

Communications security - encompasses the protection of organization's communications media, technology and content.

10. Define Network security

Network security - is the protection of networking components, connections and contents

11. Define Information security

Information security - is the protection of information and its critical elements, including the systems and hardware that use, store and transmit the information

12. What are the critical characteristics of information?

Availability

Accuracy

Authenticity

Confidentiality

Integrity

Utility

Possession

13. What is NSTISSC Security model?

This refers to “The National Security Telecommunications and Information Systems Security Committee” document. This document presents a comprehensive model for information security. The model consists of three dimensions.

14. What are the components of an information system?

An Information System (IS) is much more than computer hardware; it is the entire set of software, hardware, data, people, and procedures necessary to use information as a resource in the organization.

15. What is meant by balancing Security and Access?

Balancing Security and Access

It is impossible to obtain perfect security - it is not an absolute; it is a process

Security should be considered a balance between protection and availability

To achieve balance, the level of security must allow reasonable access, yet protect against threats

16. What are the approaches used for implementing information security?

Bottom Up Approach

Top-down Approach

17. What is SDLC?

The Systems Development Life Cycle

Information security must be managed in a manner similar to any other major system implemented in the organization

Using a methodology

ensures a rigorous process

avoids missing steps

18. What is Security SDLC?

Security Systems Development Life Cycle

The same phases used in the traditional SDLC adapted to support the specialized implementation of a security project

Basic process is identification of threats and controls to counter them

The sec SDLC is a coherent program rather than a series of random, seemingly unconnected actions

19. What are the four important functions, the information security performs in an organization?

Information security performs four important functions for an organization:

Protects the organization's ability to function

Enables the safe operation of applications implemented on the organization's IT systems

Protects the data the organization collects and uses

Safeguards the technology assets in use at the organization

20. What are threats?

A threat is an object, person, or other entity that represents a constant danger to an asset

Management must be informed of the various kinds of threats facing the organization

By examining each threat category in turn, management effectively

Protects its information through policy, education and training, and technology controls.

21. What are different acts of Human error or failure?

Includes acts done without malicious intent. It is Caused by:

Inexperience

Improper training

Incorrect assumptions

Other circumstances

22. What is Intellectual property?

Intellectual property is “the ownership of ideas and control over the tangible or virtual representation of those ideas”. Many organizations are in business to create intellectual property

trade secrets

copyrights

trademarks

patents

23. What is deliberate acts of espionage or trespass?

Broad category of activities that breach confidentiality

Unauthorized accessing of information

Competitive intelligence vs. espionage

Shoulder surfing can occur any place a person is accessing confidential information

Controls implemented to mark the boundaries of an organization's virtual territory giving notice to trespassers that they are encroaching on the organization's cyberspace

Hackers uses skill, guile, or fraud to steal the property of someone else.

24. Who are Hackers? What are the two hacker levels?

The classic perpetrator of deliberate acts of espionage or trespass is the hacker. Hackers are “people who use and create computer software [to] gain access to information illegally”. Generally two skill levels among hackers:

Expert hacker

unskilled hacker (Script kiddies)

25. What is information extortion?

Information extortion is an attacker or formerly trusted insider stealing information from a computer system and demanding compensation for its return or non-use

Extortion found in credit card number theft (A Russian hacker named Maxus, who hacked the online vendor and stole several

hundred thousand credit card numbers.

26. What is Cyber terrorism?

Cyberterrorism is amongst sinister form of hacking involving cyberterrorists hacking systems to conduct terrorist activities through network or internet pathways.

An example was defacement of NATO web pages during the war in Kosovo.

27. What are deliberate software attacks?

When an individual or group designs software to attack systems, they create malicious code/software called malware

Designed to damage, destroy, or deny service to the target systems

Includes:

macro virus

boot virus

worms

Trojan horses

logic bombs

back door or trap door

denial-of-service attacks

polymorphic

28. What are technical hardware failures or errors?

Technical hardware failures or errors occur when a manufacturer distributes to users equipment containing flaws

These defects can cause the system to perform outside of expected parameters, resulting in unreliable service or lack of availability

Some errors are terminal, in that they result in the unrecoverable loss of the equipment

Some errors are intermittent, in that they only periodically manifest themselves, resulting in faults that are not easily repeated

29. What are technical software failures or errors?

This category of threats comes from purchasing software with unrevealed faults

Large quantities of computer code are written, debugged, published, and sold only to determine that not all bugs were resolved

Sometimes, unique combinations of certain software and hardware reveal new bugs

Sometimes, these items aren't errors, but are purposeful shortcuts left by programmers for honest or dishonest reasons

30. What is technological obsolescence?

When the infrastructure becomes antiquated or outdated, it leads to unreliable and untrustworthy systems

Management must recognize that when technology becomes outdated, there is a risk of loss of data integrity to threats and attacks

Ideally, proper planning by management should prevent the risks from technology obsolescence, but when obsolescence is identified, management must take action

31. What is an attack?

An attack is the deliberate act that exploits vulnerability

It is accomplished by a threat-agent to damage or steal an organization's information or physical asset

An exploit is a technique to compromise a system

A vulnerability is an identified weakness of a controlled system whose controls are not present or are no longer effective

An attack is then the use of an exploit to achieve the compromise of a controlled system

32. What is a malicious code?

This kind of attack includes the execution of viruses, worms, Trojan horses, and active web scripts with the intent to destroy or steal information. The state of the art in attacking systems in 2002 is the multi-vector worm using up to six attack vectors to exploit a variety of vulnerabilities in commonly found information system devices.

33. What is Distributed Denial-of-service (DDoS)?

DDoS is an attack in which a coordinated stream of requests is launched against a target from many locations at the same time.

34. Define Dictionary attack

The dictionary password attack narrows the field by selecting specific accounts to attack and uses a list of commonly used passwords (the dictionary) to guide guesses.

35. What are the various forms of attacks?

IP Scan and Attack

Web Browsing

Virus

Unprotected Shares

Mass Mail

SNMP

Hoaxes

Back Doors

Password Crack

Brute Force

Dictionary

36. What is Denial-of-service (DoS)?

attacker sends a large number of connection or information requests to a target

so many requests are made that the target system cannot handle them successfully along with other, legitimate requests for service

may result in a system crash, or merely an inability to perform ordinary functions

37. Define Spoofing

It is a technique used to gain unauthorized access whereby the intruder sends messages to a computer with an IP address indicating that the message is coming from a trusted host.

38. Define Man-in-the-Middle

Man-in-the-middle is an attacker sniffs packets from the network, modifies them, and inserts them back into the network.

39. What is risk management?

Risk management is the process of identifying vulnerabilities in an organization's information systems and taking carefully reasoned steps to assure

Confidentiality

Integrity

Availability

Of all the components in the organization's information systems

40. What the roles to be played by the communities of interest to manage the risks an organization encounters?

It is the responsibility of each community of interest to manage risks; each community has a role to play:

Information Security

Management and Users

Information Technology

41. What is the process of Risk Identification?

A risk management strategy calls on us to know ourselves by identifying, classifying, and prioritizing the organization's information assets

These assets are the targets of various threats and threat agents and our goal is to protect them from these threats.

42. What are asset identification and valuation?

This iterative process begins with the identification of assets, including all of the elements of an organization's system: people, procedures, data and information, software, hardware, and networking elements.

43. What is Asset Information for People?

Position name/number/ID

Supervisor

Security clearance level

Special skills

44. How information assets are classified?

Examples of these kinds of classifications are:

Confidential data

Internal data

Public data

Informal organizations may have to organize themselves to create a useable data classification model

The other side of the data classification scheme is the personnel security clearance structure

45. Define the process of Information asset valuation.

Create a weighting for each category based on the answers to the

previous questions

Which factor is the most important to the organization?

Once each question has been weighted, calculating the importance of each asset is straightforward

List the assets in order of importance using a weighted factor analysis worksheet.

46. What are the Questions to assist in developing the criteria to be used for asset valuation?

Which information asset is the most critical to the success of the organization?

Which information asset generates the most revenue?

Which information asset generates the most profitability?

Which information asset would be the most expensive to replace?

Which information asset would be the most expensive to protect?

Which information asset would be the most embarrassing or cause

the greatest liability if revealed.

47. Explain the process of threat identification?

Threat Identification

Each of the threats identified so far has the potential to attack any of the assets protected

This will quickly become more complex and overwhelm the ability to plan

To make this part of the process manageable, each step in the threat identification and vulnerability identification process is managed separately, and then coordinated at the end of the process

48. How to identify and Prioritize Threats?

Each threat must be further examined to assess its potential to impact organization - this is referred to as a threat assessment

To frame the discussion of threat assessment, address each threat with a few questions:

Which threats present a danger to this organization's assets in the given environment?

Which threats represent the most danger to the organization's information?

How much would it cost to recover from a successful attack?

Which of these threats would require the greatest expenditure to prevent?

49. What is Vulnerability Identification?

We now face the challenge of reviewing each information asset for each threat it faces and creating a list of the vulnerabilities that remain viable risks to the organization

Vulnerabilities are specific avenues that threat agents can exploit to attack an information asset

Examine how each of the threats that are possible or likely could be perpetrated and list the organization's assets and their vulnerabilities

The process works best when groups of people with diverse backgrounds within the organization work iteratively in a series of

brainstorming sessions

50. Mention the Risk Identification Estimate Factors

Likelihood

Value of Information Assets

Percent of Risk Mitigated

Uncertainty

51. Give an example of Risk determination.

For the purpose of relative risk assessment:

risk = likelihood of vulnerability occurrence times value (or impact)

- percentage risk already controlled + an element of uncertainty

Information Asset A has an value score of 50 and has one vulnerability:

Vulnerability 1 has a likelihood of 1.0 with no current controls and you estimate that assumptions and data are 90 % accurate

Asset A: vulnerability rated as $55 = (50 * 1.0) - 0\% + 10\%$

52. What is residual risk?

For each threat and its associated vulnerabilities that have any residual risk, create a preliminary list of control ideas

Residual risk is the risk that remains to the information asset even after the existing control has been applied

53. What is access control?

One particular application of controls is in the area of access controls

Access controls are those controls that specifically address admission of a user into a trusted area of the organization

There are a number of approaches to controlling access

Access controls can be - discretionary, mandatory, nondiscretionary

54. What are the different types of Access Controls?

Discretionary Access Controls (DAC)

Mandatory Access Controls (MACs)

Nondiscretionary Controls

Role-Based Controls

Task-Based Controls

Lattice-Based Control

55. What is the goal of documenting results of the risk assessment?

The goal of this process has been to identify the information assets of the organization that have specific vulnerabilities and create a list of them, ranked for focus on those most needing protection first

In preparing this list we have collected and preserved factual information about the assets, the threats they face, and the vulnerabilities they experience

56. What are the different risk control strategies?

Avoidance

Transference

Mitigation

Acceptance

57. Write short notes on Incident Response Plan

The actions an organization can perhaps should take while the incident is in progress are documented in what is known as Incident Response Plan(IRP).

Answers to the following type of questions will be provided in IRP:

What should the administrator should do first?

Whom should they contact?

What should they document?

58. Define Disaster Recovery Plan

The most common mitigation procedure is Disaster Recovery Plan(DRP). The DRP includes the entire spectrum of activities used

to recover from the incident and strategies to limit losses before and after the disaster. DRP usually include all preparations for the recovery process, strategies to limit losses during the disaster.

59. What is a policy?

A policy is a plan or course of action, as of a government, political party, or business, intended to influence and determine decisions, actions, and other matters.

60. What are the three types of security policies?

Management defines three types of security policy:

General or security program policy

Issue-specific security policies

Systems-specific security policies

61. What is Security Program Policy?

A security program policy (SPP) is also known as

A general security policy

II security policy

Information security policy

62. Define Issue-Specific Security Policy (ISSP)

The ISSP:

addresses specific areas of technology

requires frequent updates

contains an issue statement on the organization's position on an issue

63. What are ACL Policies?

ACLs allow configuration to restrict access from anyone and anywhere ACLs regulate:

Who can use the system

What authorized users can access

When authorized users can access the system

Where authorized users can access the system from

How authorized users can access the system

64. What is Information Security Blueprint?

The Security Blue Print is the basis for Design, Selection and Implementation of Security Policies, education and training programs, and technology controls.

65. Define ISO 17799/BS 7799 Standards and their drawbacks

One of the most widely referenced and often discussed security models is the Information Technology - Code of Practice for Information Security Management, which was originally published as British Standard BS 7799

This Code of Practice was adopted as an international standard by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC) as ISO/IEC 17799 in 2000 as a framework for information security

66. What is the alternate Security Models available other than ISO 17799/BS 7799?

Another approach available is described in the many documents available from the Computer Security Resource Center of the National Institute for Standards and Technology (csrc.nist.gov) - Including:

NIST SP 800-12 - The Computer Security Handbook

NIST SP 800-14 - Generally Accepted Principles and Practices for Securing IT Systems

NIST SP 800-18 - The Guide for Developing Security Plans for IT Systems

67. List the management controls of NIST SP 800-26

Risk Management

Review of Security Controls

Life Cycle Maintenance

Authorization of Processing (Certification and Accreditation)

System Security Plan

68. Mention the Operational Controls of NIST SP 800-26

Personnel Security

Physical Security

Production, Input/output Controls

Contingency Planning

Hardware and Systems Software

Data Integrity

Documentation

Security Awareness, Training, and Education

Incident Response Capability

69. What are the Technical Controls of NIST 800-26?

Identification and Authentication

Logical Access Controls

Audit Trails

70. What is Sphere of protection?

The “sphere of protection” overlays each of the levels of the “sphere of use” with a layer of security, protecting that layer from direct or indirect use through the next layer. The people must become a layer of security, a human firewall that protects the information from unauthorized access and use.

Information security is therefore designed and implemented in three layers:

policies

people (education, training, and awareness programs)

technology

71. What is Defense in Depth?

One of the foundations of security architectures is the requirement to implement security in layers.

Defense in depth requires that the organization establish sufficient

security controls and safeguards, so that an intruder faces multiple layers of controls

72. What is Security perimeter?

The point at which an organization's security protection ends, and the outside world begins is referred to as the security perimeter

73. What are the key technological components used for security implementation?

A firewall is a device that selectively discriminates against information flowing into or out of the organization

The DMZ (demilitarized zone) is a no-man's land, between the inside and outside networks, where some organizations place Web servers

In an effort to detect unauthorized activity within the inner network, or on individual machines, an organization may wish to implement Intrusion Detection Systems or IDS

74. What is Systems-Specific Policy (SysSP)?

SysSPs are frequently codified as standards and procedures used when configuring or maintaining systems

Systems-specific policies fall into two groups:

Access control lists (ACLs) consist of the access control lists, matrices, and capability tables governing the rights and privileges of a particular user to a particular system

75. What is the importance of blueprint?

The blueprint should specify the tasks to be accomplished and the order in which they are to be realized. It should serve as a scaleable, upgradable, and comprehensive plan for the information security needs for coming years.

76. What are the approaches of ISSP?

Three approaches:

Create a number of independent ISSP documents

Create a single comprehensive ISSP document

Create a modular ISSP document

77. What are firewalls?

A firewall is any device that prevents a specific type of information from moving between the untrusted network outside and the trusted network inside

The firewall may be:

a separate computer system

a service running on an existing router or server

a separate network containing a number of supporting devices

78. Explain different generations of firewalls.

First Generation - packet filtering firewalls

Second Generation-application-level firewall or proxy server

Third Generation-Stateful inspection firewalls

Fourth Generation-dynamic packet filtering firewall

Fifth Generation-kernel proxy

79. What is the advantage of Second Generation firewalls?

The primary disadvantage of application-level firewalls is that they are designed for a specific protocol and cannot easily be reconfigured to protect against attacks on protocols for which they are not designed.

80. What is the drawback of packet-filtering router?

The drawback of packet-filtering router includes a lack of auditing and strong authentication.

81. What are Screened-Host Firewall Systems

Screened-Host firewall system allows the router to pre-screen packets to minimize the network traffic and load on the internal proxy.

82. What is the use of an Application proxy?

An Application proxy examines an application layer protocol, such as HTTP, and performs the proxy services

83. What are Screened-Subnet Firewalls?

Consists of two or more internal bastion-hosts, behind a packet-

filtering router, with each host protecting the trusted network

The first general model consists of two filtering routers, with one or more dual-homed bastion-host between them

The second general model involves the connection from the outside or untrusted network

84. What are the factors to be considered while selecting a right firewall?

What type of firewall technology offers the right balance of protection features and cost for the needs of the organization?

What features are included in the base price? What features are available at extra cost?

Are all cost factors known?

How easy is it to set up and configure the firewall? How accessible are staff technicians with the mastery to do it well?

Can the candidate firewall adapt to the growing network in the target organization?

85. What are Sock Servers?

The SOCKS system is a proprietary circuit-level proxy server that places special SOCKS client-side agents on each workstation.

86. What are intrusion detection systems(IDS)?

IDSs work like burglar alarms

IDSs require complex configurations to provide the level of detection and response desired

An IDS operates as either network-based, when the technology is focused on protecting network information assets, or host-based, when the technology is focused on protecting server or host information assets

IDSs use one of two detection methods, signature-based or statistical anomaly-based

87. What are different types of IDSs?

Network-based IDS

Host-based IDS

Application-based IDS

Signature-based IDS

Statistical Anomaly-Based IDS

88. Define NIDS

A network-based IDS(NIDS) resides on a computer or an appliance connected to a segment of an organization's network and monitors traffic on that network segment, looking for indications of ongoing or successful attacks.

89. What is Application-based IDS?

A refinement of Host-based IDs is the application-based IDS(AppIDS). The application based IDs examines an application for abnormal incidents. It looks for anomalous occurrences such as users exceeding their authorization, invalid file executions etc.

90. What is Signature-based IDS?

A signature-based IDS(also called Knowledge-based IDs) examines data traffic in search of patterns that match known signatures - that is, preconfigured, predetermined attack patterns.

91. What are Honey Pots?

Honey pots are decoy systems designed to lure potential attackers away from critical systems and encourage attacks against the themselves. These systems are created for the sole purpose of deceiving potential attackers. In Industry they are known as decoys, lures and fly-traps.

92. What are Honey Nets?

When a collection of honey pots connects several honey pot systems on a subnet, it may be called a honey net.

93. What is Cryptography?.

Cryptography, which comes from the Greek work kryptos, meaning “hidden”, and graphe in, meaning “to write”, is a process of making and using codes to secure the transmission of information.

94. What is Cryptoanalysis?

Cryptoanalysis is the process of obtaining the original message(called plaintext) from an encrypted message(called the ciphertext) without knowing the algorithms and keys used to perform the encryption.

95. What is Public Key Infrastructure (PKI)?

PKI or Public Key Infrastructure

Public Key Infrastructure is the entire set of hardware, software, Φ and cryptosystems necessary to implement public key encryption

PKI systems are based on public-key cryptosystems and include digital certificates and certificate authorities (CAs) and can:

Issue digital certificates

Issue crypto keys

96. How E-mail systems are secured?

Encryption cryptosystems have been adapted to inject some degree of security into e-mail:

S/MIME builds on the Multipurpose Internet Mail Extensions (MIME) encoding format by adding encryption and authentication.

Privacy Enhanced Mail (PEM) was proposed by the Internet Engineering Task Force (IETF) as a standard to function with the public key cryptosystems.

PEM uses 3DES symmetric key encryption and RSA for key exchanges and digital signatures.

Pretty Good Privacy (PGP) was developed by Phil Zimmerman and uses the IDEA Cipher along with RSA for key exchange.

Previous Years University Question Papers

CYBER SECURITY

Time: 2 Hours] [Total Marks : 50

Attempt any four questions: $4 \times 3=12$

- (a) What do you understand by information system (IS)? Discuss various advantages of information system.
- (b) What are the various components of information system, discuss?
- (c) How the information system is helpful to business organizations?
- (d) Write short note on the classification of information system.
- (e) Differentiate between Information System(IS) and Information Assurance(IA).
- (f) What do you understand by cyber bullies and predators?

Attempt any four questions: $4 \times 3=12$

- (a) What major challenges are faced by software vendors regarding the security of applications?
- (b) Give two general methods that are widely used to prevent security threats.
- (c) Describe various data security considerations with examples.
- (d) Explain any one security technology that is used for data and application security.

(e) Differentiate between hardware and software firewall.

Attempt any two questions: $2 \times 6 = 12$

(a) What do you understand by information security governance and risk management?

(b) What are the primary measures applied for the security of backup?

(c) Write short notes on Closed circuit television (CCTV) surveillance.

Attempt any two questions: $2 \times 7 = 14$

(a) What are the main objectives and scope of IT Act 2000?

(b) Provide an overview of intellectual property related legislation in India.

(c) What is Smart card? Differentiate between Credit and Debit card.

CYBER SECURITY

[Time: 3 hours] (Maximum Marks: 100]

SECTION-A

I. Attempt all parts. All parts carry equal marks. Write answer of each part in short. (2×10=20)

- (a) What do you mean by Information Security?
- (b) What is Security Risk Analysis?
- (c) What is Copy Right law in Cyber Security?
- (d) Describe the security threats to E-commerce.
- (e) Explain the requirement of digital signature system.
- (f) Explain functions of Information System with suitable diagram
- (g) How do distributed information systems help the global enterprises in today's business world?
- (h) Explain the concept of EDI.
- (i) What is WWW policies in Cyber Security?
- (j) What are Email Security policies?

SECTION-B

Note: Attempt any five questions from this section: (10×5=50)

What do you mean by biometric system? Discuss the advantages of Biometrics over traditional authentication method.

Explain the concept of Intrusion Detection System.

What is intellectual Property Law?

What is Software License in Cyber Security?

What is Backup Security Measures?

What is Cyber Security? How to secure your information explain in detail.

What is Virtual Private Network?

What are the important parameters to be taken care while developing a secure information system?

SECTION-C

Note: Attempt any two questions from this section: (15×2=30)

Explain the following Payment System in E-Commerce;

- (a) e-Cash
- (b) Credit/Debit Cards
- (c) Net Banking

Explain the following in detail:

- (a) Cyber Laws in India, IT Act 2000 Provisions
- (b) Software License
- (c) Semiconductor Law

Briefly explain the following:

- (a) Access Control in Cyber Security
- (b) Public Key Cryptography
- (c) Face Recognition

CYBER SECURITY

Time: 3 Hours Max. Marks: 100

Note: Attempt all Sections. If require any missing data; then choose suitably.

SECTION-A

Attempt all questions in brief. (10×2=20)

- (a) Explain Functions of Information System with suitable diagram.
- (b) Explain the concept of EDI.
- (c) What are WWW policies in Cyber Security?
- (d) What are Email Security policies?
- (e) Explain is Copy right Law in Cyber Security.
- (f) What do you mean by access control to information resources?
- (g) How do distributed information systems help the global enterprises in today's business world?
- (h) What are basic elements of information system security?
- (i) What is Development of Information Systems?
- (j) What is digital signature?

SECTION-B

Attempt any three of the following: (3×10=30)

- (a) What is Intellectual Property Law?
- (b) What are the fingerprints? Briefly describe the use of the finger print in current scenario.
- (c) Explain Legal issues in Data mining Security.
- (d) Explain the concept of payment in E-commerce.
- (e) What are the security threats in mobile computing

SECTION-C

Attempt any one part of the following: (1×10=10)

- (a) What is Security Threats to E-Commerce?
- (b) What is Cyber Security? How to Secure you information explain in detail?

Attempt anyone part of the following (1×10=10)

- (a) What are decision support systems? Discuss major functional requirement of a decision support system.
- (b) What is Virtual Private Network?

Attempt any one part of the following: (1×10=10)

- (a) Discuss the advantages of Biometrics over traditional authentication method.
- (b) Explain the Payment System in E-Commerce.

Attempt any one part of the following: (1×10=10)

- (a) What is different type of Network Security?

(b) Explain the different types of firewall with limitations.

Attempt any one part of the following: (1×10=10)

(a) What are decision support systems? Discuss major functional requirement of a decision support system.

(b) What is Face Recognition in Cyber Security?

References

Charles P. Pfleeger, Shari Lawerance Pfleeger, “Analysing Computer Security”, Pearson Education India.

V.K. Pachghare, “Cryptography and information Security”, PHI Learning Private Limited, Delhi India.

Dr. Surya Prakash Tripathi, Ritendra Goyal, Praveen Kumar Shukla, “Introduction to Information Security and Cyber Law” Willey Dreamtech Press.

Schou, Shoemaker, “ Information Assurance for the Enterprise”, Tata McGraw Hill.

Chander, Harish,” Cyber Laws And It Protection”, PHI Learning Private Limited, Delhi, India

Chuck Eastton, “Computer Security Fundamentals” Pearson.

Mouna Jouinia, Latifa Ben Arfa Rabaia, Anis Ben Aissab
“Classification of security threats in information systems” published in 5th International Conference on Ambient Systems, Networks and Technologies (ANT-2014).

“Introduction to Information Security”, Cengage publication.

Miroslav Baca “The risk assessment of information system security”
University of Zagreb, Faculty of Organization and Informatics,
Varadin, Croatia.

“Introduction to Information Systems”, Malaysia Open University,
Malaysia.